Dossier d'analyse des risques — 2026-10-12_projet-etude-sante-2026-2027

Généré le 13/10/2026 à 16:27 · 39 actif(s) · 135 risque(s) · 51 preuve(s) citée(s)
Les identifiants (A05, M012) et les preuves [E123] sont des liens : cliquez pour passer d'un livrable à l'autre. Les décisions de l'analyste sont indiquées telles qu'enregistrées ; rien n'est validé par le programme.

Sommaire

1. Synthèse
2. Registre des risques
3. Description du système
4. Inventaire des actifs
5. Méthodes retenues
6. Menaces
7. Évaluation des risques
8. Traitement des risques
9. Validation et suivi
10. Contradictions entre documents et questions ouvertes
11. Rapport de contrôle
12. Fiches de traçabilité des risques
13. Preuves citées
14. Historique des décisions de l'analyste

Synthèse

Fichier : SYNTHESE.md

> Document d'orientation pour une décision de direction (structure inspirée du guide `ANSSI-PSSI` : faits, décisions, actions). Les chiffres sont CALCULÉS par le programme à partir du registre des risques, pas écrits par un modèle ; chaque risque garde l'identifiant du registre.

1. Résumé exécutif

L'analyse porte sur **39 actifs** et **135 risques**. 75 risques sont évalués au niveau Critique (56 %), 35 Élevé, 13 Moyen et 12 Faible. Traitement proposé : 123 à réduire, 7 à éviter, 4 à accepter, 1 à transférer. Aucun risque n'a encore été décidé : les 135 risques sont proposés et attendent la validation d'un analyste. L'actif le plus exposé est **A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11** (6 risques dont 6 critiques).

Lecture (rédigée par le modèle, dont les chiffres ont été recontrôlés par le programme) :

L'analyse porte sur 39 actifs et identifie 135 risques majeurs. Sur l'ensemble, 75 sont classés niveau Critique (56 %) et 35 sont Élevé (26 %). Les traitements principaux visent à réduire l'impact avec 123 actions prévues sur le catalogue des mesures. Seuls 7 risques

peuvent être évités par isolement ou refonte architecturale, tandis que 4 acceptations et 1 transfert complètent la stratégie de mitigation globale.

Aucun des 135 risques n'a encore été validé par l'équipe d'analyse en charge du contrôle final. Une validation humaine reste nécessaire pour trancher chaque cas et s'assurer d'une couverture complète des besoins opérationnels tout en respectant les normes de sécurité imposées.

2. Chiffres clés

Indicateur	Valeur
Actifs analysés	39
Risques au registre	135
Niveau Critique	75 (56 %)
Niveau Élevé	35 (26 %)
Niveau Moyen	13 (10 %)
Niveau Faible	12 (9 %)
Traitement : Réduire	123
Traitement : Éviter	7
Traitement : Accepter	4
Traitement : Transférer	1
Risques décidés par un analyste	0 sur 135

3. Où se concentre le risque

Actif	Risques	Dont Critique	Dont Élevé
A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11	6	6	0
A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]	6	6	0
A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139]	5	3	1
A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service	4	3	1
A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service	3	3	0
A03 — Messagerie Sécurisée de Santé (Mél) — Logiciel / Service	3	3	0
A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet	3	3	0
A18 — Application métier — DPI Progiciel Nexus	3	3	0

4. Risques prioritaires (les 10 premiers par niveau, impact puis probabilité)

ID	Actif	Menace	Niveau	Pourquoi (étape 4)	Traitement	Risque résiduel
M060	A19 — Donnée/Structure — Données Patients (DPI)	STRIDE-I — Information leakage via exploitation ProxyShell sur Exchange 2016 non patché (DMZ vulnérable aux attacks Spraying) [E168]$_{[A17]}$	Critique	ProxyShell exploitables sur Exchange 2016 non patché en DMZ + campagnes Spraying permettent extraction massive données patients critiques [E168] [A17] [CVE-2022-31497]	Réduire	Élevé
M054	A17 — Infrastructure réseau — Active Directory	STRIDE-T — Tampering des permissions AD via exploitation de compte service faible sur 60% des postes (pas de MFA sur VPN) enclinning aux attacks pass-the-hash [E140]	Critique	Compte service faible + 60% postes sans MFA VPN permettent pass-the-hash et tampering permissions AD unique CVE-2021-38619 [E140]$_{[A17]}$	Réduire	Élevé
M058	A18 — Application métier — DPI Progiciel Nexus	STRIDE-E — Élévation de privilèges via vulnérabilités Citrix XenApp/RDS (XenDesktop 7.15 CVE-2020-34692) permettant l'exécution code sur ferme RDS Siège [E146]	Critique	CVE-2020-34692 Citrix XenApp exploitables sur ferme RDS Siège permettent exécution code et élévation privilèges globale [E146] [A17]	Réduire	Élevé
M062	A19 — Donnée/Structure — Données Patients (DPI)	LINDDUN-D — Disclosure de 150 000 dossiers via API Gateway non sécurisée pour télémédecine (no authz, no encryption in transit) [E231] [A11]	Critique	API Gateway télémédecine sans authentification/ autorisation ni chiffrement transit expose 150 k dossiers patients [E146, E203, CVE-2023-38448]	Réduire	Critique
M068	A21 — Infrastructure Cloud — Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/ OVHcloud/Azure (pas d'imposition) [E142]	LINDDUN-Disclosure — Fuite de données patients via container compromis exposé sur métadonnées publics S3 → exfiltration de dossiers médicaux identifiables [E146,LINDDUN-Disclosure]	Critique	Container S3 exposé à métadonnées publiques permettant exfiltration continue de données médicales identifiées sans chiffrage [E146, E149, LINDDUN-D]	Réduire	Critique

ID	Actif	Menace	Niveau	Pourquoi (étape 4)	Traitement	Risque résiduel
M070	A22 — Infrastructure sécurité — Micro-segmentation VLAN/NAC — Architecture cible pour isoler poste clinique compromis (VLAN IoT/ Biomedical 10.1.30.0/24 non cloisonné actuellement) [E146,E150,FichedAuditTechnique-ÉtatdesLieuxSanteTechAs-Is.pdf.md,E205]	STRIDE-R — Attaquant interne : poste clinique compromis contourne NAC mal configuré → mouvement latéral via VLAN IoT non isolé (10.1.30.0/24) vers serveurs critiques PACS/RIS [E146,E205,STRIDE-R]	Critique	Poste clinique compromis atteint PACS/RIS critique via VLAN IoT non cloisonné 10.1.30.0/24 (routage direct) [E169, E203, STRIDE-R]	Éviter	Critique
M089	A26 — Parc IoT Médical	LINDDUN-D — Fuite de données sensibles via les dispositifs IoT non isolés, exploitant le routage direct vers les automates [E203]	Critique	IoT biomédical connecté sans isolation réseau → données capteurs patient fuites routage direct vers automates [E203] → atteinte confidentialité/ sécurité patients grave [LINDDUN-D,EBIOS-RM-A4]	Réduire	Faible : IoT biomédical isolé physiquement + flux capteurs cryptés en transit [E140]
M091	A27 — Ferme Citrix/RDS	STRIDE-S — Spoofing via le réseau MPLS non segmenté, permettant l'accès à tous les serveurs physiques [E139]	Critique	Ferme Citrix/RDS connectée sur réseau MPLS non segmenté avec accès physique direct à tous serveurs → compromission systémique tout le siège [E139,STRIDE-S] → atteinte intégrité masse données [EBIOS-RM-A4]	Réduire	Faible : ferme Citrix/RDS isolée sur MPLS segmenté + accès direct restreint à serveurs certifiés [E139]
M093	A28 — Postes legacy	LINDDUN-D — Fuite de données patients via les postes Windows 7/XP, non durcis contre les attaques par usurpation [E150]	Critique	Postes Windows 7/ XP non durcis + système de santé sensible → fuites données patients vulnérabilités connues exploitables (MS08-067 SMBv1, EternalBlue) [E150,LINDDUN-D] → données critiques exposées	Éviter	Négligeable : postes Windows 7/XP mis en service de secours uniquement (non critiques) + migration planifiée [E150]
M095	A29 — MPLS Hub & Spoke	STRIDE-S — Spoofing via le réseau centralisé sans isolation, permis par la micro-segmentation absente [E139]	Critique	Réseau MPLS Hub&Spoke centralisé sans isolation micro-segmentation → spoofing routes atteste exposition tous sites [E139,STRIDE-S] → accès transversal clinique à clinique	Réduire	Très Faible : interconnexion sites via IPsec chiffré seul + ACL routage segmenté [E140]

5. Actions recommandées

Chaque action vient du traitement de l'étape 5 pour le risque indiqué ; la revue suit le plan de `06-validation.md`.

Priorité	Risque	Action (contre-mesures proposées)	Prochaine revue
Critique	M060	Patch Exchange 2016 (ANSSI-RECYF) + MFA (ISO27002-8.8)	mensuelle
Critique	M054	MFA FIDO2 (ISO27002-8.8) + rotation cred (ANSSI-HYGIENE)	mensuelle
Critique	M058	Patch immédiat CVE-2020-34692 (ANSSI-RECYF) + virtualisation (ISO27002-8.16)	mensuelle
Critique	M062	Authentification à deux facteurs (ISO27002-8.8), Chiffrement transit (ANSSI-HYGIENE-8.14), Audit API Gateway (ANSSI-RECYF)	mensuelle
Critique	M068	Chiffrement S3 (ISO27002-8.14), Séparation containers (ANSSI-HYGIENE-8.11), Audit métadonnées (STRIDE-D)	mensuelle
Critique	M070	Cloisonnement VLAN 10.1.30.0/24 (ANSSI-HYGIENE-8.11), NAC étendu (ISO27002-8.2), Suppression routage direct (STRIDE-R)	mensuelle
Critique	M089	Isolation réseau physique (pas logique seulement) pour dispositifs biomédicaux critiques + chiffrement de bout en bout des flux capteurs [ANSSI-PSSI,ISO27002-8.5,LINDDUN-D]	mensuelle
Critique	M091	Segment MPLS avec micro-segmentation (VLAN par service) + accès direct limité uniquement par IP + authentification réseau 802.1X obligatoire [ANSSI-CARTO-SI,ISO27002-5.4,STRIDE-S]	mensuelle
Critique	M093	Migration progressive vers Windows 10/11 LTSC ou Linux avec agents HDS [ANSSI-HYGIENE-5,EBIOS-RM-A4,LINDDUN-D]	mensuelle
Critique	M095	Intersegment MPLS avec ACL strictes (IPsec VPN entre hubs) + chiffrement TLS obligatoire sur toutes routes transversales + IDS L7 inspection trafic [ANSSI-CARTO-SI,ISO27002-6.3,STRIDE-S]	mensuelle

6. Décisions de l'analyste

Aucune décision enregistrée : les 135 risques restent « À valider par l'analyste ».

7. Limites et points à vérifier

- **Niveaux à relire en priorité** : 75 risques sur 135 (56 %) sont évalués Critique. Le niveau est CALCULÉ par le programme (matrice probabilité × impact) à partir des valeurs proposées par le modèle ; quand presque tout est critique, la hiérarchie ne guide plus : relisez d'abord les probabilités et les impacts.
- **Étapes à valider par une personne** : 1, 2, 3, 4, 5 ; 163 ligne(s) dont la preuve citée n'a pas pu être établie par la machine (page ④, « Lignes à relire », par pages de dix).

8. Comment lire ce dossier

- `registre-risques.md` : tous les risques, une ligne chacun, de la menace au traitement.
- `06-validation.md` : ce qui reste à décider, le plan de suivi, et les décisions prises.
- `03-menaces.md`, `04-evaluation.md`, `05-traitement.md` : le détail et les preuves `[E…]`.
- `RAPPORT-CONTROLE.md` : ce que le contrôle a relevé, étape par étape.

Registre des risques

Fichier : registre-risques.md

> Registre établi par le programme, ligne à ligne, à partir des étapes 3 (menaces), 4 (évaluation) et 5 (traitement) : aucune valeur n'est modifiée ni inventée, et chaque risque garde le même identifiant (M001…) d'un livrable à l'autre. La colonne `valide_par` reste vide tant qu'une personne n'a pas décidé (page ④ du site).

135 risques — Critique : 75 · Élevé : 35 · Moyen : 13 · Faible : 12.

ID	Actif	Menace	Niveau	Probabilité	Impact	Justification	Traitement
M001	A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service	STRIDE-T — Attentat cyber : accès aux dossiers patients via exploitation des vulnérabilités legacy sur Citrix/RDS avec RDP non filtré, permettant l'exfiltration de données médicales critiques [E203]$_{[A16][EBIOS-RM-A3]}$	Critique	Élevé	Élevé	Serveur Citrix/RDS non filtré [E203], exposition à l'exploitation de vulnérabilités legacy [E203]	Réduire
M002	A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service	LINDDUN-Disclosure — Fuite de données patients : progression horizontale (MOVElaterally) depuis les 185 serveurs legacy vers autres systèmes via absence de micro-segmentation sur le VLAN local [10.100.0.0/16] [E203]$_{[A17][LINDDUN-Disclosure]}$	Critique	Élevé	Élevé	VLAN local non cloisonné (10.100.0.0/16) avec progression horizontale [E203], absence de micro-segmentation [E203]	Réduire
M003	A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service	STRIDE-I — Injection malveillante : modification des dossiers patients pendant la migration legacy-to-cloud via API Gateway non sécurisée ou failles RDS [E203]$_{[A16]}$	Critique	Élevé	Élevé	API Gateway non sécurisée [E203], failles RDS non patchées [E203]	Réduire
M004	A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service	STRIDE-S — Substitution d'imagerie : injection de fichiers DICOM malformés ou corrompus via SMBv1 non patché dans les baies SAN locales vieillissantes [E203]$_{[PASTA-A5]}$	Critique	Élevé	Élevé	SMBv1 non patché [E203], vulnérabilité CVE-2017-7482 [E203]	Réduire

ID	Actif	Menace	Niveau	Probabilité	Impact	Justification	Traitement
M005	A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service	STRIDE-R — Ransomware : chiffrement des images DICOM stockées sur baies SAN sans EDR, exploitant les failles de partage SMB [E203][EBIOS-RM-A3]	Critique	Élevé	Élevé	Partage SMB non sécurisé [E203], absence d'EDR [E203]	Réduire
M006	A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service	LINDDUN-Disclosure — Accès non autorisé aux images médicales : compromission d'un cache local en clinique via VLAN IoT non cloisonné (10.1.30.0/24, routage direct vers automates) [E203][E7]	Critique	Élevé	Élevé	VLAN IoT (10.1.30.0/24) non cloisonné [E203], routage direct vers automates [E203]	Réduire
M007	A03 — Messagerie Sécurisée de Santé (Mél) — Logiciel / Service	STRIDE-S — ProxyShell exploitation : accès distant aux dossiers Exchange 2016 DMZ via vulnérabilité ProxyShell/ Spraying sur webmail.santetech-sante.fr [E7][E5]	Critique	Élevé	Élevé	Vulnérabilité ProxyShell/Spraying [E7][E5], absence de MFA sur Exchange 2016 [E7][E5]	Réduire
M008	A03 — Messagerie Sécurisée de Santé (Mél) — Logiciel / Service	LINDDUN-Disclosure — Fuite d'emails sensibles : exfiltration via OWA vulnérable et absence de filtrage SSL sur webmail.santetech-sante.fr exposant données patients [E7] [E5]	Critique	Élevé	Élevé	OWA vulnérable [E203][E5], absence de filtrage SSL [E203] [E5]	Réduire
M009	A03 — Messagerie Sécurisée de Santé (Mél) — Logiciel / Service	STRIDE-E — Modification d'identité : création de comptes malveillants ou usurpation d'identité via exploitation Exchange 2016 sans MFA [E7][A19]	Critique	Élevé	Élevé	Absence de MFA sur Exchange 2016 [E7] [A19], exploitation possible [E7][A19]	Réduire
M010	A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet	STRIDE-I — Injection de session : authentification compromise par absence de MFA sur 60% des comptes AD, permettant prise de contrôle distante via vpn.santetech-sante.fr [E7][A19][EBIOS-RM-A3]	Critique	Élevé	Élevé	Absence de MFA sur 60% des comptes AD [E7][A19], injection de session via vpn.santetech-sante.fr [E203]	Réduire
M011	A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet	LINDDUN-L — Usurpation d'identité légitime : accès non filtré au portail VPN permet impersonner des praticiens libéraux ou soignants pour fraudes [E7][A5]	Critique	Élevé	Élevé	Portail VPN non filtré [E7][A5], risque d'usurpation d'identité [E7][A5]	Réduire

ID	Actif	Menace	Niveau	Probabilité	Impact	Justification	Traitement
M012	A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet	STRIDE-R — Ransomware sur accès distant : compromission du FortiGate via failles de certificats TLS non renouvelés, exposant le réseau interne [E203] [A17]	Critique	Élevé	Élevé	Certificats TLS non renouvelés [E203] [A17], exposition du réseau interne [E203] [A17]	Réduire
M013	A05 — Webmail de Santé & Accès Externe (OWA) — Service / Site Internet	STRIDE-E — Escalade de privilèges : exfiltration et modification des données via OWA Exchange 2016 non patché sur DMZ, sans filtrage SSL [E7][E5]	Critique	Élevée	Élevé	Exchange 2016 DMZ non patché exposé à ProxyShell/Spraying [E192] → exfiltration données patients via CVE-2023-21768	Réduire
M014	A05 — Webmail de Santé & Accès Externe (OWA) — Service / Site Internet	LINDDUN-Disclosure — Fuite massive via campagnes Spraying : botnets exploitant Exchange 2016 DMZ pour exfiltrer données patients vers serveurs tiers [E7] [E5][EBIOS-RM-A3]	Critique	Élevée	Élevé	Botnets ciblant Exchange 2016 DMZ exploitable sans filtrage SSL [E192] [E203] → fuite massive vers tiers [E203][EBIOS-RM-A3]	Réduire
M015	A05 — Webmail de Santé & Accès Externe (OWA) — Service / Site Internet	STRIDE-T — Attaque par le temps (DoS) : épuisement des ressources Exchange 2016 via requêtes malveillantes sur OWA sans rate limiting [E7] [A11]	Élevé	Moyenne	Élevé	OWA non rate-limited laisse épuiser ressources Exchange 2016 via requêtes DoS [E192][A11]	Réduire
M016	A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service	STRIDE-D — Destruction d'images DICOM : corruption des baies SAN locales via malware SMB qui supprime les données critiques [E203][EBIOS-RM-A3]	Élevé	Moyenne	Élevé	SMB vulnérabilités (CVE-2019-10605) sur baies SAN locales avec SMBv3/SMBv1 actif [E155][E203] [EBIOS-RM-A3] → corruption données critiques	Réduire
M017	A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérieurs E7E5	STRIDE-S — Authentification par certificat faible [E160] → attaquants externes (groupes ransomware ciblant hôpitaux) → compromis de certificat ou injection credentials dans extranet → accès non autorisé aux résultats médicaux des patients [A3][E203]	Élevé	Moyenne	Élevé	Certificat faible + accès externes médicaux E7E5 sans MFA solide [E160] [E203] → ransomware compromis credentials vers résultats patients [A3][E203]	Réduire

ID	Actif	Menace	Niveau	Probabilité	Impact	Justification	Traitement
M018	A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérieurs E7E5	LINDDUN-Disclosure — Fuite des résultats médicaux via portail non durci : attaquants exploitent vulnérabilité d'authentification → exfiltration de données sensibles externes → violation RGPD et confidentialité des dossiers patients externes [E203][A19]	Élevé	Moyenne	Élevé	Portail partenaire non durci avec authentification simple et certificat faible [E197][E203] → exfiltration données externes via canal compromis [A3][A19] [EBIOS-RM-A3]	Réduire
M019	A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérieurs E7E5	STRIDE-I — Modification des données médicales : attaquants interceptent flux authentifiés vers portail webmodifié → exfiltration ou altération des profils patients externes en transit via canal non chiffré [E38] [A17]	Élevé	Moyenne	Élevé	Site tiers WebModif sans canal chiffré robuste intercepte flux authentifiés [E38] [A17] → altération profils patients en transit [EBIOS-RM-A3]	Réduire
M020	A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérieurs E7E5	STRIDE-T — Attaques de type defacement/ phishing : site compromis sert de plateforme d'hébergement pour malware redirigeant vers attaques contre SI interne [A3][E203]	Faible	Faible	Moyen	Site compromis défacement/phishing rare mais peut rediriger malware vers interne [A3][E203] → impact limité faute de lien direct SI interne [E198]	Accepter
M021	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond E7E5	STRIDE-E — Accès aux données sensibles via exploitation vulnérabilités serveur web : attaquants accèdent au contenu médical stocké sur hébergement externe → exfiltration de flux web vers cloud malveillant [A17][E38]	Élevé	Moyenne	Élevé	CMS WordPress tiers sans patching + vulnérabilités connues CVE-2024-6273/ CVE-2019-5409 [E199][E203][A17] → exfiltration contenus hébergés externes [E38] [EBIOS-RM-A3]	Éviter
M022	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond E7E5	STRIDE-D — Défacement de contenu médical et profils patients : attaquants modifient pages web hébergées → altération des informations cliniques visibles publiquement [A3][E203]	Faible	Faible	Moyen	Défacement WordPress tiers non critique pour opérationnel mais altère contenu clinique public visible [A3][E203] → impact réputationnel limité	Réduire
M023	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond E7E5	STRIDE-T — Attaques de type defacement/ phishing : site compromis sert de plateforme d'hébergement pour malware redirigeant vers attaques contre SI interne [A3][E203]	Élevé	Moyenne	Élevé	Phishing défacement sur CMS tiers moins probable que DoS/ exfiltration directe [E199] → redirection vers sites malveillants [A3]	Réduire

ID	Actif	Menace	Niveau	Probabilité	Impact	Justification	Traitement
M024	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond E7E5	LINDDUN-Disclosure — Fuite des données sensibles via exploitation vulnérabilités CMS : attaquants accèdent aux contenus médicaux hébergés → exfiltration de flux web vers cloud malveillant [A19][E203]	Faible	Faible	Moyen	Exploitation CMS pour fuite limitée via contenu public, non base de données patients directe [E199][EBIOS-RM-A3] [A19]	Accepter
M025	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond E7E5	LINDDUN-Unawareness — Non-documentation des vulnérabilités du CMS : attaquants exploitent failles non patchées de plugins WordPress → exfiltration de dossiers patients sans consentement [A19] [E203]	Élevé	Élevé	Moyen	CMS WordPress vulnérable avec plugins obsolets exposés publiquement [E195] [A19]	Réduire
M026	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/ RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5	STRIDE-S — Compromission d'identité centralisée : attaquants injectent objets utilisateurs malveillants dans forêt racine → accès non autorisé aux dossiers patients via mouvement latéral [A17][E38]	Critique	Élevé	Élevé	Authentification centralisée sans segmentation forestière et sans MFA systématique [E24] [E145]	Réduire
M027	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/ RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5	STRIDE-T — Attaques via usurpation d'identité : attaquants bypassent authentification sans MFA sur 60% des comptes → compromission de compte administratif centralisé → accès transverse à toutes les cliniques [A16][E203]	Critique	Élevé	Élevé	Bypass authentification possible sur 60% des comptes sans double facteur [E186] [E145]	Réduire
M028	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/ RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5	STRIDE-E — Interception d'authentification : attaquants captent flux réseau sans chiffrage SSL renforcé → rejeu d'identifiants depuis session compromis → accès aux identités validées [E38][A17]	Élevé	Moyen	Élevé	Connexions non chiffrées SSL permettent rejeu d'identifiants depuis session capturée [E197][E137]	Réduire
M029	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/ RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5	LINDDUN-Disclosure — Fuite des identités : attaquants exploitent forêt non cloisonnée pour exfiltrer données sensibles → accès aux profils patients centralisés sans consentement [A19][E9]	Élevé	Moyen	Élevé	Architecture monolithique AD unique facilite exfiltration transversale des profils patients [E103][E240]	Réduire

ID	Actif	Menace	Niveau	Probabilité	Impact	Justification	Traitement
M030	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/ RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5	LINDDUN-L — Modification des attributs utilisateurs : attaquants altèrent droits d'accès dans forêt racine → accès non documenté aux dossiers patients via promotion d'utilisateur faible [A3]	Faible	Faible	Moyen	Modification requiert permissions administrateur supérieures dans forêt racine non cloisonnée [E2][E103]	Réduire
M031	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/ RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5	STRIDE-I — Altération des clés Kerberos : attaquants réplication compromise → exfiltration et altération du catalogue AD vers endpoints externes [E38][A17]	Moyen	Faible	Élevé	Vulnérabilité spécifique nécessitant conditions d'exploitation précises sur réplication AD [E145]	Réduire
M032	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5	STRIDE-S — Compromission contrôleurs de domaine : attaquants exploitent faille matérielle ou corruption disque → perte d'authenticité des identités cliniques [A3] [E203]	Moyen	Faible	Élevé	Compromise nécessite accès physique ou exploit ciblé sur 185 serveurs hétérogènes [E9][E176][]	Réduire
M033	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5	STRIDE-T — Défaillance des serveurs DC/RODC : panne matérielle critique → perte d'authentification pour toute la clinique → déni de service système [A3][E9]	Moyen	Faible	Élevé	Redondance DC localisée limite probabilité de coupure simultanée mais impact clinique total [E146]	Réduire
M034	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5	LINDDUN-Unawareness — Non-patching hétérogène : attaquants exploitent faille de serveur non corrige → exfiltration depuis DC vieillissant sans agent EDR moderne [A3][E2]	Élevé	Élevé	Moyen	Surface d'attaque étendue avec gestion patch hétérogène sur 12 sites et OS non patchables [E7][E98]	Réduire
M035	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5	STRIDE-E — Accès aux données de l'AD : attaquants accèdent au système de réplication → lecture des catalogues utilisateurs depuis DC compromis [A17][E38]	Moyen	Faible	Élevé	Exploitation du canal de réplication requiert privilèges avancés pour lecture catalogue utilisateurs [E123] [A17]	Réduire
M036	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5	STRIDE-I — Altération des données d'AD : attaquants modifient catalogue AD vers DC local → invalidation des tickets Kerberos pour tous les comptes cliniques [A17]	Moyen	Faible	Élevé	Modification catalogue nécessite accès privilégié direct au DC local compromis [E148][A17]	Réduire

ID	Actif	Menace	Niveau	Probabilité	Impact	Justification	Traitement
M037	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11	STRIDE-S — Compromission migration cloud : attaquants infiltrent flux de migration → altération des métadonnées patients dans cible hybride [A3][E203]	Critique	Élevé	Élevé	Compromission migration cloud : attaquants infiltrent flux de migration → altération des métadonnées patients [E203]	Réduire
M038	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11	STRIDE-E — Exfiltration de flux API : attaquants accèdent aux endpoints cloud non authentifiés → lecture des dossiers patients dans infrastructure hybride [A19][E5]	Critique	Élevé	Élevé	Exfiltration API non authentifiés → lecture dossiers patients [E203][E5]	Réduire
M039	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11	STRIDE-T — Attaques de type defacement/ application : attaquants compromise flux télémédecine via API mal protégée → redirige communications vers services hostiles [A3] [E203]	Critique	Élevé	Élevé	Attaques defacement via API mal protégée → redirige communications [E203]	Réduire
M040	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11	LINDDUN-Disclosure — Fuite des données patients cloud : attaquants exploitent faille API Gateway → exfiltration continue des flux télémédicaux vers endpoints externes [A19] [E5]	Critique	Élevé	Élevé	Fuite données patients via faille API Gateway → exfiltration télémédicale [E203] [E5]	Réduire + Transférer
M041	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11	LINDDUN-Unawareness — Non-documentation des flux API : attaquants exploitent endpoints non inventorisés dans architecture cloud → exfiltration de données sensibles sans traçabilité [A3][E9]	Critique	Élevé	Élevé	Non-documentation API → exfiltration données sans traçabilité [E9]	Éviter
M042	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11	STRIDE-I — Altération des flux télémédicaux : attaquants interceptent messages cloud → modification des données médicales transmises entre cliniques [A3] [E203]	Critique	Élevé	Élevé	Interception messages cloud → modification données médicales [E203][E5]	Réduire

ID	Actif	Menace	Niveau	Probabilité	Impact	Justification	Traitement
M043	A11 — Fournisseur Cloud HDS	STRIDE-S — [E140] Attaque de spoofing via certification HDS non conforme : un fournisseur malveillant pourrait falsifier l'identité d'un hôte Cloud HDS et accéder aux données patients via le portail vpn.santetech-sante.fr sans authentification MFA.	Critique	Élevé	Élevé	Spoofing via certification HDS non conforme [E140]	Éviter
M044	A11 — Fournisseur Cloud HDS	LINDDUN-D — [E203] Fuite de données via exposition Cloud Act : le Cloud HDS sans analyse rigoureuse pourrait exposer les dossiers patients aux attaques de type data exfiltration via le portail extranet.santetech-sante.fr.	Critique	Élevé	Élevé	Fuite données via exposition Cloud Act [E203]	Réduire + Transférer
M045	A12 — Parc IoT Médical	STRIDE-T — [E205] Manipulation de dispositifs non-patchables : les moniteurs et scanners avec micro-noyaux temps réel non patchables (OS non patchables partie parc) pourraient être compromis pour injecter des données falsifiées dans le système PACS/RIS.	Critique	Élevé	Élevé	Manipulation dispositifs non-patchables → injection données falsifiées [E205]	Accepter
M046	A12 — Parc IoT Médical	LINDDUN-I — [E140] Perturbation de l'intégrité des données : le VLAN IoT/Biomédical non cloisonné (10.1.30.0/24) permettrait à un attaquant de modifier les paramètres des dispositifs médicaux via le routage direct vers les automates.	Critique	Élevé	Élevé	Perturbation intégrité via VLAN non cloisonné [E203]	Réduire + Éviter
M047	A13 — Segmentation Réseau VLAN/NAC	STRIDE-R — [E203] Négation de service via routage non cloisonné : le VLAN IoT/Biomédical non cloisonné (10.1.30.0/24) permettrait à un attaquant de saturer le réseau avec des paquets malformés, causant une perte de disponibilité des dispositifs de surveillance.	Critique	Élevé	Élevé	Négation service via routage non cloisonné [E203]	Éviter

ID	Actif	Menace	Niveau	Probabilité	Impact	Justification	Traitement
M048	A14 — Wi-Fi Invités/Patients	STRIDE-I — [E140] Divulgation d'informations via filtrage SSL manquant : le VLAN Wi-Fi Invités/Patients (10.1.40.0/24) sans filtrage SSL permettrait à un attaquant d'intercepter les communications via le portail webmail.santetech-sante.fr et d'extraire des données sensibles.	Critique	Élevé	Élevé	Divulgation données via filtrage SSL manquant [E140] [E203]	Réduire
M049	A14 — Wi-Fi Invités/Patients	LINDDUN-D — [E203] Fuite de données via access point non sécurisé : le VLAN Wi-Fi Invités/Patients (10.1.40.0/24) avec sortie Internet directe sans filtrage SSL pourrait être utilisé pour des attaques de type phishing de rebond vers les cliniques.	Critique	Élevée	Élevé	VLAN Wi-Fi Invités/Patients (10.1.40.0/24) avec sortie Internet directe sans filtrage SSL permet du phishing de rebond [E203]	Réduire
M050	A15 — API SaaS / APIs Télémedecine	STRIDE-E — [E146] Élévation de privilèges via API Gateway non sécurisée : l'exposition de l'API Gateway Cloud Hybride sans signature images Docker/SBOM pourrait permettre à un attaquant de s'insérer dans la brique télémédecine et accéder à des données patients.	Critique	Élevée	Élevé	API Gateway Cloud Hybride exposée sans signature images Docker/SBOM favorise élévation de privilèges et infiltration télémédecine [E146]	Réduire
M051	A15 — API SaaS / APIs Télémedecine	[E146] Compromission de la confidentialité via API non durcie : l'API Gateway exposée sans vérification des signatures Docker/SBOM pourrait être exploitée pour des attaques de type data exfiltration via les flux de télémédecine.	Élevé	Élevée	Moyen	Exposition API non durcie (sans vérification signatures) permet data exfiltration via flux télémedecine [E146]	Réduire
M052	A16 — Domaine hospitalier — Site	STRIDE-D — Vol de données via vol d'identifiants administrateur (credential stuffing) sur postes non patchables et VPN FortiGate sans MFA [E163] [A17]	Critique	Élevée	Élevé	Forêt AD unique sans cloisonnement + SMB/CIFS exposés vulnérables aux credential stuffing et exposition de données patients [E140] [E145]	Réduire

ID	Actif	Menace	Niveau	Probabilité	Impact	Justification	Traitement
M053	A16 — Domaine hospitalier — Site	LINDDUN-L — Dénonciation de données patients via exposition physique des locaux informatiques (contrôle d'accès défaillant en période posturée) [E142]	Moyen	Moyenne	Moyen	Contrôle d'accès défaillant en période posturée expose physiques des locaux à déniement de confidentialité sur dossiers patients [E142]	Réduire
M054	A17 — Infrastructure réseau — Active Directory	STRIDE-T — Tampering des permissions AD via exploitation de compte service faible sur 60% des postes (pas de MFA sur VPN) enclinning aux attacks pass-the-hash [E140]	Critique	Élevée	Critique	Compte service faible + 60% postes sans MFA VPN permettent pass-the-hash et tampering permissions AD unique CVE-2021-38619 [E140]$_{[A17]}$	Réduire
M055	A17 — Infrastructure réseau — Active Directory	STRIDE-I — Denial of service du contrôleur de domaine unique par saturation DNS (DC/RODC sans replication) bloquant les authentifications à tous clinique [E140]	Élevé	Moyenne	Critique	DC/RODC unique sans replication + saturation DNS possible bloque authentifications tous sites clinique en cas DoS par épuisement DNS [E140]	Réduire
M056	A17 — Infrastructure réseau — Active Directory	LINDDUN-D — Disclosure personnelle des dossiers patients via forêt AD unique non cloisonnée avec partage SMB/CIFS sans filtrage SSL entre cliniques [E204][E145]	Élevé	Moyenne	Élevé	Forêt AD unique non cloisonnée permit partages SMB/CIFS sans filtrage SSL entre cliniques exposent dossiers patients transversalement [E145]$_{[A17]}$	Réduire
M057	A18 — Application métier — DPI Progiciel Nexus	STRIDE-R — Irresponsabilité des accès via RDS mis en réseau direct MPLS sans micro-segmentation VLAN/NAC permettant aux cliniques non sécurisées d'accéder à tous données [E38]	Critique	Élevée	Élevé	RDS mis en réseau direct MPLS sans micro-segmentation VLAN/NAC permet aux cliniques non sécurisées d'accéder à toutes données DPI [E38]	Réduire
M058	A18 — Application métier — DPI Progiciel Nexus	STRIDE-E — Élévation de privilèges via vulnérabilités Citrix XenApp/RDS (XenDesktop 7.15 CVE-2020-34692) permettant l'exécution code sur ferme RDS Siège [E146]	Critique	Élevée	Critique	CVE-2020-34692 Citrix XenApp exploitables sur ferme RDS Siège permettent exécution code et élévation privilèges globale [E146]$_{[A17]}$	Réduire

ID	Actif	Menace	Niveau	Probabilité	Impact	Justification	Traitement
M059	A18 — Application métier — DPI Progiciel Nexus	LINDDUN-L — Leakage des données patients via exploitation SMBv1 legacy actif sur PACS/RIS pour compatibilité scanners anciens [E131]	Critique	Élevée	Élevé	SMBv1 legacy actif sur PACS/RIS pour compatibilité scanners anciens vulnérable à exploitation CVE-2020-1479 et fuite données patients [E131]	Réduire
M060	A19 — Donnée/Structure — Données Patients (DPI)	STRIDE-I — Information leakage via exploitation ProxyShell sur Exchange 2016 non patché (DMZ vulnérable aux attacks Spraying) [E168][A17]	Critique	Critique	Critique	ProxyShell exploitables sur Exchange 2016 non patché en DMZ + campagnes Spraying permettent extraction massive données patients critiques [E168][A17] [CVE-2022-31497]	Réduire
M061	A19 — Donnée/Structure — Données Patients (DPI)	STRIDE-R — Repudiation des accès via logs citrix incomplets sur RDS legacy ne traçant pas les connexions aux dossiers patients [E208]	Élevé	Moyenne	Élevé	Logs Citrix legacy non traçants sur RDS exposés aux attaques de répudiation [E144, E203]	Réduire
M062	A19 — Donnée/Structure — Données Patients (DPI)	LINDDUN-D — Disclosure de 150 000 dossiers via API Gateway non sécurisée pour télémédecine (no authz, no encryption in transit) [E231][A11]	Critique	Élevée	Critique	API Gateway télémédecine sans authentification/ autorisation ni chiffrement transit expose 150 k dossiers patients [E146, E203, CVE-2023-38448]	Réduire
M063	A20 — Matériel IoT — Dispositifs Médicaux Connectés	STRIDE-S — Spoofing des commandes médicales via protocole Wi-Fi 6 non crypté (moniteurs, pompes perfusion) [E115][E204]	Critique	Élevée	Élevé	Protocoles Wi-Fi 6 non cryptés sur dispositifs médicaux permettent spoofing de commandes critiques [E203, CVE-2018-8962]	Réduire
M064	A20 — Matériel IoT — Dispositifs Médicaux Connectés	STRIDE-T — Tamper des paramètres d'automates via micro-noyaux temps réel non patchables permettant dosage erreur [E146]	Élevé	Moyenne	Élevé	Micro-noyaux temps réel non patchables sur automates médicaux permettant modification des dosages thérapeutiques [E209, CVE-2017-5369]	Réduire
M065	A20 — Matériel IoT — Dispositifs Médicaux Connectés	STRIDE-D — Disclosure de logs médicaux via exploitation Bluetooth LE sur appareils non isolés réseau (pompes à perfusion) [E117]	Faible	Faible	Moyen	Logs médicaux accessibles via Bluetooth LE uniquement sur appareils non isolés réseau (isolation hypothétiquement prévue) [E204, E147]	Réduire

ID	Actif	Menace	Niveau	Probabilité	Impact	Justification	Traitement
M066	A20 — Matériel IoT — Dispositifs Médicaux Connectés	LINDDUN-L — Leakage de données patients via Wi-Fi 6 non patché sur scanners (exposés au réseau Wi-Fi Invités sans filtrage SSL) [E120]	Élevé	Moyenne	Élevé	Scanner exposé au VLAN Wi-Fi Invités sans filtrage SSL permet exfiltration massive de données patients [E205, CVE-2023-32278]	Réduire
M067	A21 — Infrastructure Cloud — Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/ OVHcloud/Azure (pas d'imposition) [E142]	STRIDE-S — Attaquant tiers cloud : compromission de compte administrateur via phishing → élévation des privilèges sur infrastructure hybride (VM/K8s) ; accès non autorisé aux instances et données clients via interface console [E146,EBIOS-RM-A3]	Moyen	Moyenne	Moyen	Compromission compte cloud hybride via phishing possible (MFA inadapté sur 60% des comptes) mais HDS certifié réduit impact [E12, E145, CVE-2023-XXX]	Réduire
M068	A21 — Infrastructure Cloud — Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/ OVHcloud/Azure (pas d'imposition) [E142]	LINDDUN-Disclosure — Fuite de données patients via container compromis exposé sur métadonnées publics S3 → exfiltration de dossiers médicaux identifiables [E146,LINDDUN-Disclosure]	Critique	Élevée	Critique	Container S3 exposé à métadonnées publiques permettant exfiltration continue de données médicales identifiées sans chiffrage [E146, E149, LINDDUN-D]	Réduire
M069	A21 — Infrastructure Cloud — Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/ OVHcloud/Azure (pas d'imposition) [E142]	STRIDE-E — Attaquant réseau : écoute man-in-the-middle sur API de gestion IAM cloud hybride → injection de tokens JWT falsifiés pour impersonner soignants [E146,STRIDE-E]	Moyen	Faible	Élevé	Injection JWT falsifiée via attaque réseau possible mais infrastructure IAM centralisée (Entra ID/ Keycloak) atténue l'impact [E13, E145]	Réduire
M070	A22 — Infrastructure sécurité — Micro-segmentation VLAN/NAC — Architecture cible pour isoler poste clinique compromis (VLAN IoT/Biomedical 10.1.30.0/24 non cloisonné actuellement) [E146,E150,FichedAuditTechnique-ÉtatdesLieuxSanteTechAs-Is.pdf.md,E205]	STRIDE-R — Attaquant interne : poste clinique compromis contourne NAC mal configuré → mouvement latéral via VLAN IoT non isolé (10.1.30.0/24) vers serveurs critiques PACS/ RIS [E146,E205,STRIDE-R]	Critique	Élevée	Critique	Poste clinique compromis atteint PACS/RIS critique via VLAN IoT non cloisonné 10.1.30.0/24 (routage direct) [E169, E203, STRIDE-R]	Éviter
M071	A22 — Infrastructure sécurité — Micro-segmentation VLAN/NAC — Architecture cible pour isoler poste clinique compromis (VLAN IoT/Biomedical 10.1.30.0/24 non cloisonné actuellement) [E146,E150,FichedAuditTechnique-ÉtatdesLieuxSanteTechAs-Is.pdf.md,E205]	STRIDE-I — Attaquant externe : injection de paquets falsifiés entre VLAN Wi-Fi Invités (10.1.40.0/24) et VLAN Biomed → interception de flux IoT non chiffrés vers automates [E146,E205,STRIDE-I]	Faible	Faible	Moyen	Injection paquets entre VLANs possible mais hypothèse retenue interdiction Internet directe limite l'échelle [E171, E205, E140]	Transférer

ID	Actif	Menace	Niveau	Probabilité	Impact	Justification	Traitement
M072	A22 — Infrastructure sécurité — Micro-segmentation VLAN/NAC — Architecture cible pour isoler poste clinique compromis (VLAN IoT/Biomedical 10.1.30.0/24 non cloisonné actuellement) [E146,E150,FichedAuditTechnique-ÉtatdesLieuxSanteTechAs-Is.pdf.md,E205]	LINDDUN-Unawareness — Utilisateur soignant : clic sur lien de phishing redirigeant vers intranet compromis via VLAN invité → exécution malware sans MFA requis [E146,LINDDUN-Unawareness]	Critique	Élevée	Élevé	Phishing vers intranet via VLAN invité sans MFA requis expose utilisateurs à malware (déplacement de cible vers zone moins surveillée) [E13, E113]	Réduire
M073	A23 — Application/Rôle — IdP Gestion Identités (TO-BE) — Déploiement cible IdP centralisé (Entra ID/Keycloak) avec MFA FIDO2/Carte CPS [E146]	STRIDE-E — Attaquant : contournement processus de MFA sur application mobile compromise → injection de session utilisateur validée via exploit framework [E146,STRIDE-E,CVE-2023-29358 (si applicable)]	Critique	Élevé	Élevé	Contournement MFA via exploit framework [E146]. Mesures existantes (MFA FIDO2) réduisent probabilité mais impact critique sur accès aux données patients.	Réduire
M074	A23 — Application/Rôle — IdP Gestion Identités (TO-BE) — Déploiement cible IdP centralisé (Entra ID/Keycloak) avec MFA FIDO2/Carte CPS [E146]	Attaquant : lecture de logs d'authentification exposés via interface d'administration Keycloak → inférence données sensibles de patients sur les tokens validés [E146]	Élevé	Moyen	Élevé	Lecture de logs d'authentification exposés via Keycloak [E146]. Inférence de données sensibles via tokens validés.	Réduire
M075	A23 — Application/Rôle — IdP Gestion Identités (TO-BE) — Déploiement cible IdP centralisé (Entra ID/Keycloak) avec MFA FIDO2/Carte CPS [E146]	LINDDUN-L — Attaquant : accès non autorisé aux rapports d'audit d'authentification → profilage des habitudes médicales des soignants via historiques de connexions [E146,LINDDUN-L]	Élevé	Moyen	Élevé	Accès non autorisé aux rapports d'audit [E146]. Profilage médical via historiques de connexions.	Réduire
M076	A23 — Application/Rôle — IdP Gestion Identités (TO-BE) — Déploiement cible IdP centralisé (Entra ID/Keycloak) avec MFA FIDO2/Carte CPS [E146]	LINDDUN-Disclosure — Atteignant à travers le flux API admin : récupération de tokens refresh compromis → accès indirect aux données personnelles des patients (noms, diagnostics) sans consentement explicite [E146,LINDDUN-D]	Critique	Élevé	Élevé	Récupération de tokens refresh compromis via API admin [E146]. Accès indirect aux données patients sans consentement.	Réduire
M077	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]	STRIDE-T — Attaquant web : exploitation d'endpoint API non rate-limited → déni de service massif par requêtes inondées bloquant consultations télé-médicales urgentes [E146,STRIDE-T]	Critique	Élevé	Élevé	Exploitation d'endpoint non rate-limited [E146]. Dénigrement de service sur consultations urgentes.	Réduire

ID	Actif	Menace	Niveau	Probabilité	Impact	Justification	Traitement
M078	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]	STRIDE-I — Attaquant réseau : injection payload sur endpoint de télétransmission → interception flux DICOM/HEM (données patients en transit via HTTPS mal configured) [E146,STRIDE-I]	Critique	Élevé	Élevé	Injection payload sur endpoint HTTPS mal configuré [E146]. Interceptation de flux DICOM/HEM sensibles.	Réduire
M079	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]	STRIDE-E — Attaquant : falsification d'en-têtes Authorization sur API Gateway → élévation privilèges pour accéder dossiers patients hors périmètre de rôle soignant [E146,STRIDE-E]	Critique	Élevé	Élevé	Falsification d'en-têtes Authorization [E146]. Élévation de privilèges pour accès hors périmètre.	Réduire
M080	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]	LINDDUN-Disclosure — Exfiltration de données sensibles : accès indirect via endpoint /public-health-exports → lecture des historiques médicaux anonymisés identifiants [E146,LINDDUN-D]	Critique	Élevé	Élevé	Exfiltration de données via endpoint / public-health-exports [E146]. Lecture d'historiques médicaux anonymisés.	Réduire
M081	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]	STRIDE-S — Compromission d'accès admin à l'API Gateway cloud → substitution des certificates TLS au routage (SSL/TLS stripping) interceptant consultations [E146,STRIDE-S]	Critique	Élevé	Élevé	Substitution de certificates TLS via compromission admin [E146]. Interception de consultations sécurisées.	Réduire
M082	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]	LINDDUN-Unawareness — Patient connecté : clic sur lien de vérification SMS compromis par attaquants → validation de session sans connaissance du contexte médical (phishing social) [E146]	Critique	Élevé	Élevé	Phishing via lien SMS compromis [E146]. Validation de session sans contrôle contextuel.	Réduire
M083	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139]	STRIDE-R — Attaquant interne : exploit Citrix RDS (CVE-2021-37119) → élévation privilèges globale sur serveur de dossier patients puis accès aux archives cliniques [E139,STRIDE-R,CVE-2021-37119]	Critique	Élevé	Élevé	Exploit Citrix RDS (CVE-2021-37119) [E139]. Accès à archives cliniques via élévation de privilèges.	Réduire
M084	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139]	STRIDE-I — Attaquant réseau : redirection DNS vers serveur compromis → interception des échanges RDP/ICM entre médecins et postes navigateurs patients [E139,STRIDE-I]	Critique	Élevé	Élevé	Redirection DNS vers serveur compromis [E139]. Interception des échanges RDP/ICM médicaux.	Réduire

ID	Actif	Menace	Niveau	Probabilité	Impact	Justification	Traitement
M085	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139]	LINDDUN-Disclosure — Attaquant : lecture de logs serveur d'application expose en clair les infos patients en erreur → extraction noms, diagnostics via page 404 mal config [E139,LINDDUN-D]	Critique	Élevée	Élevé	Logs serveur exposés en clair + page 404 malconfig → extraction noms/diagnostics [E139] → fuite donnée patients critique [EBIOS-RM-A4,LINDDUN-D]	Réduire
M086	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139]	STRIDE-E — Attaquant : injection de script XSS en-page administration → exécution non autorisée permettant d'accéder aux dossiers patients sans authentification valide [E139,STRIDE-E]	Élevé	Moyenne	Élevé	Injection XSS côté serveur sur interface admin sans authentification robuste exploitable (CVE-2023-50387) → accès non autorisé aux dossiers patients [E139,STRIDE-E]	Réduire
M087	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139]	LINDDUN-L — Attaquant : accès non autorisé à API d'export de rapports → profilage des habitudes de soins des patients via agrégation des résultats anonymisés [E139,LINDDUN-L]	Moyen	Moyenne	Moyen	Accès API export de rapports mal protégé → agrégation résultats anonymisés reconstituent profils patients [E139,LINDDUN-L] → atteinte vie privée modérée [EBIOS-RM-A4]	Réduire
M088	A26 — Parc IoT Médical	STRIDE-D — Attaque par exploitation de vulnérabilités non-patchées sur les dispositifs IoT, exposés via le VLAN non cloisonné [E205]	Critique	Élevée	Élevé	IoT non-patchés routés dans VLAN médical non cloisonné → exploitation vulnérabilités connues possible (EOL) [E203,E205,STRIDE-D] → impact santé direct [EBIOS-RM-A4]	Réduire
M089	A26 — Parc IoT Médical	LINDDUN-D — Fuite de données sensibles via les dispositifs IoT non isolés, exploitant le routage direct vers les automates [E203]	Critique	Élevée	Critique	IoT biomédical connecté sans isolation réseau → données capteurs patient fuites routage direct vers automates [E203] → atteinte confidentialité/ sécurité patients grave [LINDDUN-D,EBIOS-RM-A4]	Réduire
M090	A26 — Parc IoT Médical	STRIDE-S — Attaque de spoofing via les micro-noyaux temps réel non patchables, exposés sans segmentation [E205]	Moyen	Moyenne	Moyen	Micro-noyaux temps réel IoT non patchables + exposition sans segmentation → spoofing attaques système possible [E205,STRIDE-S] → dégradation fonctionnalité critique	Réduire

ID	Actif	Menace	Niveau	Probabilité	Impact	Justification	Traitement
M091	A27 — Ferme Citrix/RDS	STRIDE-S — Spoofing via le réseau MPLS non segmenté, permettant l'accès à tous les serveurs physiques [E139]	Critique	Élevée	Critique	Ferme Citrix/RDS connectée sur réseau MPLS non segmenté avec accès physique direct à tous serveurs → compromission systémique tout le siège [E139,STRIDE-S] → atteinte intégrité masse données [EBIOS-RM-A4]	Réduire
M092	A27 — Ferme Citrix/RDS	STRIDE-R — Reproduction de trafic via la micro-segmentation absente, facilitant la lateralité [E139]	Élevé	Moyenne	Élevé	Micro-segmentation absente sur domaine Citrix/RDS → trafic capturé et reproduit lateralité entre serveurs physiques [E139,STRIDE-R] → propagation latérale possible	Réduire
M093	A28 — Postes legacy	LINDDUN-D — Fuite de données patients via les postes Windows 7/XP, non durcis contre les attaques par usurpation [E150]	Critique	Élevée	Critique	Postes Windows 7/XP non durcis + système de santé sensible → fuites données patients vulnérabilités connues exploitables (MS08-067 SMBv1, EternalBlue) [E150,LINDDUN-D] → données critiques exposées	Éviter
M094	A28 — Postes legacy	STRIDE-E — Élévation de privilèges via les postes Windows 7/XP, vulnérables aux exploits SMBv1 [E203]	Critique	Élevée	Élevé	Postes Windows 7/XP non patchés + protocoles legacy SMBv1 actifs → élévation privilèges exploits connus vulnérables [E203,STRIDE-E] → compromission poste puis réseau local [EBIOS-RM-A4]	Réduire
M095	A29 — MPLS Hub & Spoke	STRIDE-S — Spoofing via le réseau centralisé sans isolation, permis par la micro-segmentation absente [E139]	Critique	Élevée	Critique	Réseau MPLS Hub&Spoke centralisé sans isolation micro-segmentation → spoofing routes atteste exposition tous sites [E139,STRIDE-S] → accès transversal clinique à clinique	Réduire
M096	A29 — MPLS Hub & Spoke	STRIDE-R — Reproduction de trafic entre cliniques via l'IP directe, sans filtre SSL [E203]	Élevé	Moyenne	Élevé	Interconnexion IP directe entre cliniques + absence filtre SSL sur trafic répliqué → reproduction trafic sensible inter-sites [E203,STRIDE-R] → écoute/captation données en transit	Réduire

ID	Actif	Menace	Niveau	Probabilité	Impact	Justification	Traitement
M097	A30 — Active Directory	STRIDE-S — Spoofing via le domaine AD sans MFA, permettant la DCSync [E150]	Critique	Élevée	Critique	Domaine AD forest unique (corp.santetech.local) sans MFA sur 60% des comptes [E139] [E149], forêt Windows Server 2012 R2 avec rétrocabilité historique active [E201] permettant DCSync pour exfiltration totale de l'annuaire [E202].	Réduire
M098	A30 — Active Directory	STRIDE-E — Élévation de privilèges via les contrôleurs de domaine non durcis, vulnérables à Kerberoasting [E203]	Critique	Élevée	Élevé	16 contrôleurs de domaine (1 DC/RODC par clinique dans une forêt multisite) [E203], DC non durcis en VLAN interconnecté sans micro-segmentation [E140] exposés aux techniques Kerberoasting et spraying d'hash SHA [E203].	Réduire
M099	A31 — Base de Données PACS/RIS Imagerie	STRIDE-S — Stockage images radiologiques non chiffrées sur disque local en cliniques, exposé aux fuites lors de la copie vers USB ou cloud privé [E140][EBIOS-RM-A3]	Critique	Élevée	Élevé	Stockage DICOM sur baies SAN locales dans 12 cliniques avec SMBv1 encore actif par endroits pour compatibilité scanners [E205], copie vers USB/cloud sans chiffrement fort possible lors des exfiltrations physiques ou hybrides [E140].	Réduire
M100	A31 — Base de Données PACS/RIS Imagerie	STRIDE-I — Injection via DICOM gateway non filtrée sur 10.1.10.0/24, permettant l'écriture malveillante dans les études cliniques [E140] [E205]	Élevé	Moyenne	Élevé	Gateway DICOM non filtrée sur 10.1.10.0/24 connectée au VLAN IoT/Biomédical non cloisonné [E203] permettant écriture malveillante direct dans les bases cliniques sans isolation logique stricte [E145].	Réduire

ID	Actif	Menace	Niveau	Probabilité	Impact	Justification	Traitement
M101	A31 — Base de Données PACS/RIS Imagerie	STRIDE-R — Altération des métadonnées DICOM par un attaquant ayant accès au VLAN Serveurs Locaux compromis via lateral movement [E205][EBIOS-RM-A3]	Moyen	Moyenne	Moyen	Accès au VLAN Serveurs Locaux via lateral movement exploitable depuis une clinique compromise, corruption DICOM possible mais impact limité aux métadonnées si segmentation réseau partiellement efficace [E140][E203].	Réduire
M102	A32 — Messagerie Exchange 2016 OWA Webmail	STRIDE-T — Modification d'emails (email spoofing) depuis webmail exposé en DMZ sur webmail.santetech-sante.fr, campagne de phishing ciblant soignants [E140][E159]	Critique	Élevée	Critique	OWA Exchange 2016 exposé en DMZ sur webmail.santetech-sante.fr vulnérable à ProxyShell/Spraying si non patché (Exchange 2016 legacy) [E140] [E152], ciblage direct des soignants via phishing depuis interface web accessible extérieurement.	Réduire
M103	A32 — Messagerie Exchange 2016 OWA Webmail	LINDDUN-L — Leakage des dossiers patients via OWA non durci, accès distant par certificats faibles permet lecture mails contenant données sensibles [E152][E203] [LINDDUN-L]	Critique	Élevée	Élevé	OWA webmail sans filtrage SSL fort sur portail DMZ externe [E140], certificats faibles permettant lecture emails contenant données patients sensibles (mél messagerie sécurisée de santé) accessibles via authentification compromise [E152].	Réduire
M104	A32 — Messagerie Exchange 2016 OWA Webmail	STRIDE-E — Exploitation ProxyShell/Spraying non corrigé par patching Exchange 2016 legacy, permettant exécution RCE sur serveur messagerie [E152] [CVE-2022-41040]	Critique	Élevée	Critique	ProxyShell/Spraying vulnérabilité CVE-2022-41040 connue et non corrigée selon audit technique [E205], permettant exécution code arbitraire RCE sur serveur messagerie critique exposé en DMZ [E171].	Réduire

ID	Actif	Menace	Niveau	Probabilité	Impact	Justification	Traitement
M105	A33 — Portail VPN FortiGate	STRIDE-T — Compromission de session via authentification simple login/mot de passe sans MFA, injection de tokens dans les flux d'authentification [E149] [E150]	Moyen	Moyenne	Moyen	Authentification simple login/mot de passe sans MFA systématique sur 60% des comptes VPN FortiGate [E139] [E149], injection tokens possible dans flux d'authentification non chiffrés ou faiblement sécurisés.	Réduire
M106	A33 — Portail VPN FortiGate	LINDDUN-Disclosure — Fuite d'identifiants VPN 60% des comptes sans MFA, accès privilégié aux ressources internes après compromission de credentia [E140][E149]	Critique	Élevée	Élevé	Fuite identifiants VPN sur 60% des comptes sans double facteur [E152], accès privilégié interne post-compromission crédentiel avec accès VLAN biomédical IoT direct [E203][E140] et cloud externe exfiltrable.	Réduire
M107	A33 — Portail VPN FortiGate	STRIDE-I — Attaques d'injection dans les logs FortiGate pour corrompre l'historique des accès, masquer les tentatives de bypass [E150]	Faible	Faible	Moyen	Logs FortiGate exposés mais non chiffrés sans impact immédiat masquage, corrompre historique accessible uniquement depuis admin compromise ou faille côté passerelle VPN [E231][E176].	Réduire
M108	A34 — Contrôleur de Domaine RODC par Clinique	STRIDE-S — Dumping de hachages d'identifiants via LSASS compromise sur 12 RODC, exfiltration vers cloud externe [E202][E140]	Critique	Élevée	Critique	12 RODC (1 par clinique) avec dumping LSASS possible sur 12 contrôleurs en distribution régionale [E202], hachages non salés exposés à exfiltration totale vers cloud externe ou stockage adverse [E140].	Réduire
M109	A34 — Contrôleur de Domaine RODC par Clinique	STRIDE-T — Création d'objets Kerberos faux sur réseau 10.1.0.0/16, permettant délégué d'accès à tous les DC du périmètre [E202][E138] [MITRE-T1558]	Critique	Élevée	Élevé	12 DC RODC sans micro-segmentation [E138], absence SOC [E9] → compromission totale AD possible, impact sur toutes les cliniques	Réduire

ID	Actif	Menace	Niveau	Probabilité	Impact	Justification	Traitement
M110	A34 — Contrôleur de Domaine RODC par Clinique	STRIDE-E — Poisoning LDAP via écriture sur RODC (mode read-only théoriquement mais pas en pratique), injection d'objets malveillants [E202]	Élevé	Moyen	Élevé	RODC en mode read-only théorique mais pas appliqué [E138], injection objets via LDAP vulnérable [E202] → persistance long terme sans détection	Réduire
M111	A35 — Sécurité IT (SOC/EDR/SIEM)	STRIDE-T — Détection inexistante d'attaques Ransomware en temps réel, propagation latérale non surveillée via réseau MPLS [E140][E40]	Critique	Élevée	Critique	Détection Ransomware nulle, absence EDR/SIEM centralisé [E9][E40] → propagation latérale dans les 185 serveurs legacy indétectable	Réduire
M112	A35 — Sécurité IT (SOC/EDR/SIEM)	STRIDE-I — Ingestion d'alertes de sécurité nulle, absence d'intégrité sur les logs SIEM ne permet pas la chasse aux intrus [E9][E139]	Élevé	Moyenne	Élevé	Absence ingestion alertes sécurité [E9], logs SIEM sans intégrité [E139] → chasse aux intrus impossible en environnement on-premise legacy	Réduire
M113	A35 — Sécurité IT (SOC/EDR/SIEM)	LINDDUN-L — Non-détection des exfiltrations de données patients vers cloud tiers, absence de comportement Anomaly sur les flux EDR [E40] [EBIOS-RM-A3]	Critique	Élevée	Critique	Exfiltration cloud tiers non déteccable, absence EDR sur flux critiques [E40] [EBIOS-RM-A3] → violation RGPD avec données patients 150 000 dossiers	Réduire
M114	A36 — Attestation de relecture croisée	STRIDE-S — Attaque par phishing via le portail VPN (E140)	Critique	Élevée	Critique	Phishing portail VPN FortiGate simple login [E139], CVE-2023-23977 exploité, absence MFA sur 60% comptes [E160] → accès direct AD compromise global	Réduire
M115	A36 — Attestation de relecture croisée	LINDDUN-Disclosure — Fuite de données via le Webmail OWA non patché (E201)	Critique	Élevée	Critique	Webmail Exchange 2016 DMZ exposé sans patchs [E163], vulnérable campagnes ProxyShell/Spraying [E9][E145] → fuite emails médicaux sensibles	Réduire

ID	Actif	Menace	Niveau	Probabilité	Impact	Justification	Traitement
M116	A37 — CISO / Lead GRC	STRIDE-T — Élevaison de privilèges via accès non surveillé aux serveurs legacy (E203)	Élevé	Moyenne	Élevé	Accès non surveillé serveurs legacy obsolètes [E203] [E30], absence MFA + absence EDR [E9] → élèvasion privileges root sur infrastructure critique	Réduire
M117	A37 — CISO / Lead GRC	LINDDUN-Unawareness — Ignorance des protocoles RGPD par le Chef de projet sécurité (E149)	Faible	Faible	Moyen	Ignorance RGPD personnel sécurité CISO (E149), formation non documentée dans les preuves → non-conformité réglementaire impact modéré sur sanctions	Réduire + Accepter
M118	A38 — Blue Team & SOC	STRIDE-D — Déni de service via surcharge des serveurs de secours locaux (E201)	Moyen	Faible	Élevé	Serveurs secours locaux saturés DDoS [E201] → déni service mais pas compromission systèmes cœur (backup non critique pour disponibilité continue)	Réduire + Accepter
M119	A38 — Blue Team & SOC	LINDDUN-NC — Non-conformité aux standards ISO 27001 pour les analyses de menace (E223)	Faible	Moyenne	Faible	Analyses menace non conformes ISO 27001 [E223], processus EBIOS RM requis mais absent [E9][E4] → impact limité à certification, pas sécurité opérationnelle	Réduire + Accepter
M120	A39 — CTI & OSINT	STRIDE-I — Interceptation des flux API Gateway via le VLAN IoT non cloisonné (E205)	Critique	Élevée	Critique	VLAN IoT biomédical non cloisonné routage direct automate [E205][E136], interception API Gateway possible sans micro-segmentation [E228] → accès flux données patients via canal compromis	Réduire
M121	A39 — CTI & OSINT	LINDDUN-Disclosure — Fuite d'OSINT via les sites web des cliniques hébergés par des prestataires tiers (E201)	Faible	Moyen	Faible	Sites web des cliniques hébergés par prestataires tiers (E201) : exposition publique aux moteurs de recherche et attaques OSINT, mais données patient non stockées sur ces sites → fuite informations organisationnelles seulement.	Accepter

ID	Actif	Menace	Niveau	Probabilité	Impact	Justification	Traitement
M122	Frontière Internet ↔ VPN_Gateway (FortiGate)	STRIDE-S — Portail vpn.santetech-sante.fr expose avec login/mot de passe simple sans MFA sur 60% des comptes [E7][E38][E203] → attaquant réalise brute-force ou credential stuffing pour obtenir accès interne au backbone MPLS.	Élevé	Élevée	Moyen	Portail VPN sans MFA sur 60% des comptes confirmé audit (E7, E38, E203) : attaquant peut effectuer brute-force ou credential stuffing pour accès interne backbone MPLS.	Réduire
M123	Frontière Internet ↔ VPN_Gateway (FortiGate)	STRIDE-I — Extranet médecins (extranet.santetech-sante.fr) [E32][A7] : authentification faible permet usurpation d'identité soignant pour modifier/falsifier données médicales ou prescriptions.	Critique	Élevée	Élevé	Extranet médecins E32, A7 : authentification faible permet usurpation identité soignant pour modifier/falsifier données médicales ou prescriptions (EBIOS-RM-A3).	Réduire
M124	Frontière Internet ↔ Portail OWA (Exchange 2016 DMZ)	STRIDE-I — Webmail OWA public (webmail.santetech-sante.fr) [E3][E57] : vulnérabilités ProxyShell/ CVE-2024 potentielles exposent dossiers patients aux fuites par accès RCE sans filtre SSL.	Élevé	Moyenne	Élevé	Webmail OWA public (E3, E57) vulnérable ProxyShell/CVE-2024 potentiel sans filtre SSL : accès RCE expose dossiers patients à fuites (CVE-2024-26099, STRIDE-I).	Réduire
M125	Frontière DMZ ↔ WAF optionnel (non déployé As-Is)	STRIDE-R — WAF/SIEM absent [E36][E271] → attaque DoS direct contre API Gateway/Cloud_HDS possible sans atténuation, paralysant services télémédecine.	Élevé	Élevée	Moyen	WAF/SIEM absent (E36, E271) → attaque DoS direct API Gateway/CloudHDS possible sans atténuation, paralysant services télémédecine (EBIOS-RM-A3).	Réduire
M126	Frontière DMZ ↔ WAF optionnel (non déployé As-Is)	STRIDE-T — Site WordPress vitrine [E274] [E9] : injection SQL/XSS possible via absence de couche WAF pour compromettre réputation clinique et filer données personnelles exposées.	Faible	Moyenne	Faible	Site WordPress vitrine (E274, E9) : injection SQL/XSS possible via absence WAF, compromettant réputation clinique mais pas données critiques SI (ANSSI-CARTO-SI).	Réduire
M127	Frontière Réseau Interne ↔ Backbone MPLS (sans micro-segmentation)	STRIDE-T — Backbone MPLS centralisé sans isolation logique [E36] [E203][E277] → un poste compromis clinique peut communiquer IP directe avec tout réseau interne, accédant serveurs sensibles siège.	Élevé	Moyen	Élevé	Backbone MPLS sans micro-segmentation (E36, E203, E277) : un poste compromis clinique communique IP directe avec tout réseau interne, accédant serveurs sensibles siège.	Réduire

ID	Actif	Menace	Niveau	Probabilité	Impact	Justification	Traitement
M128	Frontière Réseau Interne ↔ Backbones AD (Forêt unique)	STRIDE-S — Forêt Active Directory corp.santetech.local 16 DC/RODC [E2][A7] [E277] : absence micro-segmentation permet propagation latérale compromise RODC → forêt principale via Kerberoasting/DCE-RPC.	Élevé	Moyenne	Élevé	Forêt AD unique 16 DC/RODC sans micro-segmentation (E2, A7, E277) : absence isolation logique permet propagation latérale compromise RODC → forêt principale via Kerberoasting/DCE-RPC.	Réduire
M129	Frontière Réseau Interne ↔ Citrix Farm (DPI Nexus)	STRIDE-S — Ferme Citrix/ RDS Rennes héberge DPI Nexus [E25][E148] [A7] : accès RDP interne non contrôlé expose données patients 150k dossiers à extraction par attaquant pivotant via réseaux internes.	Élevé	Moyenne	Élevé	Ferme Citrix/RDS Rennes héberge DPI Nexus (E25, E148, A7) : accès RDP interne non contrôlé expose données patients 150k dossiers à extraction par attaquant.	Réduire
M130	Frontière VLAN IoT ↔ Core_Net (routage direct)	STRIDE-R — VLAN IoT/ Biomédical 10.1.30.0/24 routé directement vers automates [E9][A17] : botnets Mirai infecte pompes perfusion/ moniteurs non patchables, attaques DoS internes critiques bloques soins vitaux.	Critique	Élevée	Critique	VLAN IoT routé directement vers automates (E9, A17) : botnets Mirai infecte pompes perfusion/ moniteurs non patchables, attaque DoS interne bloquant soins vitaux (EBIOS-RM-A3).	Éviter
M131	Frontière VLAN IoT ↔ Core_Net (routage direct)	STRIDE-T — VLAN IoT non cloisonné [E9][E277] : compromis device biomédical permet exécution commandes malveillantes sur automates sensibles et fuite logs d'audit.	Faible	Moyenne	Faible	VLAN IoT non cloisonné (E9, E277) : compromis device biomédical permet exécution commandes malveillantes et fuite logs d'audit mais sans impact SI critique.	Réduire
M132	Frontière Wi-Fi Invités ↔ Internet (sans SSL filtering)	LINDDUN-Disclosure — Wi-Fi patients 10.1.40.0/24 sortant internet sans filtrage SSL [E18][A7] : malware contourne firewall via trafic HTTP non inspecté, vol données sensibles requêtes outbounds.	Élevé	Élevée	Moyen	Wi-Fi patients sortant internet sans filtrage SSL (E18, A7) : malware contourne firewall via trafic HTTP non inspecté, vol données sensibles requêtes outbounds (LINDDUN-Disclosure).	Réduire

ID	Actif	Menace	Niveau	Probabilité	Impact	Justification	Traitement
M133	Frontière Wi-Fi Invités ↔ Internet (sans SSL filtering)	STRIDE-E — Accès libre sans authentification Wi-Fi patients mobiles [E9] : attaquant établit position de listening sur réseau de confiance pour intercepter sessions et élever privilèges via MITRE T1548.5.	Élevé	Élevé	Moyen	VLAN Wi-Fi Invités/ Sortie Internet directe sans filtrage SSL [E203], attaquant intercepte sessions patients mobiles sans authentification requise — risque d'enregistrement passif de trafic chiffré et injection dans session utilisateur [E9]	Réduire
M134	Frontière Cloud_HDS ↔ API Gateway (hybride To-Be)	STRIDE-S — Migration DPI Nexus vers Cloud HDS [E9][A7] : absence contrôle d'accès API Gateway initial permet intrusions dans infra hébergement hybride et accès non autorisé ressources sensibles.	Critique	Élevé	Élevé	Migration hybride To-Be API Gateway CloudHDS absence contrôle accès initial [E9][A7], intrusions permises dans infra hébergement et accès non autorisé ressources sensibles — surface d'attaque élargie par exposition API télémédecine vers Internet [E231]	Réduire
M135	Frontière Cloud_HDS ↔ API Gateway (hybride To-Be)	LINDDUN-L — Exposition contrôlée mais signature SBOM/Docker absente [E16] → fuite données santé via endpoints API non signés ou conteneurs compromis sans attestation d'intégrité.	Élevé	Moyen	Élevé	Exposition contrôlée mais signature SBOM/ Docker absente [E16], fuite données santé via endpoints API non signés et conteneurs sans attestation d'intégrité — fuites possibles avant mise en place pipeline signature intégrée [E232]	Réduire

Description du système

Fichier : 00-description.md

1. Résumé de la fiche (cas étudié)

Cas SanteTech : Étude de Sécurité — Projet SECU-CLOUD-HEALTH (M2 Cybersécurité, bloc 1)

Ce document résume l'architecture **AS-IS** du groupe hospitalier **SanteTech**, les périmètres, les contraintes réglementaires et techniques, ainsi que les hypothèses validées pour l'analyse de risques E21. L'ensemble est ancré dans la méthode de cartographie des systèmes d'information de référence **ANSSI-CARTO-SI** (2018).

Éléments	Valeurs validées
Secteur / Enjeu	Santé numérique, migration vers un cloud hybride certifié HDS
Périmètre physique	Siège social (Rennes) + 12 cliniques régionales (Grand Ouest & Île-de-France) [E10][E224]
Collaborateurs	~4 500 personnes : 1 200 médecins, 2 300 soignants, 1 000 administratifs [E204]
Dossiers patients actifs	150 000 dossiers dans le DPI Nexus legacy [E19][E223]
Serveurs & applications	185 serveurs (65 physiques, 120 virtuels) ; 3 200 postes + ~4 000 dispositifs IoT médicaux [E147][E3][E230]
Contraintes réglementaires	RGPD, NIS 2, certification HDS, ISO 27001
Objectif de la mission	Concevoir une architecture sécurisée (To-Be) : cloud hybride HDS, microservices, zero trust et API Gateway. Tester la résilience contre ransomwares/fuites [E224]

🗺️ 2. Architecture et frontières de confiance (DFD — diagramme des flux)

La figure ci-dessous représente les vues **métier → applicative → technique** selon la logique de l'ANSSI, avec les frontières de confiance principales :

```
flowchart LR
    subgraph sg1["Internet (Zone externe non contrôlée)"]
        Web_Sites[Cliniques web sites WordPress]
        VPN_Fortigate[Portail VPN vpn.santetech-sante.fr]
        OWA[Webmail OWA webmail.santetech-sante.fr]
        Extranet[Extranet médecins partenaires extranet.santetech-sante.fr]
    end

    subgraph sg2["DMZ / Zone de périmètre (FortiGate, WAF optionnel)"]
        VPN_Gateway[Passerelle FortiGate + MFA FIDO2/Carte CPS]
        WAF_Optionnel[Filtre WAF/SIEM non déployé As-Is]
    end

    subgraph sg3["Réseau interne (Hub & Spoke — MPLS)"]
        Core_Net[Backbone MPLS interconnecté]
        AD_Forest["Forêt AD corp.santetech.local (16 DC/RODC)"]
        Citrix_Farm["Ferme Citrix/RDS Rennes — DPI Nexus"]
        SAN_PACS[Baies SAN PACS / DICOM / RIS]
    end

    subgraph sg4["IoT médical (VLAN isolé mais non cloisonné Actuel)"]
        VLAN_IoT["10.1.30.0/24 — VLAN IoT/Biomédical"]
        WiFi_Invites["10.1.40.0/24 — Wi-Fi invités/Patients sortant Internet direct"]
    end
```

```
    subgraph sg5["Exposition externe / Cloud Hybride To-Be"]
        API_Gateway[API Gateway Cloud Hybride HDS]
    Cloud_ToBe["Migration DPI Nexus + télémédecine vers Cloud HDS (Azure/OVHcloud
    end

    Web_Sites -->|HTTPS/HTTP| Internet[(Internet)]
    VPN_Fortigate -->|"FortiGate + MFA →"| VPN_Gateway
    OWA -->|Webmail public| Internet
    Extranet -->|Authentification faible| Internet
    VPN_Gateway -->|RDP/JAAS interne| AD_Forest
    VPN_Gateway -->|Réseau Soignants| Core_Net
    Core_Net -->|MPLS backbone| Citrix_Farm
    Core_Net -->|Stockage DICOM/SMBv1| SAN_PACS
    VLAN_IoT ----->|Routage direct, non cloisonné| Core_Net
    WiFi_Invites -->|Sortie Internet sans SSL filtering| Internet
    AD_Forest -->|Active Directory / Samba| Citrix_Farm
    %% SAN_PACS <----Core_Net--- Citrix_Farm

    Core_Net -.-> API_Gateway
    API_Gateway -.-> Cloud_ToBe

    style Internet fill:#f9f ,stroke:#333,stroke-width:2px
    style Internet fill:#f9f,stroke:#333
    style DMZ fill:#ff9,stroke:#333
    style Réseau_interne fill:#bbf,stroke:#333
    style IoT_medical fill:#bfa5c3,stroke:#845a74
    style Exposition_Cloud fill:#bfb
```

Schéma Mermaid — si le dessin ne s'affiche pas (hors ligne, PDF), le texte ci-dessus est le code du schéma.

Explication des zones (selon la cartographie ANSSI) :

Zone	Description	Frontière de confiance
Internet	Extérieur non contrôlé, attaques OT/BOT, scanning, phishing.	Interface sortante/entrée directe sans contrôle fort (WAF, SIEM).
DMZ / VPN Gateway	Point d'entrée principal (vpn.santetech-sante.fr) + OWA. Authentification simple → risque accès non filtré [E7][E203]	FortiGate + login/mot de passe sans MFA sur 60% des comptes (hypothèse validée As-Is) [E44].
Réseau interne (Hub & Spoke)	Backbone MPLS centralisé par le siège. Routage direct entre clinique et siège. Micro-segmentation absente : un poste compromis peut tout atteindre [E36][E203]	Interne — accès restreint aux identités AD, mais absence de micro-segmentation VLAN.

Zone	Description	Frontière de confiance
VLAN IoT/Biomédical (10.1.30.0/24)	Dispositifs non patchables : pompes perfusion, moniteurs, scanners. OS temps réel non patchables [E17][E3]. Routage direct vers les automates — absence de NAT/firewall interne entre VLAN IoT et cœur réseau [E9]	Frontière technique : VLAN isolé mais routage direct actif (absence de micro-sgmentation VLAN/NAC).
VLAN Wi-Fi Invités/ Patients (10.1.40.0/24)	Accès Internet sans filtrage SSL pour la connectivité des patients [E18][E203]. Risque rebond défacement/phishing.	Exposé à Internet, accès libre, sortie non contrôlée.
Cloud hybride To-Be	Migration du DPI Nexus vers un cloud certifié HDS (Scaleway/ OVHcloud/Azure) + nouvelle API Gateway télémédecine. Contrainte : hébergeur HDS obligatoire [E5][E9]	Frontière hybride contrôlée — accès via API Gateway sécurisée, signature images Docker/SBOM à intégrer.

---

3. Contexte métier & contraintes (données personnelles = `true`)

Données personnelles et sensibilité

Ce système traite, stocke et transmet des **données de santé**, données sensibles par nature :

Type de donnée	Sensibilité	Volume	Préoccupations principales RGPD/ NIS 2
Dossiers patients (DPI Nexus)	Critique / Données à caractère personnel sensibles	150 000 dossiers actifs [E19]	Accès non autorisé, fuites via RDP/Citrix, fuite de données via API Gateway [E18]
Stockage images radiologiques (PACS/ RIS)	Critique / Données à caractère personnel sensibles	150 k dossiers + imagerie DICOM	Protocoles SMBv1 actifs → vulnérabilités non patchées, accès RDP internes [E2] [E5]
Messagerie sécurisée (Mél)	Sensible / Données personnelles	Exchange 2016 DMZ + Webmail OWA	Vulnérabilités ProxyShell/Spraying, absence de filtrage SSL externe, exposition DMZ [E3][E5]
Parc Wi-Fi Invités/ Patients	Publique (accès libre)	700 PC portables administratifs, 4 500 collaborateurs	Accès Internet direct sans filtrage SSL → fuites potentielles via conteneurs/ patients mobiles [E18]
Identities AD / Rôles & permissions	Sensible (identifiants/ MDP)	Forêt unique corp.santetech.local avec 16 DC/RODC, pas de MFA systématique sur le VPN As-Is	Authentications faibles, absence de MFA FIDO2/Carte CPS [E45]

Champ `donnees_personnelles` = `true` — L'analyse STRIDE doit donc être complétée par une gride LINDDUN (confidentialité, intégrité, authenticabilité, non-repudiation) pour les échanges sensibles, notamment via l'API Gateway et les flux DMZ [E8][E9].

Contraintes réglementaires & exigences techniques

Référence	Exigence applicable / Impact sur l'analyse
RGPD	Traitements de données sensibles ; registre de traitement à produire ; droit à l'effacement, limitation de conservation.
NIS 2	Obligation d'évaluer les risques, SOC centralisé (EDR/SIEM), plans de reprise (PCA/PRA).
HDS (Certification)	Hébergement dans un cloud certifié HDS (obligatoire pour migration du DPI et télémédecine). Analyse exposition Cloud Act pour souveraineté des données.

Référence	Exigence applicable / Impact sur l'analyse
PSSI / ISO 27001	Durcissement des accès, gestion des vulnérabilités (patch management) ; revue de politiques de sécurité (PSSI).

Hypothèses techniques (validées + écarts à signaler)

Certaines hypothèses « To-Be » doivent être traitées comme des éléments non documentés tant qu'aucune preuve n'est disponible :

Élément	Hypothèse retenue / État actuel	Écarts notables (à valider)
Migration DPI Nexus	Vers Cloud HDS certifié, pas de fournisseur imposé. API Gateway nouvelle brique.	Aucun choix de fournisseur imposé ; analyse Cloud Act obligatoire [E6][E9]
MFA systématique	Déploiement cible Entra ID / Keycloak avec MFA FIDO2 / Carte CPS pour les soignants [E45].	As-Is : pas de MFA sur le VPN → 60% des comptes sans MFA, simple login/mot de passe [E7][E203]
VLAN IoT vs VLAN Wi-Fi	Isolation logique stricte (micro-segmentation) pour la cible To-Be. Actuellement : routage direct entre automate et cœur réseau, VLAN IoT non cloisonné [E15].	Écart documenté : fiche FAQ (doc) vs audit technique (fiche d'audit) : les deux documents s'accordent sur l'absence de micro-segmentation actuelle [E9] [E203]
SOC / EDR / SIEM	Absence initiale des 3 briques SOC centralisé. Projet doit répondre aux exigences NIS 2/RGPD/HDS.	Aucun SOC/EDR/SIEM déployé en As-Is ; Blue Team & SOC non implémentée [E140][E38]
Postes irréductibles (Windows 7/XP Embedded)	~5% du parc (~200 postes) ne peuvent être patchés ou upgradées. Utilisés pour l'imagerie médicale et automates vieux scanners.	Pas de plan de remplacement prévu ; risque vulnérabilité élevée par absence de correctifs [E139]
Postes legacy imagerie	200 postes Windows 7/XP Embedded pilotant des vieux automates d'imagerie (pas de patch possible) [E18] [E140].	Risque élevé : vulnérabilités connues non patchables ; dépendance forte à l'application métier PACS/RIS.
Postes portables cadres	700 PC portables BitLocker mais sans agent EDR moderne, uniquement antivirus signature ancien [E156].	Absence d'agent EDR ; vulnérabilités potentielles Ransomware via ports USB ou connexion Wi-Fi non filtré.

---

4. Actifs « à ne pas oublier » (liste courte pour l'évaluation LINDDUN)

Pour la grille LINDDUN, l'analyse porte prioritairement sur ces éléments sensibles et exposés :

Actif stratégique	Pourquoi important	Exposition principale
API Gateway Cloud Hybride – Nouvelle brique de télémédecine [E16]	Interface REST/HTTPS entre le cloud HDS et les systèmes clients. Signature SBOM et images Docker doivent être intégrées.	Fuite de données (Linddun-**L**), usurpation d'identité (A), non-repudiation (NR) si signature API absente.
DPI Nexus Legacy (Citrix/RDS) – Données patients + 185 serveurs [E1] [E25]	Cœur métier du traitement administratif/ consommation médicale.	Accès interne via RDP non contrôlé, absence de micro-segmentation, vulnérabilité proxyshell si Exchange exposé.
VLAN IoT/Biomédical (10.1.30.0/24) – 4 000 dispositifs [E17]	Dispositifs médicaux critiques non patchables : pompes perfusion, moniteurs, scanners.	Risque de contrôle à distance si compromis via botnets (ex. Mirai) ou attaques DoS interne.

Actif stratégique	Pourquoi important	Exposition principale
VLAN Wi-Fi Invités/Patients (10.1.40.0/24) – Accès Internet direct sans SSL filtering [E18]	Exposition directe aux attaquants depuis l'internet pour les patients mobiles.	Attaques pharming/phishing, fuite de données via conteneurs malveillants dans le trafic sortant Wi-Fi.
Messagerie OWA (webmail.santetech-sante.fr) – Serveur Exchange 2016 DMZ [E3]	Accès Webmail public et messages cliniques entre professionnels externes/parisiennes.	Attaques Spraying/ProxyShell, accès non filtré SSL, vulnérabilités connues CVE-2024… potentielles si version > 2024.

Conclusion de l'étape 1 (cartographie)

La vue **AS-Is** présente une architecture legacy fortement couplée :

- Un backbone MPLS centralisé mais **sans micro-segmentation**, ce qui fait de chaque clinique un point d'accès potentiel aux serveurs sensibles du siège.
- Des applications métier critiques (DPI Nexus, PACS/RIS) hébergées sur des infrastructures **legacy** avec absence de SOC/EDR/SIEM centralisé.
- Du domaine IoT médical exposé à Internet via VLAN non cloisonné et Wi-Fi patient, ce qui ouvre la voie à des attaques botnet/ransomware ciblant les automates sensibles.

Le projet SECU-CLOUD-HEALTH propose une transformation vers un **cloud hybride HDS** certifié avec :

- Migration du DPI Nexus vers un cloud HDS (choix fournisseur libre : Azure, Scaleway ou OVHcloud).
- Déploiement d'un **IdP centralisé** avec MFA systématique FIDO2 / Carte CPS.
- Nouvelle **API Gateway sécurisée** pour la télémédecine et exposition contrôlée des flux sensibles.

Les écarts de sécurité (absence SOC, VLAN non cloisonné, MFA partiel) doivent être priorisés via une grille LINDDUN + scoring CVSS/CVE pour définir les risques résiduels du To-Be.

Inventaire des actifs

Fichier : 01-actifs.md

ID	Actif	Type	Description, périmètre et valeur	Sensibilité	Preuve source
A01	Dossier Patient Informatisé (DPI) Nexus	Logiciel / Service	185 serveurs (65 physiques, 120 virtuels), Progiciel Nexus version legacy sur ferme Citrix/RDS, accès soignants RDP interne, valeur métier critique pour le traitement administratif et médical [E203]	Critique	[E203][E5][E7]

ID	Actif	Type	Description, périmètre et valeur	Sensibilité	Preuve source
A02	PACS/RIS (Archivage & Imagerie)	Logiciel / Service	Stockage DICOM/SMBv1 sur baies SAN locales vieillissantes, caches DICOM/PACS restants en local des cliniques, protocoles SMBv1 pour compatibilité scanners anciens [E203][E7]	Critique	[E203][E5][E7]
A03	Messagerie Sécurisée de Santé (Mél)	Logiciel / Service	Serveur Exchange 2016 exposé DMZ, Webmail OWA webmail.santetech-sante.fr, vulnérable ProxyShell/ Spraying si non patché [E7][E5]	Sensible	[E7][E203][E5]
A04	Portail VPN Télétravail & Praticiens Libéraux	Service / Site Internet	vpn.santetech-sante.fr (Passerelle FortiGate/FortiSSL), Login/Mot de passe AD sans MFA sur 60% des comptes, authentification simple [E7] [E5]	Sensible	[E7][E203][E5]
A05	Webmail de Santé & Accès Externe (OWA)	Service / Site Internet	webmail.santetech-sante.fr (Exchange 2016 DMZ), non filtré SSL si vulnérabilités, campagnes Spraying/ ProxyShell potentielles [E7][E5]	Sensible	[E7][E203][E5]
A06	Extranet Partenaires / Médecins Libéraux	Service / Site Internet	extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérieurs [E7][E5]	Sensible	[E7][E203][E5]
A07	Sites Web Cliniques (12 sites)	Site Internet / Prestataire	Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond [E7][E5]	Publique	[E7][E203][E5]
A08	Domaine Active Directory (corp.santetech.local)	Logiciel / Infrastructure	Forêt AD unique, 16 contrôleurs de domaine (1 DC/RODC par clinique), pas de MFA systématique VPN As-Is [E9][E7][E5]	Sensible	[E9][E7][E203]
A09	Contrôleurs de Domaine AD (16 unités)	Matériel / Infrastructure	1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène [E9][E5]	Critique	[E9][E7][E203]
A10	Applications Cloud Hybride (To-Be)	Logiciel / Service	Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique [E9][E5][E11]	Sensible	[E9][E7][E203]
A11	Fournisseur Cloud HDS (Prestataire)	Prestataire	Certification HDS obligatoire pour hébergeur données de santé, analyse exposition Cloud Act, aucun fournisseur imposé [E9][E7][E5]	Sensible	[E9][E7][E203]
A12	Parc IoT Médical (4 000 dispositifs)	Matériel	~350 par site (pompes perfusion, moniteurs, scanners), OS non patchables partie parc, interdictions accès Internet direct [E9][E11]	Critique	[E9][E7][E203]

ID	Actif	Type	Description, périmètre et valeur	Sensibilité	Preuve source
A13	Segmentation Réseau VLAN/NAC IoT (Micro-segmentation)	Infrastructure / Service	Micro-segmentation VLAN/NAC pour iso logique automate compromis, 10.1.30.0/24 VLAN IoT/Biomédical non cloisonné routage direct [E9][E203]	Sensible	[E9][E7][E203]
A14	Wi-Fi Invités/Patients (VLAN 10.1.40.0/24)	Infrastructure / Service	10.1.40.0/24 VLAN sortant Internet direct sans filtrage SSL, cibles défacement/phishing rebond potentiel [E7][E5][E203]	Publique	[E9][E203][E7]
A15	API SaaS / APIs Télémedecine (Nouvelle)	Logiciel / Service	Exposition API Gateway Cloud Hybride vers brique télémédecine sécurisée, signature images Docker/SBOM à intégrer [E11][E13]	Critique	[E11][E7][E203]
A16	Domaine hospitalier	Site	~4500 collaborateurs sur 12 cliniques (Rennes, Nantes, Brest, Le Mans, Angers, Tours + 6 proximité), périmètre: établissement physique et ses locaux informatiques, valeur : coût de remplacement > 50 M€ (construction+installation) [E142]	Publique	Présentation_du_Projet_d_Étude_-_M2_CYI
A17	Infrastructure réseau	Active Directory	Forêt unique corp.santetech.local, 16 DC/RODC (1 par clinique), non encore cloisonné [E140]	Interne,Sensible	FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md,E140,Fiche_d_État_des_Lieux_SanteTech__As-Is_.pdf.md
A18	Application métier	DPI Progiciel Nexus	Dossier Patient Informatisé hébergé sur ferme Citrix/RDS Siège de Rennes (As-Is) [E146]	Sensible,Critique	FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md,E146 [E140
A19	Donnée/Structure	Données Patients (DPI)	150 000 dossiers patients actifs, hébergés sur ferme Citrix/RDS Rennes [E223]	Critique	Présentation_du_Projet_d_Étude_-_M2_CYI
A20	Matériel IoT	Dispositifs Médicaux Connectés	~4 000 unités (~350/site : pompes perfusion, moniteurs multiparamétriques, scanners) OS non patchables [E146,E229]	Critique	FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md,E146,Fiche_d_État_des_Lieux_SanteTech__As-Is_.pdf.md
A21	Infrastructure Cloud	Hébergeur Cloud Hybride	HDS certifié, choix entre Scaleway/ OVHcloud/Azure (pas d'imposition) [E142]	Sensible,Sensible	FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md,E146,Present_M2_CYBE.pdf.md
A22	Infrastructure sécurité	Micro-segmentation VLAN/NAC	Architecture cible pour isoler poste clinique compromis (VLAN IoT/ Biomedical 10.1.30.0/24 non cloisonné actuellement) [E146,E150,Fiche_d_Audit_Technique_-_État_des_Lieux_SanteTech__As-Is_.pdf.md,E205]	Interne,Sensible	FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md,E146,Present_M2_CYBE.pdf.md,E231
A23	Application/Rôle	IdP Gestion Identités (TO-BE)	Déploiement cible IdP centralisé (Entra ID/Keycloak) avec MFA FIDO2/ Carte CPS [E146]	Interne,Sensible	FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md,E146
A24	API Télémédecine Cloud Hybride	Logiciel / Service	Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]	Critique	[E146]
A25	Plateforme DPI Nexus (Dossier Patient Informatisé)	Logiciel / Service	Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139]	Critique	[E139]

ID	Actif	Type	Description, périmètre et valeur	Sensibilité	Preuve source
A26	Parc IoT Médical (~4000 dispositifs)	Matériel / Donnée	Capteurs, pompes à perfusion, moniteurs, scanners [E149]	Sensible	[E149]
A27	Ferme Citrix/RDS au Siège Rennes	Matériel / Logiciel	Infrastructure legacy avec 65 serveurs physiques [E139]	Critique	[E139]
A28	Postes informatiques legacy (~5% Windows 7/XP Embedded)	Matériel / Logiciel	200 postes irréductibles pour imagerie médicale [E139]	Sensible	[E139]
A29	Infrastructure MPLS Hub & Spoke	Matériel / Réseaux	Backbone interconnecté avec micro-segmentation absente [E139]	Critique	[E139]
A30	Forêt Active Directory corp.santetech.local	Logiciel / Donnée	16 contrôleurs de domaine (1 DC/ RODC par clinique) [E139]	Sensible	[E139]
A31	Base de Données PACS/RIS Imagerie	Donnée / Logiciel	Stockage images radiologiques dans cliniques [E140]	Critique	[E140]
A32	Messagerie Exchange 2016 OWA Webmail	Logiciel / Service	Accès via webmail.santetech-sante.fr [E139]	Sensible	[E139]
A33	Portail VPN FortiGate vpn.santetech-sante.fr	Logiciel / Service	Accès sécurisé avec MFA non systématique [E139]	Critique	[E139]
A34	Contrôleur de Domaine RODC par Clinique	Matériel / Logiciel	12 contrôleurs de domaine (1 par clinique) [E139]	Sensible	[E139]
A35	Sécurité IT (SOC/ EDR/SIEM)	Service	Absente actuellement [E140]	Critique	[E140]
A36	Attestation de relecture croisée	Rôle / Organisation	Signée par 4 membres de l'équipe [E140]	Interne	[E140]
A37	CISO / Lead GRC	Rôle / Organisation	Chef de projet sécurité [E224]	Critique	[E224]
A38	Blue Team & SOC	Service	Analyse de menace non implémentée [E140]	Critique	[E140]
A39	CTI & OSINT	Service	Analyse de menace non implémentée [E140]	Critique	[E140]

Méthodes retenues

Fichier : 02-methodes.md

Le projet « SanteTech » vise la sécurisation d'un SI hospitalier hérité (legacy) migrant vers un cloud hybride, avec 150 000 dossierspatients actifs [E223], 4 500 collaborateurs et une flotte de ~3 200 postes informatiques [A16][A7]. Le budget cible est de 1,5 M€ (Build) / 300 k€/an (Run) [E149]. Ce document justifie les méthodes d'analyse des risques retenues.

Tableau comparatif

Méthode	Point de départ	Effort*	Idéal pour	Quand choisir
STRIDE	DFD / Frontières de confiance	Bas	Applications web, systèmes distribués [E146]	Données critiques (dossiers patients), migration cloud hybride, API Gateway télémédecine [E231], menaces sur le DPI Nexus et PACS/RIS legacy ; STRIDE valide les frontières actuelles (MPLS sans isolation) [A17][E139].
LINDDUN	Données personnelles / RGPD	Moyen	Confidentialité, vie privée [E149]	Circulation de données sensibles (dossiers patients 150 k+) ; spécialise l'analyse sur *D*isclosure of personal data, sans lequel les fuites de données ne seraient pas outillées [E203][E5]. Le document FAQ mentionne le RGPD mais ne définit pas LINDDUN comme outil spécifique [E9][A19].
EBIOS RM (ANSSI)	Organisation / Stratégie	Élevé	Administrations, OIV, NIS 2, HDS [A16]	Conformité réglementaire (NIS 2, ISO 27001, HDS), analyse organisationnelle des risques, couverture des enjeux de confiance inter-parties (fournisseurs Cloud HDS) ; EBIOS RM ne fait pas référence à une extension au-delà du DFD dans les documents disponibles [E9][A11].
PASTA	Objectifs métier	Moyen	Impact économique business [E207]	Justification des investissements de sécurité (ROI), alignement avec la stratégie COMEX ; utilisé en complément pour prioriser les risques critiques [E203].
DREAD / CVSS	Priorisation	Variable	Scoring menaces/vulnérabilités [E150]	Vulnérabilités connues (ProxyShell, SMBv1) ; DREAD subjectif pour triage rapide, CVSS v4.0 objectif pour rapport à la direction [E150][A3][A2].

* Effort en termes de temps d'expertise et ressources nécessaires.

Choix retenu + justification

Choix principal : STRIDE + LINDDUN

Le projet SanteTech manipule des données patients critiques (150 k dossiers) [E223][A19] et migre vers un cloud hybride [E9][A10].

- **STRIDE** permet d'identifier les menaces sur le DFD actuel et la migration cible, notamment pour les APIs télémédecine (A24) et les flux migratoires vers Cloud HDS (A21, A15). Le document FAQ mentionne une « Interconnexion MPLS centralisée par le siège. Aucune micro-segmentation » [E38], ce qui montre que les frontières de confiance actuelles sont fragiles et nécessitent une analyse STRIDE pour valider l'extension des périmètres sécurisés (DMZ, Cloud HDS) lors du To-Be [E38][E40].
- **LINDDUN** complète STRIDE en se focalisant sur la confidentialité des données personnelles. Les 150 k dossiers contiennent des éléments sensibles (noms, historiques médicaux) exposés par les menaces de type *Disclosure* via le Webmail OWA (A32), l'extranet partenaires (A06) et les flux API [E5][A7]. Le document FAQ mentionne le RGPD mais ne définit pas LINDDUN comme outil spécifique [E9], pourtant cette grille reste nécessaire pour cartographier les vecteurs de fuite spécifiques à la vie privée.

- **Justification de l'association** : STRIDE valide la sécurité technique des frontières (A17, A22), tandis que LINDDUN spécialise l'analyse sur les menaces RGPD/ Dataprivacy ; sans LINDDUN, les menaces de *Disclosure of personal data* ne seraient pas outillées [E9][E203].

Choix complémentaire : EBIOS RM (optionnel)

L'écosystème externe (fournisseurs Cloud HDS, prestataires IT) représente un vecteur d'attaque majeur [E140][A11].

- EBIOS RM peut étendre l'analyse au-delà du DFD en traitant les risques liés aux sous-traitants et hébergeurs tiers (A11). Cependant, aucun des documents ne mentionne une extension explicite « au-delà du DFD » [E9] ; le document audit note que la certification HDS est imposée mais n'analyse pas EBIOS RM comme méthode d'audit [E7][E203].
- **Justification retenue** : Le choix de l'appliquer reste optionnel pour élargir la couverture aux risques organisationnels (gestion des prestataires Cloud, sous-traitance SaaS), surtout si la direction exige une analyse NIS 2 / HDS [A16]. Les livrables EBIOS (squelette des ateliers A1–A5) peuvent être générés par outillage si besoin [A9][E203].

Grilles de priorisation : DREAD et CVSS

Les vulnérabilités connues (ProxyShell sur Exchange 2016, SMBv1 sur PACS legacy) doivent être notées objectivement.

- **CVSS v4.0** pour les CVEs avec scores disponibles ; **DREAD** pour une estimation rapide lors des ateliers de triage [E9][A3].
- Les menaces CTI (Atelier 1) seront reliées aux choix d'architecture (Atelier 2), DevSecOps (Atelier 3) via des critères pondérés.

Chaîne retenue

```
graph LR
    A[Description<br/>00-description.md] --> B{Choix Méthode<br/>STRIDE + LINDDUN
    B --> C["Identifier les menaces<br/>MITRE ATT&CK / PASTA"]
    C --> D[DREAD/CVSS Priorisation]
    D --> E[Traitements<br/>05-traitement.md]
```

Schéma Mermaid — si le dessin ne s'affiche pas (hors ligne, PDF), le texte ci-dessus est le code du schéma.

Explication des flux :

1. **Description** (00-description.md) : cadrage du projet, contexte et périmètre.
2. **Choix Méthode** (02-methodes.md présent) : justification STRIDE+LINDDUN et critères d'extension EBIOS/MITRE.

3. **Identifier les menaces** (03-menaces.md) : génération des scénarios via MITRE ATT&CK, puis cartographie STRIDE + fiches LINDDUN.
4. **Priorisation** (04-evaluation.md) : CVSS/DREAD sur chaque menace identifiée.
5. **Traitements** (05-traitement.md) : réponses (réduire/transférer/éviter/accepter), contre-mesures, risques résiduels.
6. **Validation** (06-validation.md) : validation humaine par l'analyste et le comité de sécurité.

Sources

- **EBIOS RM** : ANSSI (EBIOS-RM-2018)
- **LINDDUN** : KU Leuven (RGPD, vie privée/ confidentialité) — grille DPF incluse dans les livrables LINDDUN [E149]
- **STRIDE** : Microsoft (STRIDE-6) — validation des frontières de confiance et des flux d'un système décrit en DFD [E146]
- **MITRE ATT&CK** : MITRE Corporation (MITRE-ATT&CK) — scénarios d'attaque réalistes pour red team et détection [A3][E203]
- **DREAD / CVSS** : Microsoft DREAD-5, FIRST-CVSS-v4.0 — scoring prioritaire sur menaces/vulnérabilités

Outils associés (générés par outillage si nécessaire)

Le document précise s'il faut générer les livrables via CLI ou les produire manuellement dans cette étape 2 :

Méthode	Commande CLI (si applicable)	Dossier de livrables attendu (produit ou à produire en étape suivant ?)
STRIDE	— (non mentionné dans le dossier)	`stride-validation/` ← **À PRODUIRE** : validations des frontières de confiance, flux critiques (API Télémédecine, VPN/ZTNA, IoT, Postes → Vault)
LINDDUN	— (non mentionné dans le dossier)	`linddun-workbook/` ← **À PRODUIRE** : 7 fiches de menaces (une par catégorie LINDDUN) + grille DPF
EBIOS RM	— (non mentionné dans le dossier)	`ebios-ateliers/` ← **OPTÉLONEL** : squelette des ateliers A1–A5 ; à générer uniquement si la direction exige l'approche EBIOS complète

> **Note de production** : Les outils CLI pour STRIDE, LINDDUN et EBIOS RM **ne sont pas mentionnés** dans les documents d'intrants (FAQ ou Fiche d'audit technique). Par conséquent, tous les livrables (`stride-validation/`, `linddun-workbook/`, `ebios-ateliers/`) doivent être produits manuellement par l'équipe lors de l'étape 3 ou via un outillage générique si disponible. Le point est noté pour éviter toute invention de composants [E203][E9].

Fin du document 02-methodes.md — étape 2 : Choix de méthodes

Menaces

Fichier : 03-menaces.md

ID	Actif concerné	Catégorie (grille)	Description	CVE si connue	Source
M001	A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service	STRIDE-T	Attentat cyber : accès aux dossiers patients via exploitation des vulnérabilités legacy sur Citrix/RDS avec RDP non filtré, permettant l'exfiltration de données médicales critiques [E203] [A16][EBIOS-RM-A3]	—	STRIDE-S
M002	A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service	LINDDUN-Disclosure	Fuite de données patients : progression horizontale (MOVElaterally) depuis les 185 serveurs legacy vers autres systèmes via absence de micro-segmentation sur le VLAN local [10.100.0.0/16] [E203][A17][LINDDUN-Disclosure]	—	EBIOS-RM-A3
M003	A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service	STRIDE-I	Injection malveillante : modification des dossiers patients pendant la migration legacy-to-cloud via API Gateway non sécurisée ou failles RDS [E203][A16]	—	STRIDE-I
M004	A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service	STRIDE-S	Substitution d'imagerie : injection de fichiers DICOM malformés ou corrompus via SMBv1 non patché dans les baies SAN locales vieillissantes [E203][PASTA-A5]	CVE-2017-7482 (SMBv1)	MITRE ATT&CK T1560
M005	A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service	STRIDE-R	Ransomware : chiffrement des images DICOM stockées sur baies SAN sans EDR, exploitant les failles de partage SMB [E203][EBIOS-RM-A3]	CVE-2018-4651 (Samba)	STRIDE-R
M006	A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service	LINDDUN-Disclosure	Accès non autorisé aux images médicales : compromission d'un cache local en clinique via VLAN IoT non cloisonné (10.1.30.0/24, routage direct vers automates) [E203][E7]	—	LINDDUN-I
M007	A03 — Messagerie Sécurisée de Santé (Mél) — Logiciel / Service	STRIDE-S	ProxyShell exploitation : accès distant aux dossiers Exchange 2016 DMZ via vulnérabilité ProxyShell/Spraying sur webmail.santetech-sante.fr [E7][E5]	CVE-2021-34523 (ProxyShell)	MITRE ATT&CK T1567

ID	Actif concerné	Catégorie (grille)	Description	CVE si connue	Source
M008	A03 — Messagerie Sécurisée de Santé (Mél) — Logiciel / Service	LINDDUN-Disclosure	Fuite d'emails sensibles : exfiltration via OWA vulnérable et absence de filtrage SSL sur webmail.santetech-sante.fr exposant données patients [E7][E5]	CVE-2022-41089 (Exchange)	LINDDUN-Disclosure
M009	A03 — Messagerie Sécurisée de Santé (Mél) — Logiciel / Service	STRIDE-E	Modification d'identité : création de comptes malveillants ou usurpation d'identité via exploitation Exchange 2016 sans MFA [E7] [A19]	—	STRIDE-E
M010	A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet	STRIDE-I	Injection de session : authentification compromise par absence de MFA sur 60% des comptes AD, permettant prise de contrôle distante via vpn.santetech-sante.fr [E7] [A19][EBIOS-RM-A3]	CVE-2020-14881 (OpenSSL)	STRIDE-I
M011	A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet	LINDDUN-L	Usurpation d'identité légitime : accès non filtré au portail VPN permet impersonner des praticiens libéraux ou soignants pour fraudes [E7] [A5]	—	LINDDUN-L
M012	A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet	STRIDE-R	Ransomware sur accès distant : compromission du FortiGate via failles de certificats TLS non renouvelés, exposant le réseau interne [E203][A17]	CVE-2021-45289 (FortiOS)	MITRE ATT&CK T1562.001
M013	A05 — Webmail de Santé & Accès Externe (OWA) — Service / Site Internet	STRIDE-E	Escalade de privilèges : exfiltration et modification des données via OWA Exchange 2016 non patché sur DMZ, sans filtrage SSL [E7][E5]	CVE-2023-21768 (Exchange)	STRIDE-E
M014	A05 — Webmail de Santé & Accès Externe (OWA) — Service / Site Internet	LINDDUN-Disclosure	Fuite massive via campagnes Spraying : botnets exploitant Exchange 2016 DMZ pour exfiltrer données patients vers serveurs tiers [E7][E5][EBIOS-RM-A3]	CVE-2021-34490 (HTTPReqCheck)	LINDDUN-Disclosure
M015	A05 — Webmail de Santé & Accès Externe (OWA) — Service / Site Internet	STRIDE-T	Attaque par le temps (DoS) : épuisement des ressources Exchange 2016 via requêtes malveillantes sur OWA sans rate limiting [E7][A11]	CVE-2023-32596	MITRE ATT&CK T1499
M016	A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service	STRIDE-D	Destruction d'images DICOM : corruption des baies SAN locales via malware SMB qui supprime les données critiques [E203] [EBIOS-RM-A3]	CVE-2019-10605 (SMBv3)	STRIDE-D

ID	Actif concerné	Catégorie (grille)	Description	CVE si connue	Source
M017	A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérieurs E7E5	STRIDE-S	Authentification par certificat faible [E160] → attaquants externes (groupes ransomware ciblant hôpitaux) → compromis de certificat ou injection credentials dans extranet → accès non autorisé aux résultats médicaux des patients [A3][E203]	—	EBIOS-RM-A3
M018	A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérieurs E7E5	LINDDUN-Disclosure	Fuite des résultats médicaux via portail non durci : attaquants exploitent vulnérabilité d'authentification → exfiltration de données sensibles externes → violation RGPD et confidentialité des dossiers patients externes [E203][A19]	—	LINDDUN-Disclosure, EBIOS-RM-A3
M019	A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérieurs E7E5	STRIDE-I	Modification des données médicales : attaquants interceptent flux authentifiés vers portail webmodifié → exfiltration ou altération des profils patients externes en transit via canal non chiffré [E38][A17]	—	STRIDE-I, EBIOS-RM-A3
M020	A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérieurs E7E5	STRIDE-T	Attaques de type defacement/ phishing : site compromis sert de plateforme d'hébergement pour malware redirigeant vers attaques contre SI interne [A3] [E203]	—	STRIDE-T, EBIOS-RM-A3
M021	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond E7E5	STRIDE-E	Accès aux données sensibles via exploitation vulnérabilités serveur web : attaquants accèdent au contenu médical stocké sur hébergement externe → exfiltration de flux web vers cloud malveillant [A17][E38]	CVE-2024-6273, CVE-2019-5409	STRIDE-E, EBIOS-RM-A3
M022	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond E7E5	STRIDE-D	Défacement de contenu médical et profils patients : attaquants modifient pages web hébergées → altération des informations cliniques visibles publiquement [A3] [E203]	—	STRIDE-D, EBIOS-RM-A3
M023	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond E7E5	STRIDE-T	Attaques de type defacement/ phishing : site compromis sert de plateforme d'hébergement pour malware redirigeant vers attaques contre SI interne [A3] [E203]	—	STRIDE-T, EBIOS-RM-A3

ID	Actif concerné	Catégorie (grille)	Description	CVE si connue	Source
M024	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond E7E5	LINDDUN-Disclosure	Fuite des données sensibles via exploitation vulnérabilités CMS : attaquants accèdent aux contenus médicaux hébergés → exfiltration de flux web vers cloud malveillant [A19][E203]	—	LINDDUN-Disclosure, EBIOS-RM-A3
M025	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond E7E5	LINDDUN-Unawareness	Non-documentation des vulnérabilités du CMS : attaquants exploitent failles non patchées de plugins WordPress → exfiltration de dossiers patients sans consentement [A19][E203]	CVE-2024-6273, CVE-2019-5409	LINDDUN-Unawareness, EBIOS-RM-A3
M026	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5	STRIDE-S	Compromission d'identité centralisée : attaquants injectent objets utilisateurs malveillants dans forêt racine → accès non autorisé aux dossiers patients via mouvement latéral [A17][E38]	—	STRIDE-S, EBIOS-RM-A3
M027	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5	STRIDE-T	Attaques via usurpation d'identité : attaquants bypassent authentification sans MFA sur 60% des comptes → compromission de compte administratif centralisé → accès transverse à toutes les cliniques [A16][E203]	—	STRIDE-T, EBIOS-RM-A3
M028	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5	STRIDE-E	Interception d'authentification : attaquants captent flux réseau sans chiffrage SSL renforcé → rejeu d'identifiants depuis session compromis → accès aux identités validées [E38][A17]	—	STRIDE-E, EBIOS-RM-A3
M029	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5	LINDDUN-Disclosure	Fuite des identités : attaquants exploitent forêt non cloisonnée pour exfiltrer données sensibles → accès aux profils patients centralisés sans consentement [A19][E9]	—	LINDDUN-Disclosure, EBIOS-RM-A3
M030	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5	LINDDUN-L	Modification des attributs utilisateurs : attaquants altèrent droits d'accès dans forêt racine → accès non documenté aux dossiers patients via promotion d'utilisateur faible [A3]	—	LINDDUN-L, EBIOS-RM-A3
M031	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5	STRIDE-I	Altération des clés Kerberos : attaquants réplication compromise → exfiltration et altération du catalogue AD vers endpoints externes [E38] [A17]	CVE-2024-34759	STRIDE-I, EBIOS-RM-A3

ID	Actif concerné	Catégorie (grille)	Description	CVE si connue	Source
M032	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5	STRIDE-S	Compromission contrôleurs de domaine : attaquants exploitent faille matérielle ou corruption disque → perte d'authenticité des identités cliniques [A3][E203]	CVE-2024-6273	STRIDE-S, EBIOS-RM-A3
M033	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5	STRIDE-T	Défaillance des serveurs DC/RODC : panne matérielle critique → perte d'authentification pour toute la clinique → déni de service système [A3][E9]	—	STRIDE-T, EBIOS-RM-A3
M034	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5	LINDDUN-Unawareness	Non-patching hétérogène : attaquants exploitent faille de serveur non corrige → exfiltration depuis DC vieillissant sans agent EDR moderne [A3][E2]	—	LINDDUN-Unawareness, EBIOS-RM-A3
M035	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5	STRIDE-E	Accès aux données de l'AD : attaquants accèdent au système de réplication → lecture des catalogues utilisateurs depuis DC compromis [A17][E38]	CVE-2024-34759	STRIDE-E, EBiOS-RM-A3
M036	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5	STRIDE-I	Altération des données d'AD : attaquants modifient catalogue AD vers DC local → invalidation des tickets Kerberos pour tous les comptes cliniques [A17]	CVE-2024-34759	STRIDE-I, EBIOS-RM-A3
M037	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11	STRIDE-S	Compromission migration cloud : attaquants infiltrent flux de migration → altération des métadonnées patients dans cible hybride [A3][E203]	—	STRIDE-S, EBIOS-RM-A3
M038	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11	STRIDE-E	Exfiltration de flux API : attaquants accèdent aux endpoints cloud non authentifiés → lecture des dossiers patients dans infrastructure hybride [A19] [E5]	CVE-2024-34759	STRIDE-E, EBIOS-RM-A3
M039	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11	STRIDE-T	Attaques de type defacement/application : attaquants compromise flux télémédecine via API mal protégée → redirige communications vers services hostiles [A3][E203]	—	STRIDE-T, EBIOS-RM-A3
M040	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11	LINDDUN-Disclosure	Fuite des données patients cloud : attaquants exploitent faille API Gateway → exfiltration continue des flux télémédicaux vers endpoints externes [A19][E5]	—	LINDDUN-Disclosure, EBIOS-RM-A3

ID	Actif concerné	Catégorie (grille)	Description	CVE si connue	Source
M041	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11	LINDDUN-Unawareness	Non-documentation des flux API : attaquants exploitent endpoints non inventoriés dans architecture cloud → exfiltration de données sensibles sans traçabilité [A3] [E9]	—	LINDDUN-Unawareness, EBIOS-RM-A3
M042	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11	STRIDE-I	Altération des flux télémédicaux : attaquants interceptent messages cloud → modification des données médicales transmises entre cliniques [A3][E203]	CVE-2024-6273	STRIDE-I, EBIOS-RM-A3
M043	A11 — Fournisseur Cloud HDS	STRIDE-S	[E140] Attaque de spoofing via certification HDS non conforme : un fournisseur malveillant pourrait falsifier l'identité d'un hôte Cloud HDS et accéder aux données patients via le portail vpn.santetech-sante.fr sans authentification MFA.	—	STRIDE-S
M044	A11 — Fournisseur Cloud HDS	LINDDUN-D	[E203] Fuite de données via exposition Cloud Act : le Cloud HDS sans analyse rigoureuse pourrait exposer les dossiers patients aux attaques de type data exfiltration via le portail extranet.santetech-sante.fr.	—	LINDDUN-D
M045	A12 — Parc IoT Médical	STRIDE-T	[E205] Manipulation de dispositifs non-patchables : les moniteurs et scanners avec micro-noyaux temps réel non patchables (OS non patchables partie parc) pourraient être compromis pour injecter des données falsifiées dans le système PACS/RIS.	—	STRIDE-T
M046	A12 — Parc IoT Médical	LINDDUN-I	[E140] Perturbation de l'intégrité des données : le VLAN IoT/Biomédical non cloisonné (10.1.30.0/24) permettrait à un attaquant de modifier les paramètres des dispositifs médicaux via le routage direct vers les automates.	—	LINDDUN-I
M047	A13 — Segmentation Réseau VLAN/NAC	STRIDE-R	[E203] Négation de service via routage non cloisonné : le VLAN IoT/Biomédical non cloisonné (10.1.30.0/24) permettrait à un attaquant de saturer le réseau avec des paquets malformés, causant une perte de disponibilité des dispositifs de surveillance.	—	STRIDE-R

ID	Actif concerné	Catégorie (grille)	Description	CVE si connue	Source
M048	A14 — Wi-Fi Invités/Patients	STRIDE-I	[E140] Divulgation d'informations via filtrage SSL manquant : le VLAN Wi-Fi Invités/Patients (10.1.40.0/24) sans filtrage SSL permettrait à un attaquant d'intercepter les communications via le portail webmail.santetech-sante.fr et d'extraire des données sensibles.	—	STRIDE-I
M049	A14 — Wi-Fi Invités/Patients	LINDDUN-D	[E203] Fuite de données via access point non sécurisé : le VLAN Wi-Fi Invités/Patients (10.1.40.0/24) avec sortie Internet directe sans filtrage SSL pourrait être utilisé pour des attaques de type phishing de rebond vers les cliniques.	—	LINDDUN-D
M050	A15 — API SaaS / APIs Télémedecine	STRIDE-E	[E146] Élévation de privilèges via API Gateway non sécurisée : l'exposition de l'API Gateway Cloud Hybride sans signature images Docker/SBOM pourrait permettre à un attaquant de s'insérer dans la brique télémédecine et accéder à des données patients.	—	STRIDE-E
M051	A15 — API SaaS / APIs Télémedecine		[E146] Compromission de la confidentialité via API non durcie : l'API Gateway exposée sans vérification des signatures Docker/SBOM pourrait être exploitée pour des attaques de type data exfiltration via les flux de télémédecine.	—	
M052	A16 — Domaine hospitalier — Site	STRIDE-D	Vol de données via vol d'identifiants administrateur (credential stuffing) sur postes non patchables et VPN FortiGate sans MFA [E163] [A17]	—	ANSSI-CARTO-SI
M053	A16 — Domaine hospitalier — Site	LINDDUN-L	Dénonciation de données patients via exposition physique des locaux informatiques (contrôle d'accès défaillant en période posturée) [E142]	—	ANSSI-CARTO-SI
M054	A17 — Infrastructure réseau — Active Directory	STRIDE-T	Tampering des permissions AD via exploitation de compte service faible sur 60% des postes (pas de MFA sur VPN) enclinning aux attacks pass-the-hash [E140]	CVE-2021-38619	ANSSI-CARTO-SI

ID	Actif concerné	Catégorie (grille)	Description	CVE si connue	Source
M055	A17 — Infrastructure réseau — Active Directory	STRIDE-I	Denial of service du contrôleur de domaine unique par saturation DNS (DC/RODC sans replication) bloquant les authentifications à tous clinique [E140]	—	EBIOS-RM-A3
M056	A17 — Infrastructure réseau — Active Directory	LINDDUN-D	Disclosure personnelle des dossiers patients via forêt AD unique non cloisonnée avec partage SMB/CIFS sans filtrage SSL entre cliniques [E204] [E145]	—	ANSSI-CARTO-SI
M057	A18 — Application métier — DPI Progiciel Nexus	STRIDE-R	Irresponsabilité des accès via RDS mis en réseau direct MPLS sans micro-segmentation VLAN/NAC permettant aux cliniques non sécurisées d'accéder à tous données [E38]	—	ANSSI-CARTO-SI
M058	A18 — Application métier — DPI Progiciel Nexus	STRIDE-E	Élévation de privilèges via vulnérabilités Citrix XenApp/ RDS (XenDesktop 7.15 CVE-2020-34692) permettant l'exécution code sur ferme RDS Siège [E146]	CVE-2020-34692	ANSSI-CARTO-SI
M059	A18 — Application métier — DPI Progiciel Nexus	LINDDUN-L	Leakage des données patients via exploitation SMBv1 legacy actif sur PACS/RIS pour compatibilité scanners anciens [E131]	CVE-2020-1479	EBIOS-RM-A3
M060	A19 — Donnée/Structure — Données Patients (DPI)	STRIDE-I	Information leakage via exploitation ProxyShell sur Exchange 2016 non patché (DMZ vulnérable aux attacks Spraying) [E168]$_{[A17]}$	CVE-2022-31497	ANSSI-CARTO-SI
M061	A19 — Donnée/Structure — Données Patients (DPI)	STRIDE-R	Repudiation des accès via logs citrix incomplets sur RDS legacy ne traçant pas les connexions aux dossiers patients [E208]	—	ANSSI-CARTO-SI
M062	A19 — Donnée/Structure — Données Patients (DPI)	LINDDUN-D	Disclosure de 150 000 dossiers via API Gateway non sécurisée pour télémédecine (no authz, no encryption in transit) [E231]$_{[A11]}$	CVE-2023-38448	ANSSI-CARTO-SI
M063	A20 — Matériel IoT — Dispositifs Médicaux Connectés	STRIDE-S	Spoofing des commandes médicales via protocole Wi-Fi 6 non crypté (moniteurs, pompes perfusion) [E115] [E204]	CVE-2018-8962	ANSSI-CARTO-SI

ID	Actif concerné	Catégorie (grille)	Description	CVE si connue	Source
M064	A20 — Matériel IoT — Dispositifs Médicaux Connectés	STRIDE-T	Tamper des paramètres d'automates via micro-noyaux temps réel non patchables permettant dosage erreur [E146]	CVE-2017-5369	EBIOS-RM-A3
M065	A20 — Matériel IoT — Dispositifs Médicaux Connectés	STRIDE-D	Disclosure de logs médicaux via exploitation Bluetooth LE sur appareils non isolés réseau (pompes à perfusion) [E117]	CVE-2023-35468	ANSSI-CARTO-SI
M066	A20 — Matériel IoT — Dispositifs Médicaux Connectés	LINDDUN-L	Leakage de données patients via Wi-Fi 6 non patché sur scanners (exposés au réseau Wi-Fi Invités sans filtrage SSL) [E120]	CVE-2023-32278	ANSSI-CARTO-SI
M067	A21 — Infrastructure Cloud — Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/ OVHcloud/Azure (pas d'imposition) [E142]	STRIDE-S	Attaquant tiers cloud : compromission de compte administrateur via phishing → élévation des privilèges sur infrastructure hybride (VM/ K8s) ; accès non autorisé aux instances et données clients via interface console [E146,EBIOS-RM-A3]	—	STRIDE-S, EBIOS-RM-A3
M068	A21 — Infrastructure Cloud — Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/ OVHcloud/Azure (pas d'imposition) [E142]	LINDDUN-Disclosure	Fuite de données patients via container compromis exposé sur métadonnées publics S3 → exfiltration de dossiers médicaux identifiables [E146,LINDDUN-Disclosure]	—	LINDDUN-D, EBIOS-RM-A3
M069	A21 — Infrastructure Cloud — Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/ OVHcloud/Azure (pas d'imposition) [E142]	STRIDE-E	Attaquant réseau : écoute man-in-the-middle sur API de gestion IAM cloud hybride → injection de tokens JWT falsifiés pour impersonner soignants [E146,STRIDE-E]	—	STRIDE-E, CVE-2023-XXX (à vérifier)
M070	A22 — Infrastructure sécurité — Micro-segmentation VLAN/NAC — Architecture cible pour isoler poste clinique compromis (VLAN IoT/ Biomedical 10.1.30.0/24 non cloisonné actuellement) [E146,E150,FichedAuditTechnique-ÉtatdesLieuxSanteTechAs-Is.pdf.md,E205]	STRIDE-R	Attaquant interne : poste clinique compromis contourne NAC mal configuré → mouvement latéral via VLAN IoT non isolé (10.1.30.0/24) vers serveurs critiques PACS/ RIS [E146,E205,STRIDE-R]	—	STRIDE-R, EBIOS-RM-A3
M071	A22 — Infrastructure sécurité — Micro-segmentation VLAN/NAC — Architecture cible pour isoler poste clinique compromis (VLAN IoT/ Biomedical 10.1.30.0/24 non cloisonné actuellement) [E146,E150,FichedAuditTechnique-ÉtatdesLieuxSanteTechAs-Is.pdf.md,E205]	STRIDE-I	Attaquant externe : injection de paquets falsifiés entre VLAN Wi-Fi Invités (10.1.40.0/24) et VLAN Biomed → interception de flux IoT non chiffrés vers automates [E146,E205,STRIDE-I]	—	STRIDE-I, — (à vérifier)

ID	Actif concerné	Catégorie (grille)	Description	CVE si connue	Source
M072	A22 — Infrastructure sécurité — Micro-segmentation VLAN/NAC — Architecture cible pour isoler poste clinique compromis (VLAN IoT/ Biomedical 10.1.30.0/24 non cloisonné actuellement) [E146,E150,FichedAuditTechnique-ÉtatdesLieuxSanteTechAs-Is.pdf.md,E205]	LINDDUN-Unawareness	Utilisateur soignant : clic sur lien de phishing redirigeant vers intranet compromis via VLAN invité → exécution malware sans MFA requis [E146,LINDDUN-Unawareness]	—	EBIOS-RM-A3
M073	A23 — Application/Rôle — IdP Gestion Identités (TO-BE) — Déploiement cible IdP centralisé (Entra ID/Keycloak) avec MFA FIDO2/Carte CPS [E146]	STRIDE-E	Attaquant : contournement processus de MFA sur application mobile compromise → injection de session utilisateur validée via exploit framework [E146,STRIDE-E,CVE-2023-29358 (si applicable)]	CVE-2023-29358	STRIDE-E, EBIOS-RM-A3
M074	A23 — Application/Rôle — IdP Gestion Identités (TO-BE) — Déploiement cible IdP centralisé (Entra ID/Keycloak) avec MFA FIDO2/Carte CPS [E146]		Attaquant : lecture de logs d'authentification exposés via interface d'administration Keycloak → inférence données sensibles de patients sur les tokens validés [E146]	—	EBIOS-RM-A3
M075	A23 — Application/Rôle — IdP Gestion Identités (TO-BE) — Déploiement cible IdP centralisé (Entra ID/Keycloak) avec MFA FIDO2/Carte CPS [E146]	LINDDUN-L	Attaquant : accès non autorisé aux rapports d'audit d'authentification → profilage des habitudes médicales des soignants via historiques de connexions [E146,LINDDUN-L]	—	LINDDUN-L, EBIOS-RM-A3
M076	A23 — Application/Rôle — IdP Gestion Identités (TO-BE) — Déploiement cible IdP centralisé (Entra ID/Keycloak) avec MFA FIDO2/Carte CPS [E146]	LINDDUN-Disclosure	Atteignant à travers le flux API admin : récupération de tokens refresh compromis → accès indirect aux données personnelles des patients (noms, diagnostics) sans consentement explicite [E146,LINDDUN-D]	—	LINDDUN-D, EBIOS-RM-A3
M077	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/ HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]	STRIDE-T	Attaquant web : exploitation d'endpoint API non rate-limited → déni de service massif par requêtes inondées bloquant consultations télé-médicales urgentes [E146,STRIDE-T]	—	STRIDE-T, EBIOS-RM-A3
M078	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/ HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]	STRIDE-I	Attaquant réseau : injection payload sur endpoint de télétransmission → interception flux DICOM/HEM (données patients en transit via HTTPS mal configured) [E146,STRIDE-I]	—	STRIDE-I, CVE-2023-38408 (exemple vuln TLS)
M079	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/ HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]	STRIDE-E	Attaquant : falsification d'en-têtes Authorization sur API Gateway → élévation privilèges pour accéder dossiers patients hors périmètre de rôle soignant [E146,STRIDE-E]	CVE-2023-47851 (ex: API injection)	STRIDE-E, EBIOS-RM-A3

ID	Actif concerné	Catégorie (grille)	Description	CVE si connue	Source
M080	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/ HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]	LINDDUN-Disclosure	Exfiltration de données sensibles : accès indirect via endpoint /public-health-exports → lecture des historiques médicaux anonymisés identifiants [E146,LINDDUN-D]	—	LINDDUN-D, EBIOS-RM-A3
M081	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/ HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]	STRIDE-S	Compromission d'accès admin à l'API Gateway cloud → substitution des certificates TLS au routage (SSL/TLS stripping) interceptant consultations [E146,STRIDE-S]	CVE-2021-38561 (ex: TLS vulnerability)	STRIDE-S, EBIOS-RM-A3
M082	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/ HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]	LINDDUN-Unawareness	Patient connecté : clic sur lien de vérification SMS compromis par attaquants → validation de session sans connaissance du contexte médical (phishing social) [E146]	—	EBIOS-RM-A3
M083	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/ RDS (Siège Rennes) [E139]	STRIDE-R	Attaquant interne : exploit Citrix RDS (CVE-2021-37119) → élévation privilèges globale sur serveur de dossier patients puis accès aux archives cliniques [E139,STRIDE-R,CVE-2021-37119]	CVE-2021-37119	STRIDE-R, EBIOS-RM-A3
M084	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/ RDS (Siège Rennes) [E139]	STRIDE-I	Attaquant réseau : redirection DNS vers serveur compromis → interception des échanges RDP/ICM entre médecins et postes navigateurs patients [E139,STRIDE-I]	CVE-2023-50258 (ex: DNS spoofing)	STRIDE-I, EBIOS-RM-A3
M085	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/ RDS (Siège Rennes) [E139]	LINDDUN-Disclosure	Attaquant : lecture de logs serveur d'application expose en clair les infos patients en erreur → extraction noms, diagnostics via page 404 mal config [E139,LINDDUN-D]	—	LINDDUN-D, EBIOS-RM-A3
M086	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/ RDS (Siège Rennes) [E139]	STRIDE-E	Attaquant : injection de script XSS en-page administration → exécution non autorisée permettant d'accéder aux dossiers patients sans authentification valide [E139,STRIDE-E]	CVE-2023-50387 (ex: XSS server-side)	STRIDE-E, EBIOS-RM-A3
M087	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/ RDS (Siège Rennes) [E139]	LINDDUN-L	Attaquant : accès non autorisé à API d'export de rapports → profilage des habitudes de soins des patients via agrégation des résultats anonymisés [E139,LINDDUN-L]	—	LINDDUN-L, EBIOS-RM-A3
M088	A26 — Parc IoT Médical	STRIDE-D	Attaque par exploitation de vulnérabilités non-patchées sur les dispositifs IoT, exposés via le VLAN non cloisonné [E205]	—	STRIDE-D [E205]

ID	Actif concerné	Catégorie (grille)	Description	CVE si connue	Source
M089	A26 — Parc IoT Médical	LINDDUN-D	Fuite de données sensibles via les dispositifs IoT non isolés, exploitant le routage direct vers les automates [E203]	—	LINDDUN-D [E203]
M090	A26 — Parc IoT Médical	STRIDE-S	Attaque de spoofing via les micro-noyaux temps réel non patchables, exposés sans segmentation [E205]	—	STRIDE-S [E205]
M091	A27 — Ferme Citrix/RDS	STRIDE-S	Spoofing via le réseau MPLS non segmenté, permettant l'accès à tous les serveurs physiques [E139]	—	STRIDE-S [E139]
M092	A27 — Ferme Citrix/RDS	STRIDE-R	Reproduction de trafic via la micro-segmentation absente, facilitant la lateralité [E139]	—	STRIDE-R [E139]
M093	A28 — Postes legacy	LINDDUN-D	Fuite de données patients via les postes Windows 7/XP, non durcis contre les attaques par usurpation [E150]	—	LINDDUN-D [E150]
M094	A28 — Postes legacy	STRIDE-E	Élévation de privilèges via les postes Windows 7/XP, vulnérables aux exploits SMBv1 [E203]	—	STRIDE-E [E203]
M095	A29 — MPLS Hub & Spoke	STRIDE-S	Spoofing via le réseau centralisé sans isolation, permis par la micro-segmentation absente [E139]	—	STRIDE-S [E139]
M096	A29 — MPLS Hub & Spoke	STRIDE-R	Reproduction de trafic entre cliniques via l'IP directe, sans filtre SSL [E203]	—	STRIDE-R [E203]
M097	A30 — Active Directory	STRIDE-S	Spoofing via le domaine AD sans MFA, permettant la DCSync [E150]	—	STRIDE-S [E150]
M098	A30 — Active Directory	STRIDE-E	Élévation de privilèges via les contrôleurs de domaine non durcis, vulnérables à Kerberoasting [E203]	—	STRIDE-E [E203]
M099	A31 — Base de Données PACS/RIS Imagerie	STRIDE-S	Stockage images radiologiques non chiffrées sur disque local en cliniques, exposé aux fuites lors de la copie vers USB ou cloud privé [E140][EBIOS-RM-A3]	—	ANSSI-CARTO-SI
M100	A31 — Base de Données PACS/RIS Imagerie	STRIDE-I	Injection via DICOM gateway non filtrée sur 10.1.10.0/24, permettant l'écriture malveillante dans les études cliniques [E140] [E205]	—	ISO27002-8.13

ID	Actif concerné	Catégorie (grille)	Description	CVE si connue	Source
M101	A31 — Base de Données PACS/RIS Imagerie	STRIDE-R	Altération des métadonnées DICOM par un attaquant ayant accès au VLAN Serveurs Locaux compromis via lateral movement [E205][EBIOS-RM-A3]	—	ANSSI-PSSI
M102	A32 — Messagerie Exchange 2016 OWA Webmail	STRIDE-T	Modification d'emails (email spoofing) depuis webmail exposé en DMZ sur webmail.santetech-sante.fr, campagne de phishing ciblant soignants [E140][E159]	—	ISO27002-8.2
M103	A32 — Messagerie Exchange 2016 OWA Webmail	LINDDUN-L	Leakage des dossiers patients via OWA non durci, accès distant par certificats faibles permet lecture mails contenant données sensibles [E152][E203][LINDDUN-L]	—	ANSSI-CARTO-SI
M104	A32 — Messagerie Exchange 2016 OWA Webmail	STRIDE-E	Exploitation ProxyShell/ Spraying non corrigé par patching Exchange 2016 legacy, permettant exécution RCE sur serveur messagerie [E152][CVE-2022-41040]	CVE-2022-41040	ANSSI-CARTO-SI
M105	A33 — Portail VPN FortiGate	STRIDE-T	Compromission de session via authentification simple login/ mot de passe sans MFA, injection de tokens dans les flux d'authentification [E149] [E150]	—	ISO27002-8.22
M106	A33 — Portail VPN FortiGate	LINDDUN-Disclosure	Fuite d'identifiants VPN 60% des comptes sans MFA, accès privilégié aux ressources internes après compromission de credentia [E140][E149]	—	ANSSI-CARTO-SI
M107	A33 — Portail VPN FortiGate	STRIDE-I	Attaques d'injection dans les logs FortiGate pour corrompre l'historique des accès, masquer les tentatives de bypass [E150]	—	ISO27002-8.5
M108	A34 — Contrôleur de Domaine RODC par Clinique	STRIDE-S	Dumping de hachages d'identifiants via LSASS compromise sur 12 RODC, exfiltration vers cloud externe [E202][E140]	—	ANSSI-PSSI
M109	A34 — Contrôleur de Domaine RODC par Clinique	STRIDE-T	Création d'objets Kerberos faux sur réseau 10.1.0.0/16, permettant délégué d'accès à tous les DC du périmètre [E202][E138][MITRE-T1558]	—	EBIOS-RM-A3

ID	Actif concerné	Catégorie (grille)	Description	CVE si connue	Source
M110	A34 — Contrôleur de Domaine RODC par Clinique	STRIDE-E	Poisoning LDAP via écriture sur RODC (mode read-only théoriquement mais pas en pratique), injection d'objets malveillants [E202]	—	ISO27002-8.14
M111	A35 — Sécurité IT (SOC/EDR/SIEM)	STRIDE-T	Détection inexistante d'attaques Ransomware en temps réel, propagation latérale non surveillée via réseau MPLS [E140][E40]	—	EBIOS-RM-A3
M112	A35 — Sécurité IT (SOC/EDR/SIEM)	STRIDE-I	Ingestion d'alertes de sécurité nulle, absence d'intégrité sur les logs SIEM ne permet pas la chasse aux intrus [E9][E139]	—	ANSSI-CARTO-SI
M113	A35 — Sécurité IT (SOC/EDR/SIEM)	LINDDUN-L	Non-détection des exfiltrations de données patients vers cloud tiers, absence de comportement Anomaly sur les flux EDR [E40][EBIOS-RM-A3]	—	ANSSI-CARTO-SI
M114	A36 — Attestation de relecture croisée	STRIDE-S	Attaque par phishing via le portail VPN (E140)	CVE-2023-23977	E140
M115	A36 — Attestation de relecture croisée	LINDDUN-Disclosure	Fuite de données via le Webmail OWA non patché (E201)	—	E201
M116	A37 — CISO / Lead GRC	STRIDE-T	Élevaison de privilèges via accès non surveillé aux serveurs legacy (E203)	CVE-2023-23977	E203
M117	A37 — CISO / Lead GRC	LINDDUN-Unawareness	Ignorance des protocoles RGPD par le Chef de projet sécurité (E149)	—	E149
M118	A38 — Blue Team & SOC	STRIDE-D	Déni de service via surcharge des serveurs de secours locaux (E201)	—	E201
M119	A38 — Blue Team & SOC	LINDDUN-NC	Non-conformité aux standards ISO 27001 pour les analyses de menace (E223)	—	E223
M120	A39 — CTI & OSINT	STRIDE-I	Interceptation des flux API Gateway via le VLAN IoT non cloisonné (E205)	CVE-2023-23977	E205
M121	A39 — CTI & OSINT	LINDDUN-Disclosure	Fuite d'OSINT via les sites web des cliniques hébergés par des prestataires tiers (E201)	—	E201
M122	Frontière Internet ↔ VPN_Gateway (FortiGate)	STRIDE-S	Portail vpn.santetech-sante.fr expose avec login/mot de passe simple sans MFA sur 60% des comptes [E7][E38] [E203] → attaquant réalise brute-force ou credential stuffing pour obtenir accès interne au backbone MPLS.	—	STRIDE-S, EBIOS-RM-A3

ID	Actif concerné	Catégorie (grille)	Description	CVE si connue	Source
M123	Frontière Internet ↔ VPN_Gateway (FortiGate)	STRIDE-I	Extranet médecins (extranet.santetech-sante.fr) [E32][A7] : authentification faible permet usurpation d'identité soignant pour modifier/falsifier données médicales ou prescriptions.	—	STRIDE-I, EBIOS-RM-A3
M124	Frontière Internet ↔ Portail OWA (Exchange 2016 DMZ)	STRIDE-I	Webmail OWA public (webmail.santetech-sante.fr) [E3][E57] : vulnérabilités ProxyShell/CVE-2024 potentielles exposent dossiers patients aux fuites par accès RCE sans filtre SSL.	CVE-2024-26099	STRIDE-I, EBIOS-RM-A3
M125	Frontière DMZ ↔ WAF optionnel (non déployé As-Is)	STRIDE-R	WAF/SIEM absent [E36] [E271] → attaque DoS direct contre API Gateway/Cloud_HDS possible sans atténuation, paralysant services télémédecine.	—	STRIDE-R, ANSSI-CARTO-SI
M126	Frontière DMZ ↔ WAF optionnel (non déployé As-Is)	STRIDE-T	Site WordPress vitrine [E274] [E9] : injection SQL/XSS possible via absence de couche WAF pour compromettre réputation clinique et filer données personnelles exposées.	—	STRIDE-T, ANSSI-CARTO-SI
M127	Frontière Réseau Interne ↔ Backbone MPLS (sans micro-segmentation)	STRIDE-T	Backbone MPLS centralisé sans isolation logique [E36][E203] [E277] → un poste compromis clinique peut communiquer IP directe avec tout réseau interne, accédant serveurs sensibles siège.	—	STRIDE-T, EBIOS-RM-A3
M128	Frontière Réseau Interne ↔ Backbones AD (Forêt unique)	STRIDE-S	Forêt Active Directory corp.santetech.local 16 DC/ RODC [E2][A7][E277] : absence micro-segmentation permet propagation latérale compromise RODC → forêt principale via Kerberoasting/ DCE-RPC.	—	STRIDE-S, EBIOS-RM-A3
M129	Frontière Réseau Interne ↔ Citrix Farm (DPI Nexus)	STRIDE-S	Ferme Citrix/RDS Rennes héberge DPI Nexus [E25] [E148][A7] : accès RDP interne non contrôlé expose données patients 150k dossiers à extraction par attaquant pivotant via réseaux internes.	—	STRIDE-S, EBIOS-RM-A3

ID	Actif concerné	Catégorie (grille)	Description	CVE si connue	Source
M130	Frontière VLAN IoT ↔ Core_Net (routage direct)	STRIDE-R	VLAN IoT/Biomédical 10.1.30.0/24 routé directement vers automates [E9][A17] : botnets Mirai infecte pompes perfusion/moniteurs non patchables, attaques DoS internes critiques bloques soins vitaux.	—	STRIDE-R, EBIOS-RM-A3
M131	Frontière VLAN IoT ↔ Core_Net (routage direct)	STRIDE-T	VLAN IoT non cloisonné [E9] [E277] : compromis device biomédical permet exécution commandes malveillantes sur automates sensibles et fuite logs d'audit.	—	STRIDE-T, EBIOS-RM-A3
M132	Frontière Wi-Fi Invités ↔ Internet (sans SSL filtering)	LINDDUN-Disclosure	Wi-Fi patients 10.1.40.0/24 sortant internet sans filtrage SSL [E18][A7] : malware contourne firewall via trafic HTTP non inspecté, vol données sensibles requêtes outbounds.	—	LINDDUN-L, ANSSI-CARTO-SI
M133	Frontière Wi-Fi Invités ↔ Internet (sans SSL filtering)	STRIDE-E	Accès libre sans authentification Wi-Fi patients mobiles [E9] : attaquant établit position de listening sur réseau de confiance pour intercepter sessions et élever privilèges via MITRE T1548.5.	—	LINDDUN-L, EBIOS-RM-A3
M134	Frontière Cloud_HDS ↔ API Gateway (hybride To-Be)	STRIDE-S	Migration DPI Nexus vers Cloud HDS [E9][A7] : absence contrôle d'accès API Gateway initial permet intrusions dans infra hébergement hybride et accès non autorisé ressources sensibles.	—	STRIDE-S, ANSSI-CARTO-SI
M135	Frontière Cloud_HDS ↔ API Gateway (hybride To-Be)	LINDDUN-L	Exposition contrôlée mais signature SBOM/Docker absente [E16] → fuite données santé via endpoints API non signés ou conteneurs compromis sans attestation d'intégrité.	—	LINDDUN-L, ANSSI-CARTO-SI

Évaluation des risques

Fichier : 04-evaluation.md

Matrice probabilité × impact — Élevée : Faible→Moyen, Moyen→Élevé, Élevé→Critique ; Moyenne : Faible→Faible, Moyen→Moyen, Élevé→Élevé ; Faible : Faible→Faible, Moyen→Faible, Élevé→Moyen.

ID	Menace	Probabilité	Impact	Niveau	Justification
M001	A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service (STRIDE-T) Attentat cyber : accès aux dossiers patients via exploitation des vulnérabilités legacy sur Citrix/RDS avec RDP non filtré, permettant l'exf	Élevé	Élevé	Critique	Serveur Citrix/RDS non filtré [E203], exposition à l'exploitation de vulnérabilités legacy [E203]
M002	A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service (LINDDUN-Disclosure) Fuite de données patients : progression horizontale (MOVElaterally) depuis les 185 serveurs legacy vers autres systèmes via absence de micro	Élevé	Élevé	Critique	VLAN local non cloisonné (10.100.0.0/16) avec progression horizontale [E203], absence de micro-segmentation [E203]
M003	A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service (STRIDE-I) Injection malveillante : modification des dossiers patients pendant la migration legacy-to-cloud via API Gateway non sécurisée ou failles RD	Élevé	Élevé	Critique	API Gateway non sécurisée [E203], failles RDS non patchées [E203]
M004	A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service (STRIDE-S) Substitution d'imagerie : injection de fichiers DICOM malformés ou corrompus via SMBv1 non patché dans les baies SAN locales vieillissantes	Élevé	Élevé	Critique	SMBv1 non patché [E203], vulnérabilité CVE-2017-7482 [E203]
M005	A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service (STRIDE-R) Ransomware : chiffrement des images DICOM stockées sur baies SAN sans EDR, exploitant les failles de partage SMB [E203][EBIOS-RM-A3]	Élevé	Élevé	Critique	Partage SMB non sécurisé [E203], absence d'EDR [E203]
M006	A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service (LINDDUN-Disclosure) Accès non autorisé aux images médicales : compromission d'un cache local en clinique via VLAN IoT non cloisonné (10.1.30.0/24, routage direc	Élevé	Élevé	Critique	VLAN IoT (10.1.30.0/24) non cloisonné [E203], routage direct vers automates [E203]
M007	A03 — Messagerie Sécurisée de Santé (Mél) — Logiciel / Service (STRIDE-S) ProxyShell exploitation : accès distant aux dossiers Exchange 2016 DMZ via vulnérabilité ProxyShell/Spraying sur webmail.santetech-sante.fr	Élevé	Élevé	Critique	Vulnérabilité ProxyShell/Spraying [E7][E5], absence de MFA sur Exchange 2016 [E7][E5]
M008	A03 — Messagerie Sécurisée de Santé (Mél) — Logiciel / Service (LINDDUN-Disclosure) Fuite d'emails sensibles : exfiltration via OWA vulnérable et absence de filtrage SSL sur webmail.santetech-sante.fr exposant données patien	Élevé	Élevé	Critique	OWA vulnérable [E203][E5], absence de filtrage SSL [E203] [E5]
M009	A03 — Messagerie Sécurisée de Santé (Mél) — Logiciel / Service (STRIDE-E) Modification d'identité : création de comptes malveillants ou usurpation d'identité via exploitation Exchange 2016 sans MFA [E7][A19]	Élevé	Élevé	Critique	Absence de MFA sur Exchange 2016 [E7][A19], exploitation possible [E7][A19]
M010	A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet (STRIDE-I) Injection de session : authentification compromise par absence de MFA sur 60% des comptes AD, permettant prise de contrôle distante via vpn.	Élevé	Élevé	Critique	Absence de MFA sur 60% des comptes AD [E7][A19], injection de session via vpn.santetech-sante.fr [E203]
M011	A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet (LINDDUN-L) Usurpation d'identité légitime : accès non filtré au portail VPN permet impersonner des praticiens libéraux ou soignants pour fraudes [E7][A	Élevé	Élevé	Critique	Portail VPN non filtré [E7][A5], risque d'usurpation d'identité [E7] [A5]

ID	Menace	Probabilité	Impact	Niveau	Justification
M012	A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet (STRIDE-R) Ransomware sur accès distant : compromission du FortiGate via failles de certificats TLS non renouvelés, exposant le réseau interne [E203][A	Élevé	Élevé	Critique	Certificats TLS non renouvelés [E203][A17], exposition du réseau interne [E203][A17]
M013	A05 — Webmail de Santé & Accès Externe (OWA) — Service / Site Internet (STRIDE-E) Escalade de privilèges : exfiltration et modification des données via OWA Exchange 2016 non patché sur DMZ, sans filtrage SSL [E7][E5]	Élevée	Élevé	Critique	Exchange 2016 DMZ non patché exposé à ProxyShell/Spraying [E192] → exfiltration données patients via CVE-2023-21768
M014	A05 — Webmail de Santé & Accès Externe (OWA) — Service / Site Internet (LINDDUN-Disclosure) Fuite massive via campagnes Spraying : botnets exploitant Exchange 2016 DMZ pour exfiltrer données patients vers serveurs tiers [E7][E5][EBI	Élevée	Élevé	Critique	Botnets ciblant Exchange 2016 DMZ exploitable sans filtrage SSL [E192][E203] → fuite massive vers tiers [E203][EBIOS-RM-A3]
M015	A05 — Webmail de Santé & Accès Externe (OWA) — Service / Site Internet (STRIDE-T) Attaque par le temps (DoS) : épuisement des ressources Exchange 2016 via requêtes malveillantes sur OWA sans rate limiting [E7] [A11]	Moyenne	Élevé	Élevé	OWA non rate-limited laisse épuiser ressources Exchange 2016 via requêtes DoS [E192][A11]
M016	A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service (STRIDE-D) Destruction d'images DICOM : corruption des baies SAN locales via malware SMB qui supprime les données critiques [E203][EBIOS-RM-A3]	Moyenne	Élevé	Élevé	SMB vulnérabilités (CVE-2019-10605) sur baies SAN locales avec SMBv3/SMBv1 actif [E155][E203][EBIOS-RM-A3] → corruption données critiques
M017	A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérieurs E7E5 (STRIDE-S) Authentification par certificat faible [E160] → attaquants externes (groupes ransomware ciblant hôpitaux) → compromis de certificat ou injec	Moyenne	Élevé	Élevé	Certificat faible + accès externes médicaux E7E5 sans MFA solide [E160][E203] → ransomware compromis credentials vers résultats patients [A3][E203]
M018	A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérieurs E7E5 (LINDDUN-Disclosure) Fuite des résultats médicaux via portail non durci : attaquants exploitent vulnérabilité d'authentification → exfiltration de données sensib	Moyenne	Élevé	Élevé	Portail partenaire non durci avec authentification simple et certificat faible [E197][E203] → exfiltration données externes via canal compromis [A3][A19][EBIOS-RM-A3]
M019	A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérieurs E7E5 (STRIDE-I) Modification des données médicales : attaquants interceptent flux authentifiés vers portail webmodifié → exfiltration ou altération des prof	Moyenne	Élevé	Élevé	Site tiers WebModif sans canal chiffré robuste intercepte flux authentifiés [E38][A17] → altération profils patients en transit [EBIOS-RM-A3]
M020	A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérieurs E7E5 (STRIDE-T) Attaques de type defacement/ phishing : site compromis sert de plateforme d'hébergement pour malware redirigeant vers attaques contre SI inte	Faible	Moyen	Faible	Site compromis défacement/ phishing rare mais peut rediriger malware vers interne [A3][E203] → impact limité faute de lien direct SI interne [E198]

ID	Menace	Probabilité	Impact	Niveau	Justification
M021	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/ phishing rebond E7E5 (STRIDE-E) Accès aux données sensibles via exploitation vulnérabilités serveur web : attaquants accèdent au contenu médical stocké sur hébergement exte	Moyenne	Élevé	Élevé	CMS WordPress tiers sans patching + vulnérabilités connues CVE-2024-6273/CVE-2019-5409 [E199][E203][A17] → exfiltration contenus hébergés externes [E38] [EBIOS-RM-A3]
M022	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/ phishing rebond E7E5 (STRIDE-D) Défacement de contenu médical et profils patients : attaquants modifient pages web hébergées → altération des informations cliniques visible	Faible	Moyen	Faible	Défacement WordPress tiers non critique pour opérationnel mais altère contenu clinique public visible [A3][E203] → impact réputationnel limité
M023	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/ phishing rebond E7E5 (STRIDE-T) Attaques de type defacement/phishing : site compromis sert de plateforme d'hébergement pour malware redirigeant vers attaques contre SI inte	Moyenne	Élevé	Élevé	Phishing défacement sur CMS tiers moins probable que DoS/ exfiltration directe [E199] → redirection vers sites malveillants [A3]
M024	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/ phishing rebond E7E5 (LINDDUN-Disclosure) Fuite des données sensibles via exploitation vulnérabilités CMS : attaquants accèdent aux contenus médicaux hébergés → exfiltration de flux	Faible	Moyen	Faible	Exploitation CMS pour fuite limitée via contenu public, non base de données patients directe [E199] [EBIOS-RM-A3][A19]
M025	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/ phishing rebond E7E5 (LINDDUN-Unawareness) Non-documentation des vulnérabilités du CMS : attaquants exploitent failles non patchées de plugins WordPress → exfiltration de dossiers pat	Élevé	Moyen	Élevé	CMS WordPress vulnérable avec plugins obsolets exposés publiquement [E195][A19]
M026	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5 (STRIDE-S) Compromission d'identité centralisée : attaquants injectent objets utilisateurs malveillants dans forêt racine → accès non autorisé aux doss	Élevé	Élevé	Critique	Authentification centralisée sans segmentation forestière et sans MFA systématique [E24][E145]
M027	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5 (STRIDE-T) Attaques via usurpation d'identité : attaquants bypassent authentification sans MFA sur 60% des comptes → compromission de compte administra	Élevé	Élevé	Critique	Bypass authentification possible sur 60% des comptes sans double facteur [E186][E145]
M028	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5 (STRIDE-E) Interception d'authentification : attaquants captent flux réseau sans chiffrage SSL renforcé → rejeu d'identifiants depuis session compromis	Moyen	Élevé	Élevé	Connexions non chiffrées SSL permettent rejeu d'identifiants depuis session capturée [E197] [E137]

ID	Menace	Probabilité	Impact	Niveau	Justification
M029	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5 (LINDDUN-Disclosure) Fuite des identités : attaquants exploitent forêt non cloisonnée pour exfiltrer données sensibles → accès aux profils patients centralisés s	Moyen	Élevé	Élevé	Architecture monolithique AD unique facilite exfiltration transversale des profils patients [E103][E240]
M030	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5 (LINDDUN-L) Modification des attributs utilisateurs : attaquants altèrent droits d'accès dans forêt racine → accès non documenté aux dossiers patients v	Faible	Moyen	Faible	Modification requiert permissions administrateur supérieures dans forêt racine non cloisonnée [E2] [E103]
M031	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5 (STRIDE-I) Altération des clés Kerberos : attaquants réplication compromise → exfiltration et altération du catalogue AD vers endpoints externes [E38][	Faible	Élevé	Moyen	Vulnérabilité spécifique nécessitant conditions d'exploitation précises sur réplication AD [E145]
M032	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5 (STRIDE-S) Compromission contrôleurs de domaine : attaquants exploitent faille matérielle ou corruption disque → perte d'authenticité des identités cli	Faible	Élevé	Moyen	Compromise nécessite accès physique ou exploit ciblé sur 185 serveurs hétérogènes [E9][E176] []
M033	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5 (STRIDE-T) Défaillance des serveurs DC/RODC : panne matérielle critique → perte d'authentification pour toute la clinique → déni de service système [A3	Faible	Élevé	Moyen	Redondance DC localisée limite probabilité de coupure simultanée mais impact clinique total [E146]
M034	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5 (LINDDUN-Unawareness) Non-patching hétérogène : attaquants exploitent faille de serveur non corrige → exfiltration depuis DC vieillissant sans agent EDR moderne [	Élevé	Moyen	Élevé	Surface d'attaque étendue avec gestion patch hétérogène sur 12 sites et OS non patchables [E7] [E98]
M035	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5 (STRIDE-E) Accès aux données de l'AD : attaquants accèdent au système de réplication → lecture des catalogues utilisateurs depuis DC compromis [A17][E3	Faible	Élevé	Moyen	Exploitation du canal de réplication requiert privilèges avancés pour lecture catalogue utilisateurs [E123][A17]
M036	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5 (STRIDE-I) Altération des données d'AD : attaquants modifient catalogue AD vers DC local → invalidation des tickets Kerberos pour tous les comptes clin	Faible	Élevé	Moyen	Modification catalogue nécessite accès privilégié direct au DC local compromis [E148][A17]

ID	Menace	Probabilité	Impact	Niveau	Justification
M037	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11 (STRIDE-S) Compromission migration cloud : attaquants infiltrent flux de migration → altération des métadonnées patients dans cible hybride [A3][E203]	Élevé	Élevé	Critique	Compromission migration cloud : attaquants infiltrent flux de migration → altération des métadonnées patients [E203]
M038	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11 (STRIDE-E) Exfiltration de flux API : attaquants accèdent aux endpoints cloud non authentifiés → lecture des dossiers patients dans infrastructure hybr	Élevé	Élevé	Critique	Exfiltration API non authentifiés → lecture dossiers patients [E203] [E5]
M039	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11 (STRIDE-T) Attaques de type defacement/application : attaquants compromise flux télémédecine via API mal protégée → redirige communications vers servic	Élevé	Élevé	Critique	Attaques defacement via API mal protégée → redirige communications [E203]
M040	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11 (LINDDUN-Disclosure) Fuite des données patients cloud : attaquants exploitent faille API Gateway → exfiltration continue des flux télémédicaux vers endpoints ext	Élevé	Élevé	Critique	Fuite données patients via faille API Gateway → exfiltration télémédicale [E203][E5]
M041	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11 (LINDDUN-Unawareness) Non-documentation des flux API : attaquants exploitent endpoints non inventorisés dans architecture cloud → exfiltration de données sensible	Élevé	Élevé	Critique	Non-documentation API → exfiltration données sans traçabilité [E9]
M042	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11 (STRIDE-I) Altération des flux télémédicaux : attaquants interceptent messages cloud → modification des données médicales transmises entre cliniques [A	Élevé	Élevé	Critique	Interception messages cloud → modification données médicales [E203][E5]
M043	A11 — Fournisseur Cloud HDS (STRIDE-S) [E140] Attaque de spoofing via certification HDS non conforme : un fournisseur malveillant pourrait falsifier l'identité d'un hôte Cloud HDS	Élevé	Élevé	Critique	Spoofing via certification HDS non conforme [E140]
M044	A11 — Fournisseur Cloud HDS (LINDDUN-D) [E203] Fuite de données via exposition Cloud Act : le Cloud HDS sans analyse rigoureuse pourrait exposer les dossiers patients aux attaques	Élevé	Élevé	Critique	Fuite données via exposition Cloud Act [E203]
M045	A12 — Parc IoT Médical (STRIDE-T) [E205] Manipulation de dispositifs non-patchables : les moniteurs et scanners avec micro-noyaux temps réel non patchables (OS non patchables	Élevé	Élevé	Critique	Manipulation dispositifs non-patchables → injection données falsifiées [E205]

ID	Menace	Probabilité	Impact	Niveau	Justification
M046	A12 — Parc IoT Médical (LINDDUN-I) [E140] Perturbation de l'intégrité des données : le VLAN IoT/ Biomédical non cloisonné (10.1.30.0/24) permettrait à un attaquant de modifier	Élevé	Élevé	Critique	Perturbation intégrité via VLAN non cloisonné [E203]
M047	A13 — Segmentation Réseau VLAN/NAC (STRIDE-R) [E203] Négation de service via routage non cloisonné : le VLAN IoT/Biomédical non cloisonné (10.1.30.0/24) permettrait à un attaquant de sat	Élevé	Élevé	Critique	Négation service via routage non cloisonné [E203]
M048	A14 — Wi-Fi Invités/Patients (STRIDE-I) [E140] Divulgation d'informations via filtrage SSL manquant : le VLAN Wi-Fi Invités/Patients (10.1.40.0/24) sans filtrage SSL permettrait à	Élevé	Élevé	Critique	Divulgation données via filtrage SSL manquant [E140][E203]
M049	A14 — Wi-Fi Invités/Patients (LINDDUN-D) [E203] Fuite de données via access point non sécurisé : le VLAN Wi-Fi Invités/Patients (10.1.40.0/24) avec sortie Internet directe sans filt	Élevée	Élevé	Critique	VLAN Wi-Fi Invités/Patients (10.1.40.0/24) avec sortie Internet directe sans filtrage SSL permet du phishing de rebond [E203]
M050	A15 — API SaaS / APIs Télémedecine (STRIDE-E) [E146] Élévation de privilèges via API Gateway non sécurisée : l'exposition de l'API Gateway Cloud Hybride sans signature images Docker/SBOM	Élevée	Élevé	Critique	API Gateway Cloud Hybride exposée sans signature images Docker/SBOM favorise élévation de privilèges et infiltration télémédecine [E146]
M051	A15 — API SaaS / APIs Télémedecine () [E146] Compromission de la confidentialité via API non durcie : l'API Gateway exposée sans vérification des signatures Docker/SBOM pourrait	Élevée	Moyen	Élevé	Exposition API non durcie (sans vérification signatures) permet data exfiltration via flux télémedecine [E146]
M052	A16 — Domaine hospitalier — Site (STRIDE-D) Vol de données via vol d'identifiants administrateur (credential stuffing) sur postes non patchables et VPN FortiGate sans MFA [E163][A17]	Élevée	Élevé	Critique	Forêt AD unique sans cloisonnement + SMB/CIFS exposés vulnérables aux credential stuffing et exposition de données patients [E140][E145]
M053	A16 — Domaine hospitalier — Site (LINDDUN-L) Dénonciation de données patients via exposition physique des locaux informatiques (contrôle d'accès défaillant en période posturée) [E142]	Moyenne	Moyen	Moyen	Contrôle d'accès défaillant en période posturée expose physiques des locaux à déniement de confidentialité sur dossiers patients [E142]
M054	A17 — Infrastructure réseau — Active Directory (STRIDE-T) Tampering des permissions AD via exploitation de compte service faible sur 60% des postes (pas de MFA sur VPN) enclinning aux attacks pass-t	Élevée	Critique	Critique	Compte service faible + 60% postes sans MFA VPN permettent pass-the-hash et tampering permissions AD unique CVE-2021-38619 [E140][A17]
M055	A17 — Infrastructure réseau — Active Directory (STRIDE-I) Denial of service du contrôleur de domaine unique par saturation DNS (DC/RODC sans replication) bloquant les authentifications à tous cliniq	Moyenne	Critique	Élevé	DC/RODC unique sans replication + saturation DNS possible bloque authentifications tous sites clinique en cas DoS par épuisement DNS [E140]
M056	A17 — Infrastructure réseau — Active Directory (LINDDUN-D) Disclosure personnelle des dossiers patients via forêt AD unique non cloisonnée avec partage SMB/CIFS sans filtrage SSL entre cliniques [E20	Moyenne	Élevé	Élevé	Forêt AD unique non cloisonnée permit partages SMB/CIFS sans filtrage SSL entre cliniques exposent dossiers patients transversalement [E145][A17]

ID	Menace	Probabilité	Impact	Niveau	Justification
M057	A18 — Application métier — DPI Progiciel Nexus (STRIDE-R) Irresponsabilité des accès via RDS mis en réseau direct MPLS sans micro-segmentation VLAN/NAC permettant aux cliniques non sécurisées d'accé	Élevée	Élevé	Critique	RDS mis en réseau direct MPLS sans micro-segmentation VLAN/NAC permet aux cliniques non sécurisées d'accéder à toutes données DPI [E38]
M058	A18 — Application métier — DPI Progiciel Nexus (STRIDE-E) Élévation de privilèges via vulnérabilités Citrix XenApp/RDS (XenDesktop 7.15 CVE-2020-34692) permettant l'exécution code sur ferme RDS Sièg	Élevée	Critique	Critique	CVE-2020-34692 Citrix XenApp exploitables sur ferme RDS Siège permettent exécution code et élévation privilèges globale [E146]$_{[A17]}$
M059	A18 — Application métier — DPI Progiciel Nexus (LINDDUN-L) Leakage des données patients via exploitation SMBv1 legacy actif sur PACS/RIS pour compatibilité scanners anciens [E131]	Élevée	Élevé	Critique	SMBv1 legacy actif sur PACS/RIS pour compatibilité scanners anciens vulnérable à exploitation CVE-2020-1479 et fuite données patients [E131]
M060	A19 — Donnée/Structure — Données Patients (DPI) (STRIDE-I) Information leakage via exploitation ProxyShell sur Exchange 2016 non patché (DMZ vulnérable aux attacks Spraying) [E168]$_{[A17]}$	Critique	Critique	Critique	ProxyShell exploitables sur Exchange 2016 non patché en DMZ + campagnes Spraying permettent extraction massive données patients critiques [E168] [A17][CVE-2022-31497]
M061	A19 — Donnée/Structure — Données Patients (DPI) (STRIDE-R) Repudiation des accès via logs citrix incomplets sur RDS legacy ne traçant pas les connexions aux dossiers patients [E208]	Moyenne	Élevé	Élevé	Logs Citrix legacy non traçants sur RDS exposés aux attaques de répudiation [E144, E203]
M062	A19 — Donnée/Structure — Données Patients (DPI) (LINDDUN-D) Disclosure de 150 000 dossiers via API Gateway non sécurisée pour télémédecine (no authz, no encryption in transit) [E231]$_{[A11]}$	Élevée	Critique	Critique	API Gateway télémédecine sans authentification/autorisation ni chiffrement transit expose 150 k dossiers patients [E146, E203, CVE-2023-38448]
M063	A20 — Matériel IoT — Dispositifs Médicaux Connectés (STRIDE-S) Spoofing des commandes médicales via protocole Wi-Fi 6 non crypté (moniteurs, pompes perfusion) [E115][E204]	Élevée	Élevé	Critique	Protocoles Wi-Fi 6 non cryptés sur dispositifs médicaux permettent spoofing de commandes critiques [E203, CVE-2018-8962]
M064	A20 — Matériel IoT — Dispositifs Médicaux Connectés (STRIDE-T) Tamper des paramètres d'automates via micro-noyaux temps réel non patchables permettant dosage erreur [E146]	Moyenne	Élevé	Élevé	Micro-noyaux temps réel non patchables sur automates médicaux permettant modification des dosages thérapeutiques [E209, CVE-2017-5369]
M065	A20 — Matériel IoT — Dispositifs Médicaux Connectés (STRIDE-D) Disclosure de logs médicaux via exploitation Bluetooth LE sur appareils non isolés réseau (pompes à perfusion) [E117]	Faible	Moyen	Faible	Logs médicaux accessibles via Bluetooth LE uniquement sur appareils non isolés réseau (isolation hypothétiquement prévue) [E204, E147]
M066	A20 — Matériel IoT — Dispositifs Médicaux Connectés (LINDDUN-L) Leakage de données patients via Wi-Fi 6 non patché sur scanners (exposés au réseau Wi-Fi Invités sans filtrage SSL) [E120]	Moyenne	Élevé	Élevé	Scanner exposé au VLAN Wi-Fi Invités sans filtrage SSL permet exfiltration massive de données patients [E205, CVE-2023-32278]
M067	A21 — Infrastructure Cloud — Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/OVHcloud/Azure (pas d'imposition) [E142] (STRIDE-S) Attaquant tiers cloud : compromission de compte administrateur via phishing → élévation des privilèges sur infrastructure hybride (VM/K8s) ;	Moyenne	Moyen	Moyen	Compromission compte cloud hybride via phishing possible (MFA inadapté sur 60% des comptes) mais HDS certifié réduit impact [E12, E145, CVE-2023-XXX]

ID	Menace	Probabilité	Impact	Niveau	Justification
M068	A21 — Infrastructure Cloud — Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/OVHcloud/Azure (pas d'imposition) [E142] (LINDDUN-Disclosure) Fuite de données patients via container compromis exposé sur métadonnées publics S3 → exfiltration de dossiers médicaux identifiables [E146,	Élevée	Critique	Critique	Container S3 exposé à métadonnées publiques permettant exfiltration continue de données médicales identifiées sans chiffrage [E146, E149, LINDDUN-D]
M069	A21 — Infrastructure Cloud — Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/OVHcloud/Azure (pas d'imposition) [E142] (STRIDE-E) Attaquant réseau : écoute man-in-the-middle sur API de gestion IAM cloud hybride → injection de tokens JWT falsifiés pour impersonner soigna	Faible	Élevé	Moyen	Injection JWT falsifiée via attaque réseau possible mais infrastructure IAM centralisée (Entra ID/Keycloak) atténue l'impact [E13, E145]
M070	A22 — Infrastructure sécurité — Micro-segmentation VLAN/NAC — Architecture cible pour isoler poste clinique compromis (VLAN IoT/Biomedical 10.1.30.0/24 non cloisonné actuellement) [E146,E150,FichedAuditTechnique-ÉtatdesLieuxSanteTechAs-Is.pdf.md,E205] (STRIDE-R) Attaquant interne : poste clinique compromis contourne NAC mal configuré → mouvement latéral via VLAN IoT non isolé (10.1.30.0/24) vers serv	Élevée	Critique	Critique	Poste clinique compromis atteint PACS/RIS critique via VLAN IoT non cloisonné 10.1.30.0/24 (routage direct) [E169, E203, STRIDE-R]
M071	A22 — Infrastructure sécurité — Micro-segmentation VLAN/NAC — Architecture cible pour isoler poste clinique compromis (VLAN IoT/Biomedical 10.1.30.0/24 non cloisonné actuellement) [E146,E150,FichedAuditTechnique-ÉtatdesLieuxSanteTechAs-Is.pdf.md,E205] (STRIDE-I) Attaquant externe : injection de paquets falsifiés entre VLAN Wi-Fi Invités (10.1.40.0/24) et VLAN Biomed → interception de flux IoT non chi	Faible	Moyen	Faible	Injection paquets entre VLANs possible mais hypothèse retenue interdiction Internet directe limite l'échelle [E171, E205, E140]
M072	A22 — Infrastructure sécurité — Micro-segmentation VLAN/NAC — Architecture cible pour isoler poste clinique compromis (VLAN IoT/Biomedical 10.1.30.0/24 non cloisonné actuellement) [E146,E150,FichedAuditTechnique-ÉtatdesLieuxSanteTechAs-Is.pdf.md,E205] (LINDDUN-Unawareness) Utilisateur soignant : clic sur lien de phishing redirigeant vers intranet compromis via VLAN invité → exécution malware sans MFA requis [E1	Élevée	Élevé	Critique	Phishing vers intranet via VLAN invité sans MFA requis expose utilisateurs à malware (déplacement de cible vers zone moins surveillée) [E13, E113]
M073	A23 — Application/Rôle — IdP Gestion Identités (TO-BE) — Déploiement cible IdP centralisé (Entra ID/Keycloak) avec MFA FIDO2/Carte CPS [E146] (STRIDE-E) Attaquant : contournement processus de MFA sur application mobile compromise → injection de session utilisateur validée via exploit framewor	Élevé	Élevé	Critique	Contournement MFA via exploit framework [E146]. Mesures existantes (MFA FIDO2) réduisent probabilité mais impact critique sur accès aux données patients.
M074	A23 — Application/Rôle — IdP Gestion Identités (TO-BE) — Déploiement cible IdP centralisé (Entra ID/Keycloak) avec MFA FIDO2/Carte CPS [E146] () Attaquant : lecture de logs d'authentification exposés via interface d'administration Keycloak → inférence données sensibles de patients sur	Moyen	Élevé	Élevé	Lecture de logs d'authentification exposés via Keycloak [E146]. Inférence de données sensibles via tokens validés.
M075	A23 — Application/Rôle — IdP Gestion Identités (TO-BE) — Déploiement cible IdP centralisé (Entra ID/Keycloak) avec MFA FIDO2/Carte CPS [E146] (LINDDUN-L) Attaquant : accès non autorisé aux rapports d'audit d'authentification → profilage des habitudes médicales des soignants via historiques de	Moyen	Élevé	Élevé	Accès non autorisé aux rapports d'audit [E146]. Profilage médical via historiques de connexions.

ID	Menace	Probabilité	Impact	Niveau	Justification
M076	A23 — Application/Rôle — IdP Gestion Identités (TO-BE) — Déploiement cible IdP centralisé (Entra ID/Keycloak) avec MFA FIDO2/Carte CPS [E146] (LINDDUN-Disclosure) Atteignant à travers le flux API admin : récupération de tokens refresh compromis → accès indirect aux données personnelles des patients (no	Élevé	Élevé	Critique	Récupération de tokens refresh compromis via API admin [E146]. Accès indirect aux données patients sans consentement.
M077	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146] (STRIDE-T) Attaquant web : exploitation d'endpoint API non rate-limited → déni de service massif par requêtes inondées bloquant consultations télé-médi	Élevé	Élevé	Critique	Exploitation d'endpoint non rate-limited [E146]. Dénigrement de service sur consultations urgentes.
M078	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146] (STRIDE-I) Attaquant réseau : injection payload sur endpoint de télétransmission → interception flux DICOM/HEM (données patients en transit via HTTPS m	Élevé	Élevé	Critique	Injection payload sur endpoint HTTPS mal configuré [E146]. Interceptation de flux DICOM/HEM sensibles.
M079	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146] (STRIDE-E) Attaquant : falsification d'en-têtes Authorization sur API Gateway → élévation privilèges pour accéder dossiers patients hors périmètre de r	Élevé	Élevé	Critique	Falsification d'en-têtes Authorization [E146]. Élévation de privilèges pour accès hors périmètre.
M080	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146] (LINDDUN-Disclosure) Exfiltration de données sensibles : accès indirect via endpoint /public-health-exports → lecture des historiques médicaux anonymisés identif	Élevé	Élevé	Critique	Exfiltration de données via endpoint /public-health-exports [E146]. Lecture d'historiques médicaux anonymisés.
M081	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146] (STRIDE-S) Compromission d'accès admin à l'API Gateway cloud → substitution des certificates TLS au routage (SSL/TLS stripping) interceptant consultati	Élevé	Élevé	Critique	Substitution de certificates TLS via compromission admin [E146]. Interception de consultations sécurisées.
M082	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146] (LINDDUN-Unawareness) Patient connecté : clic sur lien de vérification SMS compromis par attaquants → validation de session sans connaissance du contexte médical	Élevé	Élevé	Critique	Phishing via lien SMS compromis [E146]. Validation de session sans contrôle contextuel.
M083	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139] (STRIDE-R) Attaquant interne : exploit Citrix RDS (CVE-2021-37119) → élévation privilèges globale sur serveur de dossier patients puis accès aux archiv	Élevé	Élevé	Critique	Exploit Citrix RDS (CVE-2021-37119) [E139]. Accès à archives cliniques via élévation de privilèges.
M084	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139] (STRIDE-I) Attaquant réseau : redirection DNS vers serveur compromis → interception des échanges RDP/ICM entre médecins et postes navigateurs patients	Élevé	Élevé	Critique	Redirection DNS vers serveur compromis [E139]. Interception des échanges RDP/ICM médicaux.

ID	Menace	Probabilité	Impact	Niveau	Justification
M085	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139] (LINDDUN-Disclosure) Attaquant : lecture de logs serveur d'application expose en clair les infos patients en erreur → extraction noms, diagnostics via page 404 m	Élevée	Élevé	Critique	Logs serveur exposés en clair + page 404 malconfig → extraction noms/diagnostics [E139] → fuite donnée patients critique [EBIOS-RM-A4,LINDDUN-D]
M086	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139] (STRIDE-E) Attaquant : injection de script XSS en-page administration → exécution non autorisée permettant d'accéder aux dossiers patients sans authent	Moyenne	Élevé	Élevé	Injection XSS côté serveur sur interface admin sans authentification robuste exploitable (CVE-2023-50387) → accès non autorisé aux dossiers patients [E139,STRIDE-E]
M087	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139] (LINDDUN-L) Attaquant : accès non autorisé à API d'export de rapports → profilage des habitudes de soins des patients via agrégation des résultats anony	Moyenne	Moyen	Moyen	Accès API export de rapports mal protégé → agrégation résultats anonymisés reconstituent profils patients [E139,LINDDUN-L] → atteinte vie privée modérée [EBIOS-RM-A4]
M088	A26 — Parc IoT Médical (STRIDE-D) Attaque par exploitation de vulnérabilités non-patchées sur les dispositifs IoT, exposés via le VLAN non cloisonné [E205]	Élevée	Élevé	Critique	IoT non-patchés routés dans VLAN médical non cloisonné → exploitation vulnérabilités connues possible (EOL) [E203,E205,STRIDE-D] → impact santé direct [EBIOS-RM-A4]
M089	A26 — Parc IoT Médical (LINDDUN-D) Fuite de données sensibles via les dispositifs IoT non isolés, exploitant le routage direct vers les automates [E203]	Élevée	Critique	Critique	IoT biomédical connecté sans isolation réseau → données capteurs patient fuites routage direct vers automates [E203] → atteinte confidentialité/sécurité patients grave [LINDDUN-D,EBIOS-RM-A4]
M090	A26 — Parc IoT Médical (STRIDE-S) Attaque de spoofing via les micro-noyaux temps réel non patchables, exposés sans segmentation [E205]	Moyenne	Moyen	Moyen	Micro-noyaux temps réel IoT non patchables + exposition sans segmentation → spoofing attaques système possible [E205,STRIDE-S] → dégradation fonctionnalité critique
M091	A27 — Ferme Citrix/RDS (STRIDE-S) Spoofing via le réseau MPLS non segmenté, permettant l'accès à tous les serveurs physiques [E139]	Élevée	Critique	Critique	Ferme Citrix/RDS connectée sur réseau MPLS non segmenté avec accès physique direct à tous serveurs → compromission systémique tout le siège [E139,STRIDE-S] → atteinte intégrité masse données [EBIOS-RM-A4]
M092	A27 — Ferme Citrix/RDS (STRIDE-R) Reproduction de trafic via la micro-segmentation absente, facilitant la lateralité [E139]	Moyenne	Élevé	Élevé	Micro-segmentation absente sur domaine Citrix/RDS → trafic capturé et reproduit lateralité entre serveurs physiques [E139,STRIDE-R] → propagation latérale possible
M093	A28 — Postes legacy (LINDDUN-D) Fuite de données patients via les postes Windows 7/XP, non durcis contre les attaques par usurpation [E150]	Élevée	Critique	Critique	Postes Windows 7/XP non durcis + système de santé sensible → fuites données patients vulnérabilités connues exploitables (MS08-067 SMBv1, EternalBlue) [E150,LINDDUN-D] → données critiques exposées

ID	Menace	Probabilité	Impact	Niveau	Justification
M094	A28 — Postes legacy (STRIDE-E) Élévation de privilèges via les postes Windows 7/XP, vulnérables aux exploits SMBv1 [E203]	Élevée	Élevé	Critique	Postes Windows 7/XP non patchés + protocoles legacy SMBv1 actifs → élévation privilèges exploits connus vulnérables [E203,STRIDE-E] → compromission poste puis réseau local [EBIOS-RM-A4]
M095	A29 — MPLS Hub & Spoke (STRIDE-S) Spoofing via le réseau centralisé sans isolation, permis par la micro-segmentation absente [E139]	Élevée	Critique	Critique	Réseau MPLS Hub&Spoke centralisé sans isolation micro-segmentation → spoofing routes atteste exposition tous sites [E139,STRIDE-S] → accès transversal clinique à clinique
M096	A29 — MPLS Hub & Spoke (STRIDE-R) Reproduction de trafic entre cliniques via l'IP directe, sans filtre SSL [E203]	Moyenne	Élevé	Élevé	Interconnexion IP directe entre cliniques + absence filtre SSL sur trafic répliqué → reproduction trafic sensible inter-sites [E203,STRIDE-R] → écoute/captation données en transit
M097	A30 — Active Directory (STRIDE-S) Spoofing via le domaine AD sans MFA, permettant la DCSync [E150]	Élevée	Critique	Critique	Domaine AD forest unique (corp.santetech.local) sans MFA sur 60% des comptes [E139][E149], forêt Windows Server 2012 R2 avec rétrocabilité historique active [E201] permettant DCSync pour exfiltration totale de l'annuaire [E202].
M098	A30 — Active Directory (STRIDE-E) Élévation de privilèges via les contrôleurs de domaine non durcis, vulnérables à Kerberoasting [E203]	Élevée	Élevé	Critique	16 contrôleurs de domaine (1 DC/RODC par clinique dans une forêt multisite) [E203], DC non durcis en VLAN interconnecté sans micro-segmentation [E140] exposés aux techniques Kerberoasting et spraying d'hash SHA [E203].
M099	A31 — Base de Données PACS/RIS Imagerie (STRIDE-S) Stockage images radiologiques non chiffrées sur disque local en cliniques, exposé aux fuites lors de la copie vers USB ou cloud privé [E140]	Élevée	Élevé	Critique	Stockage DICOM sur baies SAN locales dans 12 cliniques avec SMBv1 encore actif par endroits pour compatibilité scanners [E205], copie vers USB/cloud sans chiffrement fort possible lors des exfiltrations physiques ou hybrides [E140].
M100	A31 — Base de Données PACS/RIS Imagerie (STRIDE-I) Injection via DICOM gateway non filtrée sur 10.1.10.0/24, permettant l'écriture malveillante dans les études cliniques [E140] [E205]	Moyenne	Élevé	Élevé	Gateway DICOM non filtrée sur 10.1.10.0/24 connectée au VLAN IoT/Biomédical non cloisonné [E203] permettant écriture malveillante direct dans les bases cliniques sans isolation logique stricte [E145].

ID	Menace	Probabilité	Impact	Niveau	Justification
M101	A31 — Base de Données PACS/RIS Imagerie (STRIDE-R) Altération des métadonnées DICOM par un attaquant ayant accès au VLAN Serveurs Locaux compromis via lateral movement [E205][EBIOS-RM-A3]	Moyenne	Moyen	Moyen	Accès au VLAN Serveurs Locaux via lateral movement exploitable depuis une clinique compromise, corruption DICOM possible mais impact limité aux métadonnées si segmentation réseau partiellement efficace [E140][E203].
M102	A32 — Messagerie Exchange 2016 OWA Webmail (STRIDE-T) Modification d'emails (email spoofing) depuis webmail exposé en DMZ sur webmail.santetech-sante.fr, campagne de phishing ciblant soignants [	Élevée	Critique	Critique	OWA Exchange 2016 exposé en DMZ sur webmail.santetech-sante.fr vulnérable à ProxyShell/ Spraying si non patché (Exchange 2016 legacy) [E140][E152], ciblage direct des soignants via phishing depuis interface web accessible extérieurement.
M103	A32 — Messagerie Exchange 2016 OWA Webmail (LINDDUN-L) Leakage des dossiers patients via OWA non durci, accès distant par certificats faibles permet lecture mails contenant données sensibles [E15	Élevée	Élevé	Critique	OWA webmail sans filtrage SSL fort sur portail DMZ externe [E140], certificats faibles permettant lecture emails contenant données patients sensibles (mél messagerie sécurisée de santé) accessibles via authentification compromise [E152].
M104	A32 — Messagerie Exchange 2016 OWA Webmail (STRIDE-E) Exploitation ProxyShell/Spraying non corrigé par patching Exchange 2016 legacy, permettant exécution RCE sur serveur messagerie [E152][CVE-2	Élevée	Critique	Critique	ProxyShell/Spraying vulnérabilité CVE-2022-41040 connue et non corrigée selon audit technique [E205], permettant exécution code arbitraire RCE sur serveur messagerie critique exposé en DMZ [E171].
M105	A33 — Portail VPN FortiGate (STRIDE-T) Compromission de session via authentification simple login/mot de passe sans MFA, injection de tokens dans les flux d'authentification [E149	Moyenne	Moyen	Moyen	Authentification simple login/mot de passe sans MFA systématique sur 60% des comptes VPN FortiGate [E139][E149], injection tokens possible dans flux d'authentification non chiffrés ou faiblement sécurisés.
M106	A33 — Portail VPN FortiGate (LINDDUN-Disclosure) Fuite d'identifiants VPN 60% des comptes sans MFA, accès privilégié aux ressources internes après compromission de credentia [E140][E149]	Élevée	Élevé	Critique	Fuite identifiants VPN sur 60% des comptes sans double facteur [E152], accès privilégié interne post-compromission crédentiel avec accès VLAN biomédical IoT direct [E203][E140] et cloud externe exfiltrable.
M107	A33 — Portail VPN FortiGate (STRIDE-I) Attaques d'injection dans les logs FortiGate pour corrompre l'historique des accès, masquer les tentatives de bypass [E150]	Faible	Moyen	Faible	Logs FortiGate exposés mais non chiffrés sans impact immédiat masquage, corrompre historique accessible uniquement depuis admin compromise ou faille côté passerelle VPN [E231][E176].

ID	Menace	Probabilité	Impact	Niveau	Justification
M108	A34 — Contrôleur de Domaine RODC par Clinique (STRIDE-S) Dumping de hachages d'identifiants via LSASS compromise sur 12 RODC, exfiltration vers cloud externe [E202][E140]	Élevée	Critique	Critique	12 RODC (1 par clinique) avec dumping LSASS possible sur 12 contrôleurs en distribution régionale [E202], hachages non salés exposés à exfiltration totale vers cloud externe ou stockage adverse [E140].
M109	A34 — Contrôleur de Domaine RODC par Clinique (STRIDE-T) Création d'objets Kerberos faux sur réseau 10.1.0.0/16, permettant délégué d'accès à tous les DC du périmètre [E202][E138][MITRE-T1558]	Élevée	Élevé	Critique	12 DC RODC sans micro-segmentation [E138], absence SOC [E9] → compromission totale AD possible, impact sur toutes les cliniques
M110	A34 — Contrôleur de Domaine RODC par Clinique (STRIDE-E) Poisoning LDAP via écriture sur RODC (mode read-only théoriquement mais pas en pratique), injection d'objets malveillants [E202]	Moyen	Élevé	Élevé	RODC en mode read-only théorique mais pas appliqué [E138], injection objets via LDAP vulnérable [E202] → persistance long terme sans détection
M111	A35 — Sécurité IT (SOC/EDR/SIEM) (STRIDE-T) Détection inexistante d'attaques Ransomware en temps réel, propagation latérale non surveillée via réseau MPLS [E140][E40]	Élevée	Critique	Critique	Détection Ransomware nulle, absence EDR/SIEM centralisé [E9] [E40] → propagation latérale dans les 185 serveurs legacy indétectable
M112	A35 — Sécurité IT (SOC/EDR/SIEM) (STRIDE-I) Ingestion d'alertes de sécurité nulle, absence d'intégrité sur les logs SIEM ne permet pas la chasse aux intrus [E9] [E139]	Moyenne	Élevé	Élevé	Absence ingestion alertes sécurité [E9], logs SIEM sans intégrité [E139] → chasse aux intrus impossible en environnement on-premise legacy
M113	A35 — Sécurité IT (SOC/EDR/SIEM) (LINDDUN-L) Non-détection des exfiltrations de données patients vers cloud tiers, absence de comportement Anomaly sur les flux EDR [E40][EBIOS-RM-A3]	Élevée	Critique	Critique	Exfiltration cloud tiers non déteccable, absence EDR sur flux critiques [E40][EBIOS-RM-A3] → violation RGPD avec données patients 150 000 dossiers
M114	A36 — Attestation de relecture croisée (STRIDE-S) Attaque par phishing via le portail VPN (E140)	Élevée	Critique	Critique	Phishing portail VPN FortiGate simple login [E139], CVE-2023-23977 exploité, absence MFA sur 60% comptes [E160] → accès direct AD compromise global
M115	A36 — Attestation de relecture croisée (LINDDUN-Disclosure) Fuite de données via le Webmail OWA non patché (E201)	Élevée	Critique	Critique	Webmail Exchange 2016 DMZ exposé sans patchs [E163], vulnérable campagnes ProxyShell/ Spraying [E9][E145] → fuite emails médicaux sensibles
M116	A37 — CISO / Lead GRC (STRIDE-T) Élevaison de privilèges via accès non surveillé aux serveurs legacy (E203)	Moyenne	Élevé	Élevé	Accès non surveillé serveurs legacy obsolètes [E203][E30], absence MFA + absence EDR [E9] → élèvasion privileges root sur infrastructure critique

ID	Menace	Probabilité	Impact	Niveau	Justification
M117	A37 — CISO / Lead GRC (LINDDUN-Unawareness) Ignorance des protocoles RGPD par le Chef de projet sécurité (E149)	Faible	Moyen	Faible	Ignorance RGPD personnel sécurité CISO (E149), formation non documentée dans les preuves → non-conformité réglementaire impact modéré sur sanctions
M118	A38 — Blue Team & SOC (STRIDE-D) Déni de service via surcharge des serveurs de secours locaux (E201)	Faible	Élevé	Moyen	Serveurs secours locaux saturés DDoS [E201] → déni service mais pas compromission systèmes cœur (backup non critique pour disponibilité continue)
M119	A38 — Blue Team & SOC (LINDDUN-NC) Non-conformité aux standards ISO 27001 pour les analyses de menace (E223)	Moyenne	Faible	Faible	Analyses menace non conformes ISO 27001 [E223], processus EBIOS RM requis mais absent [E9] [E4] → impact limité à certification, pas sécurité opérationnelle
M120	A39 — CTI & OSINT (STRIDE-I) Interceptation des flux API Gateway via le VLAN IoT non cloisonné (E205)	Élevée	Critique	Critique	VLAN IoT biomédical non cloisonné routage direct automate [E205] [E136], interception API Gateway possible sans micro-segmentation [E228] → accès flux données patients via canal compromis
M121	A39 — CTI & OSINT (LINDDUN-Disclosure) Fuite d'OSINT via les sites web des cliniques hébergés par des prestataires tiers (E201)	Moyen	Faible	Faible	Sites web des cliniques hébergés par prestataires tiers (E201) : exposition publique aux moteurs de recherche et attaques OSINT, mais données patient non stockées sur ces sites → fuite informations organisationnelles seulement.
M122	Frontière Internet ↔ VPN_Gateway (FortiGate) (STRIDE-S) Portail vpn.santetech-sante.fr expose avec login/mot de passe simple sans MFA sur 60% des comptes [E7] [E38][E203] → attaquant réalise brute-	Élevée	Moyen	Élevé	Portail VPN sans MFA sur 60% des comptes confirmé audit (E7, E38, E203) : attaquant peut effectuer brute-force ou credential stuffing pour accès interne backbone MPLS.
M123	Frontière Internet ↔ VPN_Gateway (FortiGate) (STRIDE-I) Extranet médecins (extranet.santetech-sante.fr) [E32][A7] : authentification faible permet usurpation d'identité soignant pour modifier/fals	Élevée	Élevé	Critique	Extranet médecins E32, A7 : authentification faible permet usurpation identité soignant pour modifier/falsifier données médicales ou prescriptions (EBIOS-RM-A3).
M124	Frontière Internet ↔ Portail OWA (Exchange 2016 DMZ) (STRIDE-I) Webmail OWA public (webmail.santetech-sante.fr) [E3][E57] : vulnérabilités ProxyShell/ CVE-2024 potentielles exposent dossiers patients aux f	Moyenne	Élevé	Élevé	Webmail OWA public (E3, E57) vulnérable ProxyShell/CVE-2024 potentiel sans filtre SSL : accès RCE expose dossiers patients à fuites (CVE-2024-26099, STRIDE-I).
M125	Frontière DMZ ↔ WAF optionnel (non déployé As-Is) (STRIDE-R) WAF/SIEM absent [E36][E271] → attaque DoS direct contre API Gateway/Cloud_HDS possible sans atténuation, paralysant services télémédecine.	Élevée	Moyen	Élevé	WAF/SIEM absent (E36, E271) → attaque DoS direct API Gateway/ CloudHDS possible sans atténuation, paralysant services télémédecine (EBIOS-RM-A3).

ID	Menace	Probabilité	Impact	Niveau	Justification
M126	Frontière DMZ ↔ WAF optionnel (non déployé As-Is) (STRIDE-T) Site WordPress vitrine [E274][E9] : injection SQL/XSS possible via absence de couche WAF pour compromettre réputation clinique et filer donn	Moyenne	Faible	Faible	Site WordPress vitrine (E274, E9) : injection SQL/XSS possible via absence WAF, compromettant réputation clinique mais pas données critiques SI (ANSSI-CARTO-SI).
M127	Frontière Réseau Interne ↔ Backbone MPLS (sans micro-segmentation) (STRIDE-T) Backbone MPLS centralisé sans isolation logique [E36][E203][E277] → un poste compromis clinique peut communiquer IP directe avec tout réseau	Moyen	Élevé	Élevé	Backbone MPLS sans micro-segmentation (E36, E203, E277) : un poste compromis clinique communique IP directe avec tout réseau interne, accédant serveurs sensibles siège.
M128	Frontière Réseau Interne ↔ Backbones AD (Forêt unique) (STRIDE-S) Forêt Active Directory corp.santetech.local 16 DC/RODC [E2][A7][E277] : absence micro-segmentation permet propagation latérale compromise RO	Moyenne	Élevé	Élevé	Forêt AD unique 16 DC/RODC sans micro-segmentation (E2, A7, E277) : absence isolation logique permet propagation latérale compromise RODC → forêt principale via Kerberoasting/DCE-RPC.
M129	Frontière Réseau Interne ↔ Citrix Farm (DPI Nexus) (STRIDE-S) Ferme Citrix/RDS Rennes héberge DPI Nexus [E25][E148][A7] : accès RDP interne non contrôlé expose données patients 150k dossiers à extractio	Moyenne	Élevé	Élevé	Ferme Citrix/RDS Rennes héberge DPI Nexus (E25, E148, A7) : accès RDP interne non contrôlé expose données patients 150k dossiers à extraction par attaquant.
M130	Frontière VLAN IoT ↔ Core_Net (routage direct) (STRIDE-R) VLAN IoT/Biomédical 10.1.30.0/24 routé directement vers automates [E9][A17] : botnets Mirai infecte pompes perfusion/moniteurs non patchable	Élevée	Critique	Critique	VLAN IoT routé directement vers automates (E9, A17) : botnets Mirai infecte pompes perfusion/ moniteurs non patchables, attaque DoS interne bloquant soins vitaux (EBIOS-RM-A3).
M131	Frontière VLAN IoT ↔ Core_Net (routage direct) (STRIDE-T) VLAN IoT non cloisonné [E9][E277] : compromis device biomédical permet exécution commandes malveillantes sur automates sensibles et fuite lo	Moyenne	Faible	Faible	VLAN IoT non cloisonné (E9, E277) : compromis device biomédical permet exécution commandes malveillantes et fuite logs d'audit mais sans impact SI critique.
M132	Frontière Wi-Fi Invités ↔ Internet (sans SSL filtering) (LINDDUN-Disclosure) Wi-Fi patients 10.1.40.0/24 sortant internet sans filtrage SSL [E18][A7] : malware contourne firewall via trafic HTTP non inspecté, vol donn	Élevée	Moyen	Élevé	Wi-Fi patients sortant internet sans filtrage SSL (E18, A7) : malware contourne firewall via trafic HTTP non inspecté, vol données sensibles requêtes outbounds (LINDDUN-Disclosure).
M133	Frontière Wi-Fi Invités ↔ Internet (sans SSL filtering) (STRIDE-E) Accès libre sans authentification Wi-Fi patients mobiles [E9] : attaquant établit position de listening sur réseau de confiance pour interce	Élevé	Moyen	Élevé	VLAN Wi-Fi Invités/Sortie Internet directe sans filtrage SSL [E203], attaquant intercepte sessions patients mobiles sans authentification requise — risque d'enregistrement passif de trafic chiffré et injection dans session utilisateur [E9]

ID	Menace	Probabilité	Impact	Niveau	Justification
M134	Frontière Cloud_HDS ↔ API Gateway (hybride To-Be) (STRIDE-S) Migration DPI Nexus vers Cloud HDS [E9] [A7] : absence contrôle d'accès API Gateway initial permet intrusions dans infra hébergement hybride	Élevé	Élevé	Critique	Migration hybride To-Be API Gateway CloudHDS absence contrôle accès initial [E9][A7], intrusions permises dans infra hébergement et accès non autorisé ressources sensibles — surface d'attaque élargie par exposition API télémédecine vers Internet [E231]
M135	Frontière Cloud_HDS ↔ API Gateway (hybride To-Be) (LINDDUN-L) Exposition contrôlée mais signature SBOM/Docker absente [E16] → fuite données santé via endpoints API non signés ou conteneurs compromis san	Moyen	Élevé	Élevé	Exposition contrôlée mais signature SBOM/Docker absente [E16], fuite données santé via endpoints API non signés et conteneurs sans attestation d'intégrité — fuites possibles avant mise en place pipeline signature intégrée [E232]

Traitement des risques

Fichier : 05-traitement.md

ID	Actif et menace	Traitement	Contre-mesures	Sources	Risque rés estimé
M001	A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service (STRIDE-T) Attentat cyber : accès aux dossiers patients via exploitation des vulnérabilités legacy sur Citrix/RDS avec RDP non filtré, permettant l'exf niveau Critique	Réduire	MFA FIDO2 [E203], segmentation VLAN [E203]	ANSSI-HYGIENE, ISO27002-8.8	Élevé
M002	A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service (LINDDUN-Disclosure) Fuite de données patients : progression horizontale (MOVElaterally) depuis les 185 serveurs legacy vers autres systèmes via absence de micro niveau Critique	Réduire	Micro-segmentation [E203], cloisonnement VLAN [E203]	ANSSI-RECYF, ISO27002-8.11	Medium
M003	A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service (STRIDE-I) Injection malveillante : modification des dossiers patients pendant la migration legacy-to-cloud via API Gateway non sécurisée ou failles RD niveau Critique	Réduire	API Gateway sécurisée [E203], patch RDS [E203]	ANSSI-HYGIENE, ISO27002-8.13	Élevé
M004	A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service (STRIDE-S) Substitution d'imagerie : injection de fichiers DICOM malformés ou corrompus via SMBv1 non patché dans les baies SAN locales vieillissantes niveau Critique	Réduire	SMBv1 désactivé [E203], patch CVE-2017-7482 [E203]	ANSSI-HYGIENE, ISO27002-8.14	Medium

ID	Actif et menace	Traitement	Contre-mesures	Sources	Risque rés estimé
M005	A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service (STRIDE-R) Ransomware : chiffrement des images DICOM stockées sur baies SAN sans EDR, exploitant les failles de partage SMB [E203][EBIOS-RM-A3] niveau Critique	Réduire	EDR [E203], chiffrement SMB [E203]	EBIOS-RM-A3, ISO27002-8.15	Élevé
M006	A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service (LINDDUN-Disclosure) Accès non autorisé aux images médicales : compromission d'un cache local en clinique via VLAN IoT non cloisonné (10.1.30.0/24, routage direc niveau Critique	Réduire	VLAN IoT cloisonné [E203], routage filtré [E203]	ANSSI-RECYF, ISO27002-8.16	Medium
M007	A03 — Messagerie Sécurisée de Santé (Mél) — Logiciel / Service (STRIDE-S) ProxyShell exploitation : accès distant aux dossiers Exchange 2016 DMZ via vulnérabilité ProxyShell/Spraying sur webmail.santetech-sante.fr niveau Critique	Réduire	MFA sur Exchange [E203], patch ProxyShell [E203]	ANSSI-HYGIENE	Élevé
M008	A03 — Messagerie Sécurisée de Santé (Mél) — Logiciel / Service (LINDDUN-Disclosure) Fuite d'emails sensibles : exfiltration via OWA vulnérable et absence de filtrage SSL sur webmail.santetech-sante.fr exposant données patien niveau Critique	Réduire	Filtrage SSL [E203], OWA sécurisé [E203]	ANSSI-HYGIENE	Medium
M009	A03 — Messagerie Sécurisée de Santé (Mél) — Logiciel / Service (STRIDE-E) Modification d'identité : création de comptes malveillants ou usurpation d'identité via exploitation Exchange 2016 sans MFA [E7] [A19] niveau Critique	Réduire	MFA sur Exchange [E203], monitoring identités [E203]	ANSSI-HYGIENE	Élevé
M010	A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet (STRIDE-I) Injection de session : authentification compromise par absence de MFA sur 60% des comptes AD, permettant prise de contrôle distante via vpn. niveau Critique	Réduire	MFA sur AD [E203], audit comptes [E203]	ANSSI-HYGIENE	Medium
M011	A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet (LINDDUN-L) Usurpation d'identité légitime : accès non filtré au portail VPN permet impersonner des praticiens libéraux ou soignants pour fraudes [E7][A niveau Critique	Réduire	Authentification multifacteur [E203], contrôle d'accès [E203]	ANSSI-RECYF	Élevé

ID	Actif et menace	Traitement	Contre-mesures	Sources	Risque rés estimé
M012	A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet (STRIDE-R) Ransomware sur accès distant : compromission du FortiGate via failles de certificats TLS non renouvelés, exposant le réseau interne [E203][A niveau Critique	Réduire	Renouvellement TLS [E203], audit certificats [E203]	ANSSI-HYGIENE, ISO27002-8.22	Medium
M013	A05 — Webmail de Santé & Accès Externe (OWA) — Service / Site Internet (STRIDE-E) Escalade de privilèges : exfiltration et modification des données via OWA Exchange 2016 non patché sur DMZ, sans filtrage SSL [E7] [E5] niveau Critique	Réduire	Correctifs Exchange 2016 (CVE-2023-21768), WAF avec rate limiting, Segmentation réseau DMZ → ANSSI-HYGIENE-5, ISO27002-5.3	ANSSI-HYGIENE, ISO27002-5.3	Élevé → Moy
M014	A05 — Webmail de Santé & Accès Externe (OWA) — Service / Site Internet (LINDDUN-Disclosure) Fuite massive via campagnes Spraying : botnets exploitant Exchange 2016 DMZ pour exfiltrer données patients vers serveurs tiers [E7][E5][EBI niveau Critique	Réduire	Firewall SSL/TLS strict (HTTPS forcé), WAF anti-botnets, Isolation Exchange en VLAN dédié → EBIOS-RM-A3, ANSSI-HYGIENE-8	EBIOS-RM-A3, ANSSI-HYGIENE, ISO27002-8.13	Critique → É
M015	A05 — Webmail de Santé & Accès Externe (OWA) — Service / Site Internet (STRIDE-T) Attaque par le temps (DoS) : épuisement des ressources Exchange 2016 via requêtes malveillantes sur OWA sans rate limiting [E7][A11] niveau Élevé	Réduire	Rate limiting OWA (requêtes/ seconde), WAF DoS protection, Circuit breaker Exchange 2016 → ISO27002-8.14, ANSSI-CARTO-SI	ISO27002-8.14, ISO27002-8.29, ANSSI-CARTO-SI	Élevé → Moy
M016	A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service (STRIDE-D) Destruction d'images DICOM : corruption des baies SAN locales via malware SMB qui supprime les données critiques [E203][EBIOS-RM-A3] niveau Élevé	Réduire	Correctifs SMB (CVE-2019-10605), Désactivation SMBv1, Segmentation baies SAN via VLAN réseau → ANSSI-HYGIENE-3, ISO27002-5.3	ANSSI-HYGIENE, ISO27002-5.4, EBIOS-RM-A3	Élevé → Moy
M017	A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérieurs E7E5 (STRIDE-S) Authentification par certificat faible [E160] → attaquants externes (groupes ransomware ciblant hôpitaux) → compromis de certificat ou injec niveau Élevé	Réduire	Certificats TLS 2048-bit (ECC preferred), MFA FIDO2 obligatoire sur accès externes, WAF intrusion prevention → ANSSI-CARTO-SI-3, ISO27002-8.22	ANSSI-CARTO-SI, ISO27002-8.13, ISO27002-8.22	Élevé → Moy

ID	Actif et menace	Traitement	Contre-mesures	Sources	Risque rés estimé
M018	A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérieurs E7E5 (LINDDUN-Disclosure) Fuite des résultats médicaux via portail non durci : attaquants exploitent vulnérabilité d'authentification → exfiltration de données sensib niveau Élevé	Réduire	Chiffrement TLS 1.3 forcé, WAF XSS/ SQL injection sur extranet, PAM (Privilege Access Management) médical → ANSSI-CARTO-SI-5	ANSSI-CARTO-SI, ISO27002-8.14, EBIOS-RM-A3	Élevé → Moy
M019	A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérieurs E7E5 (STRIDE-I) Modification des données médicales : attaquants interceptent flux authentifiés vers portail webmodifié → exfiltration ou altération des prof niveau Élevé	Réduire	VPN site-to-site chiffré AES-256 pour flux authentifiés, Canal séparé sans partage firewall vers tiers → ANSSI-HYGIENE-7, ISO27002-8.16	ANSSI-HYGIENE, ISO27002-8.13, LINDDUN-Disclosure	Élevé → Faib
M020	A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérieurs E7E5 (STRIDE-T) Attaques de type defacement/ phishing : site compromis sert de plateforme d'hébergement pour malware redirigeant vers attaques contre SI inte niveau Faible	Accepter	Surveillance WAF pour détection défacement, Notification incident <5 minures, Plan continuité activité → ANSSI-RECYF, ISO27002-8.25	ANSSI-RECYF	Faible-Moye
M021	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond E7E5 (STRIDE-E) Accès aux données sensibles via exploitation vulnérabilités serveur web : attaquants accèdent au contenu médical stocké sur hébergement exte niveau Élevé	Éviter	Migration hébergement vers serveur HDS (hébergement de données santé certifié français), Audit vulnérabilités WordPress trimestriel → ANSSI-HOMOLOGATION, EBIOS-RM-A4	ANSSI-CARTO-SI, EBIOS-RM-A4, ISO27002-5.15	Élevé → Faib

ID	Actif et menace	Traitement	Contre-mesures	Sources	Risque rés estimé
M022	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond E7E5 (STRIDE-D) Défacement de contenu médical et profils patients : attaquants modifient pages web hébergées → altération des informations cliniques visible niveau Faible	Réduire	CMS hardened WordPress (plugins sécurisés, headers HTTPS HSTS), ModSecurity WAF anti-modification → ANSSI-HYGIENE-6, ISO27002-8.11	ANSSI-HYGIENE, ISO27002-8.11, ISO27002-8.29	Faible-Moye
M023	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond E7E5 (STRIDE-T) Attaques de type defacement/phishing : site compromis sert de plateforme d'hébergement pour malware redirigeant vers attaques contre SI inte niveau Élevé	Réduire	Blocage redirections phishing via WAF/IPS, Headers de contenu X-Frame-Options DENY, SPF/DKIM sur emails → ANSSI-HYGIENE-4, ISO27002-8.15	ANSSI-HYGIENE, ISO27002-8.26, LINDDUN-Unawareness	Moyen → Fa
M024	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond E7E5 (LINDDUN-Disclosure) Fuite des données sensibles via exploitation vulnérabilités CMS : attaquants accèdent aux contenus médicaux hébergés → exfiltration de flux niveau Faible	Accepter	Monitoring contenu web pour détection fuite, WAF rate limiting sur CMS tiers, Sauvegarde hebdomadaire → ANSSI-HYGIENE-5, ISO27002-8.13	ANSSI-HYGIENE, ISO27002-8.28, EBIOS-RM-A3	Faible-Moye Faible
M025	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond E7E5 (LINDDUN-Unawareness) Non-documentation des vulnérabilités du CMS : attaquants exploitent failles non patchées de plugins WordPress → exfiltration de dossiers pat niveau Élevé	Réduire	MFA FIDO2 pour le VPN (ANSSI-RECYF), durcissement WordPress (ISO27002-8.8)	[E195][E145]	Élevé
M026	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/ RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5 (STRIDE-S) Compromission d'identité centralisée : attaquants injectent objets utilisateurs malveillants dans forêt racine → accès non autorisé aux doss niveau Critique	Réduire	MFA systématique AD (ANSSI-HYGIENE), segmentation forestière (ISO27002-8.11)	[E24][E145]	Critique

ID	Actif et menace	Traitement	Contre-mesures	Sources	Risque rés estimé
M027	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/ RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5 (STRIDE-T) Attaques via usurpation d'identité : attaquants bypassent authentification sans MFA sur 60% des comptes → compromission de compte administra niveau Critique	Réduire	MFA obligatoire sur 100% des comptes (ISO27002-8.2)	[E186][E145]	Critique
M028	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/ RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5 (STRIDE-E) Interception d'authentification : attaquants captent flux réseau sans chiffrage SSL renforcé → rejeu d'identifiants depuis session compromis niveau Élevé	Réduire	Chiffrage SSL/TLS (ANSSI-HYGIENE), audit cryptographique (ISO27002-8.14)	[E197][E137]	Élevé
M029	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/ RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5 (LINDDUN-Disclosure) Fuite des identités : attaquants exploitent forêt non cloisonnée pour exfiltrer données sensibles → accès aux profils patients centralisés s niveau Élevé	Réduire	Cloisonnement AD (ISO27002-8.13), audit de vulnérabilités (ANSSI-IA-GEN)	[E103][E240]	Élevé
M030	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/ RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5 (LINDDUN-L) Modification des attributs utilisateurs : attaquants altèrent droits d'accès dans forêt racine → accès non documenté aux dossiers patients v niveau Faible	Réduire	Contrôle d'accès granulaire (ISO27002-8.26), audit attributs utilisateurs (ANSSI-HYGIENE)	[E2][E103]	Faible
M031	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/ RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5 (STRIDE-I) Altération des clés Kerberos : attaquants réplication compromise → exfiltration et altération du catalogue AD vers endpoints externes [E38][niveau Moyen	Réduire	Chiffrement des clés Kerberos (ISO27002-8.28), audit réplication AD (ANSSI-RECYF)	[E38][E145]	Moyen

ID	Actif et menace	Traitement	Contre-mesures	Sources	Risque rés estimé
M032	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5 (STRIDE-S) Compromission contrôleurs de domaine : attaquants exploitent faille matérielle ou corruption disque → perte d'authenticité des identités cli niveau Moyen	Réduire	Patching systématique (ISO27002-8.16), audit matériel (ANSSI-HYGIENE)	[E9][E176]	Moyen
M033	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5 (STRIDE-T) Défaillance des serveurs DC/ RODC : panne matérielle critique → perte d'authentification pour toute la clinique → déni de service système [A3 niveau Moyen	Réduire	Redondance DC locale (ISO27002-8.22), monitoring disponibilité (ANSSI-RECYF)	[E146]	Moyen
M034	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5 (LINDDUN-Unawareness) Non-patching hétérogène : attaquants exploitent faille de serveur non corrige → exfiltration depuis DC vieillissant sans agent EDR moderne [niveau Élevé	Réduire	Patching hétérogène (ISO27002-8.15), isolation VLAN/NAC (ANSSI-RECYF)	[E7][E98]	Élevé
M035	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5 (STRIDE-E) Accès aux données de l'AD : attaquants accèdent au système de réplication → lecture des catalogues utilisateurs depuis DC compromis [A17][E3 niveau Moyen	Réduire	Séparation réplication AD (ISO27002-8.24), audit lecture catalogue (ANSSI-HYGIENE)	[A17][E123]	Élevé

ID	Actif et menace	Traitement	Contre-mesures	Sources	Risque rés estimé
M036	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5 (STRIDE-I) Altération des données d'AD : attaquants modifient catalogue AD vers DC local → invalidation des tickets Kerberos pour tous les comptes clin niveau Moyen	Réduire	Contrôle d'accès DC local (ISO27002-8.25), invalidation tickets Kerberos (ANSSI-RECYF)	[E148]$_{[A17]}$	Moyen
M037	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11 (STRIDE-S) Compromission migration cloud : attaquants infiltrent flux de migration → altération des métadonnées patients dans cible hybride [A3][E203] niveau Critique	Réduire	Chiffrage TLS 1.3+ avec ECDHE (E9E5E11 [DREAD-D]); Authentification OAuth2/OIDC avec JWT short-living tokens (E9E5E11 [DREAD-D]); Segmentation VLAN IoT/ Biomédical (10.1.30.0/24) [E203]	ANSSI-HYGIENE-5.3, ISO27002-8.8, STRIDE-S	Élevé
M038	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11 (STRIDE-E) Exfiltration de flux API : attaquants accèdent aux endpoints cloud non authentifiés → lecture des dossiers patients dans infrastructure hybr niveau Critique	Réduire	Authentification OAuth2/OIDC avec JWT short-living tokens (E9E5E11 [DREAD-D]); WAF Next-Gen (OWASP Core Rule Set) [ISO27002-8.11]	ANSSI-HYGIENE-5.19, STRIDE-E	Élevé
M039	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11 (STRIDE-T) Attaques de type defacement/application : attaquants compromise flux télémédecine via API mal protégée → redirige communications vers servic niveau Critique	Réduire	Chiffrage E2E avec TLS 1.3 [ISO27002-8.14]; MFA FIDO2/CPS pour soignants (E9E5E11 [DREAD-D])	ANSSI-HYGIENE-5.4, ISO27002-8.8	Élevé

ID	Actif et menace	Traitement	Contre-mesures	Sources	Risque rés estimé
M040	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11 (LINDDUN-Disclosure) Fuite des données patients cloud : attaquants exploitent faille API Gateway → exfiltration continue des flux télémédicaux vers endpoints ext niveau Critique	Réduire + Transférer	Chiffrage E2E avec TLS 1.3 [ISO27002-8.14]; JWT signed RS256 + OAuth2 (E9E5E11 [DREAD-D])	ISO27002-8.8, ANSSI-RECYF-8.2	Élevé
M041	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11 (LINDDUN-Unawareness) Non-documentation des flux API : attaquants exploitent endpoints non inventorisés dans architecture cloud → exfiltration de données sensible niveau Critique	Éviter	Registre API centralisé (APIM Azure/ AWS) inventorier tous endpoints [E143]; Analyse de traçabilité flux API [E144]	ANSSI-RECYF-8.8, LINDDUN-Unawareness	Critique
M042	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11 (STRIDE-I) Altération des flux télémédicaux : attaquants interceptent messages cloud → modification des données médicales transmises entre cliniques [A niveau Critique	Réduire	Chiffrement TLS 1.3 avec certifiats HDS homologués [E203]; S/MIME pour messagerie [ISO27002-8.15]	ANSSI-HOMOLOGATION, ISO27002-8.13	Élevé
M043	A11 — Fournisseur Cloud HDS (STRIDE-S) [E140] Attaque de spoofing via certification HDS non conforme : un fournisseur malveillant pourrait falsifier l'identité d'un hôte Cloud HDS niveau Critique	Éviter	Impose certification HDS obligatoire fournisseur Cloud Act [E203]; Audit trimestriel de conformité HDS [E140]	ANSSI-RECYF-8.8, STRIDE-R	Critique
M044	A11 — Fournisseur Cloud HDS (LINDDUN-D) [E203] Fuite de données via exposition Cloud Act : le Cloud HDS sans analyse rigoureuse pourrait exposer les dossiers patients aux attaques niveau Critique	Réduire + Transférer	Addendum contractuel DSA-Cloud avec clauses RGPD [E203]; Clause de non-divulgation SSL [E140]	ANSSI-IA-GEN, ISO27002-8.2	Élevé
M045	A12 — Parc IoT Médical (STRIDE-T) [E205] Manipulation de dispositifs non-patchables : les moniteurs et scanners avec micro-noyaux temps réel non patchables (OS non patchables niveau Critique	Accepter	Segmentation micro-segmentation VLAN IoT isolé (10.1.30.0/24) [E203]; Interdiction accès Internet direct [E143]	ANSSI-HYGIENE-5.30, LINDDUN-Disclosure	Critique

ID	Actif et menace	Traitement	Contre-mesures	Sources	Risque rés estimé
M046	A12 — Parc IoT Médical (LINDDUN-I) [E140] Perturbation de l'intégrité des données : le VLAN IoT/Biomédical non cloisonné (10.1.30.0/24) permettrait à un attaquant de modifier niveau Critique	Réduire + Éviter	Cloisonnement VLAN IoT/Biomédical par firewall interne [E203]; ACL bloquant accès non autorisés [E140]	ISO27002-8.24, STRIDE-T	Élevé
M047	A13 — Segmentation Réseau VLAN/NAC (STRIDE-R) [E203] Négation de service via routage non cloisonné : le VLAN IoT/ Biomédical non cloisonné (10.1.30.0/24) permettrait à un attaquant de sat niveau Critique	Éviter	Routage firewall interne cloisonné VLANs (10.1.30.0/24) [E203]; Audit de segmentation [E140]	ANSSI-RECYF-8.8, STRIDE-R	Élevé
M048	A14 — Wi-Fi Invités/Patients (STRIDE-I) [E140] Divulgation d'informations via filtrage SSL manquant : le VLAN Wi-Fi Invités/ Patients (10.1.40.0/24) sans filtrage SSL permettrait à niveau Critique	Réduire	Filtrage SSL manquant corrigé (10.1.40.0/24) [E203]; Chiffrage TLS 1.3 avec certificats HDS [E140]	ISO27002-8.16, ANSSI-HYGIENE-5.3	Élevé
M049	A14 — Wi-Fi Invités/Patients (LINDDUN-D) [E203] Fuite de données via access point non sécurisé : le VLAN Wi-Fi Invités/ Patients (10.1.40.0/24) avec sortie Internet directe sans filt niveau Critique	Réduire	Micro-segmentation VLAN/NAC (ANSSI-HYGIENE) + filtrage SSL (ISO27002-8.8)	[E203]	Élevé
M050	A15 — API SaaS / APIs Télémedecine (STRIDE-E) [E146] Élévation de privilèges via API Gateway non sécurisée : l'exposition de l'API Gateway Cloud Hybride sans signature images Docker/SBOM niveau Critique	Réduire	Vérification signatures Docker/SBOM (ANSSI-RECYF) + cosign (ISO27002-8.16)	[E146]	Élevé
M051	A15 — API SaaS / APIs Télémedecine () [E146] Compromission de la confidentialité via API non durcie : l'API Gateway exposée sans vérification des signatures Docker/SBOM pourrait niveau Élevé	Réduire	Chiffrement TLS 1.3 OAuth2/OIDC (ISO27002-8.14) + ISO27002-8.8	[E146]	Élevé
M052	A16 — Domaine hospitalier — Site (STRIDE-D) Vol de données via vol d'identifiants administrateur (credential stuffing) sur postes non patchables et VPN FortiGate sans MFA [E163][A17] niveau Critique	Réduire	MFA FIDO2 (ANSSI-HYGIENE) + rotation cred (ISO27002-8.13)	[E163]	Élevé

ID	Actif et menace	Traitement	Contre-mesures	Sources	Risque rés estimé
M053	A16 — Domaine hospitalier — Site (LINDDUN-L) Dénonciation de données patients via exposition physique des locaux informatiques (contrôle d'accès défaillant en période posturée) [E142] niveau Moyen	Réduire	Biométrie/USB sécurisé (ANSSI-HYGIENE) + RFID G4 (ISO27002-8.11)	[E142]	Élevé
M054	A17 — Infrastructure réseau — Active Directory (STRIDE-T) Tampering des permissions AD via exploitation de compte service faible sur 60% des postes (pas de MFA sur VPN) enclinning aux attacks pass-t niveau Critique	Réduire	MFA FIDO2 (ISO27002-8.8) + rotation cred (ANSSI-HYGIENE)	[E140]	Élevé
M055	A17 — Infrastructure réseau — Active Directory (STRIDE-I) Denial of service du contrôleur de domaine unique par saturation DNS (DC/RODC sans replication) bloquant les authentifications à tous cliniq niveau Élevé	Réduire	Réplication DC/RODC (ISO27002-8.2) + DNSSEC/TLS (ANSSI-RECYF)	[E140]	Élevé
M056	A17 — Infrastructure réseau — Active Directory (LINDDUN-D) Disclosure personnelle des dossiers patients via forêt AD unique non cloisonnée avec partage SMB/CIFS sans filtrage SSL entre cliniques [E20 niveau Élevé	Réduire	Forêt AD multi-domaine (ANSSI-RECYF) + filtrage SMB (ISO27002-8.8)	[E145]	Élevé
M057	A18 — Application métier — DPI Progiciel Nexus (STRIDE-R) Irresponsabilité des accès via RDS mis en réseau direct MPLS sans micro-segmentation VLAN/NAC permettant aux cliniques non sécurisées d'accé niveau Critique	Réduire	Micro-segmentation VLAN/NAC (ANSSI-HYGIENE) + isolation Group (ISO27002-8.16)	[E38]	Élevé
M058	A18 — Application métier — DPI Progiciel Nexus (STRIDE-E) Élévation de privilèges via vulnérabilités Citrix XenApp/RDS (XenDesktop 7.15 CVE-2020-34692) permettant l'exécution code sur ferme RDS Sièg niveau Critique	Réduire	Patch immédiat CVE-2020-34692 (ANSSI-RECYF) + virtualisation (ISO27002-8.16)	[E146]	Élevé
M059	A18 — Application métier — DPI Progiciel Nexus (LINDDUN-L) Leakage des données patients via exploitation SMBv1 legacy actif sur PACS/RIS pour compatibilité scanners anciens [E131] niveau Critique	Réduire	Désactivation SMBv1 (ANSSI-RECYF) + GPO (ISO27002-8.8)	[E131]	Élevé

ID	Actif et menace	Traitement	Contre-mesures	Sources	Risque rés estimé
M060	A19 — Donnée/Structure — Données Patients (DPI) (STRIDE-I) Information leakage via exploitation ProxyShell sur Exchange 2016 non patché (DMZ vulnérable aux attacks Spraying) [E168] [A17] niveau Critique	Réduire	Patch Exchange 2016 (ANSSI-RECYF) + MFA (ISO27002-8.8)	[E168]	Élevé
M061	A19 — Donnée/Structure — Données Patients (DPI) (STRIDE-R) Repudiation des accès via logs citrix incomplets sur RDS legacy ne traçant pas les connexions aux dossiers patients [E208] niveau Élevé	Réduire	MFA FIDO2 (ISO27002-8.8), Cloisonnement VLAN IoT (ANSSI-HYGIENE-8.11), Journalisation complète Citrix (ANSSI-HYGIENE-8.8)	[E144], [E203]	Moyen
M062	A19 — Donnée/Structure — Données Patients (DPI) (LINDDUN-D) Disclosure de 150 000 dossiers via API Gateway non sécurisée pour télémédecine (no authz, no encryption in transit) [E231] [A11] niveau Critique	Réduire	Authentification à deux facteurs (ISO27002-8.8), Chiffrement transit (ANSSI-HYGIENE-8.14), Audit API Gateway (ANSSI-RECYF)	[E231], [E146], [CVE-2023-38448]	Critique
M063	A20 — Matériel IoT — Dispositifs Médicaux Connectés (STRIDE-S) Spoofing des commandes médicales via protocole Wi-Fi 6 non crypté (moniteurs, pompes perfusion) [E115][E204] niveau Critique	Réduire	Cryptage Wi-Fi 6 (ANSSI-HYGIENE-8.13), Mise à jour micrologiciels (ISO27002-8.24), Surveillance protocoles (STRIDE-S)	[E115], [E204], [CVE-2018-8962]	Élevé
M064	A20 — Matériel IoT — Dispositifs Médicaux Connectés (STRIDE-T) Tamper des paramètres d'automates via micro-noyaux temps réel non patchables permettant dosage erreur [E146] niveau Élevé	Réduire	Patch micro-noyaux (ISO27002-8.22), Isolation réseau (ANSSI-HYGIENE-8.14), Contrôle matériel (EBIOS-RM-A4)	[E146], [E209], [CVE-2017-5369]	Élevé
M065	A20 — Matériel IoT — Dispositifs Médicaux Connectés (STRIDE-D) Disclosure de logs médicaux via exploitation Bluetooth LE sur appareils non isolés réseau (pompes à perfusion) [E117] niveau Faible	Réduire	Séparation VLAN médical (ANSSI-HYGIENE-8.11), Filtrage Bluetooth (ISO27002-8.15), Audit sécurité IoT (STRIDE-D)	[E117], [E147], [E204]	Faible
M066	A20 — Matériel IoT — Dispositifs Médicaux Connectés (LINDDUN-L) Leakage de données patients via Wi-Fi 6 non patché sur scanners (exposés au réseau Wi-Fi Invités sans filtrage SSL) [E120] niveau Élevé	Réduire	Séparation VLAN Wi-Fi Invités (ANSSI-HYGIENE-8.11), Chiffrement SSL (ISO27002-8.8), Surveillance trafic (STR0DE-D)	[E120], [E205], [CVE-2023-32278]	Élevé

ID	Actif et menace	Traitement	Contre-mesures	Sources	Risque rés estimé
M067	A21 — Infrastructure Cloud — Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/ OVHcloud/Azure (pas d'imposition) [E142] (STRIDE-S) Attaquant tiers cloud : compromission de compte administrateur via phishing → élévation des privilèges sur infrastructure hybride (VM/K8s) ; niveau Moyen	Réduire	MFA renforcé (ISO27002-8.8), Audit comptes administrateurs (ANSSI-HYGIENE-8.8), Séparation cloud hybride (ANSSI-RECYF)	[E142], [E12], [E145]	Moyen
M068	A21 — Infrastructure Cloud — Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/ OVHcloud/Azure (pas d'imposition) [E142] (LINDDUN-Disclosure) Fuite de données patients via container compromis exposé sur métadonnées publics S3 → exfiltration de dossiers médicaux identifiables [E146, niveau Critique	Réduire	Chiffrement S3 (ISO27002-8.14), Séparation containers (ANSSI-HYGIENE-8.11), Audit métadonnées (STRIDE-D)	[E142], [E146], [E149]	Critique
M069	A21 — Infrastructure Cloud — Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/ OVHcloud/Azure (pas d'imposition) [E142] (STRIDE-E) Attaquant réseau : écoute man-in-the-middle sur API de gestion IAM cloud hybride → injection de tokens JWT falsifiés pour impersonner soigna niveau Moyen	Réduire	Authentification JWT (ISO27002-8.8), Audit API IAM (STRIDE-E), Séparation réseau (ANSSI-HYGIENE-8.11)	[E142], [E13], [E145]	Moyen
M070	A22 — Infrastructure sécurité — Micro-segmentation VLAN/NAC — Architecture cible pour isoler poste clinique compromis (VLAN IoT/Biomedical 10.1.30.0/24 non cloisonné actuellement) [E146,E150,FichedAuditTechnique-ÉtatdesLieuxSanteTechAs-Is.pdf.md,E205] (STRIDE-R) Attaquant interne : poste clinique compromis contourne NAC mal configuré → mouvement latéral via VLAN IoT non isolé (10.1.30.0/24) vers serv niveau Critique	Éviter	Cloisonnement VLAN 10.1.30.0/24 (ANSSI-HYGIENE-8.11), NAC étendu (ISO27002-8.2), Suppression routage direct (STRIDE-R)	[E146], [E150], [E203]	Critique

ID	Actif et menace	Traitement	Contre-mesures	Sources	Risque rés estimé
M071	A22 — Infrastructure sécurité — Micro-segmentation VLAN/NAC — Architecture cible pour isoler poste clinique compromis (VLAN IoT/Biomedical 10.1.30.0/24 non cloisonné actuellement) [E146,E150,FichedAuditTechnique-ÉtatdesLieuxSanteTechAs-Is.pdf.md,E205] (STRIDE-I) Attaquant externe : injection de paquets falsifiés entre VLAN Wi-Fi Invités (10.1.40.0/24) et VLAN Biomed → interception de flux IoT non chi niveau Faible	Transférer	Cyber-assurance (ANSSI-RECYF), Audit IPv4/IPv6 (STRIDE-T), Segmentation VLAN (ISO27002-8.11)	[E146], [E150], [E140]	Faible
M072	A22 — Infrastructure sécurité — Micro-segmentation VLAN/NAC — Architecture cible pour isoler poste clinique compromis (VLAN IoT/Biomedical 10.1.30.0/24 non cloisonné actuellement) [E146,E150,FichedAuditTechnique-ÉtatdesLieuxSanteTechAs-Is.pdf.md,E205] (LINDDUN-Unawareness) Utilisateur soignant : clic sur lien de phishing redirigeant vers intranet compromis via VLAN invité → exécution malware sans MFA requis [E1 niveau Critique	Réduire	Séparation VLAN invités (ANSSI-HYGIENE-8.11), Éducation phishing (ISO27002-8.8), MFA pour intranet (STRIDE-I)	[E146], [E150], [E113]	Critique
M073	A23 — Application/Rôle — IdP Gestion Identités (TO-BE) — Déploiement cible IdP centralisé (Entra ID/Keycloak) avec MFA FIDO2/Carte CPS [E146] (STRIDE-E) Attaquant : contournement processus de MFA sur application mobile compromise → injection de session utilisateur validée via exploit framewor niveau Critique	Réduire	MFA FIDO2 (ANSSI-HYGIENE-5.3), segmentation VLAN (ISO27002-8.14)	E146, ANSSI-HYGIENE	Risque moy
M074	A23 — Application/Rôle — IdP Gestion Identités (TO-BE) — Déploiement cible IdP centralisé (Entra ID/Keycloak) avec MFA FIDO2/Carte CPS [E146] () Attaquant : lecture de logs d'authentification exposés via interface d'administration Keycloak → inférence données sensibles de patients sur niveau Élevé	Réduire	Cryptage des logs d'authentification (ISO27002-8.11), pare-feu applicatif	E146, ANSSI-HYGIENE	Risque élev

ID	Actif et menace	Traitement	Contre-mesures	Sources	Risque rés estimé
M075	A23 — Application/Rôle — IdP Gestion Identités (TO-BE) — Déploiement cible IdP centralisé (Entra ID/Keycloak) avec MFA FIDO2/Carte CPS [E146] (LINDDUN-L) Attaquant : accès non autorisé aux rapports d'audit d'authentification → profilage des habitudes médicales des soignants via historiques de niveau Élevé	Réduire	Contrôle d'accès RBAC (ISO27002-8.13), audit régulier (ANSSI-RECYF)	E146, ANSSI-HYGIENE	Risque moy
M076	A23 — Application/Rôle — IdP Gestion Identités (TO-BE) — Déploiement cible IdP centralisé (Entra ID/Keycloak) avec MFA FIDO2/Carte CPS [E146] (LINDDUN-Disclosure) Atteignant à travers le flux API admin : récupération de tokens refresh compromis → accès indirect aux données personnelles des patients (no niveau Critique	Réduire	API Gateway rate-limited (ISO27002-8.8), certificats TLS renouvelés (ANSSI-IA-GEN)	E146, ANSSI-HYGIENE	Risque critic
M077	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146] (STRIDE-T) Attaquant web : exploitation d'endpoint API non rate-limited → déni de service massif par requêtes inondées bloquant consultations télé-médi niveau Critique	Réduire	Authentification multifacteur (ISO27002-8.2), chiffrement des payloads (ANSSI-PSSI)	E146, ANSSI-HYGIENE	Risque critic
M078	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146] (STRIDE-I) Attaquant réseau : injection payload sur endpoint de télétransmission → interception flux DICOM/HEM (données patients en transit via HTTPS m niveau Critique	Réduire	Validation des certificats mutualisés (ISO27002-8.22), inspection des paquets (ANSSI-RECYF)	E146, ANSSI-HYGIENE	Risque critic
M079	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146] (STRIDE-E) Attaquant : falsification d'en-têtes Authorization sur API Gateway → élévation privilèges pour accéder dossiers patients hors périmètre de r niveau Critique	Réduire	Équilibrage de charge sécurisé (ISO27002-8.24), suppression des headers non vérifiés (ANSSI-HYGIENE)	E146, ANSSI-HYGIENE	Risque critic

ID	Actif et menace	Traitement	Contre-mesures	Sources	Risque rés estimé
M080	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146] (LINDDUN-Disclosure) Exfiltration de données sensibles : accès indirect via endpoint /public-health-exports → lecture des historiques médicaux anonymisés identif niveau Critique	Réduire	Cryptage des exports (ISO27002-8.25), journalisation des accès (ANSSI-HYGIENE)	E146, ANSSI-HYGIENE	Risque critiq
M081	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146] (STRIDE-S) Compromission d'accès admin à l'API Gateway cloud → substitution des certificates TLS au routage (SSL/TLS stripping) interceptant consultati niveau Critique	Réduire	Système de détection d'intrusion (ISO27002-8.26), validation des certificats TLS (ANSSI-IA-GEN)	E146, ANSSI-HYGIENE	Risque critiq
M082	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146] (LINDDUN-Unawareness) Patient connecté : clic sur lien de vérification SMS compromis par attaquants → validation de session sans connaissance du contexte médical niveau Critique	Réduire	Éducation des utilisateurs (ISO27002-8.28), validation des liens (ANSSI-HYGIENE)	E146, ANSSI-HYGIENE	Risque critiq
M083	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139] (STRIDE-R) Attaquant interne : exploit Citrix RDS (CVE-2021-37119) → élévation privilèges globale sur serveur de dossier patients puis accès aux archiv niveau Critique	Réduire	Patching systématique (ISO27002-8.16), segmentation réseau (ANSSI-HYGIENE)	E139, ANSSI-HYGIENE	Risque critiq
M084	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139] (STRIDE-I) Attaquant réseau : redirection DNS vers serveur compromis → interception des échanges RDP/ICM entre médecins et postes navigateurs patients niveau Critique	Réduire	Filtrage DNS (ISO27002-8.15), chiffrement des échanges (ANSSI-PSSI)	E139, ANSSI-HYGIENE	Risque critiq

ID	Actif et menace	Traitement	Contre-mesures	Sources	Risque rés estimé
M085	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139] (LINDDUN-Disclosure) Attaquant : lecture de logs serveur d'application expose en clair les infos patients en erreur → extraction noms, diagnostics via page 404 m niveau Critique	Réduire	Journalisation des logs serveur chiffrée + correction page 404 (renvoyant login admin avec MFA) + filtrage X-WAF sur endpoints log [ANSSI-CARTO-SI,ANSSI-HYGIENE-7,ISO27002-8.15]	ANSSI-CARTO-SI,ANSSI-HYGIENE-7,ISO27002-8.15,E139	Faible : logs corrigés via journalisatio + page 404
M086	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139] (STRIDE-E) Attaquant : injection de script XSS en-page administration → exécution non autorisée permettant d'accéder aux dossiers patients sans authent niveau Élevé	Réduire	Protection CSP strict sur application admin + Sanitization des données d'entrée + WAF XSS RASP + authentification obligatoire MFA FIDO2 [ANSSI-CARTO-SI,ISO27002-8.15,STRIDE-E]	ANSSI-CARTO-SI,ISO27002-8.15,STRIDE-E,CVE-2023-50387	Faible : inte admin durci authentifica MFA + CSP [E146]
M087	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139] (LINDDUN-L) Attaquant : accès non autorisé à API d'export de rapports → profilage des habitudes de soins des patients via agrégation des résultats anony niveau Moyen	Réduire	Limitation des quotas d'appels API + chiffrement TLS 1.3 obligatoire + anonymisation renforcée (k-anonymité k≥50) + accès IP restreint [ANSSI-CARTO-SI,ISO27002-6.3,LINDDUN-L]	ANSSI-CARTO-SI,ISO27002-6.3,LINDDUN-L,EBIOS-RM-A4	Très Faible : protégée av restrictions chiffrement [E145]
M088	A26 — Parc IoT Médical (STRIDE-D) Attaque par exploitation de vulnérabilités non-patchées sur les dispositifs IoT, exposés via le VLAN non cloisonné [E205] niveau Critique	Réduire	Segmentation VLAN IoT médicale isolée (VLAN 10.1.30.0/24 cloisonné) + NAT strict sans accès Internet direct + patch management plan pour dispositifs EOL [ANSSI-HYGIENE-9,ISO27002-8.8,STRIDE-D]	ANSSI-HYGIENE-9,ISO27002-8.8,STRIDE-D,E203,E205	Moyen : VLA médical isol production restreint ve automates [
M089	A26 — Parc IoT Médical (LINDDUN-D) Fuite de données sensibles via les dispositifs IoT non isolés, exploitant le routage direct vers les automates [E203] niveau Critique	Réduire	Isolation réseau physique (pas logique seulement) pour dispositifs biomédicaux critiques + chiffrement de bout en bout des flux capteurs [ANSSI-PSSI,ISO27002-8.5,LINDDUN-D]	ANSSI-PSSI,ISO27002-8.5,LINDDUN-D,EBIOS-RM-A4	Faible : IoT isolé physiq flux capteur en transit [E
M090	A26 — Parc IoT Médical (STRIDE-S) Attaque de spoofing via les micro-noyaux temps réel non patchables, exposés sans segmentation [E205] niveau Moyen	Réduire	Isolation par VLAN dédié micro-noyaux temps réel + surveillance intrusion IDS/IPS pour spoofing détectation précoce + authentification network NAC obligatoire [EBIOS-RM-A3,ISO27002-8.11,STRIDE-S]	EBIOS-RM-A3,ISO27002-8.11,STRIDE-S,E205	Très Faible : noyaux IoT par VLAN + actif pour d spoofing [E
M091	A27 — Ferme Citrix/RDS (STRIDE-S) Spoofing via le réseau MPLS non segmenté, permettant l'accès à tous les serveurs physiques [E139] niveau Critique	Réduire	Segment MPLS avec micro-segmentation (VLAN par service) + accès direct limité uniquement par IP + authentification réseau 802.1X obligatoire [ANSSI-CARTO-SI,ISO27002-5.4,STRIDE-S]	ANSSI-CARTO-SI,ISO27002-5.4,STRIDE-S,E139	Faible : ferm RDS isolée s segmenté + direct restre serveurs ce [E139]

ID	Actif et menace	Traitement	Contre-mesures	Sources	Risque rés estimé
M092	A27 — Ferme Citrix/RDS (STRIDE-R) Reproduction de trafic via la micro-segmentation absente, facilitant la lateralité [E139] niveau Élevé	Réduire	Déploiement micro-segmentation (NSX/Tanzu/VMware) sur domaine Citrix + politiques ZTNA par travailleur + journalisation trafic inter-serveurs [ISO27002-8.2,ISO27002-5.30,EBIOS-RM-A4]	ISO27002-8.2,ISO27002-5.30,EBIOS-RM-A4,E139	Faible : micr segmentatio déployée su Citrix/RDS + bloquée [E1
M093	A28 — Postes legacy (LINDDUN-D) Fuite de données patients via les postes Windows 7/XP, non durcis contre les attaques par usurpation [E150] niveau Critique	Éviter	Migration progressive vers Windows 10/11 LTSC ou Linux avec agents HDS [ANSSI-HYGIENE-5,EBIOS-RM-A4,LINDDUN-D]	ANSSI-HYGIENE-5,EBIOS-RM-A4,LINDDUN-D,E150	Négligeable Windows 7/ service de s uniquement critiques) + planifiée [E
M094	A28 — Postes legacy (STRIDE-E) Élévation de privilèges via les postes Windows 7/XP, vulnérables aux exploits SMBv1 [E203] niveau Critique	Réduire	Bloquer SMBv1 firewall par défaut + déploiement patches EternalBlue via GPO obligatoire + dégradation poste à terminal KVM sécurisé [ISO27002-8.8,STRIDE-E]	ISO27002-8.8,STRIDE-E,EBIOS-RM-A4,E203	Faible : SMB réseau local XP en mode avec isolatio
M095	A29 — MPLS Hub & Spoke (STRIDE-S) Spoofing via le réseau centralisé sans isolation, permis par la micro-segmentation absente [E139] niveau Critique	Réduire	Intersegment MPLS avec ACL strictes (IPsec VPN entre hubs) + chiffrement TLS obligatoire sur toutes routes transversales + IDS L7 inspection trafic [ANSSI-CARTO-SI,ISO27002-6.3,STRIDE-S]	ANSSI-CARTO-SI,ISO27002-6.3,STRIDE-S,E139	Très Faible : interconnex via IPsec ch ACL routage segmenté [
M096	A29 — MPLS Hub & Spoke (STRIDE-R) Reproduction de trafic entre cliniques via l'IP directe, sans filtre SSL [E203] niveau Élevé	Réduire	SSL/TLS inspection inter-clinique obligatoire + déploiement WAF Gateway inter-VSite + chiffrement TLS 1.3 avec ECDHE obligatoire [ANSSI-PSSI,ISO27002-8.14,LINDDUN-N]	ANSSI-PSSI,ISO27002-8.14,LINDDUN-N,E203	Très Faible : inter-cliniqu TLS 1.3 + g WAF inspect réplication [
M097	A30 — Active Directory (STRIDE-S) Spoofing via le domaine AD sans MFA, permettant la DCSync [E150] niveau Critique	Réduire	MFA FIDO2 pour 100% des comptes AD + Upgrade forêt DC Windows Server 2016 minimum (ISO27002-8.2) [E139][E149] [E201]	ANSSI-HYGIENE[2]-MFA, ISO27002-8.2	Élevée·Criti
M098	A30 — Active Directory (STRIDE-E) Élévation de privilèges via les contrôleurs de domaine non durcis, vulnérables à Kerberoasting [E203] niveau Critique	Réduire	Micro-segmentation VLAN par DC + Renversement RODC (hachages unidiirectionnels) [E140][E203]	ANSSI-HYGIENE[3]-Cloisonnement, ISO27002-5.4	Élevée·Criti
M099	A31 — Base de Données PACS/RIS Imagerie (STRIDE-S) Stockage images radiologiques non chiffrées sur disque local en cliniques, exposé aux fuites lors de la copie vers USB ou cloud privé [E140] niveau Critique	Réduire	Chiffrement AES-256 DICOM au repos + Désactivation SMBv1 + Isolation baies SAN VLAN (ANSSI-HOMOLOGATION) [E140][E205]	ANSSI-HYGIENE[6]-Chiffrement, ISO27002-8.13	Élevée·Criti
M100	A31 — Base de Données PACS/RIS Imagerie (STRIDE-I) Injection via DICOM gateway non filtrée sur 10.1.10.0/24, permettant l'écriture malveillante dans les études cliniques [E140] [E205] niveau Élevé	Réduire	Filtre DPI DICOM gateway 10.1.10.0/24 + Cloisonnement VLAN biomédical IoT [E140][E205] [E203]	ANSSI-RECYF[8]-Contrôle accès, ISO27002-8.16	Élevée·Élev

ID	Actif et menace	Traitement	Contre-mesures	Sources	Risque rés estimé
M101	A31 — Base de Données PACS/RIS Imagerie (STRIDE-R) Altération des métadonnées DICOM par un attaquant ayant accès au VLAN Serveurs Locaux compromis via lateral movement [E205][EBIOS-RM-A3] niveau Moyen	Réduire	Segment réseau VLAN Serveurs + Isolation logique PACS (VLAN biomédical séparé) [EBIOS-RM-A3]	ANSSI-HYGIENE[14]-Segmentation, EBIOS-RM-A3	Moyenne·M
M102	A32 — Messagerie Exchange 2016 OWA Webmail (STRIDE-T) Modification d'emails (email spoofing) depuis webmail exposé en DMZ sur webmail.santetech-sante.fr, campagne de phishing ciblant soignants [niveau Critique	Réduire	Patching Exchange 2016 (CVE-2022-41040 corrigé) + WAF Reverse Proxy OWA DMZ [E152] [E205]	ANSSI-HYGIENE[9]-Correctifs, ISO27002-8.13	Élevée·Criti
M103	A32 — Messagerie Exchange 2016 OWA Webmail (LINDDUN-L) Leakage des dossiers patients via OWA non durci, accès distant par certificats faibles permet lecture mails contenant données sensibles [E15 niveau Critique	Réduire	Certificats TLS ECDHE 4096bits + HSTS OWA DMZ + Double filtrage SMTP [E152]	ANSSI-HYGIENE[7]-Chiffrement SSL, ISO27002-8.8	Élevée·Élev
M104	A32 — Messagerie Exchange 2016 OWA Webmail (STRIDE-E) Exploitation ProxyShell/Spraying non corrigé par patching Exchange 2016 legacy, permettant exécution RCE sur serveur messagerie [E152] [CVE-2 niveau Critique	Réduire	Correction CVE-2022-41040 + Isolation OWA DMZ sous VLAN propre (micro-segmentation) [E205]	ANSSI-HYGIENE[9]-Correctifs, ISO27002-8.13	Élevée·Criti
M105	A33 — Portail VPN FortiGate (STRIDE-T) Compromission de session via authentification simple login/mot de passe sans MFA, injection de tokens dans les flux d'authentification [E149 niveau Moyen	Réduire	Déploiement MFA FIDO2 FortiGate (60% comptes manquants) + SAML/ SSO IDP [E149][E139]	ANSSI-HYGIENE[8]-Double facteur, ISO27002-8.2	Moyenne·M
M106	A33 — Portail VPN FortiGate (LINDDUN-Disclosure) Fuite d'identifiants VPN 60% des comptes sans MFA, accès privilégié aux ressources internes après compromission de credentia [E140][E149] niveau Critique	Réduire	MFA FIDO2/MAPF (carte CPS) VPN FortiGate + Journalisation accès [E149][E203]	ANSSI-HYGIENE[8]-Double facteur, ISO27002-8.28	Élevée·Criti
M107	A33 — Portail VPN FortiGate (STRIDE-I) Attaques d'injection dans les logs FortiGate pour corrompre l'historique des accès, masquer les tentatives de bypass [E150] niveau Faible	Réduire	Logs FortiGate chiffrés TLS 1.3 + Normalisation format JSON (non affecte l'attaque) [E231]	ANSSI-HYGIENE[9]-Journalisation, ISO27002-8.26	Faible·Moye

ID	Actif et menace	Traitement	Contre-mesures	Sources	Risque rés estimé
M108	A34 — Contrôleur de Domaine RODC par Clinique (STRIDE-S) Dumping de hachages d'identifiants via LSASS compromise sur 12 RODC, exfiltration vers cloud externe [E202][E140] niveau Critique	Réduire	Désactivation LSASS RODC + Renversement AD (hachages salés unidirectionnels) [E202][E140]	ANSSI-HYGIENE[5]-Contrôle accès, ISO27002-5.3	Élevée·Criti
M109	A34 — Contrôleur de Domaine RODC par Clinique (STRIDE-T) Création d'objets Kerberos faux sur réseau 10.1.0.0/16, permettant délégué d'accès à tous les DC du périmètre [E202] [E138][MITRE-T1558] niveau Critique	Réduire	Micro-segmentation réseau VLAN/ NAC, isolation RODC par firewall ACL strict (ISO27002-8.15), déploiement SOC centralisé avec EDR (EBIOS-RM-A3), MFA sur accès DCs critiques (ANSSI-HYGIENE 6)	ISO27002-8.15, ANSSI-HYGIENE, EBIOS-RM-A3	Moyenne — Moyen
M110	A34 — Contrôleur de Domaine RODC par Clinique (STRIDE-E) Poisoning LDAP via écriture sur RODC (mode read-only théoriquement mais pas en pratique), injection d'objets malveillants [E202] niveau Élevé	Réduire	Validation schema LDAP strict avec ACL écriture limitée, monitoring injection objets via journalisation SIEM centralisé (ISO27002-8.8), alertes anomalies RODC écr (EBIOS-RM-A3)	ISO27002-8.8, ISO27002-5.3, ANSSI-HYGIENE 12	Faible — Mo Faible
M111	A35 — Sécurité IT (SOC/EDR/ SIEM) (STRIDE-T) Détection inexistante d'attaques Ransomware en temps réel, propagation latérale non surveillée via réseau MPLS [E140][E40] niveau Critique	Réduire	Déploiement EDR/SIEM centralisé sur tous serveurs (EBIOS-RM-A3), segmentation MPLS en zones DMZ critiques (ISO27002-8.15), déploiement SOC 24/7 (ANSSI-HYGIENE)	ISO27002-8.15, ANSSI-HYGIENE, EBIOS-RM-A3	Élevée — Cr Faible
M112	A35 — Sécurité IT (SOC/EDR/ SIEM) (STRIDE-I) Ingestion d'alertes de sécurité nulle, absence d'intégrité sur les logs SIEM ne permet pas la chasse aux intrus [E9][E139] niveau Élevé	Réduire	Journalisation sécurisée tamponnement logs (ISO27002-8.28), vérification intégrité hash SHA-256 logs SIEM, ingestion alertes via pipeline EDR/ EDR-SIEM centralisé (EBIOS-RM-A4), audit logs mensuel (ANSSI-HYGIENE 13)	ISO27002-8.28, ISO27002-8.29, ANSSI-HYGIENE 13, EBIOS-RM-A4	Moyenne — Faible
M113	A35 — Sécurité IT (SOC/EDR/ SIEM) (LINDDUN-L) Non-détection des exfiltrations de données patients vers cloud tiers, absence de comportement Anomaly sur les flux EDR [E40][EBIOS-RM-A3] niveau Critique	Réduire	DLP Cloud tiers avec classification données sensibles patients (LINDDUN-L), EDR comportemental monitoring anomalies transferts outbound (EBIOS-RM-A3), chiffrement egress + logging connexion cloud (ISO27001-8.26)	ISO27001-8.26, ANSSI-PSSI-134, LINDDUN-L, ANSSI-HYGIENE 14	Élevée — Cr Faible
M114	A36 — Attestation de relecture croisée (STRIDE-S) Attaque par phishing via le portail VPN (E140) niveau Critique	Réduire	Implémentation MFA FIDO2 sur 100% comptes VPN (STRIDE-S), patching CVE-2023-23977 FortiGate via vuln feed (ISO27002-8.5), sensibilisation phishing obligatoire CISO/Lead GRC (EBIOS-RM-A3)	ISO27001-8.5, ANSSI-HYGIENE 6, STRIDE-S, EBIOS-RM-A3	Moyenne — — Faible

ID	Actif et menace	Traitement	Contre-mesures	Sources	Risque rés estimé
M115	A36 — Attestation de relecture croisée (LINDDUN-Disclosure) Fuite de données via le Webmail OWA non patché (E201) niveau Critique	Réduire	Patch rapide Exchange 2016 DMZ (ISO27002-8.5), segment VLAN DMZ pour Webmail avec WAF (ISO27002-8.34), règles iptables blocage campagnes ProxyShell/ Spraying, monitoring inbound port 443/80 anomalies (ANSSI-HYGIENE)	ISO27001-8.5, ISO27002-8.34, ANSSI-HYGIENE 6, EBIOS-RM-A3	Faible — Cri Faible
M116	A37 — CISO / Lead GRC (STRIDE-T) Élevaison de privilèges via accès non surveillé aux serveurs legacy (E203) niveau Élevé	Réduire	Gestion privilégiée MoP (principle least privilege) + MFA accès serveurs legacy (ANSII-HYGIENE 37), déploiement EDR sur 185 serveurs avec blocage élévation privilèges signatures (ISO27002-8.16)	ISO27002-8.2, ISO27002-8.15, ISO27002-8.16, ANSSI-HYGIENE 37, EBIOS-RM-A3	Faible — Mo Faible
M117	A37 — CISO / Lead GRC (LINDDUN-Unawareness) Ignorance des protocoles RGPD par le Chef de projet sécurité (E149) niveau Faible	Réduire + Accepter	Programme formation RGPD obligatoire CISO/Lead GRC avec attestation compétence (LINDDUN-Unawareness), audit conformité annuel documenté (ISO27001-8.5, ANSSI-RECYF 1.3.1) — risque résiduel accepté sur non-conformité mineure	ISO27001-8.5, LINDDUN-Unawareness, EBIOS-RM-A4, ANSSI-HYGIENE 22	Non docume Non docume Faible
M118	A38 — Blue Team & SOC (STRIDE-D) Déni de service via surcharge des serveurs de secours locaux (E201) niveau Moyen	Réduire + Accepter	CDN Cloudflare DDoS mitigation Rate Limiting (ISO27001-8.11), réplication backup cloud offsite multi-régions AWS/Azure (ISO27002-5.19), acceptabilité business impact limité données non critiques	ISO27002-5.19, ISO27001-8.11, ANSSI-HYGIENE 24, EBIOS-RM-A3	Faible — Cri Faible
M119	A38 — Blue Team & SOC (LINDDUN-NC) Non-conformité aux standards ISO 27001 pour les analyses de menace (E223) niveau Faible	Réduire + Accepter	Implémentation processus EBIOS RM 2018 pour analyses menace (EBIOS-RM-2018), certification ISO 27001 audit externe (ISO27002-8.22), mise à jour Plan de Management Sécurité annuel — impact limité certification uniquement	EBIOS-RM-2018, ISO27001-8.5, ISO27002-8.22 4.3.2	Faible — Mo Faible
M120	A39 — CTI & OSINT (STRIDE-I) Interceptation des flux API Gateway via le VLAN IoT non cloisonné (E205) niveau Critique	Réduire	Micro-segmentation VLAN IoT biomédical routage ACL restreint automate (ISO27001-8.13), isolation API Gateway DMZ réseau segmenté VLAN, chiffrement TLS 1.3 flux API + DDoS protection WAF (ISO27002-5.19)	ISO27001-8.13, ISO27002-5.19, ANSSI-HYGIENE 6, EBIOS-RM-A3	Faible — Cri Moyenne
M121	A39 — CTI & OSINT (LINDDUN-Disclosure) Fuite d'OSINT via les sites web des cliniques hébergés par des prestataires tiers (E201) niveau Faible	Accepter	[ANSSI-HYGIENE-4] Documentation contacts publique sans données sensibles	[ANSSI-HYGIENE-4]	Faible - Faib
M122	Frontière Internet ↔ VPN_Gateway (FortiGate) (STRIDE-S) Portail vpn.santetech-sante.fr expose avec login/mot de passe simple sans MFA sur 60% des comptes [E7][E38][E203] → attaquant réalise brute- niveau Élevé	Réduire	[ISO27002-5.15], [ANSSI-HYGIENE-3] MFA FIDO2 sur 60% comptes VPN + PAM	[ISO27002-5.15, ANSSI-HYGIENE-3]	Faible - Faib

ID	Actif et menace	Traitement	Contre-mesures	Sources	Risque rés estimé
M123	Frontière Internet ↔ VPN_Gateway (FortiGate) (STRIDE-I) Extranet médecins (extranet.santetech-sante.fr) [E32][A7] : authentification faible permet usurpation d'identité soignant pour modifier/fals niveau Critique	Réduire	[ISO27002-5.15], [EBIOS-RM-A3] IdP Centralisé + MFA PAM extranet médecins	[ISO27002-5.15, ANSSI-HYGIENE-4]	Faible - Moy
M124	Frontière Internet ↔ Portail OWA (Exchange 2016 DMZ) (STRIDE-I) Webmail OWA public (webmail.santetech-sante.fr) [E3] [E57] : vulnérabilités ProxyShell/ CVE-2024 potentielles exposent dossiers patients aux f niveau Élevé	Réduire	[ISO27002-6.3], [ANSSI-HYGIENE-2] Patch CVE-2024-26099 + WAF OWASP SSL filter	[ISO27002-5.19, ISO27002-5.3]	Moyen - Mo
M125	Frontière DMZ ↔ WAF optionnel (non déployé As-Is) (STRIDE-R) WAF/SIEM absent [E36][E271] → attaque DoS direct contre API Gateway/Cloud_HDS possible sans atténuation, paralysant services télémédecine. niveau Élevé	Réduire	[ISO27002-8.14], [EBIOS-RM-A3] WAF FortiWeb + SIEM centralisé	[ISO27002-8.14, ANSSI-HYGIENE-7]	Faible - Faib
M126	Frontière DMZ ↔ WAF optionnel (non déployé As-Is) (STRIDE-T) Site WordPress vitrine [E274] [E9] : injection SQL/XSS possible via absence de couche WAF pour compromettre réputation clinique et filer donn niveau Faible	Réduire	[ISO27002-5.4], [ANSSI-CARTO-SI] WAF + hardening WordPress + honeypot	[ISO27002-8.8, ISO27002-5.3]	Faible - Faib
M127	Frontière Réseau Interne ↔ Backbone MPLS (sans micro-segmentation) (STRIDE-T) Backbone MPLS centralisé sans isolation logique [E36][E203] [E277] → un poste compromis clinique peut communiquer IP directe avec tout réseau niveau Élevé	Réduire	[ISO27002-8.11], [EBIOS-RM-A3] Micro-segmentation VLAN/NAC backbone MPLS	[ISO27002-8.2, ANSSI-HYGIENE-6]	Faible - Faib
M128	Frontière Réseau Interne ↔ Backbones AD (Forêt unique) (STRIDE-S) Forêt Active Directory corp.santetech.local 16 DC/RODC [E2][A7][E277] : absence micro-segmentation permet propagation latérale compromise RO niveau Élevé	Réduire	[ISO27002-5.15], [ANSSI-HYGIENE-4] PASEO AD isolé + RODC séparés	[ISO27002-8.13, EBIOS-RM-A3]	Faible - Moy
M129	Frontière Réseau Interne ↔ Citrix Farm (DPI Nexus) (STRIDE-S) Ferme Citrix/RDS Rennes héberge DPI Nexus [E25][E148][A7] : accès RDP interne non contrôlé expose données patients 150k dossiers à extractio niveau Élevé	Réduire	[ISO27002-8.2], [EBIOS-RM-A4] NAC TACACS+ + MFA RDP Gateway Citrix ADC	[ISO27002-5.19, ISO27002-6.3]	Faible - Moy

ID	Actif et menace	Traitement	Contre-mesures	Sources	Risque rés estimé
M130	Frontière VLAN IoT ↔ Core_Net (routage direct) (STRIDE-R) VLAN IoT/Biomédical 10.1.30.0/24 routé directement vers automates [E9] [A17] : botnets Mirai infecte pompes perfusion/moniteurs non patchable niveau Critique	Éviter	[ANSSI-HYGIENE-6], [ANSSI-RECYF] VLAN biomédical isolé + blocage Internet direct	[ANSSI-HYGIENE-6, ANSSI-RECYF]	Faible - Faib
M131	Frontière VLAN IoT ↔ Core_Net (routage direct) (STRIDE-T) VLAN IoT non cloisonné [E9][E277] : compromis device biomédical permet exécution commandes malveillantes sur automates sensibles et fuite lo niveau Faible	Réduire	[ISO27002-8.24], [LINDDUN-D] Isolation VLAN IoT + EDR légers détection	[ISO27002-5.3, EBIOS-RM-A3]	Faible - Faib
M132	Frontière Wi-Fi Invités ↔ Internet (sans SSL filtering) (LINDDUN-Disclosure) Wi-Fi patients 10.1.40.0/24 sortant internet sans filtrage SSL [E18][A7] : malware contourne firewall via trafic HTTP non inspecté, vol donn niveau Élevé	Réduire	[ANSSI-HYGIENE-9], [ANSSI-RECYF] SSL filtering proxy + DNS firewalling Wi-Fi patients	[ANSSI-HYGIENE-9, ISO27002-8.5]	Moyen - Fail
M133	Frontière Wi-Fi Invités ↔ Internet (sans SSL filtering) (STRIDE-E) Accès libre sans authentification Wi-Fi patients mobiles [E9] : attaquant établit position de listening sur réseau de confiance pour interce niveau Élevé	Réduire	Segmentation réseau par VLAN Wi-Fi Invités/Sortie séparé avec règles firewall restrictives [ISO27002-8.11], Authentification Wi-Fi obligatoire pour accès Internet [ANSSI-HYGIENE-4], Chiffrement SSL/TLS obligatoire sur toutes les sessions accessibles aux patients mobiles [ISO27002-5.19]	ANSSI-HYGIENE-4; ISO27002-5.19; ISO27002-8.11	Moyen (risq d'intercepti réduit mais pour connex HTTPS résid
M134	Frontière Cloud_HDS ↔ API Gateway (hybride To-Be) (STRIDE-S) Migration DPI Nexus vers Cloud HDS [E9][A7] : absence contrôle d'accès API Gateway initial permet intrusions dans infra hébergement hybride niveau Critique	Réduire	Implémentation authentification OAuth2/OIDC obligatoire [ISO27002-5.15], Rate Limiting et WAF en place sur API Gateway hybride CloudHDS [ANSSI-HYGIENE-8], Journalisation centralisée des logs d'authentification API [ISO27002-8.24]	ANSSI-HYGIENE-8; ISO27002-5.15; ISO27002-8.24	Élevé (mena persistante migration c l'API Gatewa sécurisée d HDS)
M135	Frontière Cloud_HDS ↔ API Gateway (hybride To-Be) (LINDDUN-L) Exposition contrôlée mais signature SBOM/Docker absente [E16] → fuite données santé via endpoints API non signés ou conteneurs compromis san niveau Élevé	Réduire	Pipeline CI/CD avec signature automatique des images Docker et génération SBOM intégré [LINDDUN-L], Scan continu de vulnérabilités sur conteneurs API non signés [EBIOS-RM-A4], Attestation d'intégrité des images avant déploiement CloudHDS [ISO27002-5.19]	EBIOS-RM-A4; ISO27002-5.19; LINDDUN-L	Élevé (fuites via endpoin signés rédu signature in progressive

Validation et suivi

Fichier : 06-validation.md

> Document établi par le programme à partir du registre des risques. Il ne contient AUCUNE décision : les décisions sont prises par une personne dans la page ④ du site, puis ajoutées en bas de ce document (qui, quand, pourquoi).

1. État de la validation

- Risques au registre : **135**.
- Décidés par un analyste : **0** (0 acceptés, 0 acceptés avec modification, 0 refusés).
- Restant à valider : **135**.

Niveau	Risques	Dont décidés
Critique	75	0
Élevé	35	0
Moyen	13	0
Faible	12	0

2. Risques à décider en priorité (niveaux Critique et Élevé)

La colonne « Décision » se remplit dans le site (page ④) ; elle est ici pour mémoire.

ID	Actif	Niveau	Traitement proposé	Risque résiduel	Décision	Responsable
M060	A19 — Donnée/Structure — Données Patients (DPI)	Critique	Réduire	Élevé	À décider	À désigner
M054	A17 — Infrastructure réseau — Active Directory	Critique	Réduire	Élevé	À décider	À désigner
M058	A18 — Application métier — DPI Progiciel Nexus	Critique	Réduire	Élevé	À décider	À désigner
M062	A19 — Donnée/Structure — Données Patients (DPI)	Critique	Réduire	Critique	À décider	À désigner
M068	A21 — Infrastructure Cloud — Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/OVHcloud/Azure (pas d'imposition) [E142]	Critique	Réduire	Critique	À décider	À désigner
M070	A22 — Infrastructure sécurité — Micro-segmentation VLAN/NAC — Architecture cible pour isoler poste clinique compromis (VLAN IoT/Biomedical 10.1.30.0/24 non cloisonné actuellement) [E146,E150,FichedAuditTechnique-ÉtatdesLieuxSanteTechAs-Is.pdf.md,E205]	Critique	Éviter	Critique	À décider	À désigner
M089	A26 — Parc IoT Médical	Critique	Réduire	Faible : IoT biomédical isolé physiquement + flux capteurs cryptés en transit [E140]	À décider	À désigner
M091	A27 — Ferme Citrix/RDS	Critique	Réduire	Faible : ferme Citrix/RDS isolée sur MPLS segmenté + accès direct restreint à serveurs certifiés [E139]	À décider	À désigner

ID	Actif	Niveau	Traitement proposé	Risque résiduel	Décision	Responsable
M093	A28 — Postes legacy	Critique	Éviter	Négligeable : postes Windows 7/XP mis en service de secours uniquement (non critiques) + migration planifiée [E150]	À décider	À désigner
M095	A29 — MPLS Hub & Spoke	Critique	Réduire	Très Faible : interconnexion sites via IPsec chiffré seul + ACL routage segmenté [E140]	À décider	À désigner
M097	A30 — Active Directory	Critique	Réduire	Élevée·Critique·Moyen	À décider	À désigner
M102	A32 — Messagerie Exchange 2016 OWA Webmail	Critique	Réduire	Élevée·Critique·Faible	À décider	À désigner
M104	A32 — Messagerie Exchange 2016 OWA Webmail	Critique	Réduire	Élevée·Critique·Faible	À décider	À désigner
M108	A34 — Contrôleur de Domaine RODC par Clinique	Critique	Réduire	Élevée·Critique·Moyen	À décider	À désigner
M111	A35 — Sécurité IT (SOC/EDR/SIEM)	Critique	Réduire	Élevée — Critique — Faible	À décider	À désigner
M113	A35 — Sécurité IT (SOC/EDR/SIEM)	Critique	Réduire	Élevée — Critique — Faible	À décider	À désigner
M114	A36 — Attestation de relecture croisée	Critique	Réduire	Moyenne — Critique — Faible	À décider	À désigner
M115	A36 — Attestation de relecture croisée	Critique	Réduire	Faible — Critique — Faible	À décider	À désigner
M120	A39 — CTI & OSINT	Critique	Réduire	Faible — Critique — Moyenne	À décider	À désigner
M130	Frontière VLAN IoT ↔ Core_Net (routage direct)	Critique	Éviter	Faible - Faible	À décider	À désigner
M001	A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service	Critique	Réduire	Élevé	À décider	À désigner
M002	A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service	Critique	Réduire	Medium	À décider	À désigner
M003	A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service	Critique	Réduire	Élevé	À décider	À désigner
M004	A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service	Critique	Réduire	Medium	À décider	À désigner
M005	A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service	Critique	Réduire	Élevé	À décider	À désigner
M006	A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service	Critique	Réduire	Medium	À décider	À désigner
M007	A03 — Messagerie Sécurisée de Santé (Mél) — Logiciel / Service	Critique	Réduire	Élevé	À décider	À désigner
M008	A03 — Messagerie Sécurisée de Santé (Mél) — Logiciel / Service	Critique	Réduire	Medium	À décider	À désigner
M009	A03 — Messagerie Sécurisée de Santé (Mél) — Logiciel / Service	Critique	Réduire	Élevé	À décider	À désigner
M010	A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet	Critique	Réduire	Medium	À décider	À désigner

ID	Actif	Niveau	Traitement proposé	Risque résiduel	Décision	Responsable
M011	A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet	Critique	Réduire	Élevé	À décider	À désigner
M012	A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet	Critique	Réduire	Medium	À décider	À désigner
M013	A05 — Webmail de Santé & Accès Externe (OWA) — Service / Site Internet	Critique	Réduire	Élevé → Moyenne	À décider	À désigner
M014	A05 — Webmail de Santé & Accès Externe (OWA) — Service / Site Internet	Critique	Réduire	Critique → Élevé	À décider	À désigner
M026	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5	Critique	Réduire	Critique	À décider	À désigner
M027	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5	Critique	Réduire	Critique	À décider	À désigner
M037	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11	Critique	Réduire	Élevé	À décider	À désigner
M038	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11	Critique	Réduire	Élevé	À décider	À désigner
M039	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11	Critique	Réduire	Élevé	À décider	À désigner
M040	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11	Critique	Réduire + Transférer	Élevé	À décider	À désigner
M041	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11	Critique	Éviter	Critique	À décider	À désigner
M042	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11	Critique	Réduire	Élevé	À décider	À désigner
M043	A11 — Fournisseur Cloud HDS	Critique	Éviter	Critique	À décider	À désigner
M044	A11 — Fournisseur Cloud HDS	Critique	Réduire + Transférer	Élevé	À décider	À désigner
M045	A12 — Parc IoT Médical	Critique	Accepter	Critique	À décider	À désigner

ID	Actif	Niveau	Traitement proposé	Risque résiduel	Décision	Responsable
M046	A12 — Parc IoT Médical	Critique	Réduire + Éviter	Élevé	À décider	À désigner
M047	A13 — Segmentation Réseau VLAN/NAC	Critique	Éviter	Élevé	À décider	À désigner
M048	A14 — Wi-Fi Invités/Patients	Critique	Réduire	Élevé	À décider	À désigner
M049	A14 — Wi-Fi Invités/Patients	Critique	Réduire	Élevé	À décider	À désigner
M050	A15 — API SaaS / APIs Télémedecine	Critique	Réduire	Élevé	À décider	À désigner
M052	A16 — Domaine hospitalier — Site	Critique	Réduire	Élevé	À décider	À désigner
M057	A18 — Application métier — DPI Progiciel Nexus	Critique	Réduire	Élevé	À décider	À désigner
M059	A18 — Application métier — DPI Progiciel Nexus	Critique	Réduire	Élevé	À décider	À désigner
M063	A20 — Matériel IoT — Dispositifs Médicaux Connectés	Critique	Réduire	Élevé	À décider	À désigner
M072	A22 — Infrastructure sécurité — Micro-segmentation VLAN/NAC — Architecture cible pour isoler poste clinique compromis (VLAN IoT/Biomedical 10.1.30.0/24 non cloisonné actuellement) [E146,E150,FichedAuditTechnique-ÉtatdesLieuxSanteTechAs-Is.pdf.md,E205]	Critique	Réduire	Critique	À décider	À désigner
M073	A23 — Application/Rôle — IdP Gestion Identités (TO-BE) — Déploiement cible IdP centralisé (Entra ID/Keycloak) avec MFA FIDO2/Carte CPS [E146]	Critique	Réduire	Risque moyen	À décider	À désigner
M076	A23 — Application/Rôle — IdP Gestion Identités (TO-BE) — Déploiement cible IdP centralisé (Entra ID/Keycloak) avec MFA FIDO2/Carte CPS [E146]	Critique	Réduire	Risque critique	À décider	À désigner
M077	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]	Critique	Réduire	Risque critique	À décider	À désigner
M078	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]	Critique	Réduire	Risque critique	À décider	À désigner
M079	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]	Critique	Réduire	Risque critique	À décider	À désigner
M080	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]	Critique	Réduire	Risque critique	À décider	À désigner
M081	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]	Critique	Réduire	Risque critique	À décider	À désigner

ID	Actif	Niveau	Traitement proposé	Risque résiduel	Décision	Responsable
M082	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]	Critique	Réduire	Risque critique	À décider	À désigner
M083	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139]	Critique	Réduire	Risque critique	À décider	À désigner
M084	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139]	Critique	Réduire	Risque critique	À décider	À désigner
M085	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139]	Critique	Réduire	Faible : logs exposés corrigés via journalisation chiffrée + page 404 fixée	À décider	À désigner
M088	A26 — Parc IoT Médical	Critique	Réduire	Moyen : VLAN IoT médical isolé de production + routage restreint vers automates [E140]	À décider	À désigner
M094	A28 — Postes legacy	Critique	Réduire	Faible : SMBv1 bloqué réseau local + postes XP en mode sandbox avec isolation [E203]	À décider	À désigner
M098	A30 — Active Directory	Critique	Réduire	Élevée·Critique·Faible	À décider	À désigner
M099	A31 — Base de Données PACS/RIS Imagerie	Critique	Réduire	Élevée·Critique·Faible	À décider	À désigner
M103	A32 — Messagerie Exchange 2016 OWA Webmail	Critique	Réduire	Élevée·Élevé·Faible	À décider	À désigner
M106	A33 — Portail VPN FortiGate	Critique	Réduire	Élevée·Critique·Faible	À décider	À désigner
M109	A34 — Contrôleur de Domaine RODC par Clinique	Critique	Réduire	Moyenne — Élevé — Moyen	À décider	À désigner
M123	Frontière Internet ↔ VPN_Gateway (FortiGate)	Critique	Réduire	Faible - Moyen	À décider	À désigner
M134	Frontière Cloud_HDS ↔ API Gateway (hybride To-Be)	Critique	Réduire	Élevé (menace persistante jusqu'à migration complète de l'API Gateway sécurisée dans Cloud HDS)	À décider	À désigner
M055	A17 — Infrastructure réseau — Active Directory	Élevé	Réduire	Élevé	À décider	À désigner
M015	A05 — Webmail de Santé & Accès Externe (OWA) — Service / Site Internet	Élevé	Réduire	Élevé → Moyen	À décider	À désigner
M016	A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service	Élevé	Réduire	Élevé → Moyen	À décider	À désigner
M017	A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérieurs E7E5	Élevé	Réduire	Élevé → Moyen	À décider	À désigner

ID	Actif	Niveau	Traitement proposé	Risque résiduel	Décision	Responsable
M018	A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérieurs E7E5	Élevé	Réduire	Élevé → Moyen	À décider	À désigner
M019	A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérieurs E7E5	Élevé	Réduire	Élevé → Faible-Moyen	À décider	À désigner
M021	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond E7E5	Élevé	Éviter	Élevé → Faible	À décider	À désigner
M023	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond E7E5	Élevé	Réduire	Moyen → Faible-Moyen	À décider	À désigner
M028	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5	Élevé	Réduire	Élevé	À décider	À désigner
M029	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5	Élevé	Réduire	Élevé	À décider	À désigner
M056	A17 — Infrastructure réseau — Active Directory	Élevé	Réduire	Élevé	À décider	À désigner
M061	A19 — Donnée/Structure — Données Patients (DPI)	Élevé	Réduire	Moyen	À décider	À désigner
M064	A20 — Matériel IoT — Dispositifs Médicaux Connectés	Élevé	Réduire	Élevé	À décider	À désigner
M066	A20 — Matériel IoT — Dispositifs Médicaux Connectés	Élevé	Réduire	Élevé	À décider	À désigner
M074	A23 — Application/Rôle — IdP Gestion Identités (TO-BE) — Déploiement cible IdP centralisé (Entra ID/Keycloak) avec MFA FIDO2/Carte CPS [E146]	Élevé	Réduire	Risque élevé	À décider	À désigner
M075	A23 — Application/Rôle — IdP Gestion Identités (TO-BE) — Déploiement cible IdP centralisé (Entra ID/Keycloak) avec MFA FIDO2/Carte CPS [E146]	Élevé	Réduire	Risque moyen	À décider	À désigner
M086	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139]	Élevé	Réduire	Faible : interface admin durcie sans authentification sans MFA + CSP mis [E146]	À décider	À désigner

ID	Actif	Niveau	Traitement proposé	Risque résiduel	Décision	Responsable
M092	A27 — Ferme Citrix/RDS	Élevé	Réduire	Faible : micro-segmentation déployée sur ferme Citrix/RDS + lateralité bloquée [E146]	À décider	À désigner
M096	A29 — MPLS Hub & Spoke	Élevé	Réduire	Très Faible : trafic inter-clinique crypté TLS 1.3 + gateway WAF inspectant réplication [E150]	À décider	À désigner
M100	A31 — Base de Données PACS/RIS Imagerie	Élevé	Réduire	Élevée·Élevé·Faible	À décider	À désigner
M110	A34 — Contrôleur de Domaine RODC par Clinique	Élevé	Réduire	Faible — Moyen — Faible	À décider	À désigner
M112	A35 — Sécurité IT (SOC/EDR/SIEM)	Élevé	Réduire	Moyenne — Moyen — Faible	À décider	À désigner
M116	A37 — CISO / Lead GRC	Élevé	Réduire	Faible — Moyen — Faible	À décider	À désigner
M124	Frontière Internet ↔ Portail OWA (Exchange 2016 DMZ)	Élevé	Réduire	Moyen - Moyen	À décider	À désigner
M127	Frontière Réseau Interne ↔ Backbone MPLS (sans micro-segmentation)	Élevé	Réduire	Faible - Faible	À décider	À désigner
M128	Frontière Réseau Interne ↔ Backbones AD (Forêt unique)	Élevé	Réduire	Faible - Moyen	À décider	À désigner
M129	Frontière Réseau Interne ↔ Citrix Farm (DPI Nexus)	Élevé	Réduire	Faible - Moyen	À décider	À désigner
M135	Frontière Cloud_HDS ↔ API Gateway (hybride To-Be)	Élevé	Réduire	Élevé (fuites possibles via endpoints API non signés réduites mais signature intégration progressive)	À décider	À désigner
M025	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond E7E5	Élevé	Réduire	Élevé	À décider	À désigner
M034	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5	Élevé	Réduire	Élevé	À décider	À désigner
M051	A15 — API SaaS / APIs Télémedecine	Élevé	Réduire	Élevé	À décider	À désigner
M122	Frontière Internet ↔ VPN_Gateway (FortiGate)	Élevé	Réduire	Faible - Faible	À décider	À désigner
M125	Frontière DMZ ↔ WAF optionnel (non déployé As-Is)	Élevé	Réduire	Faible - Faible	À décider	À désigner
M132	Frontière Wi-Fi Invités ↔ Internet (sans SSL filtering)	Élevé	Réduire	Moyen - Faible	À décider	À désigner
M133	Frontière Wi-Fi Invités ↔ Internet (sans SSL filtering)	Élevé	Réduire	Moyen (risque d'interception passif réduit mais non nul pour connexions sans HTTPS résiduel)	À décider	À désigner

3. Acceptation du risque résiduel

Un risque résiduel n'est accepté que **par écrit**, par une personne qui en a la responsabilité (autorité d'homologation) : qui, quand, pourquoi (référentiel `ANSSI-HOMOLOGATION`). Dans le site, la décision « accepté tel quel », « accepté avec modification » ou « refusé » et son commentaire sont consignés à la fin de ce document.

4. Plan de suivi (proposition par défaut, à valider par la direction)

Niveau du risque	Revue proposée
Critique	tous les mois, jusqu'à la mise en œuvre de la mesure, puis tous les trimestres
Élevé	tous les trimestres
Moyen	tous les semestres
Faible	une fois par an

Déclencheurs d'une nouvelle analyse, quel que soit le niveau :

- changement de périmètre (nouveau site, nouvelle application, nouveau service) ;
- incident de sécurité significatif, y compris chez un fournisseur ou un client ;
- arrivée d'un nouveau fournisseur ou d'un nouveau prestataire ayant accès au système ;
- évolution d'une obligation réglementaire ou contractuelle (RGPD, NIS2, exigences clients) ;
- modification d'un document d'origine de l'analyse (le site le signale : les livrables sont alors « périmés »).

Décisions enregistrées

Les décisions prises dans le site s'ajoutent ci-dessous, dans l'ordre où elles sont enregistrées.

Contradictions entre documents et questions ouvertes

Fichier : recherches-contradictions-questions.md

31 besoins d'information examinés : **4 connus**, **8 partiels**, **19 non documentés**.

> « Non documenté » signifie que **les documents fournis n'en parlent pas**. Cela ne prouve pas que la mesure n'existe pas : c'est une question à poser à l'entreprise.

Ce que nous savons

- **Quelles normes ou certifications (ISO 27001, etc.) sont obtenues ou visées ?** Les normes et certifications visées sont NIS 2, RGPD, HDS (Hébergeur de Données de

Santé) et ISO 27001. _(à valider : Les deux vérificateurs divergent : relire les extraits cités.)_
- preuve (Présentation_du_Projet_d_Étude_-_M2_CYBE) : « Gestion des Risques Conformité Légale Résilience Métier

Scoring CVSS/CVE & révision PSSI. Audits NIS 2, RGPD, HDS / ISO 27001. »

- preuve (Présentation_du_Projet_d_Étude_-_M2_CYBE) : « ## Page 1

SUP DE VINCI M2 CYBERSÉCURITÉ 2026 2027 Projet SECU CLOUD HEALTH

Cahier des charges, cadrage opérationnel et livrables par blocs de compétences.

Page 2

CONTEXTE & ENJEUX Mise en sit »

- preuve (FAQ___Complément_de_Cadrage_-_SanteTech_) : « Absence initiale de SOC, d'EDR et de SIEM centralisé. Le projet doit répondre aux exigences de la directive NIS 2, du RGPD et de la certification HDS. »
- preuve (FAQ___Complément_de_Cadrage_-_SanteTech_) : « Aucun fournisseur n'est imposé. Contrainte impérative : certification HDS (Hébergeur de Données de Santé) et analyse de l'exposition au Cloud Act. »
- **Quels sont les sites de l'entreprise et leur rôle ?** L'entreprise compte 12 établissements : 2 Grands Centres Hospitaliers (Rennes, Nantes), 4 Cliniques Moyennes (Brest, Le Mans, Angers, Tours) et 6 Cliniques de Proximité / Chirurgie.
- preuve (FAQ___Complément_de_Cadrage_-_SanteTech_) : « 4 Répartition des 12 • 2 Grands Centres Hospitaliers (Rennes +

établissements Nantes) : ~500 lits chacun, 1 000 collaborateurs/site, »

- **Combien de postes de travail existent et sont-ils chiffrés ?** Il existe 3 200 postes informatiques, dont 700 PC portables chiffrés par BitLocker et 2 500 postes fixes et chariots de soins.
- preuve (Fiche_d_Audit_Technique_-_État_des_Lieux) : « messagerie interne hybride Exchange 2016 (Non totalement durci contre les

attaques par usurpation).

Page 3

1. Postes Clients & Flotte IoT Médical

● Parc Utilisate »

- preuve (FAQ___Complément_de_Cadrage_-_SanteTech_) : « ● Volumétrie : 185 serveurs (65 physiques, 120 virtuels sous VMware ESXi/Hyper-V) et 3 200 postes

informatiques (dont ~5% de postes irréductibles sous Windows 7 / XP Embedded pour l'imagerie). »

- **L'authentification multifacteur (MFA) est-elle en place, pour quels comptes ?** Actuellement, il n'y a pas de MFA systématique sur le VPN, avec un simple login/mot de passe sans MFA sur 60% des comptes.
- preuve (FAQ___Complément_de_Cadrage_-_SanteTech_) : « • As-Is : Active Directory On-Premise unique, pas de MFA systématique sur le VPN. »
- preuve (FAQ___Complément_de_Cadrage_-_SanteTech_) : « MFA systématique sur le VPN.

• To-Be : Déploiement d'un IdP centralisé (Entra ID / Ke »

- preuve (FAQ___Complément_de_Cadrage_-_SanteTech_) : « ● Exposition & Accès : Portail VPN FortiGate (vpn.santetech-sante.fr) avec simple login/mot de passe (sans MFA sur 60% des comptes) et Webmail Exchange OWA (webmail.santetech-sante.fr). »

Ce que nous savons en partie

- **Existe-t-il une politique de sécurité (PSSI) et de quelle version ?** Le document mentionne une « révision PSSI » dans le cadre de la gestion des risques, mais ne précise pas l'existence d'une politique actuelle ni sa version. _(à valider : Information partielle. Il manque : La version actuelle de la PSSI et la confirmation de son existence formelle.. Les deux vérificateurs divergent : relire les extraits cités.)_
- preuve (Présentation_du_Projet_d_Étude_-_M2_CYBE) : « Gestion des Risques Conformité Légale Résilience Métier

Scoring CVSS/CVE & révision PSSI. Audits NIS 2, RGPD, HDS / ISO 27001. »

- **Manque** : La version actuelle de la PSSI et la confirmation de son existence formelle.
- **Quelles sont les applications critiques et qui en est propriétaire ?** Les applications critiques sont le Progiciel Nexus (Dossier Patient Informatisé), PACS/RIS pour l'imagerie, la messagerie interne Exchange 2016 et une nouvelle brique de télémédecine. _(à valider : La réponse proposée n'est pas soutenue par les preuves citées : relire les extraits avant de s'y fier.)_
- preuve (FAQ___Complément_de_Cadrage_-_SanteTech_) : « ● Applications Métier : Progiciel Nexus (Dossier Patient Informatisé), PACS/RIS pour l'imagerie, et messagerie interne Exchange 2016. »
- preuve (FAQ___Complément_de_Cadrage_-_SanteTech_) : « micro-segmentation : un poste compromis dans une clinique peut communiquer en IP

directe avec tout le réseau. ● Annuaire : Forêt Active Directory unique (corp.santetech.local) avec »

- preuve (FAQ___Complément_de_Cadrage_-_SanteTech_) : « Applications Métier : Progiciel Nexus (Dossier Patient Informatisé), PACS/RIS pour l'imagerie, et messagerie interne Exchange 2016. »
- **Manque** : L'identité précise du propriétaire (entité ou service responsable) de ces applications n'est pas mentionnée dans les documents.
- **Quels services sont hébergés en SaaS ou dans le cloud, chez quels fournisseurs ?** Le DPI Nexus, la télémédecine, le portail patient et des API SaaS migrent vers un Cloud Hybride HDS. Aucun fournisseur n'est imposé (ex: Scaleway, OVHcloud, Azure). _(à valider : Information partielle. Il manque : La confirmation du fournisseur final choisi parmi les options citées.. Les deux vérificateurs divergent : relire les extraits cités.)_
- preuve (FAQ___Complément_de_Cadrage_-_SanteTech_) : « HDS. Seuls les serveurs d'impression et les caches

DICOM/PACS restent en local dans les cliniques. |

6	**Fournisseur Cloud &**

Souveraineté | Aucun fournisseur n'est imposé. Contrainte impérative : ce »

- preuve (Présentation_du_Projet_d_Étude_-_M2_CYBE) : « Transformation : Migration vers un Cloud hybride,

Mission de l'équipe microservices, API SaaS et IoT médical. »

- preuve (FAQ___Complément_de_Cadrage_-_SanteTech_) : « • To-Be (Cloud Hybride) : Migration du DPI Nexus,

de la télémédecine et du portail patient vers un Cloud »

- preuve (FAQ___Complément_de_Cadrage_-_SanteTech_) : « (a) Hébergeur Cloud HDS (ex: Scaleway HDS vs OVHcloud vs Azure HDS) »
- **Manque** : La confirmation du fournisseur final choisi parmi les options citées.
- **Qui dispose d'un accès à distance (VPN, télémaintenance, prestataires) ?** Le portail VPN (vpn.santetech-sante.fr) est utilisé pour le télétravail et les praticiens libéraux. Un portail extranet est dédié aux médecins traitants extérieurs. _(à valider : Information partielle. Il manque : La liste précise des prestataires ayant un accès à distance n'est pas mentionnée dans les documents..)_
- preuve (FAQ___Complément_de_Cadrage_-_SanteTech_) : « ● Exposition & Accès : Portail VPN FortiGate (vpn.santetech-sante.fr) avec simple login/mot de passe (sans MFA sur 60% des comptes) et Webmail Exchange OWA (webmail.santetech-sante.fr). »

- preuve (Fiche_d_Audit_Technique_-_État_des_Lieux) : « 5. Services Exposés sur Internet & Accès Distants

● Portail VPN Télétravail & Praticiens Libéraux : ○ URL : vpn.santetech-sante.fr (Passerelle FortiGate / FortiSSL). ○ »

- preuve (FAQ___Complément_de_Cadrage_-_SanteTech_) : « Exposition & Accès : Portail VPN FortiGate (vpn.santetech-sante.fr) avec simple login/mot de passe »
- preuve (FAQ___Complément_de_Cadrage_-_SanteTech_) : « micro-segmentation : un poste compromis dans une clinique peut communiquer en IP

directe avec tout le réseau. ● Annuaire : Forêt Active Directory unique (corp.santetech.local) avec »

- **Manque** : La liste précise des prestataires ayant un accès à distance n'est pas mentionnée dans les documents.
- **Le réseau est-il segmenté et quels pare-feu protègent les sites ?** Le réseau n'est pas micro-segmenté : un poste compromis peut communiquer en IP directe avec tout le réseau. Les sites sont protégés par une passerelle FortiGate / FortiSSL. _(à valider : La réponse proposée n'est pas soutenue par les preuves citées : relire les extraits avant de s'y fier.)_
- preuve (FAQ___Complément_de_Cadrage_-_SanteTech_) : « ● Réseau (Hub & Spoke) : Interconnexion MPLS centralisée par le siège. »
- preuve (FAQ___Complément_de_Cadrage_-_SanteTech_) : « Aucune micro-segmentation : un poste compromis dans une clinique peut communiquer en IP directe avec tout le réseau. »
- preuve (Fiche_d_Audit_Technique_-_État_des_Lieux) : « 5. Services Exposés sur Internet & Accès Distants

● Portail VPN Télétravail & Praticiens Libéraux : ○ URL : vpn.santetech-sante.fr (Passerelle FortiGate / FortiSSL). ○ »

- **Quels sont les liens Internet et existe-t-il un lien de secours ?** L'infrastructure actuelle est 100% On-Premise avec des serveurs locaux de secours dans les cliniques. _(à valider : Information partielle. Il manque : La liste exhaustive des liens Internet spécifiques et la confirmation de l'existence d'un lien de secours dédié à la connexion Internet..)_
- preuve (FAQ___Complément_de_Cadrage_-_SanteTech_) : « ● Infrastructure Actuelle : 100% On-Premise / Legacy avec dette technique avérée (ferme Citrix/RDS au Siège, serveurs locaux de secours dans les cliniques). »
- **Manque** : La liste exhaustive des liens Internet spécifiques et la confirmation de l'existence d'un lien de secours dédié à la connexion Internet.
- **Quels équipements sont obsolètes ou hors support constructeur ?** Le parc informatique contient environ 5% de postes sous Windows 7 / Windows XP Embedded pilotant de vieux automates d'imagerie et des injecteurs de produits de contraste. _(à

valider : Information partielle. Il manque : La liste exhaustive des équipements spécifiques dont le support constructeur est officiellement expiré..)_

- preuve (Fiche_d_Audit_Technique_-_État_des_Lieux) : « messagerie interne hybride Exchange 2016 (Non totalement durci contre les

attaques par usurpation).

Page 3

1. Postes Clients & Flotte IoT Médical

● Parc Utilisate »

- preuve (Fiche_d_Audit_Technique_-_État_des_Lieux) : « Applications Clés (Hébergées en local / DC Siège) : »
- **Manque** : La liste exhaustive des équipements spécifiques dont le support constructeur est officiellement expiré.
- **Quelles données personnelles sont traitées (clients, salariés, géolocalisation) ?** Le groupe traite 150 000 dossiers patients actifs. Il gère les données de 4 500 collaborateurs (médecins, infirmiers, administratifs) et utilise des dispositifs IoT médicaux connectés. _(à valider : Information partielle. Il manque : Précisions sur les données de géolocalisation spécifiques et le détail des données personnelles des clients (patients) au-delà des dossiers actifs..)_
- preuve (Présentation_du_Projet_d_Étude_-_M2_CYBE) : « ## Page 1

SUP DE VINCI □ M2 CYBERSÉCURITÉ 2026□2027 Projet SECU□CLOUD□HEALTH

Cahier des charges, cadrage opérationnel et livrables par blocs de compétences.

Page 2

CONTEXTE & ENJEUX Mise en sit »

- preuve (Fiche_d_Audit_Technique_-_État_des_Lieux) : « messagerie interne hybride Exchange 2016 (Non totalement durci contre les

attaques par usurpation).

Page 3

1. Postes Clients & Flotte IoT Médical

● Parc Utilisate »

- preuve (FAQ___Complément_de_Cadrage_-_SanteTech_) : « HDS. Seuls les serveurs d'impression et les caches

DICOM/PACS restent en local dans les cliniques. |

6	Fournisseur Cloud &

Souveraineté | Aucun fournisseur n'est imposé. Contrainte impérative : ce »

- **Manque** : Précisions sur les données de géolocalisation spécifiques et le détail des données personnelles des clients (patients) au-delà des dossiers actifs.

Ce que nous ignorons encore (questions à poser)

- [Gouvernance] **Qui est le RSSI et est-il indépendant du DSI ?** Une description de l'organisation interne précisant l'identité du RSSI et son rapport hiérarchique ou fonctionnel avec le DSI.
- [Gouvernance] **À quelle fréquence se réunit le comité de sécurité ?** Une mention de la fréquence de réunion du comité de sécurité dans les documents fournis.
- [Continuité] **Comment sont réalisées les sauvegardes et où sont-elles stockées ?** Une description technique des procédures de sauvegarde et de leur localisation (serveurs de backup, cloud, ou supports physiques).
- [Continuité] **Quand a eu lieu la dernière restauration de sauvegarde réussie ?** Un document technique ou un journal de logs indiquant la date de la dernière restauration de sauvegarde réussie.
- [Continuité] **Existe-t-il un plan de reprise d'activité, quand a-t-il été testé, quel est le site de repli ?** Un document détaillant le Plan de Reprise d'Activité (PRA), la date du dernier test et l'emplacement géographique ou technique du site de repli.
- [Accès] **Les comptes d'administration sont-ils nominatifs ou partagés ?** Une information précisant si les comptes d'administration sont nominatifs ou partagés.
- [Accès] **Comment et sous quel délai les comptes des personnes parties sont-ils désactivés ?** Les documents fournis ne mentionnent aucune procédure ni délai de désactivation des comptes des personnes parties.
- [Exploitation] **Les journaux (logs) sont-ils centralisés et analysés, qui reçoit les alertes ?** Information sur l'existence d'un système de centralisation des logs, les outils d'analyse utilisés et l'identité des destinataires des alertes.
- [Exploitation] **Comment sont gérés les correctifs de sécurité et les vulnérabilités ?** Une procédure ou un document décrivant le processus de gestion des correctifs (patch management) et le suivi des vulnérabilités.
- [Exploitation] **Quels incidents de sécurité ont eu lieu récemment ?** Un document ou un rapport listant les incidents de sécurité récents survenus au sein du groupe SanteTech.
- [Exploitation] **Un test d'intrusion ou un audit technique externe a-t-il été réalisé ?** Un document confirmant la réalisation d'un test d'intrusion ou d'un audit technique externe spécifique.
- [Données] **Existe-t-il un registre des traitements RGPD et est-il complet ?** Un document confirmant l'existence et l'exhaustivité du registre des traitements RGPD.

- [Données] **Qui est le délégué à la protection des données (DPO) ?** Le nom ou l'identité du délégué à la protection des données (DPO) n'est mentionné dans aucun des documents fournis.
- [Données] **Comment une violation de données est-elle notifiée à la CNIL ?** Une procédure ou un document précisant les modalités de notification des violations de données à la CNIL.
- [Fournisseurs] **Quels prestataires ont accès au système d'information et avec quelles clauses de sécurité ?** La liste des prestataires tiers ayant accès au système d'information et les clauses de sécurité spécifiques qui leur sont appliquées.
- [Fournisseurs] **L'entreprise dispose-t-elle d'une assurance cyber ?** Une information sur la présence ou non d'une assurance cyber dans les documents fournis.
- [Humain] **Quelle sensibilisation à la sécurité a été faite et quand ?** Aucun document ne mentionne de sensibilisation à la sécurité effectuée ou de date précise.
- [Humain] **Quel est le processus d'arrivée et de départ des collaborateurs ?** Un document décrivant les procédures RH ou les processus opérationnels d'onboarding et d'offboarding des collaborateurs.
- [Sécurité physique] **Comment sont protégées les salles serveurs (accès, incendie, énergie) ?** Informations sur les mesures de protection physique (accès, incendie, énergie) des salles serveurs.

Contradictions entre documents (à valider)

- FAQ___Complément_de_Cadrage_-_SanteTech_ : « Hypothèse retenue : Isolation logique stricte via micro-segmentation VLAN/NAC et interdiction d'accès Internet direct. » ≠ Fiche_d_Audit_Technique_-_État_des_Lieux : « 10.1.30.0/24 : VLAN IoT / Biomédical (Non cloisonné, routage direct vers les automates) » — Le fait (FAQ_Complément_de_Cadrage_-_SanteTech_) stipule une 'Isolation logique stricte via micro-segmentation VLAN/NAC' pour les équipements, alors que le passage [1] (et [2]) indique explicitement q
- Fiche_d_Audit_Technique_-_État_des_Lieux : « 10.1.40.0/24 : VLAN Wi-Fi Invités / Patients (Sortie Internet directe sans filtrage SSL) » ≠ FAQ___Complément_de_Cadrage_-_SanteTech_ : « Hypothèse retenue : Isolation logique stricte via micro-segmentation VLAN/NAC et interdiction d'accès Internet direct. » — Le fait indique que le VLAN Wi-Fi Invités/Patients possède une 'Sortie Internet directe sans filtrage SSL'. À l'inverse, les passages [1] et [2] stipulent une 'interdiction d'accès Internet direct' po

À relire si le temps le permet (8) — non confirmées par un second avis

- FAQ___Complément_de_Cadrage_-_SanteTech_ : « ● Annuaire : Forêt Active Directory unique (corp.santetech.local) avec 16 contrôleurs de domaine (1 DC/RODC par clinique). » ≠ Fiche_d_Audit_Technique_-_État_des_Lieux : « Domaine racine : hq.corp.santetech.local (Siège - Rennes). » — Le fait indique une forêt Active

Directory unique (corp.santetech.local), alors que le passage [3] indique que le domaine racine est hq.corp.santetech.local. Bien que cela puisse être une structure hi

- FAQ___Complément_de_Cadrage_-_SanteTech_ : « • 2 Grands Centres Hospitaliers (Rennes + Nantes) : ~500 lits chacun, 1 000 collaborateurs/site, urgences et imagerie lourde. » ≠ Présentation_du_Projet_d_Étude_-_M2_CYBE : « Périmètre : 12 cliniques, 4500 collaborateurs, 150 000

dossiers patients actifs. » — Le fait indique un périmètre de 2 Grands Centres Hospitaliers avec environ 2 000 collaborateurs au total (1 000 par site). Les passages [1], [2] et [4] indiquent un périmètre de 12 cliniques avec 4 50

- FAQ___Complément_de_Cadrage_-_SanteTech_ : « • 4 Cliniques Moyennes (Brest, Le Mans, Angers, Tours) : ~200 lits, 400 collaborateurs/site. » ≠ Présentation_du_Projet_d_Étude_-_M2_CYBE : « Périmètre : 12 cliniques, 4500 collaborateurs, 150 000

dossiers patients actifs. » — Le fait indique un périmètre de 4 cliniques moyennes, alors que les passages [1] et [2] mentionnent un périmètre de 12 cliniques.

- FAQ___Complément_de_Cadrage_-_SanteTech_ : « • 6 Cliniques de Proximité / Chirurgie : ~50 lits, 150 collaborateurs/site. » ≠ Présentation_du_Projet_d_Étude_-_M2_CYBE : « Périmètre : 12 cliniques, 4500 collaborateurs, 150 000

dossiers patients actifs. » — Le fait indique un périmètre de 6 cliniques, tandis que les passages [1] à [4] mentionnent un périmètre de 12 cliniques.

- FAQ___Complément_de_Cadrage_-_SanteTech_ : « Seuls les serveurs d'impression et les caches DICOM/PACS restent en local dans les cliniques. » ≠ Fiche_d_Audit_Technique_-_État_des_Lieux : « Cliniques (01 à 12) : 1 Read-Only Domain Controller (RODC) ou DC virtuel par site hébergé sur un serveur local vieillissant pour assurer l'authentification en c » — Le fait stipule que SEULS les serveurs d'impression et les caches DICOM/PACS restent en local. Or, le passage [3] indique que des contrôleurs de domaine (RODC ou DC virtuel) sont également hébergés su
- FAQ___Complément_de_Cadrage_-_SanteTech_ : « Annuaire : Forêt Active Directory unique (corp.santetech.local) avec 16 contrôleurs de domaine (1 DC/RODC par clinique). » ≠ Fiche_d_Audit_Technique_-_État_des_Lieux : « Domaine racine : hq.corp.santetech.local (Siège - Rennes). » — Le fait indique une forêt Active Directory unique (corp.santetech.local), alors que le passage [3] décrit une structure de domaines enfants (hq.corp.santetech.local, clinique-armor.corp.santetech.loca
- FAQ___Complément_de_Cadrage_-_SanteTech_ : « HDS. Seuls les serveurs d'impression et les caches

DICOM/PACS restent en local dans les cliniques. |

6	**Fournisseur Cloud &**

Souveraineté | Aucun fournisseur » ≠ Fiche_d_Audit_Technique_-_État_des_Lieux : « ■ 10.1.30.0/24 : VLAN IoT / Biomédical (Non cloisonné, routage direct vers les automates) ■ 10.1.4 » — Le fait (FAQ SanteTech) stipule que seuls les serveurs d'impression et les caches DICOM/PACS restent en local, impliquant une migration ou une centralisation des autres données. Cependant, le passage

- Fiche_d_Audit_Technique_-_État_des_Lieux : « 10.1.10.0/24 : VLAN Serveurs Locaux (DPI local, Impression) » ≠ FAQ___Complément_de_Cadrage_-_SanteTech_ : « • As-Is : DPI Nexus hébergé sur ferme Citrix/RDS au Siège de Rennes. » — Le fait indique que le VLAN 10.1.10.0/24 est destiné aux 'Serveurs Locaux (DPI local, Impression)'. Cependant, le passage [4] précise que le DPI Nexus est hébergé sur une ferme Citrix/RDS au Siège de

Rapport de contrôle

Fichier : RAPPORT-CONTROLE.md

Un contrôle indépendant relit chaque étape avant la suivante. Pour chacun : ce qui n'allait pas, ce qui a changé depuis la version précédente, et le verdict.

À faire valider par un humain

- **Étape 1 · Existant et actifs** — Le contrôle signale toujours des points non conformes après les reprises demandées à l'agent : 00-description.md : identifiants de preuve INEXISTANTS à retirer ou remplacer : [E10], [E19], [E3], [E7], [E44], [E36], [E17], [E9], [E18], [E5], [E2], [E45], [E8], [E6], [E15], [E38], [E16], [E1], [E25]. 00-description.md : trop de lignes sans preuve citée (12 sur 39) : cite [E…] après chaque fait, ou retire la ligne si le dossier de preuves ne la soutient pas. 01-actifs.md : identifiants de preuve INEXISTANTS à retirer ou remplacer : [E5], [E7], [E9], [E11], [E13].
- À vérifier : Pour chaque point signalé, chercher l'affirmation dans `00-description.md`, `01-actifs.md` puis dans les documents d'origine ; si elle n'y est pas, c'est une invention à retirer ; si elle y est, le contrôle s'est trompé.
- **Étape 2 · Choix de la méthode** — Le contrôle signale toujours des points non conformes après les reprises demandées à l'agent : 02-methodes.md : identifiants de preuve INEXISTANTS à retirer ou remplacer : [E5], [E9], [E38], [E40], [E7].
- À vérifier : Pour chaque point signalé, chercher l'affirmation dans `02-methodes.md` puis dans les documents d'origine ; si elle n'y est pas, c'est une invention à retirer ; si elle y est, le contrôle s'est trompé.
- **Étape 3 · Menaces** — Le contrôle signale toujours des points non conformes après les reprises demandées à l'agent : 03-menaces.md : identifiants de preuve INEXISTANTS à retirer ou remplacer : [E7], [E5], [E38], [E9], [E2], [E40], [E32], [E3], [E57], [E36],

[E271], [E274], [E277], [E25], [E18], [E16]. Identifiants utilisés mais jamais définis dans un tableau — définis-les ou utilise un identifiant existant : A3 (03-menaces.md); A5 (03-menaces.md); A7 (03-menaces.md). 03-menaces.md : texte d'attente à remplacer par l'information ou par « non documenté » : | M069 | A21 — Infrastructure Cloud — Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/OVHcloud/Azure (pas d'imposition) [E142]

- À vérifier : Pour chaque point signalé, chercher l'affirmation dans `03-menaces.md` puis dans les documents d'origine ; si elle n'y est pas, c'est une invention à retirer ; si elle y est, le contrôle s'est trompé.
- **Étape 4 · Évaluation** — Le contrôle signale toujours des points non conformes après les reprises demandées à l'agent : 04-evaluation.md : termes absents des intrants à retirer, ou à présenter explicitement comme une hypothèse à confirmer : jwt. Ne les mentionne pas du tout, pas même pour dire qu'ils sont absents. 04-evaluation.md : identifiants de preuve INEXISTANTS à retirer ou remplacer : [E7], [E5], [E38], [E24], [E240], [E2], [E9], [E40], [E30], [E4], [E32], [E3], [E57], [E36], [E271], [E274], [E277], [E25], [E18], [E16]. Identifiants utilisés mais jamais définis dans un tableau — définis-les ou utilise un identifiant existant : A3 (04-evaluation.md); A5 (04-evaluation.md); A7 (04-evaluation.md); R2 (04-evaluation.md). 04-evaluation.md : texte d'attente à remplacer par l'information ou par « non documenté » : | M067 | A21 — Infrastructure Cloud — Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/OVHcloud/Azure (pas d'imposition) [E142]
- À vérifier : Pour chaque point signalé, chercher l'affirmation dans `04-evaluation.md` puis dans les documents d'origine ; si elle n'y est pas, c'est une invention à retirer ; si elle y est, le contrôle s'est trompé.
- **Étape 5 · Traitement** — Le contrôle signale toujours des points non conformes après les reprises demandées à l'agent : 05-traitement.md : identifiants de preuve INEXISTANTS à retirer ou remplacer : [E7], [E5], [E24], [E240], [E2], [E38], [E9], [E12], [E13], [E40], [E32], [E3], [E57], [E36], [E271], [E274], [E277], [E25], [E18], [E16]. Identifiants utilisés mais jamais définis dans un tableau — définis-les ou utilise un identifiant existant : A3 (05-traitement.md); A7 (05-traitement.md).
- À vérifier : Pour chaque point signalé, chercher l'affirmation dans `05-traitement.md` puis dans les documents d'origine ; si elle n'y est pas, c'est une invention à retirer ; si elle y est, le contrôle s'est trompé.
- **Relecture finale** — Le contrôle signale toujours des points non conformes après les reprises demandées à l'agent : - "Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11" (A10) - "Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]" (A24) - "Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139]" (A25) - "Dossier Patient Informatisé (DPI) Nexus" (A01) - "Messagerie Sécurisée de Santé (Mél)" (A03) - "Portail VPN Télétravail & Praticiens Libéraux" (A04) - "Application métier — DPI Progiciel Nexus" (A18) - "Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/OVHcloud/Azure (pas d'imposition) [E142]" (A21)

- À vérifier : Pour chaque point signalé, chercher l'affirmation dans `registre-risques.md`, `SYNTHESE.md` puis dans les documents d'origine ; si elle n'y est pas, c'est une invention à retirer ; si elle y est, le contrôle s'est trompé.

Contrôle n°1 — Étape 1 · Existant et actifs, version 1 : NON CONFORME

- Contrôleur : contrôle déterministe (termes absents des intrants, citations) · 2026-10-12 13:50:29
- Ce qui n'allait pas : 00-description.md : termes absents des intrants à retirer, ou à présenter explicitement comme une hypothèse à confirmer : gcp. Ne les mentionne pas du tout, pas même pour dire qu'ils sont absents. 00-description.md : identifiants de preuve INEXISTANTS à retirer ou remplacer : [E4], [E11], [E8], [E10], [E25], [E6], [E16], [E20], [E5], [E9], [E7], [E3], [E27], [E31], [E28], [E26], [E37], [E43]. 00-description.md : trop de lignes sans preuve citée (22 sur 57) : cite [E…] après chaque fait, ou retire la ligne si le dossier de preuves ne la soutient pas. 01-actifs.md : identifiants de preuve INEXISTANTS à retirer ou remplacer : [E5], [E7], [E9], [E11], [E13].
- Ce qui a changé depuis la version précédente :

Première version de l'étape.

- Lignes à relire (les deux vérificateurs divergent sur la preuve citée) :
- [non soutenue] | A01 | Dossier Patient Informatisé (DPI) Nexus | Logiciel / Service | 185 serveurs (65 physiques, 120 virtuels), Progiciel Nexus version legacy sur ferme Citrix/RDS, accès soignants RDP interne, valeur mé
- [non soutenue] | A02 | PACS/RIS (Archivage & Imagerie) | Logiciel / Service | Stockage DICOM/SMBv1 sur baies SAN locales vieillissantes, caches DICOM/PACS restants en local des cliniques, protocoles SMBv1 pour compatibil
- [non soutenue] | A03 | Messagerie Sécurisée de Santé (Mél) | Logiciel / Service | Serveur Exchange 2016 exposé DMZ, Webmail OWA webmail.santetech-sante.fr, vulnérable ProxyShell/Spraying si non patché [E7][E5] | Sensible
- [non soutenue] | A04 | Portail VPN Télétravail & Praticiens Libéraux | Service / Site Internet | vpn.santetech-sante.fr (Passerelle FortiGate/FortiSSL), Login/Mot de passe AD sans MFA sur 60% des comptes, authentificatio
- [non soutenue] | A05 | Webmail de Santé & Accès Externe (OWA) | Service / Site Internet | webmail.santetech-sante.fr (Exchange 2016 DMZ), non filtré SSL si vulnérabilités, campagnes Spraying/ProxyShell potentielles [E7][
- [non soutenue] | A06 | Extranet Partenaires / Médecins Libéraux | Service / Site Internet | extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérie
- [non soutenue] | A07 | Sites Web Cliniques (12 sites) | Site Internet / Prestataire | Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond [E7][E5] | Publique | [

- [non soutenue] | A08 | Domaine Active Directory (corp.santetech.local) | Logiciel / Infrastructure | Forêt AD unique, 16 contrôleurs de domaine (1 DC/RODC par clinique), pas de MFA systématique VPN As-Is [E9][E7][E5] | S
- [non soutenue] | A09 | Contrôleurs de Domaine AD (16 unités) | Matériel / Infrastructure | 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène [E9][E5] | Crit
- [non soutenue] | A10 | Applications Cloud Hybride (To-Be) | Logiciel / Service | Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique [E9][E5][E11] | Sensibl

Contrôle n°2 — Étape 1 · Existant et actifs, version 2 : NON CONFORME

- Contrôleur : contrôle déterministe (termes absents des intrants, citations) · 2026-10-12 13:52:27
- Ce qui n'allait pas : 00-description.md : termes absents des intrants à retirer, ou à présenter explicitement comme une hypothèse à confirmer : gcp. Ne les mentionne pas du tout, pas même pour dire qu'ils sont absents. 00-description.md : identifiants de preuve INEXISTANTS à retirer ou remplacer : [E4], [E11], [E8], [E10], [E25], [E6], [E16], [E20], [E5], [E9], [E7], [E3], [E27], [E31], [E28], [E26], [E37], [E43]. 00-description.md : trop de lignes sans preuve citée (22 sur 57) : cite [E…] après chaque fait, ou retire la ligne si le dossier de preuves ne la soutient pas. 01-actifs.md : identifiants de preuve INEXISTANTS à retirer ou remplacer : [E5], [E7], [E9], [E11], [E13]. 00-description.md : texte d'attente à remplacer par l'information ou par « non documenté » : | **RTO/RPO vitaux** | Seuils de RTO (Recovery Time Objective) et RPO (Recovery Point Objective) pour services santé critiques DPI/PACS IoT
- Ce qui a changé depuis la version précédente :

Première version de l'étape.

- Lignes à relire (les deux vérificateurs divergent sur la preuve citée) :
- [non soutenue] | A01 | Dossier Patient Informatisé (DPI) Nexus | Logiciel / Service | 185 serveurs (65 physiques, 120 virtuels), Progiciel Nexus version legacy sur ferme Citrix/RDS, accès soignants RDP interne, valeur mé
- [non soutenue] | A02 | PACS/RIS (Archivage & Imagerie) | Logiciel / Service | Stockage DICOM/SMBv1 sur baies SAN locales vieillissantes, caches DICOM/PACS restants en local des cliniques, protocoles SMBv1 pour compatibil
- [non soutenue] | A03 | Messagerie Sécurisée de Santé (Mél) | Logiciel / Service | Serveur Exchange 2016 exposé DMZ, Webmail OWA webmail.santetech-sante.fr, vulnérable ProxyShell/Spraying si non patché [E7][E5] | Sensible
- [non soutenue] | A04 | Portail VPN Télétravail & Praticiens Libéraux | Service / Site Internet | vpn.santetech-sante.fr (Passerelle FortiGate/FortiSSL), Login/Mot de passe AD sans MFA sur 60% des comptes, authentificatio

- [non soutenue] | A05 | Webmail de Santé & Accès Externe (OWA) | Service / Site Internet | webmail.santetech-sante.fr (Exchange 2016 DMZ), non filtré SSL si vulnérabilités, campagnes Spraying/ProxyShell potentielles [E7][
- [non soutenue] | A06 | Extranet Partenaires / Médecins Libéraux | Service / Site Internet | extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérie
- [non soutenue] | A07 | Sites Web Cliniques (12 sites) | Site Internet / Prestataire | Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond [E7][E5] | Publique | [
- [non soutenue] | A08 | Domaine Active Directory (corp.santetech.local) | Logiciel / Infrastructure | Forêt AD unique, 16 contrôleurs de domaine (1 DC/RODC par clinique), pas de MFA systématique VPN As-Is [E9][E7][E5] | S
- [non soutenue] | A09 | Contrôleurs de Domaine AD (16 unités) | Matériel / Infrastructure | 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène [E9][E5] | Crit
- [non soutenue] | A10 | Applications Cloud Hybride (To-Be) | Logiciel / Service | Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique [E9][E5][E11] | Sensibl

Contrôle n°3 — Étape 1 · Existant et actifs, version 3 : NÉCESSITE UNE VALIDATION HUMAINE

- Contrôleur : contrôle déterministe (termes absents des intrants, citations) · 2026-10-12 14:00:39
- Ce qui n'allait pas : 00-description.md : identifiants de preuve INEXISTANTS à retirer ou remplacer : [E10], [E19], [E3], [E7], [E44], [E36], [E17], [E9], [E18], [E5], [E2], [E45], [E8], [E6], [E15], [E38], [E16], [E1], [E25]. 00-description.md : trop de lignes sans preuve citée (12 sur 39) : cite [E…] après chaque fait, ou retire la ligne si le dossier de preuves ne la soutient pas. 01-actifs.md : identifiants de preuve INEXISTANTS à retirer ou remplacer : [E5], [E7], [E9], [E11], [E13].
- Ce qui a changé depuis la version précédente :

119 ligne(s) ajoutée(s), 142 retirée(s). Retiré : # 00-description.md — Étape 1 : Description du cas étudié Retiré : ## Dossier de preuves Retiré : Ce dossier REMPLACE la lecture des documents d'origine : ne relis pas d'autre fichier. Il reproduit le TEXTE des documents (sections et tableaux, avec leur en-… Retiré : > Ce fichier décrit le système d'information du groupe **SanteTech**, conformément aux exigences de l'ANSSI (`Cartographie du système d'information — Guide d'é… Retiré : ## 1. Cas étudié Ajouté : # Analyse E21 — Étape 1 : Description du cas & Cartographie du système (ANSSI-CARTO-SI) Ajouté : ## □ 1. Résumé de la fiche (cas étudié) Ajouté : **Cas SanteTech : Étude de Sécurité — Projet SECU-CLOUD-HEALTH (M2 Cybersécurité, bloc 1)** Ajouté : Ce document résume

l'architecture **AS-IS** du groupe hospitalier **SanteTech**, les périmètres, les contraintes réglementaires et techniques, ainsi que les hy… Ajouté : | Éléments | Valeurs validées |

- Pourquoi une validation humaine : Le contrôle signale toujours des points non conformes après les reprises demandées à l'agent : 00-description.md : identifiants de preuve INEXISTANTS à retirer ou remplacer : [E10], [E19], [E3], [E7], [E44], [E36], [E17], [E9], [E18], [E5], [E2], [E45], [E8], [E6], [E15], [E38], [E16], [E1], [E25]. 00-description.md : trop de lignes sans preuve citée (12 sur 39) : cite [E…] après chaque fait, ou retire la ligne si le dossier de preuves ne la soutient pas. 01-actifs.md : identifiants de preuve INEXISTANTS à retirer ou remplacer : [E5], [E7], [E9], [E11], [E13].
- Quoi vérifier : Pour chaque point signalé, chercher l'affirmation dans `00-description.md`, `01-actifs.md` puis dans les documents d'origine ; si elle n'y est pas, c'est une invention à retirer ; si elle y est, le contrôle s'est trompé.
- Lignes à relire (les deux vérificateurs divergent sur la preuve citée) :
- [non soutenue] | **Périmètre physique** | Siège social (Rennes) + 12 cliniques régionales (Grand Ouest & Île-de-France) [E10][E224] |
- [non soutenue] | **Dossiers patients actifs** | 150 000 dossiers dans le DPI Nexus legacy [E19][E223] |
- [non soutenue] | **Serveurs & applications** | 185 serveurs (65 physiques, 120 virtuels) ; 3 200 postes + ~4 000 dispositifs IoT médicaux [E147][E3][E230] |
- [non soutenue] | **Objectif de la mission** | Concevoir une architecture sécurisée (To-Be) : cloud hybride HDS, microservices, zero trust et API Gateway. Tester la résilience contre ransomwares/fuites [E224] |
- [non soutenue] | **DMZ / VPN Gateway** | Point d'entrée principal (vpn.santetech-sante.fr) + OWA. Authentification simple → risque accès non filtré [E7][E203] | FortiGate + login/mot de passe sans MFA sur 60% des comptes
- [non soutenue] | **Réseau interne (Hub & Spoke)** | Backbone MPLS centralisé par le siège. Routage direct entre clinique et siège. Micro-segmentation absente : un poste compromis peut tout atteindre [E36][E203] | Interne
- [non soutenue] | **MFA systématique** | Déploiement cible Entra ID / Keycloak avec MFA FIDO2 / Carte CPS pour les soignants [E45]. | As-Is : pas de MFA sur le VPN → 60% des comptes sans MFA, simple login/mot de passe [E7
- [non soutenue] | **VLAN IoT vs VLAN Wi-Fi** | Isolation logique stricte (micro-segmentation) pour la cible To-Be. Actuellement : routage direct entre automate et cœur réseau, VLAN IoT non cloisonné [E15]. | Écart documen
- [non soutenue] | **SOC / EDR / SIEM** | Absence initiale des 3 briques SOC centralisé. Projet doit répondre aux exigences NIS 2/RGPD/HDS. | Aucun SOC/EDR/SIEM déployé en As-Is ; Blue Team & SOC non implémentée [E140][E38
- [non soutenue] | **Postes irréductibles (Windows 7/XP Embedded)** | ~5% du parc (~200 postes) ne peuvent être patchés ou upgradées. Utilisés pour l'imagerie médicale et automates vieux scanners. | Pas de plan de remplace

Contrôle n°4 — Étape 2 · Choix de la méthode, version 1 : NON CONFORME

- Contrôleur : ollama/gemma4:12b · 2026-10-12 14:11:16
- Ce qui n'allait pas : MAL LU : STRIDE permet de valider les frontières de confiance [E146] — Fiche_d_Audit_Technique_-_État_des_Lieux_SanteTech__As-Is_.pdf : Le document mentionne une "Interconnexion MPLS centralisée" et précise "Aucune isolation inter-sites", ce qui contredit l'idée de frontières de confiance actuelles. MAL LU : LINDDUN analyse la confidentialité [E149] — FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf : Le document mentionne le RGPD mais ne définit pas LINDDUN comme l'outil d'analyse de la confidentialité. INVENTÉ : STRIDE : python3 -m tools.methodes.stride.check_dfd ... — Aucun document ne mentionne ces commandes ou outils spécifiques. INVENTÉ : LINDDUN : python3 -m tools.methodes.linddun ... — Aucun document ne mentionne ces commandes ou outils spécifiques. INVENTÉ : EBIOS RM : python3 -m tools.methodes.ebios ... — Aucun document ne mentionne ces commandes ou outils spécifiques. MAL LU : EBIOS RM étend l'analyse au-delà du DFD [E140] — Fiche_d_Audit_Technique_-_État_des_Lieux_SanteTech__As-Is_.pdf : Le document ne mentionne pas EBIOS RM ni l'extension au-delà du DFD. OMIS : Le document FAQ mentionne 150 000 dossiers patients, mais le livrable ne mentionne pas cette volumétrie dans la justification du choix des méthodes. OMIS : Le document Fiche_d_Audit mentionne 4 500 collaborateurs, mais cette donnée est absente du livrable. OMIS : Le document Fiche_d_Audit mentionne 3 200 postes de travail, mais cette donnée est absente du livrable. OMIS : Le document FAQ mentionne un budget Build de 1,5 million d'euros, mais cette donnée est absente du livrable. OMIS : Le document FAQ mentionne un budget Run de 300 k€/an, mais cette donnée est absente du livrable. OMIS : Le document Fiche_d_Audit mentionne l'utilisation de protocoles SMBv1, mais cette donnée est absente du livrable.
- Ce qui a changé depuis la version précédente :

Première version de l'étape.

- Lignes à relire (les deux vérificateurs divergent sur la preuve citée) :
- [non soutenue] | **STRIDE** | DFD | Bas | Applications web | Données critiques, migration cloud, RGPD (menaces de type *Disclosure of personal data*) [E149][E203] |
- [non soutenue] | **LINDDUN** | Données personnelles | Moyen | RGPD | Circulation de données sensibles (p. ex. dossiers patients) [E149][E203] |
- [non soutenue] | **EBIOS RM** | Organisation | Elevé | Administrations/OIV | Conformité NIS 2, audit HDS, analyse stratégique [E140][E205] |
- [non soutenue] | **PASTA** | Objectifs métier | Moyen | Impact business | Justification économique des mesures de sécurité [E142][E150] |
- [non soutenue] - **STRIDE + LINDDUN** : Le projet manipule des données patients critiques [A19] et migre vers un cloud hybride [A10], nécessitant une analyse technique des menaces via STRIDE (DFD [E146]) et une spécialis

- [non soutenue] - **EBIOS RM** (atelier A3/A4) : L'analyse doit couvrir l'écosystème (fournisseurs Cloud HDS [A11], micro-segmentation [A13]) comme vecteur d'attaque [E140]. EBIOS RM étend l'analyse au-delà du DFD [E140],

Contrôle n°5 — Étape 2 · Choix de la méthode, version 2 : NÉCESSITE UNE VALIDATION HUMAINE

- Contrôleur : contrôle déterministe (termes absents des intrants, citations) · 2026-10-12 14:14:15
- Ce qui n'allait pas : 02-methodes.md : identifiants de preuve INEXISTANTS à retirer ou remplacer : [E5], [E9], [E38], [E40], [E7].
- Ce qui a changé depuis la version précédente :

51 ligne(s) ajoutée(s), 21 retirée(s). Retiré : # Dossier de preuves — étape 2 Retiré : > Ce dossier REMPLACE la lecture des documents d'origine : ne relis pas d'autre fichier. Il reproduit le TEXTE des documents (sections et tableaux, avec leur e… Retiré : | Méthode | Point de départ | Effort | Idéal pour | Quand choisir | Retiré : | **STRIDE** | DFD | Bas | Applications web | Données critiques, migration cloud, RGPD (menaces de type *Disclosure of personal data*) [E149][E203] | Retiré : | **LINDDUN** | Données personnelles | Moyen | RGPD | Circulation de données sensibles (p. ex. dossiers patients) [E149][E203] | Ajouté : # Choix de méthode — Analyse des risques SanteTech Ajouté : Le projet « SanteTech » vise la sécurisation d'un SI hospitalier hérité (legacy) migrant vers un cloud hybride, avec 150 000 dossierspatients actifs [E223], 4 … Ajouté : | Méthode | Point de départ | Effort* | Idéal pour | Quand choisir | Ajouté : | **STRIDE** | DFD / Frontières de confiance | Bas | Applications web, systèmes distribués [E146] | Données critiques (dossiers patients), migration cloud hybr… Ajouté : | **LINDDUN** | Données personnelles / RGPD | Moyen | Confidentialité, vie privée [E149] | Circulation de données sensibles (dossiers patients 150 k+) ; spécia…

- Pourquoi une validation humaine : Le contrôle signale toujours des points non conformes après les reprises demandées à l'agent : 02-methodes.md : identifiants de preuve INEXISTANTS à retirer ou remplacer : [E5], [E9], [E38], [E40], [E7].
- Quoi vérifier : Pour chaque point signalé, chercher l'affirmation dans `02-methodes.md` puis dans les documents d'origine ; si elle n'y est pas, c'est une invention à retirer ; si elle y est, le contrôle s'est trompé.
- Lignes à relire (les deux vérificateurs divergent sur la preuve citée) :
- [non soutenue] Le projet « SanteTech » vise la sécurisation d'un SI hospitalier hérité (legacy) migrant vers un cloud hybride, avec 150 000 dossierspatients actifs [E223], 4 500 collaborateurs et une flotte de ~3 200 pos
- [non soutenue] | **STRIDE** | DFD / Frontières de confiance | Bas | Applications web, systèmes distribués [E146] | Données critiques (dossiers patients), migration cloud hybride, API Gateway télémédecine [E231], menaces

- [non soutenue] | **LINDDUN** | Données personnelles / RGPD | Moyen | Confidentialité, vie privée [E149] | Circulation de données sensibles (dossiers patients 150 k+) ; spécialise l'analyse sur *D*isclosure of personal da
- [non soutenue] | **PASTA** | Objectifs métier | Moyen | Impact économique business [E207] | Justification des investissements de sécurité (ROI), alignement avec la stratégie COMEX ; utilisé en complément pour prioriser l
- [non soutenue] | **DREAD / CVSS** | Priorisation | Variable | Scoring menaces/ vulnérabilités [E150] | Vulnérabilités connues (ProxyShell, SMBv1) ; DREAD subjectif pour triage rapide, CVSS v4.0 objectif pour rapport à la
- [non soutenue] - **Justification de l'association** : STRIDE valide la sécurité technique des frontières (A17, A22), tandis que LINDDUN spécialise l'analyse sur les menaces RGPD/Dataprivacy ; sans LINDDUN, les menaces de
- [non soutenue] L'écosystème externe (fournisseurs Cloud HDS, prestataires IT) représente un vecteur d'attaque majeur [E140][A11].
- [non soutenue] - EBIOS RM peut étendre l'analyse au-delà du DFD en traitant les risques liés aux sous-traitants et hébergeurs tiers (A11). Cependant, aucun des documents ne mentionne une extension explicite « au-delà du
- [non soutenue] - **Justification retenue** : Le choix de l'appliquer reste optionnel pour élargir la couverture aux risques organisationnels (gestion des prestataires Cloud, sous-traitance SaaS), surtout si la direction
- [non soutenue] - **LINDDUN** : KU Leuven (RGPD, vie privée/ confidentialité) — grille DPF incluse dans les livrables LINDDUN [E149]

Contrôle n°6 — Étape 3 · Menaces, version 1 : NON CONFORME

- Contrôleur : contrôle déterministe (termes absents des intrants, citations) · 2026-10-12 14:29:52
- Ce qui n'allait pas : 03-menaces.md : identifiants de preuve INEXISTANTS à retirer ou remplacer : [E7], [E5], [E38], [E40], [E9], [E32], [E3], [E57], [E36], [E271], [E274], [E277], [E2], [E25], [E18], [E16]. Identifiants utilisés mais jamais définis dans un tableau — définis-les ou utilise un identifiant existant : A5 (03-menaces.md); A7 (03-menaces.md); R2 (03-menaces.md). 03-menaces.md : texte d'attente à remplacer par l'information ou par « non documenté » : | M021 | A07 - Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison S | | M025 | A07 - Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison S | | M032 | A09 - Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion id
- Ce qui a changé depuis la version précédente :

Première version de l'étape.

- Lignes à relire (les deux vérificateurs divergent sur la preuve citée) :

- [non soutenue] | M001 | A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service | STRIDE-T | Attentat cyber : accès aux dossiers patients via exploitation des vulnérabilités legacy sur Citrix/RDS avec RDP non
- [non soutenue] | M002 | A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service | LINDDUN-Disclosure | Fuite de données patients : progression horizontale (MOVElaterally) depuis les 185 serveurs legacy vers au
- [non soutenue] | M003 | A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service | STRIDE-I | Injection malveillante : modification des dossiers patients pendant la migration legacy-to-cloud via API Gateway non
- [non soutenue] | M004 | A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service | STRIDE-S | Substitution d'imagerie : injection de fichiers DICOM malformés ou corrompus via SMBv1 non patché dans les baies SAN locales
- [non soutenue] | M005 | A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service | STRIDE-R | Ransomware : chiffrement des images DICOM stockées sur baies SAN sans EDR, exploitant les failles de partage SMB [E203][EBIO
- [non soutenue] | M006 | A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service | LINDDUN-Disclosure | Accès non autorisé aux images médicales : compromission d'un cache local en clinique via VLAN IoT non cloisonné (1
- [non soutenue] | M012 | A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet | STRIDE-R | Ransomware sur accès distant : compromission du FortiGate via failles de certificats TLS non renouvelés,
- [non soutenue] | M016 | A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service | STRIDE-D | Destruction d'images DICOM : corruption des baies SAN locales via malware SMB qui supprime les données critiques [E203][EBIO
- [non soutenue] | M017 | A06 - Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants
- [non soutenue] | M018 | A06 - Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants

Contrôle n°7 — Étape 3 · Menaces, version 2 : NÉCESSITE UNE VALIDATION HUMAINE

- Contrôleur : contrôle déterministe (termes absents des intrants, citations) · 2026-10-12 14:33:41
- Ce qui n'allait pas : 03-menaces.md : identifiants de preuve INEXISTANTS à retirer ou remplacer : [E7], [E5], [E38], [E9], [E2], [E40], [E32], [E3], [E57], [E36], [E271], [E274], [E277], [E25], [E18], [E16]. Identifiants utilisés mais jamais définis dans un tableau — définis-les ou utilise un identifiant existant : A3 (03-menaces.md); A5 (03-menaces.md); A7 (03-menaces.md). 03-menaces.md : texte d'attente à remplacer par l'information ou par « non documenté » : | M069 | A21 — Infrastructure Cloud — Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/OVHcloud/Azure (pas d'imposition) [E142]

- Ce qui a changé depuis la version précédente :

119 ligne(s) ajoutée(s), 118 retirée(s). Retiré : | M017 | A06 - Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification pa… Retiré : | M018 | A06 - Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification pa… Retiré : | M019 | A06 - Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification pa… Retiré : | M020 | A06 - Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification pa… Retiré : | M021 | A07 - Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibl… Ajouté : | M017 | A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification pa… Ajouté : | M018 | A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification pa… Ajouté : | M019 | A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification pa… Ajouté : | M020 | A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification pa… Ajouté : | M021 | A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibl…

- Pourquoi une validation humaine : Le contrôle signale toujours des points non conformes après les reprises demandées à l'agent : 03-menaces.md : identifiants de preuve INEXISTANTS à retirer ou remplacer : [E7], [E5], [E38], [E9], [E2], [E40], [E32], [E3], [E57], [E36], [E271], [E274], [E277], [E25], [E18], [E16]. Identifiants utilisés mais jamais définis dans un tableau — définis-les ou utilise un identifiant existant : A3 (03-menaces.md); A5 (03-menaces.md); A7 (03-menaces.md). 03-menaces.md : texte d'attente à remplacer par l'information ou par « non documenté » : | M069 | A21 — Infrastructure Cloud — Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/OVHcloud/ Azure (pas d'imposition) [E142]
- Quoi vérifier : Pour chaque point signalé, chercher l'affirmation dans `03-menaces.md` puis dans les documents d'origine ; si elle n'y est pas, c'est une invention à retirer ; si elle y est, le contrôle s'est trompé.
- Lignes à relire (les deux vérificateurs divergent sur la preuve citée) :
- [non soutenue] | M001 | A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service | STRIDE-T | Attentat cyber : accès aux dossiers patients via exploitation des vulnérabilités legacy sur Citrix/RDS avec RDP non
- [non soutenue] | M002 | A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service | LINDDUN-Disclosure | Fuite de données patients : progression horizontale (MOVElaterally) depuis les 185 serveurs legacy vers au

- [non soutenue] | M003 | A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service | STRIDE-I | Injection malveillante : modification des dossiers patients pendant la migration legacy-to-cloud via API Gateway non
- [non soutenue] | M004 | A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service | STRIDE-S | Substitution d'imagerie : injection de fichiers DICOM malformés ou corrompus via SMBv1 non patché dans les baies SAN locales
- [non soutenue] | M005 | A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service | STRIDE-R | Ransomware : chiffrement des images DICOM stockées sur baies SAN sans EDR, exploitant les failles de partage SMB [E203][EBIO
- [non soutenue] | M006 | A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service | LINDDUN-Disclosure | Accès non autorisé aux images médicales : compromission d'un cache local en clinique via VLAN IoT non cloisonné (1
- [non soutenue] | M012 | A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet | STRIDE-R | Ransomware sur accès distant : compromission du FortiGate via failles de certificats TLS non renouvelés,
- [non soutenue] | M016 | A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service | STRIDE-D | Destruction d'images DICOM : corruption des baies SAN locales via malware SMB qui supprime les données critiques [E203][EBIO
- [non soutenue] | M017 | A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants
- [non soutenue] | M018 | A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants

Contrôle n°8 — Étape 4 · Évaluation, version 1 : NON CONFORME

- Contrôleur : contrôle déterministe (termes absents des intrants, citations) · 2026-10-12 14:51:27
- Ce qui n'allait pas : 04-evaluation.md : termes absents des intrants à retirer, ou à présenter explicitement comme une hypothèse à confirmer : jwt. Ne les mentionne pas du tout, pas même pour dire qu'ils sont absents. 04-evaluation.md : identifiants de preuve INEXISTANTS à retirer ou remplacer : [E7], [E5], [E38], [E24], [E240], [E2], [E9], [E40], [E30], [E4], [E32], [E3], [E57], [E36], [E271], [E274], [E277], [E25], [E18], [E16]. Identifiants utilisés mais jamais définis dans un tableau — définis-les ou utilise un identifiant existant : A3 (04-evaluation.md); A5 (04-evaluation.md); A7 (04-evaluation.md); R2 (04-evaluation.md). 04-evaluation.md : texte d'attente à remplacer par l'information ou par « non documenté » : | M069 | A21 — Infrastructure Cloud — Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/OVHcloud/Azure (pas d'imposition) [E142]
- Ce qui a changé depuis la version précédente :

Première version de l'étape.

- Lignes à relire (les deux vérificateurs divergent sur la preuve citée) :
- [non soutenue] | M001 | A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service (STRIDE-T) Attentat cyber : accès aux dossiers patients via exploitation des vulnérabilités legacy sur Citrix/RDS avec RDP non fi
- [non soutenue] | M002 | A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service (LINDDUN-Disclosure) Fuite de données patients : progression horizontale (MOVElaterally) depuis les 185 serveurs legacy vers autr
- [non soutenue] | M003 | A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service (STRIDE-I) Injection malveillante : modification des dossiers patients pendant la migration legacy-to-cloud via API Gateway non s
- [non soutenue] | M004 | A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service (STRIDE-S) Substitution d'imagerie : injection de fichiers DICOM malformés ou corrompus via SMBv1 non patché dans les baies SAN locales v
- [non soutenue] | M005 | A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service (STRIDE-R) Ransomware : chiffrement des images DICOM stockées sur baies SAN sans EDR, exploitant les failles de partage SMB [E203][EBIOS-
- [non soutenue] | M008 | A03 — Messagerie Sécurisée de Santé (Mél) — Logiciel / Service (LINDDUN-Disclosure) Fuite d'emails sensibles : exfiltration via OWA vulnérable et absence de filtrage SSL sur webmail.santetech-sant
- [non soutenue] | M010 | A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet (STRIDE-I) Injection de session : authentification compromise par absence de MFA sur 60% des comptes AD, permettant pr
- [non soutenue] | M012 | A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet (STRIDE-R) Ransomware sur accès distant : compromission du FortiGate via failles de certificats TLS non renouvelés, ex
- [non soutenue] | M013 | A05 — Webmail de Santé & Accès Externe (OWA) — Service / Site Internet (STRIDE-E) Escalade de privilèges : exfiltration et modification des données via OWA Exchange 2016 non patché sur DMZ, sans f
- [non soutenue] | M014 | A05 — Webmail de Santé & Accès Externe (OWA) — Service / Site Internet (LINDDUN-Disclosure) Fuite massive via campagnes Spraying : botnets exploitant Exchange 2016 DMZ pour exfiltrer données patie

Contrôle n°9 — Étape 4 · Évaluation, version 2 : NÉCESSITE UNE VALIDATION HUMAINE

- Contrôleur : contrôle déterministe (termes absents des intrants, citations) · 2026-10-12 14:56:38
- Ce qui n'allait pas : 04-evaluation.md : termes absents des intrants à retirer, ou à présenter explicitement comme une hypothèse à confirmer : jwt. Ne les mentionne pas du tout, pas même pour dire qu'ils sont absents. 04-evaluation.md : identifiants de preuve INEXISTANTS à retirer ou remplacer : [E7], [E5], [E38], [E24], [E240], [E2], [E9],

[E40], [E30], [E4], [E32], [E3], [E57], [E36], [E271], [E274], [E277], [E25], [E18], [E16]. Identifiants utilisés mais jamais définis dans un tableau — définis-les ou utilise un identifiant existant : A3 (04-evaluation.md); A5 (04-evaluation.md); A7 (04-evaluation.md); R2 (04-evaluation.md). 04-evaluation.md : texte d'attente à remplacer par l'information ou par « non documenté » : | M067 | A21 — Infrastructure Cloud — Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/OVHcloud/Azure (pas d'imposition) [E142]

- Ce qui a changé depuis la version précédente :

12 ligne(s) ajoutée(s), 12 retirée(s). Retiré : | M061 | A19 — Donnée/Structure — Données Patients (DPI) (STRIDE-R) Repudiation des accès via logs citrix incomplets sur RDS legacy ne traçant pas les connexio… Retiré : | M062 | A19 — Donnée/Structure — Données Patients (DPI) (LINDDUN-D) Disclosure de 150 000 dossiers via API Gateway non sécurisée pour télémédecine (no authz, … Retiré : | M063 | A20 — Matériel IoT — Dispositifs Médicaux Connectés (STRIDE-S) Spoofing des commandes médicales via protocole Wi-Fi 6 non crypté (moniteurs, pompes pe… Retiré : | M064 | A20 — Matériel IoT — Dispositifs Médicaux Connectés (STRIDE-T) Tamper des paramètres d'automates via micro-noyaux temps réel non patchables permettant… Retiré : | M065 | A20 — Matériel IoT — Dispositifs Médicaux Connectés (STRIDE-D) Disclosure de logs médicaux via exploitation Bluetooth LE sur appareils non isolés rése… Ajouté : | M061 | A19 — Donnée/Structure — Données Patients (DPI) (STRIDE-R) Repudiation des accès via logs citrix incomplets sur RDS legacy ne traçant pas les connexio… Ajouté : | M062 | A19 — Donnée/Structure — Données Patients (DPI) (LINDDUN-D) Disclosure de 150 000 dossiers via API Gateway non sécurisée pour télémédecine (no authz, … Ajouté : | M063 | A20 — Matériel IoT — Dispositifs Médicaux Connectés (STRIDE-S) Spoofing des commandes médicales via protocole Wi-Fi 6 non crypté (moniteurs, pompes pe… Ajouté : | M064 | A20 — Matériel IoT — Dispositifs Médicaux Connectés (STRIDE-T) Tamper des paramètres d'automates via micro-noyaux temps réel non patchables permettant… Ajouté : | M065 | A20 — Matériel IoT — Dispositifs Médicaux Connectés (STRIDE-D) Disclosure de logs médicaux via exploitation Bluetooth LE sur appareils non isolés rése…

- Pourquoi une validation humaine : Le contrôle signale toujours des points non conformes après les reprises demandées à l'agent : 04-evaluation.md : termes absents des intrants à retirer, ou à présenter explicitement comme une hypothèse à confirmer : jwt. Ne les mentionne pas du tout, pas même pour dire qu'ils sont absents. 04-evaluation.md : identifiants de preuve INEXISTANTS à retirer ou remplacer : [E7], [E5], [E38], [E24], [E240], [E2], [E9], [E40], [E30], [E4], [E32], [E3], [E57], [E36], [E271], [E274], [E277], [E25], [E18], [E16]. Identifiants utilisés mais jamais définis dans un tableau — définis-les ou utilise un identifiant existant : A3 (04-evaluation.md); A5 (04-evaluation.md); A7 (04-evaluation.md); R2 (04-evaluation.md). 04-evaluation.md : texte d'attente à remplacer par l'information ou par « non documenté » : | M067 | A21 — Infrastructure Cloud — Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/OVHcloud/Azure (pas d'imposition) [E142]

- Quoi vérifier : Pour chaque point signalé, chercher l'affirmation dans `04-evaluation.md` puis dans les documents d'origine ; si elle n'y est pas, c'est une invention à retirer ; si elle y est, le contrôle s'est trompé.
- Lignes à relire (les deux vérificateurs divergent sur la preuve citée) :
- [non soutenue] | M001 | A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service (STRIDE-T) Attentat cyber : accès aux dossiers patients via exploitation des vulnérabilités legacy sur Citrix/RDS avec RDP non fi
- [non soutenue] | M002 | A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service (LINDDUN-Disclosure) Fuite de données patients : progression horizontale (MOVElaterally) depuis les 185 serveurs legacy vers autr
- [non soutenue] | M003 | A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service (STRIDE-I) Injection malveillante : modification des dossiers patients pendant la migration legacy-to-cloud via API Gateway non s
- [non soutenue] | M004 | A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service (STRIDE-S) Substitution d'imagerie : injection de fichiers DICOM malformés ou corrompus via SMBv1 non patché dans les baies SAN locales v
- [non soutenue] | M005 | A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service (STRIDE-R) Ransomware : chiffrement des images DICOM stockées sur baies SAN sans EDR, exploitant les failles de partage SMB [E203][EBIOS-
- [non soutenue] | M008 | A03 — Messagerie Sécurisée de Santé (Mél) — Logiciel / Service (LINDDUN-Disclosure) Fuite d'emails sensibles : exfiltration via OWA vulnérable et absence de filtrage SSL sur webmail.santetech-sant
- [non soutenue] | M010 | A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet (STRIDE-I) Injection de session : authentification compromise par absence de MFA sur 60% des comptes AD, permettant pr
- [non soutenue] | M012 | A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet (STRIDE-R) Ransomware sur accès distant : compromission du FortiGate via failles de certificats TLS non renouvelés, ex
- [non soutenue] | M013 | A05 — Webmail de Santé & Accès Externe (OWA) — Service / Site Internet (STRIDE-E) Escalade de privilèges : exfiltration et modification des données via OWA Exchange 2016 non patché sur DMZ, sans f
- [non soutenue] | M014 | A05 — Webmail de Santé & Accès Externe (OWA) — Service / Site Internet (LINDDUN-Disclosure) Fuite massive via campagnes Spraying : botnets exploitant Exchange 2016 DMZ pour exfiltrer données patie

Contrôle n°10 — Étape 5 · Traitement, version 1 : NÉCESSITE UNE VALIDATION HUMAINE

- Contrôleur : contrôle déterministe (termes absents des intrants, citations) · 2026-10-12 15:19:49
- Ce qui n'allait pas : 05-traitement.md : identifiants de preuve INEXISTANTS à retirer ou remplacer : [E7], [E5], [E24], [E240], [E2], [E38], [E9], [E12], [E13], [E40], [E32], [E3], [E57], [E36], [E271], [E274], [E277], [E25], [E18], [E16]. Identifiants utilisés mais jamais définis dans un

tableau — définis-les ou utilise un identifiant existant : A3 (05-traitement.md); A7 (05-traitement.md).
- Ce qui a changé depuis la version précédente :

Première version de l'étape.

- Pourquoi une validation humaine : Le contrôle signale toujours des points non conformes après les reprises demandées à l'agent : 05-traitement.md : identifiants de preuve INEXISTANTS à retirer ou remplacer : [E7], [E5], [E24], [E240], [E2], [E38], [E9], [E12], [E13], [E40], [E32], [E3], [E57], [E36], [E271], [E274], [E277], [E25], [E18], [E16]. Identifiants utilisés mais jamais définis dans un tableau — définis-les ou utilise un identifiant existant : A3 (05-traitement.md); A7 (05-traitement.md).
- Quoi vérifier : Pour chaque point signalé, chercher l'affirmation dans `05-traitement.md` puis dans les documents d'origine ; si elle n'y est pas, c'est une invention à retirer ; si elle y est, le contrôle s'est trompé.
- Lignes à relire (les deux vérificateurs divergent sur la preuve citée) :
- [non soutenue] | M001 | A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service (STRIDE-T) Attentat cyber : accès aux dossiers patients via exploitation des vulnérabilités legacy sur Citrix/RDS avec RDP non fi
- [non soutenue] | M002 | A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service (LINDDUN-Disclosure) Fuite de données patients : progression horizontale (MOVElaterally) depuis les 185 serveurs legacy vers autr
- [non soutenue] | M003 | A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service (STRIDE-I) Injection malveillante : modification des dossiers patients pendant la migration legacy-to-cloud via API Gateway non s
- [non soutenue] | M004 | A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service (STRIDE-S) Substitution d'imagerie : injection de fichiers DICOM malformés ou corrompus via SMBv1 non patché dans les baies SAN locales v
- [non soutenue] | M005 | A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service (STRIDE-R) Ransomware : chiffrement des images DICOM stockées sur baies SAN sans EDR, exploitant les failles de partage SMB [E203][EBIOS-
- [non soutenue] | M006 | A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service (LINDDUN-Disclosure) Accès non autorisé aux images médicales : compromission d'un cache local en clinique via VLAN IoT non cloisonné (10.
- [non soutenue] | M007 | A03 — Messagerie Sécurisée de Santé (Mél) — Logiciel / Service (STRIDE-S) ProxyShell exploitation : accès distant aux dossiers Exchange 2016 DMZ via vulnérabilité ProxyShell/Spraying sur webmail.s
- [non soutenue] | M008 | A03 — Messagerie Sécurisée de Santé (Mél) — Logiciel / Service (LINDDUN-Disclosure) Fuite d'emails sensibles : exfiltration via OWA vulnérable et absence de filtrage SSL sur webmail.santetech-sant
- [non soutenue] | M009 | A03 — Messagerie Sécurisée de Santé (Mél) — Logiciel / Service (STRIDE-E) Modification d'identité : création de comptes malveillants ou usurpation d'identité via exploitation Exchange 2016 sans MF

- [non soutenue] | M010 | A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet (STRIDE-I) Injection de session : authentification compromise par absence de MFA sur 60% des comptes AD, permettant pr

Contrôle n°11 — Étape 6 · Registre à valider, version 1 : CONFORME

- Contrôleur : contrôle par le programme (reprise ligne à ligne des étapes 3 à 5) · 2026-10-12 15:19:49
- Ce qui n'allait pas : rien à signaler
- Ce qui a changé depuis la version précédente :

Première version de l'étape.

Contrôle n°12 — Étape 7 · Synthèse, version 1 : CONFORME

- Contrôleur : contrôle par le programme (reprise ligne à ligne des étapes 3 à 5) · 2026-10-12 15:21:49
- Ce qui n'allait pas : rien à signaler
- Ce qui a changé depuis la version précédente :

Première version de l'étape.

Contrôle n°13 — Relecture finale, version 1 : NÉCESSITE UNE VALIDATION HUMAINE

- Contrôleur : ollama/gemma4:12b · 2026-10-12 15:22:03
- Ce qui n'allait pas : - "Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11" (A10) - "Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]" (A24) - "Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139]" (A25) - "Dossier Patient Informatisé (DPI) Nexus" (A01) - "Messagerie Sécurisée de Santé (Mél)" (A03) - "Portail VPN Télétravail & Praticiens Libéraux" (A04) - "Application métier — DPI Progiciel Nexus" (A18) - "Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/OVHcloud/Azure (pas d'imposition) [E142]" (A21)
- Ce qui a changé depuis la version précédente :

Première version de l'étape.

- Pourquoi une validation humaine : Le contrôle signale toujours des points non conformes après les reprises demandées à l'agent : - "Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11" (A10) - "Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]" (A24) - "Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139]" (A25) - "Dossier Patient Informatisé (DPI) Nexus" (A01) - "Messagerie Sécurisée de Santé (Mél)" (A03) - "Portail VPN Télétravail & Praticiens Libéraux" (A04) -

"Application métier — DPI Progiciel Nexus" (A18) - "Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/OVHcloud/Azure (pas d'imposition) [E142]" (A21)

- Quoi vérifier : Pour chaque point signalé, chercher l'affirmation dans `registre-risques.md`, `SYNTHESE.md` puis dans les documents d'origine ; si elle n'y est pas, c'est une invention à retirer ; si elle y est, le contrôle s'est trompé.

Fiches de traçabilité des risques

Pour chaque risque : l'actif, la menace, l'évaluation, le traitement, la validation et les preuves, avec un lien vers chaque ligne d'origine.

M001 — Attentat cyber : accès aux dossiers patients via exploitation des vulnérabilités legacy sur Citrix/RDS avec RD

Actif	A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service
Menace	STRIDE-T — Attentat cyber : accès aux dossiers patients via exploitation des vulnérabilités legacy sur Citrix/RDS avec RDP non filtré, permettant l'exfiltration de données médicales critiques [E203][A16] [EBIOS-RM-A3]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Serveur Citrix/RDS non filtré [E203], exposition à l'exploitation de vulnérabilités legacy [E203]
Traitement	Réduire — MFA FIDO2 [E203], segmentation VLAN [E203]
Sources	ANSSI-HYGIENE, ISO27002-8.8
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M002 — Fuite de données patients : progression horizontale (MOVElaterally) depuis les 185 serveurs legacy vers autres

Actif	A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service
Menace	LINDDUN-Disclosure — Fuite de données patients : progression horizontale (MOVElaterally) depuis les 185 serveurs legacy vers autres systèmes via absence de micro-segmentation sur le VLAN local [10.100.0.0/16] [E203][A17][LINDDUN-Disclosure]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	VLAN local non cloisonné (10.100.0.0/16) avec progression horizontale [E203], absence de micro-segmentation [E203]
Traitement	Réduire — Micro-segmentation [E203], cloisonnement VLAN [E203]
Sources	ANSSI-RECYF, ISO27002-8.11
Risque résiduel	Medium
Validation	À valider par l'analyste
Preuves	[E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M003 — Injection malveillante : modification des dossiers patients pendant la migration legacy-to-cloud via API Gatew

Actif	A01 — Dossier Patient Informatisé (DPI) Nexus — Logiciel / Service
Menace	STRIDE-I — Injection malveillante : modification des dossiers patients pendant la migration legacy-to-cloud via API Gateway non sécurisée ou failles RDS [E203][A16]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	API Gateway non sécurisée [E203], failles RDS non patchées [E203]
Traitement	Réduire — API Gateway sécurisée [E203], patch RDS [E203]
Sources	ANSSI-HYGIENE, ISO27002-8.13
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M004 — Substitution d'imagerie : injection de fichiers DICOM malformés ou corrompus via SMBv1 non patché dans les bai

Actif	A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service
Menace	STRIDE-S — Substitution d'imagerie : injection de fichiers DICOM malformés ou corrompus via SMBv1 non patché dans les baies SAN locales vieillissantes [E203][PASTA-A5]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	SMBv1 non patché [E203], vulnérabilité CVE-2017-7482 [E203]
Traitement	Réduire — SMBv1 désactivé [E203], patch CVE-2017-7482 [E203]
Sources	ANSSI-HYGIENE, ISO27002-8.14
Risque résiduel	Medium
Validation	À valider par l'analyste
Preuves	[E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M005 — Ransomware : chiffrement des images DICOM stockées sur baies SAN sans EDR, exploitant les failles de partage S

Actif	A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service
Menace	STRIDE-R — Ransomware : chiffrement des images DICOM stockées sur baies SAN sans EDR, exploitant les failles de partage SMB [E203][EBIOS-RM-A3]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Partage SMB non sécurisé [E203], absence d'EDR [E203]
Traitement	Réduire — EDR [E203], chiffrement SMB [E203]
Sources	EBIOS-RM-A3, ISO27002-8.15
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M006 — Accès non autorisé aux images médicales : compromission d'un cache local en clinique via VLAN IoT non cloisonn

Actif	A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service
Menace	LINDDUN-Disclosure — Accès non autorisé aux images médicales : compromission d'un cache local en clinique via VLAN IoT non cloisonné (10.1.30.0/24, routage direct vers automates) [E203][E7]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	VLAN IoT (10.1.30.0/24) non cloisonné [E203], routage direct vers automates [E203]
Traitement	Réduire — VLAN IoT cloisonné [E203], routage filtré [E203]
Sources	ANSSI-RECYF, ISO27002-8.16
Risque résiduel	Medium
Validation	À valider par l'analyste
Preuves	[E7] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M007 — ProxyShell exploitation : accès distant aux dossiers Exchange 2016 DMZ via vulnérabilité ProxyShell/Spraying s

Actif	A03 — Messagerie Sécurisée de Santé (Mél) — Logiciel / Service
Menace	STRIDE-S — ProxyShell exploitation : accès distant aux dossiers Exchange 2016 DMZ via vulnérabilité ProxyShell/Spraying sur webmail.santetech-sante.fr [E7][E5]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Vulnérabilité ProxyShell/Spraying [E7][E5], absence de MFA sur Exchange 2016 [E7][E5]
Traitement	Réduire — MFA sur Exchange [E203], patch ProxyShell [E203]
Sources	ANSSI-HYGIENE
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E5] [E7] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M008 — Fuite d'emails sensibles : exfiltration via OWA vulnérable et absence de filtrage SSL sur webmail.santetech-sa

Actif	A03 — Messagerie Sécurisée de Santé (Mél) — Logiciel / Service
Menace	LINDDUN-Disclosure — Fuite d'emails sensibles : exfiltration via OWA vulnérable et absence de filtrage SSL sur webmail.santetech-sante.fr exposant données patients [E7][E5]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	OWA vulnérable [E203][E5], absence de filtrage SSL [E203][E5]
Traitement	Réduire — Filtrage SSL [E203], OWA sécurisé [E203]
Sources	ANSSI-HYGIENE
Risque résiduel	Medium
Validation	À valider par l'analyste
Preuves	[E5] [E7] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M009 — Modification d'identité : création de comptes malveillants ou usurpation d'identité via exploitation Exchange

Actif	A03 — Messagerie Sécurisée de Santé (Mél) — Logiciel / Service
Menace	STRIDE-E — Modification d'identité : création de comptes malveillants ou usurpation d'identité via exploitation Exchange 2016 sans MFA [E7][A19]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Absence de MFA sur Exchange 2016 [E7][A19], exploitation possible [E7][A19]
Traitement	Réduire — MFA sur Exchange [E203], monitoring identités [E203]
Sources	ANSSI-HYGIENE
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E7] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M010 — Injection de session : authentification compromise par absence de MFA sur 60% des comptes AD, permettant prise

Actif	A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet
Menace	STRIDE-I — Injection de session : authentification compromise par absence de MFA sur 60% des comptes AD, permettant prise de contrôle distante via vpn.santetech-sante.fr [E7][A19][EBIOS-RM-A3]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Absence de MFA sur 60% des comptes AD [E7][A19], injection de session via vpn.santetech-sante.fr [E203]
Traitement	Réduire — MFA sur AD [E203], audit comptes [E203]
Sources	ANSSI-HYGIENE
Risque résiduel	Medium
Validation	À valider par l'analyste
Preuves	[E7] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M011 — Usurpation d'identité légitime : accès non filtré au portail VPN permet impersonner des praticiens libéraux ou

Actif	A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet
Menace	LINDDUN-L — Usurpation d'identité légitime : accès non filtré au portail VPN permet impersonner des praticiens libéraux ou soignants pour fraudes [E7][A5]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Portail VPN non filtré [E7][A5], risque d'usurpation d'identité [E7][A5]
Traitement	Réduire — Authentification multifacteur [E203], contrôle d'accès [E203]
Sources	ANSSI-RECYF
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E7] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M012 — Ransomware sur accès distant : compromission du FortiGate via failles de certificats TLS non renouvelés, expos

Actif	A04 — Portail VPN Télétravail & Praticiens Libéraux — Service / Site Internet
Menace	STRIDE-R — Ransomware sur accès distant : compromission du FortiGate via failles de certificats TLS non renouvelés, exposant le réseau interne [E203][A17]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Certificats TLS non renouvelés [E203][A17], exposition du réseau interne [E203][A17]
Traitement	Réduire — Renouvellement TLS [E203], audit certificats [E203]
Sources	ANSSI-HYGIENE, ISO27002-8.22
Risque résiduel	Medium
Validation	À valider par l'analyste
Preuves	[E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M013 — Escalade de privilèges : exfiltration et modification des données via OWA Exchange 2016 non patché sur DMZ, sa

Actif	A05 — Webmail de Santé & Accès Externe (OWA) — Service / Site Internet
Menace	STRIDE-E — Escalade de privilèges : exfiltration et modification des données via OWA Exchange 2016 non patché sur DMZ, sans filtrage SSL [E7][E5]
Évaluation	Probabilité : Élevée · Impact : Élevé · Niveau : **Critique**
Justification	Exchange 2016 DMZ non patché exposé à ProxyShell/Spraying [E192] → exfiltration données patients via CVE-2023-21768
Traitement	Réduire — Correctifs Exchange 2016 (CVE-2023-21768), WAF avec rate limiting, Segmentation réseau DMZ → ANSSI-HYGIENE-5, ISO27002-5.3
Sources	ANSSI-HYGIENE, ISO27002-5.3
Risque résiduel	Élevé → Moyenne
Validation	À valider par l'analyste
Preuves	[E5] [E7] [E192]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M014 — Fuite massive via campagnes Spraying : botnets exploitant Exchange 2016 DMZ pour exfiltrer données patients ve

Actif	A05 — Webmail de Santé & Accès Externe (OWA) — Service / Site Internet
Menace	LINDDUN-Disclosure — Fuite massive via campagnes Spraying : botnets exploitant Exchange 2016 DMZ pour exfiltrer données patients vers serveurs tiers [E7][E5][EBIOS-RM-A3]
Évaluation	Probabilité : Élevée · Impact : Élevé · Niveau : **Critique**
Justification	Botnets ciblant Exchange 2016 DMZ exploitable sans filtrage SSL [E192][E203] → fuite massive vers tiers [E203][EBIOS-RM-A3]
Traitement	Réduire — Firewall SSL/TLS strict (HTTPS forcé), WAF anti-botnets, Isolation Exchange en VLAN dédié → EBIOS-RM-A3, ANSSI-HYGIENE-8
Sources	EBIOS-RM-A3, ANSSI-HYGIENE, ISO27002-8.13
Risque résiduel	Critique → Élevé
Validation	À valider par l'analyste
Preuves	[E5] [E7] [E192] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M015 — Attaque par le temps (DoS) : épuisement des ressources Exchange 2016 via requêtes malveillantes sur OWA sans r

Actif	A05 — Webmail de Santé & Accès Externe (OWA) — Service / Site Internet
Menace	STRIDE-T — Attaque par le temps (DoS) : épuisement des ressources Exchange 2016 via requêtes malveillantes sur OWA sans rate limiting [E7][A11]
Évaluation	Probabilité : Moyenne · Impact : Élevé · Niveau : **Élevé**
Justification	OWA non rate-limited laisse épuiser ressources Exchange 2016 via requêtes DoS [E192][A11]
Traitement	Réduire — Rate limiting OWA (requêtes/seconde), WAF DoS protection, Circuit breaker Exchange 2016 → ISO27002-8.14, ANSSI-CARTO-SI
Sources	ISO27002-8.14, ISO27002-8.29, ANSSI-CARTO-SI
Risque résiduel	Élevé → Moyen
Validation	À valider par l'analyste
Preuves	[E7] [E192]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M016 — Destruction d'images DICOM : corruption des baies SAN locales via malware SMB qui supprime les données critiqu

Actif	A02 — PACS/RIS (Archivage & Imagerie) — Logiciel / Service
Menace	STRIDE-D — Destruction d'images DICOM : corruption des baies SAN locales via malware SMB qui supprime les données critiques [E203][EBIOS-RM-A3]
Évaluation	Probabilité : Moyenne · Impact : Élevé · Niveau : **Élevé**
Justification	SMB vulnérabilités (CVE-2019-10605) sur baies SAN locales avec SMBv3/SMBv1 actif [E155][E203] [EBIOS-RM-A3] → corruption données critiques
Traitement	Réduire — Correctifs SMB (CVE-2019-10605), Désactivation SMBv1, Segmentation baies SAN via VLAN réseau → ANSSI-HYGIENE-3, ISO27002-5.3
Sources	ANSSI-HYGIENE, ISO27002-5.4, EBIOS-RM-A3
Risque résiduel	Élevé → Moyen
Validation	À valider par l'analyste
Preuves	[E155] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M017 — Authentification par certificat faible → attaquants externes (groupes ransomware ciblant hôpitaux) → compromi

Actif	A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérieurs E7E5
Menace	STRIDE-S — Authentification par certificat faible [E160] → attaquants externes (groupes ransomware ciblant hôpitaux) → compromis de certificat ou injection credentials dans extranet → accès non autorisé aux résultats médicaux des patients [A3][E203]
Évaluation	Probabilité : Moyenne · Impact : Élevé · Niveau : **Élevé**
Justification	Certificat faible + accès externes médicaux E7E5 sans MFA solide [E160][E203] → ransomware compromis credentials vers résultats patients [A3][E203]
Traitement	Réduire — Certificats TLS 2048-bit (ECC preferred), MFA FIDO2 obligatoire sur accès externes, WAF intrusion prevention → ANSSI-CARTO-SI-3, ISO27002-8.22
Sources	ANSSI-CARTO-SI, ISO27002-8.13, ISO27002-8.22
Risque résiduel	Élevé → Moyen
Validation	À valider par l'analyste
Preuves	[E160] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M018 — Fuite des résultats médicaux via portail non durci : attaquants exploitent vulnérabilité d'authentification →

Actif	A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérieurs E7E5
Menace	LINDDUN-Disclosure — Fuite des résultats médicaux via portail non durci : attaquants exploitent vulnérabilité d'authentification → exfiltration de données sensibles externes → violation RGPD et confidentialité des dossiers patients externes [E203][A19]
Évaluation	Probabilité : Moyenne · Impact : Élevé · Niveau : **Élevé**
Justification	Portail partenaire non durci avec authentification simple et certificat faible [E197][E203] → exfiltration données externes via canal compromis [A3][A19][EBIOS-RM-A3]
Traitement	Réduire — Chiffrement TLS 1.3 forcé, WAF XSS/SQL injection sur extranet, PAM (Privilege Access Management) médical → ANSSI-CARTO-SI-5
Sources	ANSSI-CARTO-SI, ISO27002-8.14, EBIOS-RM-A3
Risque résiduel	Élevé → Moyen
Validation	À valider par l'analyste
Preuves	[E197] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M019 — Modification des données médicales : attaquants interceptent flux authentifiés vers portail webmodifié → exfil

Actif	A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérieurs E7E5
Menace	STRIDE-I — Modification des données médicales : attaquants interceptent flux authentifiés vers portail webmodifié → exfiltration ou altération des profils patients externes en transit via canal non chiffré [E38][A17]
Évaluation	Probabilité : Moyenne · Impact : Élevé · Niveau : **Élevé**
Justification	Site tiers WebModif sans canal chiffré robuste intercepte flux authentifiés [E38][A17] → altération profils patients en transit [EBIOS-RM-A3]
Traitement	Réduire — VPN site-to-site chiffré AES-256 pour flux authentifiés, Canal séparé sans partage firewall vers tiers → ANSSI-HYGIENE-7, ISO27002-8.16
Sources	ANSSI-HYGIENE, ISO27002-8.13, LINDDUN-Disclosure
Risque résiduel	Élevé → Faible-Moyen
Validation	À valider par l'analyste
Preuves	[E38]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M020 — Attaques de type defacement/phishing : site compromis sert de plateforme d'hébergement pour malware redirigean

Actif	A06 — Extranet Partenaires / Médecins Libéraux — Service / Site Internet — extranet.santetech-sante.fr (accès résultats médicaux), authentification par certificat faible, accès médecins traitants extérieurs E7E5
Menace	STRIDE-T — Attaques de type defacement/phishing : site compromis sert de plateforme d'hébergement pour malware redirigeant vers attaques contre SI interne [A3][E203]
Évaluation	Probabilité : Faible · Impact : Moyen · Niveau : Faible
Justification	Site compromis défacement/phishing rare mais peut rediriger malware vers interne [A3][E203] → impact limité faute de lien direct SI interne [E198]
Traitement	Accepter — Surveillance WAF pour détection défacement, Notification incident <5 minures, Plan continuité activité → ANSSI-RECYF, ISO27002-8.25
Sources	ANSSI-RECYF
Risque résiduel	Faible-Moyen → Faible
Validation	À valider par l'analyste
Preuves	[E198] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M021 — Accès aux données sensibles via exploitation vulnérabilités serveur web : attaquants accèdent au contenu médic

Actif	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond E7E5
Menace	STRIDE-E — Accès aux données sensibles via exploitation vulnérabilités serveur web : attaquants accèdent au contenu médical stocké sur hébergement externe → exfiltration de flux web vers cloud malveillant [A17][E38]
Évaluation	Probabilité : Moyenne · Impact : Élevé · Niveau : **Élevé**
Justification	CMS WordPress tiers sans patching + vulnérabilités connues CVE-2024-6273/CVE-2019-5409 [E199] [E203][A17] → exfiltration contenus hébergés externes [E38][EBIOS-RM-A3]
Traitement	Éviter — Migration hébergement vers serveur HDS (hébergement de données santé certifié français), Audit vulnérabilités WordPress trimestriel → ANSSI-HOMOLOGATION, EBIOS-RM-A4
Sources	ANSSI-CARTO-SI, EBIOS-RM-A4, ISO27002-5.15
Risque résiduel	Élevé → Faible
Validation	À valider par l'analyste
Preuves	[E38] [E199] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M022 — Défacement de contenu médical et profils patients : attaquants modifient pages web hébergées → altération des

Actif	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond E7E5
Menace	STRIDE-D — Défacement de contenu médical et profils patients : attaquants modifient pages web hébergées → altération des informations cliniques visibles publiquement [A3][E203]
Évaluation	Probabilité : Faible · Impact : Moyen · Niveau : Faible
Justification	Défacement WordPress tiers non critique pour opérationnel mais altère contenu clinique public visible [A3][E203] → impact réputationnel limité
Traitement	Réduire — CMS hardened WordPress (plugins sécurisés, headers HTTPS HSTS), ModSecurity WAF anti-modification → ANSSI-HYGIENE-6, ISO27002-8.11
Sources	ANSSI-HYGIENE, ISO27002-8.11, ISO27002-8.29
Risque résiduel	Faible-Moyen → Faible
Validation	À valider par l'analyste
Preuves	[E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M023 — Attaques de type defacement/phishing : site compromis sert de plateforme d'hébergement pour malware redirigean

Actif	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond E7E5
Menace	STRIDE-T — Attaques de type defacement/phishing : site compromis sert de plateforme d'hébergement pour malware redirigeant vers attaques contre SI interne [A3][E203]
Évaluation	Probabilité : Moyenne · Impact : Élevé · Niveau : **Élevé**
Justification	Phishing défacement sur CMS tiers moins probable que DoS/exfiltration directe [E199] → redirection vers sites malveillants [A3]
Traitement	Réduire — Blocage redirections phishing via WAF/IPS, Headers de contenu X-Frame-Options DENY, SPF/DKIM sur emails → ANSSI-HYGIENE-4, ISO27002-8.15
Sources	ANSSI-HYGIENE, ISO27002-8.26, LINDDUN-Unawareness
Risque résiduel	Moyen → Faible-Moyen
Validation	À valider par l'analyste
Preuves	[E199] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M024 — Fuite des données sensibles via exploitation vulnérabilités CMS : attaquants accèdent aux contenus médicaux hé

Actif	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond E7E5
Menace	LINDDUN-Disclosure — Fuite des données sensibles via exploitation vulnérabilités CMS : attaquants accèdent aux contenus médicaux hébergés → exfiltration de flux web vers cloud malveillant [A19] [E203]
Évaluation	Probabilité : Faible · Impact : Moyen · Niveau : Faible
Justification	Exploitation CMS pour fuite limitée via contenu public, non base de données patients directe [E199] [EBIOS-RM-A3][A19]
Traitement	Accepter — Monitoring contenu web pour détection fuite, WAF rate limiting sur CMS tiers, Sauvegarde hebdomadaire → ANSSI-HYGIENE-5, ISO27002-8.13
Sources	ANSSI-HYGIENE, ISO27002-8.28, EBIOS-RM-A3
Risque résiduel	Faible-Moyen → Très Faible
Validation	À valider par l'analyste
Preuves	[E199] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M025 — Non-documentation des vulnérabilités du CMS : attaquants exploitent failles non patchées de plugins WordPress

Actif	A07 — Sites Web Cliniques (12 sites) — Site Internet / Prestataire — Hébergés prestataire tiers WordPress non durci, sans liaison SI interne mais cibles défacement/phishing rebond E7E5
Menace	LINDDUN-Unawareness — Non-documentation des vulnérabilités du CMS : attaquants exploitent failles non patchées de plugins WordPress → exfiltration de dossiers patients sans consentement [A19] [E203]
Évaluation	Probabilité : Élevé · Impact : Moyen · Niveau : **Élevé**
Justification	CMS WordPress vulnérable avec plugins obsolets exposés publiquement [E195][A19]
Traitement	Réduire — MFA FIDO2 pour le VPN (ANSSI-RECYF), durcissement WordPress (ISO27002-8.8)
Sources	[E195][E145]
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E145] [E195] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M026 — Compromission d'identité centralisée : attaquants injectent objets utilisateurs malveillants dans forêt racine

Actif	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5
Menace	STRIDE-S — Compromission d'identité centralisée : attaquants injectent objets utilisateurs malveillants dans forêt racine → accès non autorisé aux dossiers patients via mouvement latéral [A17][E38]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Authentification centralisée sans segmentation forestière et sans MFA systématique [E24][E145]
Traitement	Réduire — MFA systématique AD (ANSSI-HYGIENE), segmentation forestière (ISO27002-8.11)
Sources	[E24][E145]
Risque résiduel	Critique
Validation	À valider par l'analyste
Preuves	[E24] [E38] [E145]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M027 — Attaques via usurpation d'identité : attaquants bypassent authentification sans MFA sur 60% des comptes → comp

Actif	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5
Menace	STRIDE-T — Attaques via usurpation d'identité : attaquants bypassent authentification sans MFA sur 60% des comptes → compromission de compte administratif centralisé → accès transverse à toutes les cliniques [A16][E203]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Bypass authentification possible sur 60% des comptes sans double facteur [E186][E145]
Traitement	Réduire — MFA obligatoire sur 100% des comptes (ISO27002-8.2)
Sources	[E186][E145]
Risque résiduel	Critique
Validation	À valider par l'analyste
Preuves	[E145] [E186] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M028 — Interception d'authentification : attaquants captent flux réseau sans chiffrage SSL renforcé → rejeu d'identif

Actif	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5
Menace	STRIDE-E — Interception d'authentification : attaquants captent flux réseau sans chiffrage SSL renforcé → rejeu d'identifiants depuis session compromis → accès aux identités validées [E38][A17]
Évaluation	Probabilité : Moyen · Impact : Élevé · Niveau : **Élevé**
Justification	Connexions non chiffrées SSL permettent rejeu d'identifiants depuis session capturée [E197][E137]
Traitement	Réduire — Chiffrage SSL/TLS (ANSSI-HYGIENE), audit cryptographique (ISO27002-8.14)
Sources	[E197][E137]
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E38] [E137] [E197]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M029 — Fuite des identités : attaquants exploitent forêt non cloisonnée pour exfiltrer données sensibles → accès aux

Actif	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5
Menace	LINDDUN-Disclosure — Fuite des identités : attaquants exploitent forêt non cloisonnée pour exfiltrer données sensibles → accès aux profils patients centralisés sans consentement [A19][E9]
Évaluation	Probabilité : Moyen · Impact : Élevé · Niveau : **Élevé**
Justification	Architecture monolithique AD unique facilite exfiltration transversale des profils patients [E103] [E240]
Traitement	Réduire — Cloisonnement AD (ISO27002-8.13), audit de vulnérabilités (ANSSI-IA-GEN)
Sources	[E103][E240]
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E9] [E103] [E240]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M030 — Modification des attributs utilisateurs : attaquants altèrent droits d'accès dans forêt racine → accès non doc

Actif	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5
Menace	LINDDUN-L — Modification des attributs utilisateurs : attaquants altèrent droits d'accès dans forêt racine → accès non documenté aux dossiers patients via promotion d'utilisateur faible [A3]
Évaluation	Probabilité : Faible · Impact : Moyen · Niveau : Faible
Justification	Modification requiert permissions administrateur supérieures dans forêt racine non cloisonnée [E2] [E103]
Traitement	Réduire — Contrôle d'accès granulaire (ISO27002-8.26), audit attributs utilisateurs (ANSSI-HYGIENE)
Sources	[E2][E103]
Risque résiduel	Faible
Validation	À valider par l'analyste
Preuves	[E2] [E103]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M031 — Altération des clés Kerberos : attaquants réplication compromise → exfiltration et altération du catalogue AD

Actif	A08 — Domaine Active Directory (corp.santetech.local) — Logiciel / Infrastructure — Forêt AD unique, 16 contrôleurs de domaine (1 DC/RODC par clinique), pas de MFA systématique VPN As-Is E9E7E5
Menace	STRIDE-I — Altération des clés Kerberos : attaquants réplication compromise → exfiltration et altération du catalogue AD vers endpoints externes [E38][A17]
Évaluation	Probabilité : Faible · Impact : Élevé · Niveau : Moyen
Justification	Vulnérabilité spécifique nécessitant conditions d'exploitation précises sur réplication AD [E145]
Traitement	Réduire — Chiffrement des clés Kerberos (ISO27002-8.28), audit réplication AD (ANSSI-RECYF)
Sources	[E38][E145]
Risque résiduel	Moyen
Validation	À valider par l'analyste
Preuves	[E38] [E145]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M032 — Compromission contrôleurs de domaine : attaquants exploitent faille matérielle ou corruption disque → perte d'

Actif	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5
Menace	STRIDE-S — Compromission contrôleurs de domaine : attaquants exploitent faille matérielle ou corruption disque → perte d'authenticité des identités cliniques [A3][E203]
Évaluation	Probabilité : Faible · Impact : Élevé · Niveau : Moyen
Justification	Compromise nécessite accès physique ou exploit ciblé sur 185 serveurs hétérogènes [E9][E176][]
Traitement	Réduire — Patching systématique (ISO27002-8.16), audit matériel (ANSSI-HYGIENE)
Sources	[E9][E176]
Risque résiduel	Moyen
Validation	À valider par l'analyste
Preuves	[E9] [E176] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M033 — Défaillance des serveurs DC/RODC : panne matérielle critique → perte d'authentification pour toute la clinique

Actif	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5
Menace	STRIDE-T — Défaillance des serveurs DC/RODC : panne matérielle critique → perte d'authentification pour toute la clinique → déni de service système [A3][E9]
Évaluation	Probabilité : Faible · Impact : Élevé · Niveau : Moyen
Justification	Redondance DC localisée limite probabilité de coupure simultanée mais impact clinique total [E146]
Traitement	Réduire — Redondance DC locale (ISO27002-8.22), monitoring disponibilité (ANSSI-RECYF)
Sources	[E146]
Risque résiduel	Moyen
Validation	À valider par l'analyste
Preuves	[E9] [E146]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M034 — Non-patching hétérogène : attaquants exploitent faille de serveur non corrige → exfiltration depuis DC vieilli

Actif	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5
Menace	LINDDUN-Unawareness — Non-patching hétérogène : attaquants exploitent faille de serveur non corrige → exfiltration depuis DC vieillissant sans agent EDR moderne [A3][E2]
Évaluation	Probabilité : Élevé · Impact : Moyen · Niveau : **Élevé**
Justification	Surface d'attaque étendue avec gestion patch hétérogène sur 12 sites et OS non patchables [E7] [E98]
Traitement	Réduire — Patching hétérogène (ISO27002-8.15), isolation VLAN/NAC (ANSSI-RECYF)
Sources	[E7][E98]
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E2] [E7] [E98]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M035 — Accès aux données de l'AD : attaquants accèdent au système de réplication → lecture des catalogues utilisateur

Actif	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5
Menace	STRIDE-E — Accès aux données de l'AD : attaquants accèdent au système de réplication → lecture des catalogues utilisateurs depuis DC compromis [A17][E38]
Évaluation	Probabilité : Faible · Impact : Élevé · Niveau : Moyen
Justification	Exploitation du canal de réplication requiert privilèges avancés pour lecture catalogue utilisateurs [E123]$_{[A17]}$
Traitement	Réduire — Séparation réplication AD (ISO27002-8.24), audit lecture catalogue (ANSSI-HYGIENE)
Sources	[A17][E123]
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E38] [E123]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M036 — Altération des données d'AD : attaquants modifient catalogue AD vers DC local → invalidation des tickets Kerbe

Actif	A09 — Contrôleurs de Domaine AD (16 unités) — Matériel / Infrastructure — 1 DC complet + 1 RODC par clinique (12 sites), gestion identités centralisée, patching potentiellement hétérogène E9E5
Menace	STRIDE-I — Altération des données d'AD : attaquants modifient catalogue AD vers DC local → invalidation des tickets Kerberos pour tous les comptes cliniques [A17]
Évaluation	Probabilité : Faible · Impact : Élevé · Niveau : Moyen
Justification	Modification catalogue nécessite accès privilégié direct au DC local compromis [E148]$_{[A17]}$
Traitement	Réduire — Contrôle d'accès DC local (ISO27002-8.25), invalidation tickets Kerberos (ANSSI-RECYF)
Sources	[E148]$_{[A17]}$
Risque résiduel	Moyen
Validation	À valider par l'analyste
Preuves	[E148]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M037 — Compromission migration cloud : attaquants infiltrent flux de migration → altération des métadonnées patients

Actif	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11
Menace	STRIDE-S — Compromission migration cloud : attaquants infiltrent flux de migration → altération des métadonnées patients dans cible hybride [A3][E203]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Compromission migration cloud : attaquants infiltrent flux de migration → altération des métadonnées patients [E203]
Traitement	Réduire — Chiffrage TLS 1.3+ avec ECDHE (E9E5E11 [DREAD-D]); Authentification OAuth2/OIDC avec JWT short-living tokens (E9E5E11 [DREAD-D]); Segmentation VLAN IoT/Biomédical (10.1.30.0/24) [E203]
Sources	ANSSI-HYGIENE-5.3, ISO27002-8.8, STRIDE-S
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M038 — Exfiltration de flux API : attaquants accèdent aux endpoints cloud non authentifiés → lecture des dossiers pat

Actif	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11
Menace	STRIDE-E — Exfiltration de flux API : attaquants accèdent aux endpoints cloud non authentifiés → lecture des dossiers patients dans infrastructure hybride [A19][E5]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Exfiltration API non authentifiés → lecture dossiers patients [E203][E5]
Traitement	Réduire — Authentification OAuth2/OIDC avec JWT short-living tokens (E9E5E11 [DREAD-D]); WAF Next-Gen (OWASP Core Rule Set) [ISO27002-8.11]
Sources	ANSSI-HYGIENE-5.19, STRIDE-E
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E5] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M039 — Attaques de type defacement/application : attaquants compromise flux télémédecine via API mal protégée → redir

Actif	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11
Menace	STRIDE-T — Attaques de type defacement/application : attaquants compromise flux télémédecine via API mal protégée → redirige communications vers services hostiles [A3][E203]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Attaques defacement via API mal protégée → redirige communications [E203]
Traitement	Réduire — Chiffrage E2E avec TLS 1.3 [ISO27002-8.14]; MFA FIDO2/CPS pour soignants (E9E5E11 [DREAD-D])
Sources	ANSSI-HYGIENE-5.4, ISO27002-8.8
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M040 — Fuite des données patients cloud : attaquants exploitent faille API Gateway → exfiltration continue des flux t

Actif	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11
Menace	LINDDUN-Disclosure — Fuite des données patients cloud : attaquants exploitent faille API Gateway → exfiltration continue des flux télémédicaux vers endpoints externes [A19][E5]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Fuite données patients via faille API Gateway → exfiltration télémédicale [E203][E5]
Traitement	Réduire + Transférer — Chiffrage E2E avec TLS 1.3 [ISO27002-8.14]; JWT signed RS256 + OAuth2 (E9E5E11 [DREAD-D])
Sources	ISO27002-8.8, ANSSI-RECYF-8.2
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E5] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M041 — Non-documentation des flux API : attaquants exploitent endpoints non inventoriés dans architecture cloud → ex

Actif	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11
Menace	LINDDUN-Unawareness — Non-documentation des flux API : attaquants exploitent endpoints non inventoriés dans architecture cloud → exfiltration de données sensibles sans traçabilité [A3][E9]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Non-documentation API → exfiltration données sans traçabilité [E9]
Traitement	Éviter — Registre API centralisé (APIM Azure/AWS) inventorier tous endpoints [E143]; Analyse de traçabilité flux API [E144]
Sources	ANSSI-RECYF-8.8, LINDDUN-Unawareness
Risque résiduel	Critique
Validation	À valider par l'analyste
Preuves	[E9] [E143] [E144]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M042 — Altération des flux télémédicaux : attaquants interceptent messages cloud → modification des données médicales

Actif	A10 — Applications Cloud Hybride (To-Be) — Logiciel / Service — Migration DPI Nexus vers Cloud HDS, télémédecine et portail patient en Cloud, API Gateway sécurisée nouvelle brique E9E5E11
Menace	STRIDE-I — Altération des flux télémédicaux : attaquants interceptent messages cloud → modification des données médicales transmises entre cliniques [A3][E203]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Interception messages cloud → modification données médicales [E203][E5]
Traitement	Réduire — Chiffrement TLS 1.3 avec certifiats HDS homologués [E203]; S/MIME pour messagerie [ISO27002-8.15]
Sources	ANSSI-HOMOLOGATION, ISO27002-8.13
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E5] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M043 — Attaque de spoofing via certification HDS non conforme : un fournisseur malveillant pourrait falsifier l'iden

Actif	A11 — Fournisseur Cloud HDS
Menace	STRIDE-S — [E140] Attaque de spoofing via certification HDS non conforme : un fournisseur malveillant pourrait falsifier l'identité d'un hôte Cloud HDS et accéder aux données patients via le portail vpn.santetech-sante.fr sans authentification MFA.
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Spoofing via certification HDS non conforme [E140]
Traitement	Éviter — Impose certification HDS obligatoire fournisseur Cloud Act [E203]; Audit trimestriel de conformité HDS [E140]
Sources	ANSSI-RECYF-8.8, STRIDE-R
Risque résiduel	Critique
Validation	À valider par l'analyste
Preuves	[E140] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M044 — Fuite de données via exposition Cloud Act : le Cloud HDS sans analyse rigoureuse pourrait exposer les dossier

Actif	A11 — Fournisseur Cloud HDS
Menace	LINDDUN-D — [E203] Fuite de données via exposition Cloud Act : le Cloud HDS sans analyse rigoureuse pourrait exposer les dossiers patients aux attaques de type data exfiltration via le portail extranet.santetech-sante.fr.
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Fuite données via exposition Cloud Act [E203]
Traitement	Réduire + Transférer — Addendum contractuel DSA-Cloud avec clauses RGPD [E203]; Clause de non-divulgation SSL [E140]
Sources	ANSSI-IA-GEN, ISO27002-8.2
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E140] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M045 — Manipulation de dispositifs non-patchables : les moniteurs et scanners avec micro-noyaux temps réel non patch

Actif	A12 — Parc IoT Médical
Menace	STRIDE-T — [E205] Manipulation de dispositifs non-patchables : les moniteurs et scanners avec micro-noyaux temps réel non patchables (OS non patchables partie parc) pourraient être compromis pour injecter des données falsifiées dans le système PACS/RIS.
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Manipulation dispositifs non-patchables → injection données falsifiées [E205]
Traitement	Accepter — Segmentation micro-segmentation VLAN IoT isolé (10.1.30.0/24) [E203]; Interdiction accès Internet direct [E143]
Sources	ANSSI-HYGIENE-5.30, LINDDUN-Disclosure
Risque résiduel	Critique
Validation	À valider par l'analyste
Preuves	[E143] [E203] [E205]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M046 — Perturbation de l'intégrité des données : le VLAN IoT/ Biomédical non cloisonné (10.1.30.0/24) permettrait à u

Actif	A12 — Parc IoT Médical
Menace	LINDDUN-I — [E140] Perturbation de l'intégrité des données : le VLAN IoT/Biomédical non cloisonné (10.1.30.0/24) permettrait à un attaquant de modifier les paramètres des dispositifs médicaux via le routage direct vers les automates.
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Perturbation intégrité via VLAN non cloisonné [E203]
Traitement	Réduire + Éviter — Cloisonnement VLAN IoT/Biomédical par firewall interne [E203]; ACL bloquant accès non autorisés [E140]
Sources	ISO27002-8.24, STRIDE-T
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E140] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M047 — Négation de service via routage non cloisonné : le VLAN IoT/ Biomédical non cloisonné (10.1.30.0/24) permettra

Actif	A13 — Segmentation Réseau VLAN/NAC
Menace	STRIDE-R — [E203] Négation de service via routage non cloisonné : le VLAN IoT/Biomédical non cloisonné (10.1.30.0/24) permettrait à un attaquant de saturer le réseau avec des paquets malformés, causant une perte de disponibilité des dispositifs de surveillance.
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Négation service via routage non cloisonné [E203]
Traitement	Éviter — Routage firewall interne cloisonné VLANs (10.1.30.0/24) [E203]; Audit de segmentation [E140]
Sources	ANSSI-RECYF-8.8, STRIDE-R
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E140] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M048 — Divulgation d'informations via filtrage SSL manquant : le VLAN Wi-Fi Invités/Patients (10.1.40.0/24) sans fil

Actif	A14 — Wi-Fi Invités/Patients
Menace	STRIDE-I — [E140] Divulgation d'informations via filtrage SSL manquant : le VLAN Wi-Fi Invités/Patients (10.1.40.0/24) sans filtrage SSL permettrait à un attaquant d'intercepter les communications via le portail webmail.santetech-sante.fr et d'extraire des données sensibles.
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Divulgation données via filtrage SSL manquant [E140][E203]
Traitement	Réduire — Filtrage SSL manquant corrigé (10.1.40.0/24) [E203]; Chiffrage TLS 1.3 avec certificats HDS [E140]
Sources	ISO27002-8.16, ANSSI-HYGIENE-5.3
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E140] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M049 — Fuite de données via access point non sécurisé : le VLAN Wi-Fi Invités/Patients (10.1.40.0/24) avec sortie In

Actif	A14 — Wi-Fi Invités/Patients
Menace	LINDDUN-D — [E203] Fuite de données via access point non sécurisé : le VLAN Wi-Fi Invités/Patients (10.1.40.0/24) avec sortie Internet directe sans filtrage SSL pourrait être utilisé pour des attaques de type phishing de rebond vers les cliniques.
Évaluation	Probabilité : Élevée · Impact : Élevé · Niveau : **Critique**
Justification	VLAN Wi-Fi Invités/Patients (10.1.40.0/24) avec sortie Internet directe sans filtrage SSL permet du phishing de rebond [E203]
Traitement	Réduire — Micro-segmentation VLAN/NAC (ANSSI-HYGIENE) + filtrage SSL (ISO27002-8.8)
Sources	[E203]
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M050 — Élévation de privilèges via API Gateway non sécurisée : l'exposition de l'API Gateway Cloud Hybride sans sign

Actif	A15 — API SaaS / APIs Télémedecine
Menace	STRIDE-E — [E146] Élévation de privilèges via API Gateway non sécurisée : l'exposition de l'API Gateway Cloud Hybride sans signature images Docker/SBOM pourrait permettre à un attaquant de s'insérer dans la brique télémédecine et accéder à des données patients.
Évaluation	Probabilité : Élevée · Impact : Élevé · Niveau : **Critique**
Justification	API Gateway Cloud Hybride exposée sans signature images Docker/SBOM favorise élévation de privilèges et infiltration télémédecine [E146]
Traitement	Réduire — Vérification signatures Docker/SBOM (ANSSI-RECYF) + cosign (ISO27002-8.16)
Sources	[E146]
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E146]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M051 — Compromission de la confidentialité via API non durcie : l'API Gateway exposée sans vérification des signatur

Actif	A15 — API SaaS / APIs Télémedecine
Menace	[E146] Compromission de la confidentialité via API non durcie : l'API Gateway exposée sans vérification des signatures Docker/SBOM pourrait être exploitée pour des attaques de type data exfiltration via les flux de télémédecine.
Évaluation	Probabilité : Élevée · Impact : Moyen · Niveau : **Élevé**
Justification	Exposition API non durcie (sans vérification signatures) permet data exfiltration via flux télémedecine [E146]
Traitement	Réduire — Chiffrement TLS 1.3 OAuth2/OIDC (ISO27002-8.14) + ISO27002-8.8
Sources	[E146]
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E146]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M052 — Vol de données via vol d'identifiants administrateur (credential stuffing) sur postes non patchables et VPN Fo

Actif	A16 — Domaine hospitalier — Site
Menace	STRIDE-D — Vol de données via vol d'identifiants administrateur (credential stuffing) sur postes non patchables et VPN FortiGate sans MFA [E163][A17]
Évaluation	Probabilité : Élevée · Impact : Élevé · Niveau : **Critique**
Justification	Forêt AD unique sans cloisonnement + SMB/CIFS exposés vulnérables aux credential stuffing et exposition de données patients [E140][E145]
Traitement	Réduire — MFA FIDO2 (ANSSI-HYGIENE) + rotation cred (ISO27002-8.13)
Sources	[E163]
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E140] [E145] [E163]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M053 — Dénonciation de données patients via exposition physique des locaux informatiques (contrôle d'accès défaillant

Actif	A16 — Domaine hospitalier — Site
Menace	LINDDUN-L — Dénonciation de données patients via exposition physique des locaux informatiques (contrôle d'accès défaillant en période posturée) [E142]
Évaluation	Probabilité : Moyenne · Impact : Moyen · Niveau : Moyen
Justification	Contrôle d'accès défaillant en période posturée expose physiques des locaux à déniement de confidentialité sur dossiers patients [E142]
Traitement	Réduire — Biométrie/USB sécurisé (ANSSI-HYGIENE) + RFID G4 (ISO27002-8.11)
Sources	[E142]
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E142]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M054 — Tampering des permissions AD via exploitation de compte service faible sur 60% des postes (pas de MFA sur VPN)

Actif	A17 — Infrastructure réseau — Active Directory
Menace	STRIDE-T — Tampering des permissions AD via exploitation de compte service faible sur 60% des postes (pas de MFA sur VPN) enclinning aux attacks pass-the-hash [E140]
Évaluation	Probabilité : Élevée · Impact : Critique · Niveau : **Critique**
Justification	Compte service faible + 60% postes sans MFA VPN permettent pass-the-hash et tampering permissions AD unique CVE-2021-38619 [E140][A17]
Traitement	Réduire — MFA FIDO2 (ISO27002-8.8) + rotation cred (ANSSI-HYGIENE)
Sources	[E140]
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E140]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M055 — Denial of service du contrôleur de domaine unique par saturation DNS (DC/RODC sans replication) bloquant les a

Actif	A17 — Infrastructure réseau — Active Directory
Menace	STRIDE-I — Denial of service du contrôleur de domaine unique par saturation DNS (DC/RODC sans replication) bloquant les authentifications à tous clinique [E140]
Évaluation	Probabilité : Moyenne · Impact : Critique · Niveau : **Élevé**
Justification	DC/RODC unique sans replication + saturation DNS possible bloque authentifications tous sites clinique en cas DoS par épuisement DNS [E140]
Traitement	Réduire — Réplication DC/RODC (ISO27002-8.2) + DNSSEC/TLS (ANSSI-RECYF)
Sources	[E140]
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E140]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M056 — Disclosure personnelle des dossiers patients via forêt AD unique non cloisonnée avec partage SMB/CIFS sans fil

Actif	A17 — Infrastructure réseau — Active Directory
Menace	LINDDUN-D — Disclosure personnelle des dossiers patients via forêt AD unique non cloisonnée avec partage SMB/CIFS sans filtrage SSL entre cliniques [E204][E145]
Évaluation	Probabilité : Moyenne · Impact : Élevé · Niveau : **Élevé**
Justification	Forêt AD unique non cloisonnée permit partages SMB/CIFS sans filtrage SSL entre cliniques exposent dossiers patients transversalement [E145][A17]
Traitement	Réduire — Forêt AD multi-domaine (ANSSI-RECYF) + filtrage SMB (ISO27002-8.8)
Sources	[E145]
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E145] [E204]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M057 — Irresponsabilité des accès via RDS mis en réseau direct MPLS sans micro-segmentation VLAN/NAC permettant aux c

Actif	A18 — Application métier — DPI Progiciel Nexus
Menace	STRIDE-R — Irresponsabilité des accès via RDS mis en réseau direct MPLS sans micro-segmentation VLAN/NAC permettant aux cliniques non sécurisées d'accéder à tous données [E38]
Évaluation	Probabilité : Élevée · Impact : Élevé · Niveau : **Critique**
Justification	RDS mis en réseau direct MPLS sans micro-segmentation VLAN/NAC permet aux cliniques non sécurisées d'accéder à toutes données DPI [E38]
Traitement	Réduire — Micro-segmentation VLAN/NAC (ANSSI-HYGIENE) + isolation Group (ISO27002-8.16)
Sources	[E38]
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E38]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M058 — Élévation de privilèges via vulnérabilités Citrix XenApp/RDS (XenDesktop 7.15 CVE-2020-34692) permettant l'exé

Actif	A18 — Application métier — DPI Progiciel Nexus
Menace	STRIDE-E — Élévation de privilèges via vulnérabilités Citrix XenApp/RDS (XenDesktop 7.15 CVE-2020-34692) permettant l'exécution code sur ferme RDS Siège [E146]
Évaluation	Probabilité : Élevée · Impact : Critique · Niveau : **Critique**
Justification	CVE-2020-34692 Citrix XenApp exploitables sur ferme RDS Siège permettent exécution code et élévation privilèges globale [E146][A17]
Traitement	Réduire — Patch immédiat CVE-2020-34692 (ANSSI-RECYF) + virtualisation (ISO27002-8.16)
Sources	[E146]
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E146]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M059 — Leakage des données patients via exploitation SMBv1 legacy actif sur PACS/RIS pour compatibilité scanners anci

Actif	A18 — Application métier — DPI Progiciel Nexus
Menace	LINDDUN-L — Leakage des données patients via exploitation SMBv1 legacy actif sur PACS/RIS pour compatibilité scanners anciens [E131]
Évaluation	Probabilité : Élevée · Impact : Élevé · Niveau : **Critique**
Justification	SMBv1 legacy actif sur PACS/RIS pour compatibilité scanners anciens vulnérable à exploitation CVE-2020-1479 et fuite données patients [E131]
Traitement	Réduire — Désactivation SMBv1 (ANSSI-RECYF) + GPO (ISO27002-8.8)
Sources	[E131]
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E131]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M060 — Information leakage via exploitation ProxyShell sur Exchange 2016 non patché (DMZ vulnérable aux attacks Spray

Actif	A19 — Donnée/Structure — Données Patients (DPI)
Menace	STRIDE-I — Information leakage via exploitation ProxyShell sur Exchange 2016 non patché (DMZ vulnérable aux attacks Spraying) [E168][A17]
Évaluation	Probabilité : Critique · Impact : Critique · Niveau : **Critique**
Justification	ProxyShell exploitables sur Exchange 2016 non patché en DMZ + campagnes Spraying permettent extraction massive données patients critiques [E168][A17][CVE-2022-31497]
Traitement	Réduire — Patch Exchange 2016 (ANSSI-RECYF) + MFA (ISO27002-8.8)
Sources	[E168]
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E168]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M061 — Repudiation des accès via logs citrix incomplets sur RDS legacy ne traçant pas les connexions aux dossiers pat

Actif	A19 — Donnée/Structure — Données Patients (DPI)
Menace	STRIDE-R — Repudiation des accès via logs citrix incomplets sur RDS legacy ne traçant pas les connexions aux dossiers patients [E208]
Évaluation	Probabilité : Moyenne · Impact : Élevé · Niveau : **Élevé**
Justification	Logs Citrix legacy non traçants sur RDS exposés aux attaques de répudiation [E144, E203]
Traitement	Réduire — MFA FIDO2 (ISO27002-8.8), Cloisonnement VLAN IoT (ANSSI-HYGIENE-8.11), Journalisation complète Citrix (ANSSI-HYGIENE-8.8)
Sources	[E144], [E203]
Risque résiduel	Moyen
Validation	À valider par l'analyste
Preuves	[E144] [E203] [E208]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M062 — Disclosure de 150 000 dossiers via API Gateway non sécurisée pour télémédecine (no authz, no encryption in tra

Actif	A19 — Donnée/Structure — Données Patients (DPI)
Menace	LINDDUN-D — Disclosure de 150 000 dossiers via API Gateway non sécurisée pour télémédecine (no authz, no encryption in transit) [E231][A11]
Évaluation	Probabilité : Élevée · Impact : Critique · Niveau : **Critique**
Justification	API Gateway télémédecine sans authentification/autorisation ni chiffrement transit expose 150 k dossiers patients [E146, E203, CVE-2023-38448]
Traitement	Réduire — Authentification à deux facteurs (ISO27002-8.8), Chiffrement transit (ANSSI-HYGIENE-8.14), Audit API Gateway (ANSSI-RECYF)
Sources	[E231], [E146], [CVE-2023-38448]
Risque résiduel	Critique
Validation	À valider par l'analyste
Preuves	[E146] [E231]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M063 — Spoofing des commandes médicales via protocole Wi-Fi 6 non crypté (moniteurs, pompes perfusion)

Actif	A20 — Matériel IoT — Dispositifs Médicaux Connectés
Menace	STRIDE-S — Spoofing des commandes médicales via protocole Wi-Fi 6 non crypté (moniteurs, pompes perfusion) [E115][E204]
Évaluation	Probabilité : Élevée · Impact : Élevé · Niveau : **Critique**
Justification	Protocoles Wi-Fi 6 non cryptés sur dispositifs médicaux permettent spoofing de commandes critiques [E203, CVE-2018-8962]
Traitement	Réduire — Cryptage Wi-Fi 6 (ANSSI-HYGIENE-8.13), Mise à jour micrologiciels (ISO27002-8.24), Surveillance protocoles (STRIDE-S)
Sources	[E115], [E204], [CVE-2018-8962]
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E115] [E204]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M064 — Tamper des paramètres d'automates via micro-noyaux temps réel non patchables permettant dosage erreur

Actif	A20 — Matériel IoT — Dispositifs Médicaux Connectés
Menace	STRIDE-T — Tamper des paramètres d'automates via micro-noyaux temps réel non patchables permettant dosage erreur [E146]
Évaluation	Probabilité : Moyenne · Impact : Élevé · Niveau : **Élevé**
Justification	Micro-noyaux temps réel non patchables sur automates médicaux permettant modification des dosages thérapeutiques [E209, CVE-2017-5369]
Traitement	Réduire — Patch micro-noyaux (ISO27002-8.22), Isolation réseau (ANSSI-HYGIENE-8.14), Contrôle matériel (EBIOS-RM-A4)
Sources	[E146], [E209], [CVE-2017-5369]
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E146] [E209]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M065 — Disclosure de logs médicaux via exploitation Bluetooth LE sur appareils non isolés réseau (pompes à perfusion)

Actif	A20 — Matériel IoT — Dispositifs Médicaux Connectés
Menace	STRIDE-D — Disclosure de logs médicaux via exploitation Bluetooth LE sur appareils non isolés réseau (pompes à perfusion) [E117]
Évaluation	Probabilité : Faible · Impact : Moyen · Niveau : Faible
Justification	Logs médicaux accessibles via Bluetooth LE uniquement sur appareils non isolés réseau (isolation hypothétiquement prévue) [E204, E147]
Traitement	Réduire — Séparation VLAN médical (ANSSI-HYGIENE-8.11), Filtrage Bluetooth (ISO27002-8.15), Audit sécurité IoT (STRIDE-D)
Sources	[E117], [E147], [E204]
Risque résiduel	Faible
Validation	À valider par l'analyste
Preuves	[E117] [E147] [E204]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M066 — Leakage de données patients via Wi-Fi 6 non patché sur scanners (exposés au réseau Wi-Fi Invités sans filtrage

Actif	A20 — Matériel IoT — Dispositifs Médicaux Connectés
Menace	LINDDUN-L — Leakage de données patients via Wi-Fi 6 non patché sur scanners (exposés au réseau Wi-Fi Invités sans filtrage SSL) [E120]
Évaluation	Probabilité : Moyenne · Impact : Élevé · Niveau : **Élevé**
Justification	Scanner exposé au VLAN Wi-Fi Invités sans filtrage SSL permet exfiltration massive de données patients [E205, CVE-2023-32278]
Traitement	Réduire — Séparation VLAN Wi-Fi Invités (ANSSI-HYGIENE-8.11), Chiffrement SSL (ISO27002-8.8), Surveillance trafic (STR0DE-D)
Sources	[E120], [E205], [CVE-2023-32278]
Risque résiduel	Élevé
Validation	À valider par l'analyste
Preuves	[E120] [E205]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M067 — Attaquant tiers cloud : compromission de compte administrateur via phishing → élévation des privilèges sur inf

Actif	A21 — Infrastructure Cloud — Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/ OVHcloud/Azure (pas d'imposition) [E142]
Menace	STRIDE-S — Attaquant tiers cloud : compromission de compte administrateur via phishing → élévation des privilèges sur infrastructure hybride (VM/K8s) ; accès non autorisé aux instances et données clients via interface console [E146,EBIOS-RM-A3]
Évaluation	Probabilité : Moyenne · Impact : Moyen · Niveau : Moyen
Justification	Compromission compte cloud hybride via phishing possible (MFA inadapté sur 60% des comptes) mais HDS certifié réduit impact [E12, E145, CVE-2023-XXX]
Traitement	Réduire — MFA renforcé (ISO27002-8.8), Audit comptes administrateurs (ANSSI-HYGIENE-8.8), Séparation cloud hybride (ANSSI-RECYF)
Sources	[E142], [E12], [E145]
Risque résiduel	Moyen
Validation	À valider par l'analyste
Preuves	[E12] [E142] [E145]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M068 — Fuite de données patients via container compromis exposé sur métadonnées publics S3 → exfiltration de dossiers

Actif	A21 — Infrastructure Cloud — Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/ OVHcloud/Azure (pas d'imposition) [E142]
Menace	LINDDUN-Disclosure — Fuite de données patients via container compromis exposé sur métadonnées publics S3 → exfiltration de dossiers médicaux identifiables [E146,LINDDUN-Disclosure]
Évaluation	Probabilité : Élevée · Impact : Critique · Niveau : **Critique**
Justification	Container S3 exposé à métadonnées publiques permettant exfiltration continue de données médicales identifiées sans chiffrage [E146, E149, LINDDUN-D]
Traitement	Réduire — Chiffrement S3 (ISO27002-8.14), Séparation containers (ANSSI-HYGIENE-8.11), Audit métadonnées (STRIDE-D)
Sources	[E142], [E146], [E149]
Risque résiduel	Critique
Validation	À valider par l'analyste
Preuves	[E142] [E146] [E149]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M069 — Attaquant réseau : écoute man-in-the-middle sur API de gestion IAM cloud hybride → injection de tokens JWT fal

Actif	A21 — Infrastructure Cloud — Hébergeur Cloud Hybride — HDS certifié, choix entre Scaleway/ OVHcloud/Azure (pas d'imposition) [E142]
Menace	STRIDE-E — Attaquant réseau : écoute man-in-the-middle sur API de gestion IAM cloud hybride → injection de tokens JWT falsifiés pour impersonner soignants [E146,STRIDE-E]
Évaluation	Probabilité : Faible · Impact : Élevé · Niveau : Moyen
Justification	Injection JWT falsifiée via attaque réseau possible mais infrastructure IAM centralisée (Entra ID/ Keycloak) atténue l'impact [E13, E145]
Traitement	Réduire — Authentification JWT (ISO27002-8.8), Audit API IAM (STRIDE-E), Séparation réseau (ANSSI-HYGIENE-8.11)
Sources	[E142], [E13], [E145]
Risque résiduel	Moyen
Validation	À valider par l'analyste
Preuves	[E13] [E142] [E145]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M070 — Attaquant interne : poste clinique compromis contourne NAC mal configuré → mouvement latéral via VLAN IoT non

Actif	A22 — Infrastructure sécurité — Micro-segmentation VLAN/NAC — Architecture cible pour isoler poste clinique compromis (VLAN IoT/Biomedical 10.1.30.0/24 non cloisonné actuellement) [E146,E150,FichedAuditTechnique-ÉtatdesLieuxSanteTechAs-Is.pdf.md,E205]
Menace	STRIDE-R — Attaquant interne : poste clinique compromis contourne NAC mal configuré → mouvement latéral via VLAN IoT non isolé (10.1.30.0/24) vers serveurs critiques PACS/RIS [E146,E205,STRIDE-R]
Évaluation	Probabilité : Élevée · Impact : Critique · Niveau : **Critique**
Justification	Poste clinique compromis atteint PACS/RIS critique via VLAN IoT non cloisonné 10.1.30.0/24 (routage direct) [E169, E203, STRIDE-R]
Traitement	Éviter — Cloisonnement VLAN 10.1.30.0/24 (ANSSI-HYGIENE-8.11), NAC étendu (ISO27002-8.2), Suppression routage direct (STRIDE-R)
Sources	[E146], [E150], [E203]
Risque résiduel	Critique
Validation	À valider par l'analyste
Preuves	[E146] [E150] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M071 — Attaquant externe : injection de paquets falsifiés entre VLAN Wi-Fi Invités (10.1.40.0/24) et VLAN Biomed → in

Actif	A22 — Infrastructure sécurité — Micro-segmentation VLAN/NAC — Architecture cible pour isoler poste clinique compromis (VLAN IoT/Biomedical 10.1.30.0/24 non cloisonné actuellement) [E146,E150,FichedAuditTechnique-ÉtatdesLieuxSanteTechAs-Is.pdf.md,E205]
Menace	STRIDE-I — Attaquant externe : injection de paquets falsifiés entre VLAN Wi-Fi Invités (10.1.40.0/24) et VLAN Biomed → interception de flux IoT non chiffrés vers automates [E146,E205,STRIDE-I]
Évaluation	Probabilité : Faible · Impact : Moyen · Niveau : Faible
Justification	Injection paquets entre VLANs possible mais hypothèse retenue interdiction Internet directe limite l'échelle [E171, E205, E140]
Traitement	Transférer — Cyber-assurance (ANSSI-RECYF), Audit IPv4/IPv6 (STRIDE-T), Segmentation VLAN (ISO27002-8.11)
Sources	[E146], [E150], [E140]
Risque résiduel	Faible
Validation	À valider par l'analyste
Preuves	[E140] [E146] [E150]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M072 — Utilisateur soignant : clic sur lien de phishing redirigeant vers intranet compromis via VLAN invité → exécuti

Actif	A22 — Infrastructure sécurité — Micro-segmentation VLAN/NAC — Architecture cible pour isoler poste clinique compromis (VLAN IoT/Biomedical 10.1.30.0/24 non cloisonné actuellement) [E146,E150,FichedAuditTechnique-ÉtatdesLieuxSanteTechAs-Is.pdf.md,E205]
Menace	LINDDUN-Unawareness — Utilisateur soignant : clic sur lien de phishing redirigeant vers intranet compromis via VLAN invité → exécution malware sans MFA requis [E146,LINDDUN-Unawareness]
Évaluation	Probabilité : Élevée · Impact : Élevé · Niveau : **Critique**
Justification	Phishing vers intranet via VLAN invité sans MFA requis expose utilisateurs à malware (déplacement de cible vers zone moins surveillée) [E13, E113]
Traitement	Réduire — Séparation VLAN invités (ANSSI-HYGIENE-8.11), Éducation phishing (ISO27002-8.8), MFA pour intranet (STRIDE-I)
Sources	[E146], [E150], [E113]
Risque résiduel	Critique
Validation	À valider par l'analyste
Preuves	[E113] [E146] [E150]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M073 — Attaquant : contournement processus de MFA sur application mobile compromise → injection de session utilisateu

Actif	A23 — Application/Rôle — IdP Gestion Identités (TO-BE) — Déploiement cible IdP centralisé (Entra ID/ Keycloak) avec MFA FIDO2/Carte CPS [E146]
Menace	STRIDE-E — Attaquant : contournement processus de MFA sur application mobile compromise → injection de session utilisateur validée via exploit framework [E146,STRIDE-E,CVE-2023-29358 (si applicable)]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Contournement MFA via exploit framework [E146]. Mesures existantes (MFA FIDO2) réduisent probabilité mais impact critique sur accès aux données patients.
Traitement	Réduire — MFA FIDO2 (ANSSI-HYGIENE-5.3), segmentation VLAN (ISO27002-8.14)
Sources	E146, ANSSI-HYGIENE
Risque résiduel	Risque moyen
Validation	À valider par l'analyste
Preuves	[E146]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M074 — Attaquant : lecture de logs d'authentification exposés via interface d'administration Keycloak → inférence don

Actif	A23 — Application/Rôle — IdP Gestion Identités (TO-BE) — Déploiement cible IdP centralisé (Entra ID/ Keycloak) avec MFA FIDO2/Carte CPS [E146]
Menace	Attaquant : lecture de logs d'authentification exposés via interface d'administration Keycloak → inférence données sensibles de patients sur les tokens validés [E146]
Évaluation	Probabilité : Moyen · Impact : Élevé · Niveau : **Élevé**
Justification	Lecture de logs d'authentification exposés via Keycloak [E146]. Inférence de données sensibles via tokens validés.
Traitement	Réduire — Cryptage des logs d'authentification (ISO27002-8.11), pare-feu applicatif
Sources	E146, ANSSI-HYGIENE
Risque résiduel	Risque élevé
Validation	À valider par l'analyste
Preuves	[E146]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M075 — Attaquant : accès non autorisé aux rapports d'audit d'authentification → profilage des habitudes médicales des

Actif	A23 — Application/Rôle — IdP Gestion Identités (TO-BE) — Déploiement cible IdP centralisé (Entra ID/ Keycloak) avec MFA FIDO2/Carte CPS [E146]
Menace	LINDDUN-L — Attaquant : accès non autorisé aux rapports d'audit d'authentification → profilage des habitudes médicales des soignants via historiques de connexions [E146,LINDDUN-L]
Évaluation	Probabilité : Moyen · Impact : Élevé · Niveau : **Élevé**
Justification	Accès non autorisé aux rapports d'audit [E146]. Profilage médical via historiques de connexions.
Traitement	Réduire — Contrôle d'accès RBAC (ISO27002-8.13), audit régulier (ANSSI-RECYF)
Sources	E146, ANSSI-HYGIENE
Risque résiduel	Risque moyen
Validation	À valider par l'analyste
Preuves	[E146]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M076 — Atteignant à travers le flux API admin : récupération de tokens refresh compromis → accès indirect aux données

Actif	A23 — Application/Rôle — IdP Gestion Identités (TO-BE) — Déploiement cible IdP centralisé (Entra ID/ Keycloak) avec MFA FIDO2/Carte CPS [E146]
Menace	LINDDUN-Disclosure — Atteignant à travers le flux API admin : récupération de tokens refresh compromis → accès indirect aux données personnelles des patients (noms, diagnostics) sans consentement explicite [E146,LINDDUN-D]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Récupération de tokens refresh compromis via API admin [E146]. Accès indirect aux données patients sans consentement.
Traitement	Réduire — API Gateway rate-limited (ISO27002-8.8), certificats TLS renouvelés (ANSSI-IA-GEN)
Sources	E146, ANSSI-HYGIENE
Risque résiduel	Risque critique
Validation	À valider par l'analyste
Preuves	[E146]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M077 — Attaquant web : exploitation d'endpoint API non rate-limited → déni de service massif par requêtes inondées bl

Actif	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]
Menace	STRIDE-T — Attaquant web : exploitation d'endpoint API non rate-limited → déni de service massif par requêtes inondées bloquant consultations télé-médicales urgentes [E146,STRIDE-T]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Exploitation d'endpoint non rate-limited [E146]. Dénigrement de service sur consultations urgentes.
Traitement	Réduire — Authentification multifacteur (ISO27002-8.2), chiffrement des payloads (ANSSI-PSSI)
Sources	E146, ANSSI-HYGIENE
Risque résiduel	Risque critique
Validation	À valider par l'analyste
Preuves	[E146]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M078 — Attaquant réseau : injection payload sur endpoint de télétransmission → interception flux DICOM/HEM (données p

Actif	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]
Menace	STRIDE-I — Attaquant réseau : injection payload sur endpoint de télétransmission → interception flux DICOM/HEM (données patients en transit via HTTPS mal configured) [E146,STRIDE-I]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Injection payload sur endpoint HTTPS mal configuré [E146]. Interceptation de flux DICOM/HEM sensibles.
Traitement	Réduire — Validation des certificats mutualisés (ISO27002-8.22), inspection des paquets (ANSSI-RECYF)
Sources	E146, ANSSI-HYGIENE
Risque résiduel	Risque critique
Validation	À valider par l'analyste
Preuves	[E146]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M079 — Attaquant : falsification d'en-têtes Authorization sur API Gateway → élévation privilèges pour accéder dossier

Actif	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]
Menace	STRIDE-E — Attaquant : falsification d'en-têtes Authorization sur API Gateway → élévation privilèges pour accéder dossiers patients hors périmètre de rôle soignant [E146,STRIDE-E]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Falsification d'en-têtes Authorization [E146]. Élévation de privilèges pour accès hors périmètre.
Traitement	Réduire — Équilibrage de charge sécurisé (ISO27002-8.24), suppression des headers non vérifiés (ANSSI-HYGIENE)
Sources	E146, ANSSI-HYGIENE
Risque résiduel	Risque critique
Validation	À valider par l'analyste
Preuves	[E146]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M080 — Exfiltration de données sensibles : accès indirect via endpoint / public-health-exports → lecture des historiqu

Actif	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]
Menace	LINDDUN-Disclosure — Exfiltration de données sensibles : accès indirect via endpoint /public-health-exports → lecture des historiques médicaux anonymisés identifiants [E146,LINDDUN-D]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Exfiltration de données via endpoint /public-health-exports [E146]. Lecture d'historiques médicaux anonymisés.
Traitement	Réduire — Cryptage des exports (ISO27002-8.25), journalisation des accès (ANSSI-HYGIENE)
Sources	E146, ANSSI-HYGIENE
Risque résiduel	Risque critique
Validation	À valider par l'analyste
Preuves	[E146]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M081 — Compromission d'accès admin à l'API Gateway cloud → substitution des certificates TLS au routage (SSL/TLS stri

Actif	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]
Menace	STRIDE-S — Compromission d'accès admin à l'API Gateway cloud → substitution des certificates TLS au routage (SSL/TLS stripping) interceptant consultations [E146,STRIDE-S]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Substitution de certificates TLS via compromission admin [E146]. Interception de consultations sécurisées.
Traitement	Réduire — Système de détection d'intrusion (ISO27002-8.26), validation des certificats TLS (ANSSI-IA-GEN)
Sources	E146, ANSSI-HYGIENE
Risque résiduel	Risque critique
Validation	À valider par l'analyste
Preuves	[E146]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M082 — Patient connecté : clic sur lien de vérification SMS compromis par attaquants → validation de session sans con

Actif	A24 — API Télémédecine Cloud Hybride — Logiciel / Service — Interface REST/HTTPS sécurisée via API Gateway dans Cloud Hybride [E146]
Menace	LINDDUN-Unawareness — Patient connecté : clic sur lien de vérification SMS compromis par attaquants → validation de session sans connaissance du contexte médical (phishing social) [E146]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Phishing via lien SMS compromis [E146]. Validation de session sans contrôle contextuel.
Traitement	Réduire — Éducation des utilisateurs (ISO27002-8.28), validation des liens (ANSSI-HYGIENE)
Sources	E146, ANSSI-HYGIENE
Risque résiduel	Risque critique
Validation	À valider par l'analyste
Preuves	[E146]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M083 — Attaquant interne : exploit Citrix RDS (CVE-2021-37119) → élévation privilèges globale sur serveur de dossier

Actif	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139]
Menace	STRIDE-R — Attaquant interne : exploit Citrix RDS (CVE-2021-37119) → élévation privilèges globale sur serveur de dossier patients puis accès aux archives cliniques [E139,STRIDE-R,CVE-2021-37119]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Exploit Citrix RDS (CVE-2021-37119) [E139]. Accès à archives cliniques via élévation de privilèges.
Traitement	Réduire — Patching systématique (ISO27002-8.16), segmentation réseau (ANSSI-HYGIENE)
Sources	E139, ANSSI-HYGIENE
Risque résiduel	Risque critique
Validation	À valider par l'analyste
Preuves	[E139]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M084 — Attaquant réseau : redirection DNS vers serveur compromis → interception des échanges RDP/ICM entre médecins e

Actif	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139]
Menace	STRIDE-I — Attaquant réseau : redirection DNS vers serveur compromis → interception des échanges RDP/ICM entre médecins et postes navigateurs patients [E139,STRIDE-I]
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Redirection DNS vers serveur compromis [E139]. Interception des échanges RDP/ICM médicaux.
Traitement	Réduire — Filtrage DNS (ISO27002-8.15), chiffrement des échanges (ANSSI-PSSI)
Sources	E139, ANSSI-HYGIENE
Risque résiduel	Risque critique
Validation	À valider par l'analyste
Preuves	[E139]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M085 — Attaquant : lecture de logs serveur d'application expose en clair les infos patients en erreur → extraction no

Actif	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139]
Menace	LINDDUN-Disclosure — Attaquant : lecture de logs serveur d'application expose en clair les infos patients en erreur → extraction noms, diagnostics via page 404 mal config [E139,LINDDUN-D]
Évaluation	Probabilité : Élevée · Impact : Élevé · Niveau : **Critique**
Justification	Logs serveur exposés en clair + page 404 malconfig → extraction noms/diagnostics [E139] → fuite donnée patients critique [EBIOS-RM-A4,LINDDUN-D]
Traitement	Réduire — Journalisation des logs serveur chiffrée + correction page 404 (renvoyant login admin avec MFA) + filtrage X-WAF sur endpoints log [ANSSI-CARTO-SI,ANSSI-HYGIENE-7,ISO27002-8.15]
Sources	ANSSI-CARTO-SI,ANSSI-HYGIENE-7,ISO27002-8.15,E139
Risque résiduel	Faible : logs exposés corrigés via journalisation chiffrée + page 404 fixée
Validation	À valider par l'analyste
Preuves	[E139]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M086 — Attaquant : injection de script XSS en-page administration → exécution non autorisée permettant d'accéder aux

Actif	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139]
Menace	STRIDE-E — Attaquant : injection de script XSS en-page administration → exécution non autorisée permettant d'accéder aux dossiers patients sans authentification valide [E139,STRIDE-E]
Évaluation	Probabilité : Moyenne · Impact : Élevé · Niveau : **Élevé**
Justification	Injection XSS côté serveur sur interface admin sans authentification robuste exploitable (CVE-2023-50387) → accès non autorisé aux dossiers patients [E139,STRIDE-E]
Traitement	Réduire — Protection CSP strict sur application admin + Sanitization des données d'entrée + WAF XSS RASP + authentification obligatoire MFA FIDO2 [ANSSI-CARTO-SI,ISO27002-8.15,STRIDE-E]
Sources	ANSSI-CARTO-SI,ISO27002-8.15,STRIDE-E,CVE-2023-50387
Risque résiduel	Faible : interface admin durcie sans authentification sans MFA + CSP mis [E146]
Validation	À valider par l'analyste
Preuves	[E139] [E146]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M087 — Attaquant : accès non autorisé à API d'export de rapports → profilage des habitudes de soins des patients via

Actif	A25 — Plateforme DPI Nexus (Dossier Patient Informatisé) — Logiciel / Service — Hébergé sur ferme Citrix/RDS (Siège Rennes) [E139]
Menace	LINDDUN-L — Attaquant : accès non autorisé à API d'export de rapports → profilage des habitudes de soins des patients via agrégation des résultats anonymisés [E139,LINDDUN-L]
Évaluation	Probabilité : Moyenne · Impact : Moyen · Niveau : Moyen
Justification	Accès API export de rapports mal protégé → agrégation résultats anonymisés reconstituent profils patients [E139,LINDDUN-L] → atteinte vie privée modérée [EBIOS-RM-A4]
Traitement	Réduire — Limitation des quotas d'appels API + chiffrement TLS 1.3 obligatoire + anonymisation renforcée (k-anonymité k≥50) + accès IP restreint [ANSSI-CARTO-SI,ISO27002-6.3,LINDDUN-L]
Sources	ANSSI-CARTO-SI,ISO27002-6.3,LINDDUN-L,EBIOS-RM-A4
Risque résiduel	Très Faible : API report protégée avec restrictions d'accès + chiffrement renforcé [E145]
Validation	À valider par l'analyste
Preuves	[E139] [E145]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M088 — Attaque par exploitation de vulnérabilités non-patchées sur les dispositifs IoT, exposés via le VLAN non clois

Actif	A26 — Parc IoT Médical
Menace	STRIDE-D — Attaque par exploitation de vulnérabilités non-patchées sur les dispositifs IoT, exposés via le VLAN non cloisonné [E205]
Évaluation	Probabilité : Élevée · Impact : Élevé · Niveau : **Critique**
Justification	IoT non-patchés routés dans VLAN médical non cloisonné → exploitation vulnérabilités connues possible (EOL) [E203,E205,STRIDE-D] → impact santé direct [EBIOS-RM-A4]
Traitement	Réduire — Segmentation VLAN IoT médicale isolée (VLAN 10.1.30.0/24 cloisonné) + NAT strict sans accès Internet direct + patch management plan pour dispositifs EOL [ANSSI-HYGIENE-9,ISO27002-8.8,STRIDE-D]
Sources	ANSSI-HYGIENE-9,ISO27002-8.8,STRIDE-D,E203,E205
Risque résiduel	Moyen : VLAN IoT médical isolé de production + routage restreint vers automates [E140]
Validation	À valider par l'analyste
Preuves	[E140] [E205]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M089 — Fuite de données sensibles via les dispositifs IoT non isolés, exploitant le routage direct vers les automates

Actif	A26 — Parc IoT Médical
Menace	LINDDUN-D — Fuite de données sensibles via les dispositifs IoT non isolés, exploitant le routage direct vers les automates [E203]
Évaluation	Probabilité : Élevée · Impact : Critique · Niveau : **Critique**
Justification	IoT biomédical connecté sans isolation réseau → données capteurs patient fuites routage direct vers automates [E203] → atteinte confidentialité/sécurité patients grave [LINDDUN-D,EBIOS-RM-A4]
Traitement	Réduire — Isolation réseau physique (pas logique seulement) pour dispositifs biomédicaux critiques + chiffrement de bout en bout des flux capteurs [ANSSI-PSSI,ISO27002-8.5,LINDDUN-D]
Sources	ANSSI-PSSI,ISO27002-8.5,LINDDUN-D,EBIOS-RM-A4
Risque résiduel	Faible : IoT biomédical isolé physiquement + flux capteurs cryptés en transit [E140]
Validation	À valider par l'analyste
Preuves	[E140] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M090 — Attaque de spoofing via les micro-noyaux temps réel non patchables, exposés sans segmentation

Actif	A26 — Parc IoT Médical
Menace	STRIDE-S — Attaque de spoofing via les micro-noyaux temps réel non patchables, exposés sans segmentation [E205]
Évaluation	Probabilité : Moyenne · Impact : Moyen · Niveau : Moyen
Justification	Micro-noyaux temps réel IoT non patchables + exposition sans segmentation → spoofing attaques système possible [E205,STRIDE-S] → dégradation fonctionnalité critique
Traitement	Réduire — Isolation par VLAN dédié micro-noyaux temps réel + surveillance intrusion IDS/IPS pour spoofing détectation précoce + authentification network NAC obligatoire [EBIOS-RM-A3,ISO27002-8.11,STRIDE-S]
Sources	EBIOS-RM-A3,ISO27002-8.11,STRIDE-S,E205
Risque résiduel	Très Faible : micro-noyaux IoT segmentés par VLAN + IDS/IPS actif pour détection spoofing [E140]
Validation	À valider par l'analyste
Preuves	[E140] [E205]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M091 — Spoofing via le réseau MPLS non segmenté, permettant l'accès à tous les serveurs physiques

Actif	A27 — Ferme Citrix/RDS
Menace	STRIDE-S — Spoofing via le réseau MPLS non segmenté, permettant l'accès à tous les serveurs physiques [E139]
Évaluation	Probabilité : Élevée · Impact : Critique · Niveau : **Critique**
Justification	Ferme Citrix/RDS connectée sur réseau MPLS non segmenté avec accès physique direct à tous serveurs → compromission systémique tout le siège [E139,STRIDE-S] → atteinte intégrité masse données [EBIOS-RM-A4]
Traitement	Réduire — Segment MPLS avec micro-segmentation (VLAN par service) + accès direct limité uniquement par IP + authentification réseau 802.1X obligatoire [ANSSI-CARTO-SI,ISO27002-5.4,STRIDE-S]
Sources	ANSSI-CARTO-SI,ISO27002-5.4,STRIDE-S,E139
Risque résiduel	Faible : ferme Citrix/RDS isolée sur MPLS segmenté + accès direct restreint à serveurs certifiés [E139]
Validation	À valider par l'analyste
Preuves	[E139]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M092 — Reproduction de trafic via la micro-segmentation absente, facilitant la lateralité

Actif	A27 — Ferme Citrix/RDS
Menace	STRIDE-R — Reproduction de trafic via la micro-segmentation absente, facilitant la lateralité [E139]
Évaluation	Probabilité : Moyenne · Impact : Élevé · Niveau : **Élevé**
Justification	Micro-segmentation absente sur domaine Citrix/RDS → trafic capturé et reproduit lateralité entre serveurs physiques [E139,STRIDE-R] → propagation latérale possible
Traitement	Réduire — Déploiement micro-segmentation (NSX/Tanzu/VMware) sur domaine Citrix + politiques ZTNA par travailleur + journalisation trafic inter-serveurs [ISO27002-8.2,ISO27002-5.30,EBIOS-RM-A4]
Sources	ISO27002-8.2,ISO27002-5.30,EBIOS-RM-A4,E139
Risque résiduel	Faible : micro-segmentation déployée sur ferme Citrix/RDS + lateralité bloquée [E146]
Validation	À valider par l'analyste
Preuves	[E139] [E146]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M093 — Fuite de données patients via les postes Windows 7/XP, non durcis contre les attaques par usurpation

Actif	A28 — Postes legacy
Menace	LINDDUN-D — Fuite de données patients via les postes Windows 7/XP, non durcis contre les attaques par usurpation [E150]
Évaluation	Probabilité : Élevée · Impact : Critique · Niveau : **Critique**
Justification	Postes Windows 7/XP non durcis + système de santé sensible → fuites données patients vulnérabilités connues exploitables (MS08-067 SMBv1, EternalBlue) [E150,LINDDUN-D] → données critiques exposées
Traitement	Éviter — Migration progressive vers Windows 10/11 LTSC ou Linux avec agents HDS [ANSSI-HYGIENE-5,EBIOS-RM-A4,LINDDUN-D]
Sources	ANSSI-HYGIENE-5,EBIOS-RM-A4,LINDDUN-D,E150
Risque résiduel	Négligeable : postes Windows 7/XP mis en service de secours uniquement (non critiques) + migration planifiée [E150]
Validation	À valider par l'analyste
Preuves	[E150]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M094 — Élévation de privilèges via les postes Windows 7/XP, vulnérables aux exploits SMBv1

Actif	A28 — Postes legacy
Menace	STRIDE-E — Élévation de privilèges via les postes Windows 7/XP, vulnérables aux exploits SMBv1 [E203]
Évaluation	Probabilité : Élevée · Impact : Élevé · Niveau : **Critique**
Justification	Postes Windows 7/XP non patchés + protocoles legacy SMBv1 actifs → élévation privilèges exploits connus vulnérables [E203,STRIDE-E] → compromission poste puis réseau local [EBIOS-RM-A4]
Traitement	Réduire — Bloquer SMBv1 firewall par défaut + déploiement patches EternalBlue via GPO obligatoire + dégradation poste à terminal KVM sécurisé [ISO27002-8.8,STRIDE-E]
Sources	ISO27002-8.8,STRIDE-E,EBIOS-RM-A4,E203
Risque résiduel	Faible : SMBv1 bloqué réseau local + postes XP en mode sandbox avec isolation [E203]
Validation	À valider par l'analyste
Preuves	[E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M095 — Spoofing via le réseau centralisé sans isolation, permis par la micro-segmentation absente

Actif	A29 — MPLS Hub & Spoke
Menace	STRIDE-S — Spoofing via le réseau centralisé sans isolation, permis par la micro-segmentation absente [E139]
Évaluation	Probabilité : Élevée · Impact : Critique · Niveau : **Critique**
Justification	Réseau MPLS Hub&Spoke centralisé sans isolation micro-segmentation → spoofing routes atteste exposition tous sites [E139,STRIDE-S] → accès transversal clinique à clinique
Traitement	Réduire — Intersegment MPLS avec ACL strictes (IPsec VPN entre hubs) + chiffrement TLS obligatoire sur toutes routes transversales + IDS L7 inspection trafic [ANSSI-CARTO-SI,ISO27002-6.3,STRIDE-S]
Sources	ANSSI-CARTO-SI,ISO27002-6.3,STRIDE-S,E139
Risque résiduel	Très Faible : interconnexion sites via IPsec chiffré seul + ACL routage segmenté [E140]
Validation	À valider par l'analyste
Preuves	[E139] [E140]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M096 — Reproduction de trafic entre cliniques via l'IP directe, sans filtre SSL

Actif	A29 — MPLS Hub & Spoke
Menace	STRIDE-R — Reproduction de trafic entre cliniques via l'IP directe, sans filtre SSL [E203]
Évaluation	Probabilité : Moyenne · Impact : Élevé · Niveau : **Élevé**
Justification	Interconnexion IP directe entre cliniques + absence filtre SSL sur trafic répliqué → reproduction trafic sensible inter-sites [E203,STRIDE-R] → écoute/captation données en transit
Traitement	Réduire — SSL/TLS inspection inter-clinique obligatoire + déploiement WAF Gateway inter-VSite + chiffrement TLS 1.3 avec ECDHE obligatoire [ANSSI-PSSI,ISO27002-8.14,LINDDUN-N]
Sources	ANSSI-PSSI,ISO27002-8.14,LINDDUN-N,E203
Risque résiduel	Très Faible : trafic inter-clinique crypté TLS 1.3 + gateway WAF inspectant réplication [E150]
Validation	À valider par l'analyste
Preuves	[E150] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M097 — Spoofing via le domaine AD sans MFA, permettant la DCSync

Actif	A30 — Active Directory
Menace	STRIDE-S — Spoofing via le domaine AD sans MFA, permettant la DCSync [E150]
Évaluation	Probabilité : Élevée · Impact : Critique · Niveau : **Critique**
Justification	Domaine AD forest unique (corp.santetech.local) sans MFA sur 60% des comptes [E139][E149], forêt Windows Server 2012 R2 avec rétrocabilité historique active [E201] permettant DCSync pour exfiltration totale de l'annuaire [E202].
Traitement	Réduire — MFA FIDO2 pour 100% des comptes AD + Upgrade forêt DC Windows Server 2016 minimum (ISO27002-8.2) [E139][E149][E201]
Sources	ANSSI-HYGIENE[2]-MFA, ISO27002-8.2
Risque résiduel	Élevée·Critique·Moyen
Validation	À valider par l'analyste
Preuves	[E139] [E149] [E150] [E201] [E202]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M098 — Élévation de privilèges via les contrôleurs de domaine non durcis, vulnérables à Kerberoasting

Actif	A30 — Active Directory
Menace	STRIDE-E — Élévation de privilèges via les contrôleurs de domaine non durcis, vulnérables à Kerberoasting [E203]
Évaluation	Probabilité : Élevée · Impact : Élevé · Niveau : **Critique**
Justification	16 contrôleurs de domaine (1 DC/RODC par clinique dans une forêt multisite) [E203], DC non durcis en VLAN interconnecté sans micro-segmentation [E140] exposés aux techniques Kerberoasting et spraying d'hash SHA [E203].
Traitement	Réduire — Micro-segmentation VLAN par DC + Renversement RODC (hachages unidiirectionnels) [E140][E203]
Sources	ANSSI-HYGIENE[3]-Cloisonnement, ISO27002-5.4
Risque résiduel	Élevée·Critique·Faible
Validation	À valider par l'analyste
Preuves	[E140] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M099 — Stockage images radiologiques non chiffrées sur disque local en cliniques, exposé aux fuites lors de la copie

Actif	A31 — Base de Données PACS/RIS Imagerie
Menace	STRIDE-S — Stockage images radiologiques non chiffrées sur disque local en cliniques, exposé aux fuites lors de la copie vers USB ou cloud privé [E140][EBIOS-RM-A3]
Évaluation	Probabilité : Élevée · Impact : Élevé · Niveau : **Critique**
Justification	Stockage DICOM sur baies SAN locales dans 12 cliniques avec SMBv1 encore actif par endroits pour compatibilité scanners [E205], copie vers USB/cloud sans chiffrement fort possible lors des exfiltrations physiques ou hybrides [E140].
Traitement	Réduire — Chiffrement AES-256 DICOM au repos + Désactivation SMBv1 + Isolation baies SAN VLAN (ANSSI-HOMOLOGATION) [E140][E205]
Sources	ANSSI-HYGIENE[6]-Chiffrement, ISO27002-8.13
Risque résiduel	Élevée·Critique·Faible
Validation	À valider par l'analyste
Preuves	[E140] [E205]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M100 — Injection via DICOM gateway non filtrée sur 10.1.10.0/24, permettant l'écriture malveillante dans les études c

Actif	A31 — Base de Données PACS/RIS Imagerie
Menace	STRIDE-I — Injection via DICOM gateway non filtrée sur 10.1.10.0/24, permettant l'écriture malveillante dans les études cliniques [E140] [E205]
Évaluation	Probabilité : Moyenne · Impact : Élevé · Niveau : **Élevé**
Justification	Gateway DICOM non filtrée sur 10.1.10.0/24 connectée au VLAN IoT/Biomédical non cloisonné [E203] permettant écriture malveillante direct dans les bases cliniques sans isolation logique stricte [E145].
Traitement	Réduire — Filtre DPI DICOM gateway 10.1.10.0/24 + Cloisonnement VLAN biomédical IoT [E140] [E205][E203]
Sources	ANSSI-RECYF[8]-Contrôle accès, ISO27002-8.16
Risque résiduel	Élevée·Élevé·Faible
Validation	À valider par l'analyste
Preuves	[E140] [E145] [E203] [E205]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M101 — Altération des métadonnées DICOM par un attaquant ayant accès au VLAN Serveurs Locaux compromis via lateral mo

Actif	A31 — Base de Données PACS/RIS Imagerie
Menace	STRIDE-R — Altération des métadonnées DICOM par un attaquant ayant accès au VLAN Serveurs Locaux compromis via lateral movement [E205][EBIOS-RM-A3]
Évaluation	Probabilité : Moyenne · Impact : Moyen · Niveau : Moyen
Justification	Accès au VLAN Serveurs Locaux via lateral movement exploitable depuis une clinique compromise, corruption DICOM possible mais impact limité aux métadonnées si segmentation réseau partiellement efficace [E140][E203].
Traitement	Réduire — Segment réseau VLAN Serveurs + Isolation logique PACS (VLAN biomédical séparé) [EBIOS-RM-A3]
Sources	ANSSI-HYGIENE[14]-Segmentation, EBIOS-RM-A3
Risque résiduel	Moyenne·Moyen·Faible
Validation	À valider par l'analyste
Preuves	[E140] [E203] [E205]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M102 — Modification d'emails (email spoofing) depuis webmail exposé en DMZ sur webmail.santetech-sante.fr, campagne d

Actif	A32 — Messagerie Exchange 2016 OWA Webmail
Menace	STRIDE-T — Modification d'emails (email spoofing) depuis webmail exposé en DMZ sur webmail.santetech-sante.fr, campagne de phishing ciblant soignants [E140][E159]
Évaluation	Probabilité : Élevée · Impact : Critique · Niveau : **Critique**
Justification	OWA Exchange 2016 exposé en DMZ sur webmail.santetech-sante.fr vulnérable à ProxyShell/Spraying si non patché (Exchange 2016 legacy) [E140][E152], ciblage direct des soignants via phishing depuis interface web accessible extérieurement.
Traitement	Réduire — Patching Exchange 2016 (CVE-2022-41040 corrigé) + WAF Reverse Proxy OWA DMZ [E152] [E205]
Sources	ANSSI-HYGIENE[9]-Correctifs, ISO27002-8.13
Risque résiduel	Élevée·Critique·Faible
Validation	À valider par l'analyste
Preuves	[E140] [E152] [E159] [E205]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M103 — Leakage des dossiers patients via OWA non durci, accès distant par certificats faibles permet lecture mails co

Actif	A32 — Messagerie Exchange 2016 OWA Webmail
Menace	LINDDUN-L — Leakage des dossiers patients via OWA non durci, accès distant par certificats faibles permet lecture mails contenant données sensibles [E152][E203]_[LINDDUN-L]
Évaluation	Probabilité : Élevée · Impact : Élevé · Niveau : **Critique**
Justification	OWA webmail sans filtrage SSL fort sur portail DMZ externe [E140], certificats faibles permettant lecture emails contenant données patients sensibles (mél messagerie sécurisée de santé) accessibles via authentification compromise [E152].
Traitement	Réduire — Certificats TLS ECDHE 4096bits + HSTS OWA DMZ + Double filtrage SMTP [E152]
Sources	ANSSI-HYGIENE[7]-Chiffrement SSL, ISO27002-8.8
Risque résiduel	Élevée·Élevé·Faible
Validation	À valider par l'analyste
Preuves	[E140] [E152] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M104 — Exploitation ProxyShell/Spraying non corrigé par patching Exchange 2016 legacy, permettant exécution RCE sur s

Actif	A32 — Messagerie Exchange 2016 OWA Webmail
Menace	STRIDE-E — Exploitation ProxyShell/Spraying non corrigé par patching Exchange 2016 legacy, permettant exécution RCE sur serveur messagerie [E152][CVE-2022-41040]
Évaluation	Probabilité : Élevée · Impact : Critique · Niveau : **Critique**
Justification	ProxyShell/Spraying vulnérabilité CVE-2022-41040 connue et non corrigée selon audit technique [E205], permettant exécution code arbitraire RCE sur serveur messagerie critique exposé en DMZ [E171].
Traitement	Réduire — Correction CVE-2022-41040 + Isolation OWA DMZ sous VLAN propre (micro-segmentation) [E205]
Sources	ANSSI-HYGIENE[9]-Correctifs, ISO27002-8.13
Risque résiduel	Élevée·Critique·Faible
Validation	À valider par l'analyste
Preuves	[E152] [E171] [E205]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M105 — Compromission de session via authentification simple login/mot de passe sans MFA, injection de tokens dans les

Actif	A33 — Portail VPN FortiGate
Menace	STRIDE-T — Compromission de session via authentification simple login/mot de passe sans MFA, injection de tokens dans les flux d'authentification [E149][E150]
Évaluation	Probabilité : Moyenne · Impact : Moyen · Niveau : Moyen
Justification	Authentification simple login/mot de passe sans MFA systématique sur 60% des comptes VPN FortiGate [E139][E149], injection tokens possible dans flux d'authentification non chiffrés ou faiblement sécurisés.
Traitement	Réduire — Déploiement MFA FIDO2 FortiGate (60% comptes manquants) + SAML/SSO IDP [E149] [E139]
Sources	ANSSI-HYGIENE[8]-Double facteur, ISO27002-8.2
Risque résiduel	Moyenne·Moyen·Faible
Validation	À valider par l'analyste
Preuves	[E139] [E149] [E150]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M106 — Fuite d'identifiants VPN 60% des comptes sans MFA, accès privilégié aux ressources internes après compromissio

Actif	A33 — Portail VPN FortiGate
Menace	LINDDUN-Disclosure — Fuite d'identifiants VPN 60% des comptes sans MFA, accès privilégié aux ressources internes après compromission de credentia [E140][E149]
Évaluation	Probabilité : Élevée · Impact : Élevé · Niveau : **Critique**
Justification	Fuite identifiants VPN sur 60% des comptes sans double facteur [E152], accès privilégié interne post-compromission crédentiel avec accès VLAN biomédical IoT direct [E203][E140] et cloud externe exfiltrable.
Traitement	Réduire — MFA FIDO2/MAPF (carte CPS) VPN FortiGate + Journalisation accès [E149][E203]
Sources	ANSSI-HYGIENE[8]-Double facteur, ISO27002-8.28
Risque résiduel	Élevée·Critique·Faible
Validation	À valider par l'analyste
Preuves	[E140] [E149] [E152] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M107 — Attaques d'injection dans les logs FortiGate pour corrompre l'historique des accès, masquer les tentatives de

Actif	A33 — Portail VPN FortiGate
Menace	STRIDE-I — Attaques d'injection dans les logs FortiGate pour corrompre l'historique des accès, masquer les tentatives de bypass [E150]
Évaluation	Probabilité : Faible · Impact : Moyen · Niveau : Faible
Justification	Logs FortiGate exposés mais non chiffrés sans impact immédiat masquage, corrompre historique accessible uniquement depuis admin compromise ou faille côté passerelle VPN [E231][E176].
Traitement	Réduire — Logs FortiGate chiffrés TLS 1.3 + Normalisation format JSON (non affecte l'attaque) [E231]
Sources	ANSSI-HYGIENE[9]-Journalisation, ISO27002-8.26
Risque résiduel	Faible·Moyen·Faible
Validation	À valider par l'analyste
Preuves	[E150] [E176] [E231]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M108 — Dumping de hachages d'identifiants via LSASS compromise sur 12 RODC, exfiltration vers cloud externe

Actif	A34 — Contrôleur de Domaine RODC par Clinique
Menace	STRIDE-S — Dumping de hachages d'identifiants via LSASS compromise sur 12 RODC, exfiltration vers cloud externe [E202][E140]
Évaluation	Probabilité : Élevée · Impact : Critique · Niveau : **Critique**
Justification	12 RODC (1 par clinique) avec dumping LSASS possible sur 12 contrôleurs en distribution régionale [E202], hachages non salés exposés à exfiltration totale vers cloud externe ou stockage adverse [E140].
Traitement	Réduire — Désactivation LSASS RODC + Renversement AD (hachages salés unidirectionnels) [E202] [E140]
Sources	ANSSI-HYGIENE[5]-Contrôle accès, ISO27002-5.3
Risque résiduel	Élevée·Critique·Moyen
Validation	À valider par l'analyste
Preuves	[E140] [E202]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M109 — Création d'objets Kerberos faux sur réseau 10.1.0.0/16, permettant délégué d'accès à tous les DC du périmètre

Actif	A34 — Contrôleur de Domaine RODC par Clinique
Menace	STRIDE-T — Création d'objets Kerberos faux sur réseau 10.1.0.0/16, permettant délégué d'accès à tous les DC du périmètre [E202][E138][MITRE-T1558]
Évaluation	Probabilité : Élevée · Impact : Élevé · Niveau : **Critique**
Justification	12 DC RODC sans micro-segmentation [E138], absence SOC [E9] → compromission totale AD possible, impact sur toutes les cliniques
Traitement	Réduire — Micro-segmentation réseau VLAN/NAC, isolation RODC par firewall ACL strict (ISO27002-8.15), déploiement SOC centralisé avec EDR (EBIOS-RM-A3), MFA sur accès DCs critiques (ANSSI-HYGIENE 6)
Sources	ISO27002-8.15, ANSSI-HYGIENE, EBIOS-RM-A3
Risque résiduel	Moyenne — Élevé — Moyen
Validation	À valider par l'analyste
Preuves	[E9] [E138] [E202]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M110 — Poisoning LDAP via écriture sur RODC (mode read-only théoriquement mais pas en pratique), injection d'objets m

Actif	A34 — Contrôleur de Domaine RODC par Clinique
Menace	STRIDE-E — Poisoning LDAP via écriture sur RODC (mode read-only théoriquement mais pas en pratique), injection d'objets malveillants [E202]
Évaluation	Probabilité : Moyen · Impact : Élevé · Niveau : **Élevé**
Justification	RODC en mode read-only théorique mais pas appliqué [E138], injection objets via LDAP vulnérable [E202] → persistance long terme sans détection
Traitement	Réduire — Validation schema LDAP strict avec ACL écriture limitée, monitoring injection objets via journalisation SIEM centralisé (ISO27002-8.8), alertes anomalies RODC écr (EBIOS-RM-A3)
Sources	ISO27002-8.8, ISO27002-5.3, ANSSI-HYGIENE 12
Risque résiduel	Faible — Moyen — Faible
Validation	À valider par l'analyste
Preuves	[E138] [E202]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M111 — Détection inexistante d'attaques Ransomware en temps réel, propagation latérale non surveillée via réseau MPLS

Actif	A35 — Sécurité IT (SOC/EDR/SIEM)
Menace	STRIDE-T — Détection inexistante d'attaques Ransomware en temps réel, propagation latérale non surveillée via réseau MPLS [E140][E40]
Évaluation	Probabilité : Élevée · Impact : Critique · Niveau : **Critique**
Justification	Détection Ransomware nulle, absence EDR/SIEM centralisé [E9][E40] → propagation latérale dans les 185 serveurs legacy indétectable
Traitement	Réduire — Déploiement EDR/SIEM centralisé sur tous serveurs (EBIOS-RM-A3), segmentation MPLS en zones DMZ critiques (ISO27002-8.15), déploiement SOC 24/7 (ANSSI-HYGIENE)
Sources	ISO27002-8.15, ANSSI-HYGIENE, EBIOS-RM-A3
Risque résiduel	Élevée — Critique — Faible
Validation	À valider par l'analyste
Preuves	[E9] [E40] [E140]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M112 — Ingestion d'alertes de sécurité nulle, absence d'intégrité sur les logs SIEM ne permet pas la chasse aux intru

Actif	A35 — Sécurité IT (SOC/EDR/SIEM)
Menace	STRIDE-I — Ingestion d'alertes de sécurité nulle, absence d'intégrité sur les logs SIEM ne permet pas la chasse aux intrus [E9][E139]
Évaluation	Probabilité : Moyenne · Impact : Élevé · Niveau : **Élevé**
Justification	Absence ingestion alertes sécurité [E9], logs SIEM sans intégrité [E139] → chasse aux intrus impossible en environnement on-premise legacy
Traitement	Réduire — Journalisation sécurisée tamponnement logs (ISO27002-8.28), vérification intégrité hash SHA-256 logs SIEM, ingestion alertes via pipeline EDR/EDR-SIEM centralisé (EBIOS-RM-A4), audit logs mensuel (ANSSI-HYGIENE 13)
Sources	ISO27002-8.28, ISO27002-8.29, ANSSI-HYGIENE 13, EBIOS-RM-A4
Risque résiduel	Moyenne — Moyen — Faible
Validation	À valider par l'analyste
Preuves	[E9] [E139]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M113 — Non-détection des exfiltrations de données patients vers cloud tiers, absence de comportement Anomaly sur les

Actif	A35 — Sécurité IT (SOC/EDR/SIEM)
Menace	LINDDUN-L — Non-détection des exfiltrations de données patients vers cloud tiers, absence de comportement Anomaly sur les flux EDR [E40][EBIOS-RM-A3]
Évaluation	Probabilité : Élevée · Impact : Critique · Niveau : **Critique**
Justification	Exfiltration cloud tiers non déteccable, absence EDR sur flux critiques [E40][EBIOS-RM-A3] → violation RGPD avec données patients 150 000 dossiers
Traitement	Réduire — DLP Cloud tiers avec classification données sensibles patients (LINDDUN-L), EDR comportemental monitoring anomalies transferts outbound (EBIOS-RM-A3), chiffrement egress + logging connexion cloud (ISO27001-8.26)
Sources	ISO27001-8.26, ANSSI-PSSI-134, LINDDUN-L, ANSSI-HYGIENE 14
Risque résiduel	Élevée — Critique — Faible
Validation	À valider par l'analyste
Preuves	[E40]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M114 — Attaque par phishing via le portail VPN (E140)

Actif	A36 — Attestation de relecture croisée
Menace	STRIDE-S — Attaque par phishing via le portail VPN (E140)
Évaluation	Probabilité : Élevée · Impact : Critique · Niveau : **Critique**
Justification	Phishing portail VPN FortiGate simple login [E139], CVE-2023-23977 exploité, absence MFA sur 60% comptes [E160] → accès direct AD compromise global
Traitement	Réduire — Implémentation MFA FIDO2 sur 100% comptes VPN (STRIDE-S), patching CVE-2023-23977 FortiGate via vuln feed (ISO27002-8.5), sensibilisation phishing obligatoire CISO/Lead GRC (EBIOS-RM-A3)
Sources	ISO27001-8.5, ANSSI-HYGIENE 6, STRIDE-S, EBIOS-RM-A3
Risque résiduel	Moyenne — Critique — Faible
Validation	À valider par l'analyste
Preuves	[E139] [E160]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M115 — Fuite de données via le Webmail OWA non patché (E201)

Actif	A36 — Attestation de relecture croisée
Menace	LINDDUN-Disclosure — Fuite de données via le Webmail OWA non patché (E201)
Évaluation	Probabilité : Élevée · Impact : Critique · Niveau : **Critique**
Justification	Webmail Exchange 2016 DMZ exposé sans patchs [E163], vulnérable campagnes ProxyShell/Spraying [E9][E145] → fuite emails médicaux sensibles
Traitement	Réduire — Patch rapide Exchange 2016 DMZ (ISO27002-8.5), segment VLAN DMZ pour Webmail avec WAF (ISO27002-8.34), règles iptables blocage campagnes ProxyShell/Spraying, monitoring inbound port 443/80 anomalies (ANSSI-HYGIENE)
Sources	ISO27001-8.5, ISO27002-8.34, ANSSI-HYGIENE 6, EBIOS-RM-A3
Risque résiduel	Faible — Critique — Faible
Validation	À valider par l'analyste
Preuves	[E9] [E145] [E163]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M116 — Élevaison de privilèges via accès non surveillé aux serveurs legacy (E203)

Actif	A37 — CISO / Lead GRC
Menace	STRIDE-T — Élevaison de privilèges via accès non surveillé aux serveurs legacy (E203)
Évaluation	Probabilité : Moyenne · Impact : Élevé · Niveau : **Élevé**
Justification	Accès non surveillé serveurs legacy obsolètes [E203][E30], absence MFA + absence EDR [E9] → élèvasion privileges root sur infrastructure critique
Traitement	Réduire — Gestion privilégiée MoP (principle least privilege) + MFA accès serveurs legacy (ANSII-HYGIENE 37), déploiement EDR sur 185 serveurs avec blocage élévation privilèges signatures (ISO27002-8.16)
Sources	ISO27002-8.2, ISO27002-8.15, ISO27002-8.16, ANSSI-HYGIENE 37, EBIOS-RM-A3
Risque résiduel	Faible — Moyen — Faible
Validation	À valider par l'analyste
Preuves	[E9] [E30] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M117 — Ignorance des protocoles RGPD par le Chef de projet sécurité (E149)

Actif	A37 — CISO / Lead GRC
Menace	LINDDUN-Unawareness — Ignorance des protocoles RGPD par le Chef de projet sécurité (E149)
Évaluation	Probabilité : Faible · Impact : Moyen · Niveau : Faible
Justification	Ignorance RGPD personnel sécurité CISO (E149), formation non documentée dans les preuves → non-conformité réglementaire impact modéré sur sanctions
Traitement	Réduire + Accepter — Programme formation RGPD obligatoire CISO/Lead GRC avec attestation compétence (LINDDUN-Unawareness), audit conformité annuel documenté (ISO27001-8.5, ANSSI-RECYF 1.3.1) — risque résiduel accepté sur non-conformité mineure
Sources	ISO27001-8.5, LINDDUN-Unawareness, EBIOS-RM-A4, ANSSI-HYGIENE 22
Risque résiduel	Non documenté — Non documenté — Faible
Validation	À valider par l'analyste
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M118 — Déni de service via surcharge des serveurs de secours locaux (E201)

Actif	A38 — Blue Team & SOC
Menace	STRIDE-D — Déni de service via surcharge des serveurs de secours locaux (E201)
Évaluation	Probabilité : Faible · Impact : Élevé · Niveau : Moyen
Justification	Serveurs secours locaux saturés DDoS [E201] → déni service mais pas compromission systèmes cœur (backup non critique pour disponibilité continue)
Traitement	Réduire + Accepter — CDN Cloudflare DDoS mitigation Rate Limiting (ISO27001-8.11), réplication backup cloud offsite multi-régions AWS/Azure (ISO27002-5.19), acceptabilité business impact limité données non critiques
Sources	ISO27002-5.19, ISO27001-8.11, ANSSI-HYGIENE 24, EBIOS-RM-A3
Risque résiduel	Faible — Critique — Faible
Validation	À valider par l'analyste
Preuves	[E201]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M119 — Non-conformité aux standards ISO 27001 pour les analyses de menace (E223)

Actif	A38 — Blue Team & SOC
Menace	LINDDUN-NC — Non-conformité aux standards ISO 27001 pour les analyses de menace (E223)
Évaluation	Probabilité : Moyenne · Impact : Faible · Niveau : Faible
Justification	Analyses menace non conformes ISO 27001 [E223], processus EBIOS RM requis mais absent [E9] [E4] → impact limité à certification, pas sécurité opérationnelle
Traitement	Réduire + Accepter — Implémentation processus EBIOS RM 2018 pour analyses menace (EBIOS-RM-2018), certification ISO 27001 audit externe (ISO27002-8.22), mise à jour Plan de Management Sécurité annuel — impact limité certification uniquement
Sources	EBIOS-RM-2018, ISO27001-8.5, ISO27002-8.22 4.3.2
Risque résiduel	Faible — Moyen — Faible
Validation	À valider par l'analyste
Preuves	[E4] [E9] [E223]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M120 — Interceptation des flux API Gateway via le VLAN IoT non cloisonné (E205)

Actif	A39 — CTI & OSINT
Menace	STRIDE-I — Interceptation des flux API Gateway via le VLAN IoT non cloisonné (E205)
Évaluation	Probabilité : Élevée · Impact : Critique · Niveau : **Critique**
Justification	VLAN IoT biomédical non cloisonné routage direct automate [E205][E136], interception API Gateway possible sans micro-segmentation [E228] → accès flux données patients via canal compromis
Traitement	Réduire — Micro-segmentation VLAN IoT biomédical routage ACL restreint automate (ISO27001-8.13), isolation API Gateway DMZ réseau segmenté VLAN, chiffrement TLS 1.3 flux API + DDoS protection WAF (ISO27002-5.19)
Sources	ISO27001-8.13, ISO27002-5.19, ANSSI-HYGIENE 6, EBIOS-RM-A3
Risque résiduel	Faible — Critique — Moyenne
Validation	À valider par l'analyste
Preuves	[E136] [E205] [E228]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M121 — Fuite d'OSINT via les sites web des cliniques hébergés par des prestataires tiers (E201)

Actif	A39 — CTI & OSINT
Menace	LINDDUN-Disclosure — Fuite d'OSINT via les sites web des cliniques hébergés par des prestataires tiers (E201)
Évaluation	Probabilité : Moyen · Impact : Faible · Niveau : Faible
Justification	Sites web des cliniques hébergés par prestataires tiers (E201) : exposition publique aux moteurs de recherche et attaques OSINT, mais données patient non stockées sur ces sites → fuite informations organisationnelles seulement.
Traitement	Accepter — [ANSSI-HYGIENE-4] Documentation contacts publique sans données sensibles
Sources	[ANSSI-HYGIENE-4]
Risque résiduel	Faible - Faible
Validation	À valider par l'analyste
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M122 — Portail vpn.santetech-sante.fr expose avec login/mot de passe simple sans MFA sur 60% des comptes → attaquant

Actif	Frontière Internet ↔ VPN_Gateway (FortiGate)
Menace	STRIDE-S — Portail vpn.santetech-sante.fr expose avec login/mot de passe simple sans MFA sur 60% des comptes [E7][E38][E203] → attaquant réalise brute-force ou credential stuffing pour obtenir accès interne au backbone MPLS.
Évaluation	Probabilité : Élevée · Impact : Moyen · Niveau : **Élevé**
Justification	Portail VPN sans MFA sur 60% des comptes confirmé audit (E7, E38, E203) : attaquant peut effectuer brute-force ou credential stuffing pour accès interne backbone MPLS.
Traitement	Réduire — [ISO27002-5.15], [ANSSI-HYGIENE-3] MFA FIDO2 sur 60% comptes VPN + PAM
Sources	[ISO27002-5.15, ANSSI-HYGIENE-3]
Risque résiduel	Faible - Faible
Validation	À valider par l'analyste
Preuves	[E7] [E38] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M123 — Extranet médecins (extranet.santetech-sante.fr) [A7] : authentification faible permet usurpation d'identité so

Actif	Frontière Internet ↔ VPN_Gateway (FortiGate)
Menace	STRIDE-I — Extranet médecins (extranet.santetech-sante.fr) [E32][A7] : authentification faible permet usurpation d'identité soignant pour modifier/falsifier données médicales ou prescriptions.
Évaluation	Probabilité : Élevée · Impact : Élevé · Niveau : **Critique**
Justification	Extranet médecins E32, A7 : authentification faible permet usurpation identité soignant pour modifier/falsifier données médicales ou prescriptions (EBIOS-RM-A3).
Traitement	Réduire — [ISO27002-5.15], [EBIOS-RM-A3] IdP Centralisé + MFA PAM extranet médecins
Sources	[ISO27002-5.15, ANSSI-HYGIENE-4]
Risque résiduel	Faible - Moyen
Validation	À valider par l'analyste
Preuves	[E32]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M124 — Webmail OWA public (webmail.santetech-sante.fr) : vulnérabilités ProxyShell/CVE-2024 potentielles exposent do

Actif	Frontière Internet ↔ Portail OWA (Exchange 2016 DMZ)
Menace	STRIDE-I — Webmail OWA public (webmail.santetech-sante.fr) [E3][E57] : vulnérabilités ProxyShell/ CVE-2024 potentielles exposent dossiers patients aux fuites par accès RCE sans filtre SSL.
Évaluation	Probabilité : Moyenne · Impact : Élevé · Niveau : **Élevé**
Justification	Webmail OWA public (E3, E57) vulnérable ProxyShell/CVE-2024 potentiel sans filtre SSL : accès RCE expose dossiers patients à fuites (CVE-2024-26099, STRIDE-I).
Traitement	Réduire — [ISO27002-6.3], [ANSSI-HYGIENE-2] Patch CVE-2024-26099 + WAF OWASP SSL filter
Sources	[ISO27002-5.19, ISO27002-5.3]
Risque résiduel	Moyen - Moyen
Validation	À valider par l'analyste
Preuves	[E3] [E57]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M125 — WAF/SIEM absent → attaque DoS direct contre API Gateway/ Cloud_HDS possible sans atténuation, paralysant servi

Actif	Frontière DMZ ↔ WAF optionnel (non déployé As-Is)
Menace	STRIDE-R — WAF/SIEM absent [E36][E271] → attaque DoS direct contre API Gateway/Cloud_HDS possible sans atténuation, paralysant services télémédecine.
Évaluation	Probabilité : Élevée · Impact : Moyen · Niveau : **Élevé**
Justification	WAF/SIEM absent (E36, E271) → attaque DoS direct API Gateway/CloudHDS possible sans atténuation, paralysant services télémédecine (EBIOS-RM-A3).
Traitement	Réduire — [ISO27002-8.14], [EBIOS-RM-A3] WAF FortiWeb + SIEM centralisé
Sources	[ISO27002-8.14, ANSSI-HYGIENE-7]
Risque résiduel	Faible - Faible
Validation	À valider par l'analyste
Preuves	[E36] [E271]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M126 — Site WordPress vitrine : injection SQL/XSS possible via absence de couche WAF pour compromettre réputation cl

Actif	Frontière DMZ ↔ WAF optionnel (non déployé As-Is)
Menace	STRIDE-T — Site WordPress vitrine [E274][E9] : injection SQL/XSS possible via absence de couche WAF pour compromettre réputation clinique et filer données personnelles exposées.
Évaluation	Probabilité : Moyenne · Impact : Faible · Niveau : Faible
Justification	Site WordPress vitrine (E274, E9) : injection SQL/XSS possible via absence WAF, compromettant réputation clinique mais pas données critiques SI (ANSSI-CARTO-SI).
Traitement	Réduire — [ISO27002-5.4], [ANSSI-CARTO-SI] WAF + hardening WordPress + honeypot
Sources	[ISO27002-8.8, ISO27002-5.3]
Risque résiduel	Faible - Faible
Validation	À valider par l'analyste
Preuves	[E9] [E274]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M127 — Backbone MPLS centralisé sans isolation logique → un poste compromis clinique peut communiquer IP directe ave

Actif	Frontière Réseau Interne ↔ Backbone MPLS (sans micro-segmentation)
Menace	STRIDE-T — Backbone MPLS centralisé sans isolation logique [E36][E203][E277] → un poste compromis clinique peut communiquer IP directe avec tout réseau interne, accédant serveurs sensibles siège.
Évaluation	Probabilité : Moyen · Impact : Élevé · Niveau : **Élevé**
Justification	Backbone MPLS sans micro-segmentation (E36, E203, E277) : un poste compromis clinique communique IP directe avec tout réseau interne, accédant serveurs sensibles siège.
Traitement	Réduire — [ISO27002-8.11], [EBIOS-RM-A3] Micro-segmentation VLAN/NAC backbone MPLS
Sources	[ISO27002-8.2, ANSSI-HYGIENE-6]
Risque résiduel	Faible - Faible
Validation	À valider par l'analyste
Preuves	[E36] [E203] [E277]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M128 — Forêt Active Directory corp.santetech.local 16 DC/RODC [A7] : absence micro-segmentation permet propagation la

Actif	Frontière Réseau Interne ↔ Backbones AD (Forêt unique)
Menace	STRIDE-S — Forêt Active Directory corp.santetech.local 16 DC/RODC [E2][A7][E277] : absence micro-segmentation permet propagation latérale compromise RODC → forêt principale via Kerberoasting/ DCE-RPC.
Évaluation	Probabilité : Moyenne · Impact : Élevé · Niveau : **Élevé**
Justification	Forêt AD unique 16 DC/RODC sans micro-segmentation (E2, A7, E277) : absence isolation logique permet propagation latérale compromise RODC → forêt principale via Kerberoasting/DCE-RPC.
Traitement	Réduire — [ISO27002-5.15], [ANSSI-HYGIENE-4] PASEO AD isolé + RODC séparés
Sources	[ISO27002-8.13, EBIOS-RM-A3]
Risque résiduel	Faible - Moyen
Validation	À valider par l'analyste
Preuves	[E2] [E277]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M129 — Ferme Citrix/RDS Rennes héberge DPI Nexus [A7] : accès RDP interne non contrôlé expose données patients 150k d

Actif	Frontière Réseau Interne ↔ Citrix Farm (DPI Nexus)
Menace	STRIDE-S — Ferme Citrix/RDS Rennes héberge DPI Nexus [E25][E148][A7] : accès RDP interne non contrôlé expose données patients 150k dossiers à extraction par attaquant pivotant via réseaux internes.
Évaluation	Probabilité : Moyenne · Impact : Élevé · Niveau : **Élevé**
Justification	Ferme Citrix/RDS Rennes héberge DPI Nexus (E25, E148, A7) : accès RDP interne non contrôlé expose données patients 150k dossiers à extraction par attaquant.
Traitement	Réduire — [ISO27002-8.2], [EBIOS-RM-A4] NAC TACACS+ + MFA RDP Gateway Citrix ADC
Sources	[ISO27002-5.19, ISO27002-6.3]
Risque résiduel	Faible - Moyen
Validation	À valider par l'analyste
Preuves	[E25] [E148]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M130 — VLAN IoT/Biomédical 10.1.30.0/24 routé directement vers automates [A17] : botnets Mirai infecte pompes perfusi

Actif	Frontière VLAN IoT ↔ Core_Net (routage direct)
Menace	STRIDE-R — VLAN IoT/Biomédical 10.1.30.0/24 routé directement vers automates [E9][A17] : botnets Mirai infecte pompes perfusion/moniteurs non patchables, attaques DoS internes critiques bloques soins vitaux.
Évaluation	Probabilité : Élevée · Impact : Critique · Niveau : **Critique**
Justification	VLAN IoT routé directement vers automates (E9, A17) : botnets Mirai infecte pompes perfusion/ moniteurs non patchables, attaque DoS interne bloquant soins vitaux (EBIOS-RM-A3).
Traitement	Éviter — [ANSSI-HYGIENE-6], [ANSSI-RECYF] VLAN biomédical isolé + blocage Internet direct
Sources	[ANSSI-HYGIENE-6, ANSSI-RECYF]
Risque résiduel	Faible - Faible
Validation	À valider par l'analyste
Preuves	[E9]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M131 — VLAN IoT non cloisonné : compromis device biomédical permet exécution commandes malveillantes sur automates s

Actif	Frontière VLAN IoT ↔ Core_Net (routage direct)
Menace	STRIDE-T — VLAN IoT non cloisonné [E9][E277] : compromis device biomédical permet exécution commandes malveillantes sur automates sensibles et fuite logs d'audit.
Évaluation	Probabilité : Moyenne · Impact : Faible · Niveau : Faible
Justification	VLAN IoT non cloisonné (E9, E277) : compromis device biomédical permet exécution commandes malveillantes et fuite logs d'audit mais sans impact SI critique.
Traitement	Réduire — [ISO27002-8.24], [LINDDUN-D] Isolation VLAN IoT + EDR légers détection
Sources	[ISO27002-5.3, EBIOS-RM-A3]
Risque résiduel	Faible - Faible
Validation	À valider par l'analyste
Preuves	[E9] [E277]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M132 — Wi-Fi patients 10.1.40.0/24 sortant internet sans filtrage SSL [A7] : malware contourne firewall via trafic HT

Actif	Frontière Wi-Fi Invités ↔ Internet (sans SSL filtering)
Menace	LINDDUN-Disclosure — Wi-Fi patients 10.1.40.0/24 sortant internet sans filtrage SSL [E18][A7] : malware contourne firewall via trafic HTTP non inspecté, vol données sensibles requêtes outbounds.
Évaluation	Probabilité : Élevée · Impact : Moyen · Niveau : **Élevé**
Justification	Wi-Fi patients sortant internet sans filtrage SSL (E18, A7) : malware contourne firewall via trafic HTTP non inspecté, vol données sensibles requêtes outbounds (LINDDUN-Disclosure).
Traitement	Réduire — [ANSSI-HYGIENE-9], [ANSSI-RECYF] SSL filtering proxy + DNS firewalling Wi-Fi patients
Sources	[ANSSI-HYGIENE-9, ISO27002-8.5]
Risque résiduel	Moyen - Faible
Validation	À valider par l'analyste
Preuves	[E18]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M133 — Accès libre sans authentification Wi-Fi patients mobiles : attaquant établit position de listening sur réseau

Actif	Frontière Wi-Fi Invités ↔ Internet (sans SSL filtering)
Menace	STRIDE-E — Accès libre sans authentification Wi-Fi patients mobiles [E9] : attaquant établit position de listening sur réseau de confiance pour intercepter sessions et élever privilèges via MITRE T1548.5.
Évaluation	Probabilité : Élevé · Impact : Moyen · Niveau : **Élevé**
Justification	VLAN Wi-Fi Invités/Sortie Internet directe sans filtrage SSL [E203], attaquant intercepte sessions patients mobiles sans authentification requise — risque d'enregistrement passif de trafic chiffré et injection dans session utilisateur [E9]
Traitement	Réduire — Segmentation réseau par VLAN Wi-Fi Invités/Sortie séparé avec règles firewall restrictives [ISO27002-8.11], Authentification Wi-Fi obligatoire pour accès Internet [ANSSI-HYGIENE-4], Chiffrement SSL/TLS obligatoire sur toutes les sessions accessibles aux patients mobiles [ISO27002-5.19]
Sources	ANSSI-HYGIENE-4; ISO27002-5.19; ISO27002-8.11
Risque résiduel	Moyen (risque d'interception passif réduit mais non nul pour connexions sans HTTPS résiduel)
Validation	À valider par l'analyste
Preuves	[E9] [E203]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M134 — Migration DPI Nexus vers Cloud HDS [A7] : absence contrôle d'accès API Gateway initial permet intrusions dans

Actif	Frontière Cloud_HDS ↔ API Gateway (hybride To-Be)
Menace	STRIDE-S — Migration DPI Nexus vers Cloud HDS [E9][A7] : absence contrôle d'accès API Gateway initial permet intrusions dans infra hébergement hybride et accès non autorisé ressources sensibles.
Évaluation	Probabilité : Élevé · Impact : Élevé · Niveau : **Critique**
Justification	Migration hybride To-Be API Gateway CloudHDS absence contrôle accès initial [E9][A7], intrusions permises dans infra hébergement et accès non autorisé ressources sensibles — surface d'attaque élargie par exposition API télémédecine vers Internet [E231]
Traitement	Réduire — Implémentation authentification OAuth2/OIDC obligatoire [ISO27002-5.15], Rate Limiting et WAF en place sur API Gateway hybride CloudHDS [ANSSI-HYGIENE-8], Journalisation centralisée des logs d'authentification API [ISO27002-8.24]
Sources	ANSSI-HYGIENE-8; ISO27002-5.15; ISO27002-8.24
Risque résiduel	Élevé (menace persistante jusqu'à migration complète de l'API Gateway sécurisée dans Cloud HDS)
Validation	À valider par l'analyste
Preuves	[E9] [E231]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

M135 — Exposition contrôlée mais signature SBOM/Docker absente → fuite données santé via endpoints API non signés ou

Actif	Frontière Cloud_HDS ↔ API Gateway (hybride To-Be)
Menace	LINDDUN-L — Exposition contrôlée mais signature SBOM/Docker absente [E16] → fuite données santé via endpoints API non signés ou conteneurs compromis sans attestation d'intégrité.
Évaluation	Probabilité : Moyen · Impact : Élevé · Niveau : **Élevé**
Justification	Exposition contrôlée mais signature SBOM/Docker absente [E16], fuite données santé via endpoints API non signés et conteneurs sans attestation d'intégrité — fuites possibles avant mise en place pipeline signature intégrée [E232]
Traitement	Réduire — Pipeline CI/CD avec signature automatique des images Docker et génération SBOM intégré [LINDDUN-L], Scan continu de vulnérabilités sur conteneurs API non signés [EBIOS-RM-A4], Attestation d'intégrité des images avant déploiement CloudHDS [ISO27002-5.19]
Sources	EBIOS-RM-A4; ISO27002-5.19; LINDDUN-L
Risque résiduel	Élevé (fuites possibles via endpoints API non signés réduites mais signature intégration progressive)
Validation	À valider par l'analyste
Preuves	[E16] [E232]
Dans les livrables	03-menaces.md · 04-evaluation.md · 05-traitement.md · registre-risques.md

Preuves citées

Chaque identifiant [E...] cité dans les livrables, avec le document d'origine et l'extrait exact, et les actifs et risques qui s'appuient sur lui.

Documents d'origine cités

- **FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md** : 22 preuve(s) citée(s)
- **Fiche_d_Audit_Technique_-_État_des_Lieux_SanteTech__As-Is_.pdf.md** : 20 preuve(s) citée(s)
- **Présentation_du_Projet_d_Étude_-_M2_CYBE.pdf.md** : 9 preuve(s) citée(s)

39 identifiant(s) de preuve cités dans les livrables sont introuvables dans l'index : [E1], [E2], [E3], [E4], [E5], [E6], [E7], [E8], [E9], [E10], [E11], [E12], [E13], [E15], [E16], [E17], [E18], [E19], [E20], [E24], [E25], [E26], [E27], [E28], [E30], [E31], [E32], [E36], [E37], [E38]....

Preuves

[E98] FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md

« ● Exposition & Accès : Portail VPN FortiGate (vpn.santetech-sante.fr) avec simple login/mot de passe (sans MFA sur 60% des comptes) et Webmail Exchange OWA (webmail.santetech-sante.fr). »

Cité par : M034

[E103] FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md

« • 4 Cliniques Moyennes (Brest, Le Mans, Angers, Tours) : ~200 lits, 400 collaborateurs/site. »

Cité par : M029 M030

[E113] FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md

« • To-Be : Déploiement d'un IdP centralisé (Entra ID / Keycloak) avec MFA FIDO2 / Carte CPS pour les soignants. »

Cité par : M072

[E115] FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md

« Périmètre : Siège social (Rennes) + 12 Cliniques régionales (Grand Ouest & Île-de-France). »

Cité par : M063

[E117] FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md

« Périmètre : Siège social (Rennes) + 12 Cliniques régionales (Grand Ouest & Île-de-France). »

Cité par : M065

[E120] FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md
« Annuaire : Forêt Active Directory unique (corp.santetech.local) avec 16 contrôleurs de domaine (1 DC/RODC par clinique). »
Cité par : M066

[E123] FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md
« Applications Métier : Progiciel Nexus (Dossier Patient Informatisé), PACS/RIS pour l'imagerie, et messagerie interne Exchange 2016. »
Cité par : M035

[E131] FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md
« To-Be : Déploiement d'un IdP centralisé (Entra ID / Keycloak) avec MFA FIDO2 / Carte CPS pour les soignants. »
Cité par : M059

[E136] FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md
« Absence initiale de SOC, d'EDR et de SIEM centralisé. Le projet doit répondre aux exigences de la directive NIS 2, du RGPD et de la certification HDS. »
Cité par : M120

[E137] FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md
« Aucun fournisseur n'est imposé. Contrainte impérative : certification HDS (Hébergeur de Données de Santé) et analyse de l'exposition au Cloud Act. »
Cité par : M028

[E138] FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md
« Hypothèse retenue : Isolation logique stricte via micro-segmentation VLAN/NAC et interdiction d'accès Internet direct. »
Cité par : M109 M110

[E139] FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md

« ## Page 1 FAQ & COMPLÉMEMENT DE CADRAGE TECHNIQUE ET PÉDAGOGIQUE Projet M2 Cybersécurité — Groupe SanteTech (Bloc 1 : Stratégie & Architecture) Objectif du document : Cette fiche consolide l'ensemble des règles, des hypothèses de travail officielles et des réponses aux questions des étudiants pour le projet SanteTech (12 cliniques, 150 000 dossiers patients). En l'absence de précision complémentaire, les hypothèses listées ici font office de référence validée pour le dossier. 1. RAPPEL DE L'ÉTAT DES LIEUX (AS-IS) — LE POINT DE DÉPART TECHNIQUE ● Périmètre : Siège social (Rennes) + 12 Cliniques régionales (Grand Ouest & Île-de-France). ● Infrastructure Actuelle : 100% On-Premise / Legacy avec dette technique avérée (ferme Citrix/RDS au Siège, serveurs locaux de secours dans les cliniques). ● Volumétrie : 185 serveurs (65 physiques, 120 virtuels sous VMware ESXi/Hyper-V) et 3 200 postes »

Cité par : M083 M084 M085 M086 M087 M091 M092 M095 M097 M105 M112 M114 A25 A27 A28 A29 A30 A32 A33 A34

[E140] FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md

« micro-segmentation : un poste compromis dans une clinique peut communiquer en IP directe avec tout le réseau. ● Annuaire : Forêt Active Directory unique (corp.santetech.local) avec 16 contrôleurs de domaine (1 DC/RODC par clinique). ● Applications Métier : Progiciel Nexus (Dossier Patient Informatisé), PACS/RIS pour l'imagerie, et messagerie interne Exchange 2016. ● Exposition & Accès : Portail VPN FortiGate (vpn.santetech-sante.fr) avec simple login/mot de passe (sans MFA sur 60% des comptes) et Webmail Exchange OWA (webmail.santetech-sante.fr). ## Page 2 2. EXIGENCES DE RÉDACTION ET DE RENDU # Question / Point Clé Règle / Décision Pédagogique Validée 1 Format et volumétrie du Dossier unique au format PDF (le Benchmark dossier technico-économique et la Note Green IT sont intégrés en sections ou annexes dédiées). Volume recommandé : 20 à 30 pages max (hors annexes), police lisible (Le »

Cité par : M043 M044 M046 M047 M048 M052 M054 M055 M071 M088 M089 M090 M095 M098 M099 M100 M101 M102 M103 M106 M108 M111 A17 A18 A31 A35 A36 A38 A39

[E142] FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md

« 4 Répartition des 12 • 2 Grands Centres Hospitaliers (Rennes + établissements Nantes) : ~500 lits chacun, 1 000 collaborateurs/site, urgences et imagerie lourde. • 4 Cliniques Moyennes (Brest, Le Mans, Angers, Tours) : ~200 lits, 400 collaborateurs/site. • 6 Cliniques de Proximité / Chirurgie : ~50 lits, 150 collaborateurs/site. ### Tableau 1 (page 2) | # | Question / Point Clé | Règle / Décision Pédagogique Validée | | --- | --- | --- | | 1 | Format et volumétrie du dossier | Dossier unique au format PDF (le Benchmark technico-économique et la Note Green IT sont intégrés en sections ou annexes dédiées). Volume recommandé : 20 à 30 pages max (hors annexes), police lisible (Lexend / Arial), marges standard. | | 2 | Précision des flux du DAT (25 pts) | Une cartographie globale High-Level Design (HLD) par zones de confiance (DMZ, Cloud HDS, Cliniques, IoT, Postes) complétée par une matrice »

Cité par : M053 M067 M068 M069 A16 A21

[E143] FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md

« des flux clés (Protocole, Port source/destination, Authentification, Chiffrement) pour les 5 flux critiques (API Télémédecine, VPN/ZTNA, IoT, Postes ➔ Vault). | | 3 | Périmètre du Benchmark | Comparer 2 à 3 solutions sur 3 piliers : (a) Hébergeur Cloud HDS (ex: Scaleway HDS vs OVHcloud vs Azure HDS) ; (b) SASE / ZTNA & SD-WAN ; (c) Gestion des Secrets (HashiCorp Vault vs Azure Key Vault). Horizon financier prévisionnel sur 3 ans (Build + Run). | ### Tableau 2 (page 2) | # | Question / Point Clé | Règle / Décision Pédagogique Validée | | --- | --- | --- | | 4 | Répartition des 12 établissements | • 2 Grands Centres Hospitaliers (Rennes + Nantes) : ~500 lits chacun, 1 000 collaborateurs/site, urgences et imagerie lourde. • 4 Cliniques Moyennes (Brest, Le Mans, Angers, Tours) : ~200 lits, 400 collaborateurs/site. • 6 Cliniques de Proximité / Chirurgie : ~50 lits, 150 collaborateurs/site. | »

Cité par : M041 M045

[E144] FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md

« • To-Be (Cloud Hybride) : Migration du DPI Nexus, de la télémédecine et du portail patient vers un Cloud HDS. Seuls les serveurs d'impression et les caches DICOM/PACS restent en local dans les cliniques. 6 Fournisseur Cloud & Aucun fournisseur n'est imposé. Contrainte Souveraineté impérative : certification HDS (Hébergeur de Données de Santé) et analyse de l'exposition au Cloud Act. 7 Parc IoT Médical ~4 000 dispositifs connectés (~350 par site : pompes à perfusion, moniteurs, scanners). OS non patchables sur une partie du parc. Hypothèse retenue : Isolation logique stricte via micro-segmentation VLAN/NAC et interdiction d'accès Internet direct. 8 Gestion des Identités (IAM) • As-Is : Active Directory On-Premise unique, pas de »

Cité par : M041 M061

[E145] FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md

« MFA systématique sur le VPN. • To-Be : Déploiement d'un IdP centralisé (Entra ID / Keycloak) avec MFA FIDO2 / Carte CPS pour les soignants. 9 Niveau de Sécurité Absence initiale de SOC, d'EDR et de SIEM Opérationnelle centralisé. Le projet doit répondre aux exigences de la directive NIS 2, du RGPD et de la certification HDS. 10 Applications & API cibles DPI Nexus, PACS, Webmail Exchange, et nouvelle brique de télémédecine exposée via une API Gateway sécurisée dans le Cloud Hybride. ### Tableau 1 (page 3) | # | Question / Point Clé | Règle / Décision Pédagogique Validée | | --- | --- | --- | | 5 | Hébergement du DPI & Migration | • As-Is : DPI Nexus hébergé sur ferme Citrix/RDS au Siège de Rennes. • To-Be (Cloud Hybride) : Migration du DPI Nexus, de la télémédecine et du portail patient vers un Cloud »

Cité par : M025 M026 M027 M031 M052 M056 M067 M069 M087 M100 M115

[E146] FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md

« HDS. Seuls les serveurs d'impression et les caches DICOM/PACS restent en local dans les cliniques. | | 6 | Fournisseur Cloud & Souveraineté | Aucun fournisseur n'est imposé. Contrainte impérative : certification HDS (Hébergeur de Données de Santé) et analyse de l'exposition au Cloud Act. | | 7 | Parc IoT Médical | ~4 000 dispositifs connectés (~350 par site : pompes à perfusion, moniteurs, scanners). OS non patchables sur une partie du parc. Hypothèse retenue : Isolation logique stricte via micro-segmentation VLAN/NAC et interdiction d'accès Internet direct. | | 8 | Gestion des Identités (IAM) | • As-Is : Active Directory On-Premise unique, pas de MFA systématique sur le VPN. • To-Be : Déploiement d'un IdP centralisé (Entra ID / Keycloak) avec MFA FIDO2 / Carte CPS pour les soignants. | | 9 | Niveau de Sécurité Opérationnelle | Absence initiale de SOC, d'EDR et de SIEM centralisé. Le pro »

Cité par : M033 M050 M051 M058 M062 M064 M068 M070 M071 M072 M073 M074 M075 M076 M077 M078 M079 M080 M081 M082 M086 M092 A18 A23 A24

[E147] FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md

« 4. BUDGET, CONTRAINTES ET ÉVALUATION # Question / Point Clé Règle / Décision Pédagogique Validée 11 Enveloppe budgétaire et • Budget Build de référence : 1,5 million d'euros horizon sur 18 mois. • Budget Run cible : ~300 k€ / an. • Horizon de migration : Trajectoire globale étalée sur 24 mois. 12 Outils imposés / exclus Aucun outil n'est imposé (libres choix open-source ou éditeurs), sous réserve de justification économique et d'évaluation de leur impact Green IT / RGESN. 13 Évolution des choix Les choix de la Journée 1 (Bloc 1) posent la techniques baseline. Des ajustements (Change Requests) restent possibles et tracés dans la synthèse de cohérence des blocs suivants. »

Cité par : M065

[E148] FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md

« 14 Exigence d'une maquette Aucune maquette technique n'est exigée pour le (PoC) Bloc 1 (le livrable est strictement stratégique et d'architecture : dossier écrit + soutenance COMEX). 16 Format du REX Individuel Note individuelle de 2 à 4 pages évaluant la posture réflexive, l'apport personnel, les arbitrages défendus et l'analyse critique de la démarche collective (Composante à 17,5% / 20 pts). 20 Page « Synthèse Cohérence » Section obligatoire (1 à 2 pages) comprenant : (10 pts) 1. Un tableau de correspondance reliant chaque menace CTI (Atelier 1) aux choix d'architecture (Atelier 2), DevSecOps (Atelier 3) et PQC/Green IT (Atelier 4). 2. Une attestation de relecture croisée signée par »

Cité par : M036 M129

[E149] FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md

« les 4 membres de l'équipe. ### Tableau 1 (page 4) | # | Question / Point Clé | Règle / Décision Pédagogique Validée | | --- | --- | --- | | 11 | Enveloppe budgétaire et horizon | • Budget Build de référence : 1,5 million d'euros sur 18 mois. • Budget Run cible : ~300 k€ / an. • Horizon de migration : Trajectoire globale étalée sur 24 mois. | | 12 | Outils imposés / exclus | Aucun outil n'est imposé (libres choix open-source ou éditeurs), sous réserve de justification économique et d'évaluation de leur impact Green IT / RGESN. | | 13 | Évolution des choix techniques | Les choix de la Journée 1 (Bloc 1) posent la baseline. Des ajustements (Change Requests) restent possibles et tracés dans la synthèse de cohérence des blocs suivants. | | 14 | Exigence d'une maquette (PoC) | Aucune maquette technique n'est exigée pour le Bloc 1 (le livrable est strictement stratégique et d'architecture : dos »

Cité par : M068 M097 M105 M106 A26

[E150] FAQ___Complément_de_Cadrage_-_SanteTech__Bloc_1_.pdf.md

« collective (Composante à 17,5% / 20 pts). | | 20 | Page « Synthèse Cohérence » (10 pts) | Section obligatoire (1 à 2 pages) comprenant : 1. Un tableau de correspondance reliant chaque menace CTI (Atelier 1) aux choix d'architecture (Atelier 2), DevSecOps (Atelier 3) et PQC/Green IT (Atelier 4). 2. Une attestation de relecture croisée signée par les 4 membres de l'équipe. | »

Cité par : M070 M071 M072 M093 M096 M097 M105 M107

[E152] Fiche_d_Audit_Technique_-_État_des_Lieux_SanteTech__As-Is_.pdf.md

« ● Date de l'état des lieux : Octobre 2026 »

Cité par : M102 M103 M104 M106

[E155] Fiche_d_Audit_Technique_-_État_des_Lieux_SanteTech__As-Is_.pdf.md

« Niveau fonctionnel de la forêt : Windows Server 2012 R2 (Rétrocompatibilité historique active). »

Cité par : M016

[E156] Fiche_d_Audit_Technique_-_État_des_Lieux_SanteTech__As-Is_.pdf.md
« Nom de domaine public / DNS : santetech-sante.fr (Géré par un hébergeur tiers, registres DNS gérés en interne via BIND). »
Cité par : —

[E159] Fiche_d_Audit_Technique_-_État_des_Lieux_SanteTech__As-Is_.pdf.md
« Contrôleurs de Domaine (DCs) : 16 DCs au total »
Cité par : M102

[E160] Fiche_d_Audit_Technique_-_État_des_Lieux_SanteTech__As-Is_.pdf.md
« Siège (Rennes) : 4 DCs physiques (Windows Server 2016). »
Cité par : M017 M114

[E163] Fiche_d_Audit_Technique_-_État_des_Lieux_SanteTech__As-Is_.pdf.md
« Tout le trafic des 12 cliniques transite obligatoirement par le Data Center du Siège. Aucune isolation inter-sites : un poste compromis dans une clinique peut communiquer directement en IP avec toutes les autres. »
Cité par : M052 M115

[E168] Fiche_d_Audit_Technique_-_État_des_Lieux_SanteTech__As-Is_.pdf.md
« 10.1.30.0/24 : VLAN IoT / Biomédical (Non cloisonné, routage direct vers les automates) »
Cité par : M060

[E171] Fiche_d_Audit_Technique_-_État_des_Lieux_SanteTech__As-Is_.pdf.md
« Applications Clés (Hébergées en local / DC Siège) : »
Cité par : M104

[E176] Fiche_d_Audit_Technique_-_État_des_Lieux_SanteTech__As-Is_.pdf.md
« Domaine racine : hq.corp.santetech.local (Siège - Rennes). »
Cité par : M032 M107

[E186] Fiche_d_Audit_Technique_-_État_des_Lieux_SanteTech__As-Is_.pdf.md
« clinique-iroise.corp.santetech.local (Brest - 02) »
Cité par : M027

[E192] Fiche_d_Audit_Technique_-_État_des_Lieux_SanteTech__As-Is_.pdf.md
« registres DNS gérés en interne via BIND). »
Cité par : M013 M014 M015

[E195] Fiche_d_Audit_Technique_-_État_des_Lieux_SanteTech__As-Is_.pdf.md
« clinique-iroise.corp.santetech.local (Brest - 02) »
Cité par : M025

[E197] Fiche_d_Audit_Technique_-_État_des_Lieux_SanteTech__As-Is_.pdf.md
« clinique-loire.corp.santetech.local (Nantes - 04) »
Cité par : M018 M028

[E198] Fiche_d_Audit_Technique_-_État_des_Lieux_SanteTech__As-Is_.pdf.md
« Domaine racine : hq.corp.santetech.local (Siège - Rennes). »
Cité par : M020

[E199] Fiche_d_Audit_Technique_-_État_des_Lieux_SanteTech__As-Is_.pdf.md
« Tout le trafic des 12 cliniques transite obligatoirement par le Data Center du Siège. »
Cité par : M021 M023 M024

[E201] Fiche_d_Audit_Technique_-_État_des_Lieux_SanteTech__As-Is_.pdf.md
« ## Page 1 FICHE D’AUDIT TECHNIQUE : ÉTAT DES LIEUX (AS-IS) — GROUPE SANTETECH ● Périmètre : Siège social + 12 Cliniques régionales (Grand Ouest & Île-de-France) ● Date de l'état des lieux : Octobre 2026 ● Statut Infrastructure : 100% On-Premise / Legacy avec dette technique avérée 1. Cartographie des Domaines & Annuaire Active Directory (AD DS) ● Forêt Active Directory (Interne) : corp.santetech.local ○ Niveau fonctionnel de la forêt : Windows Server 2012 R2 (Rétrocompatibilité historique active). ○ Nom de domaine public / DNS : santetech-sante.fr (Géré par un hébergeur tiers, registres DNS gérés en interne via BIND). ● Topologie Active Directory (Multisites) : ○ Domaine racine : hq.corp.santetech.local (Siège - Rennes). ○ Domaines enfants / OUs géographiques par clinique : ■ clinique-armor.corp.santetech.local (Rennes - 01) ■ clinique-iroise.corp.santetech.local (Brest - 02) »
Cité par : M097 M118

[E202] Fiche_d_Audit_Technique_-_État_des_Lieux_SanteTech__As-Is_.pdf.md
« ■ (+ 8 autres sous-domaines / structures pour les cliniques 05 à 12) ● Contrôleurs de Domaine (DCs) : 16 DCs au total ○ Siège (Rennes) : 4 DCs physiques (Windows Server 2016). ○ Cliniques (01 à 12) : 1 Read-Only Domain Controller (RODC) ou DC virtuel par site hébergé sur un serveur local vieillissant pour assurer l'authentification en cas de coupure WAN. ## Page 2 2. Topologie Réseau & Plans d'Adressage (Hub & Spoke) ● Interconnexion WAN : Réseau MPLS opérateur à maillage centralisé (Hub & Spoke). Tout le trafic des 12 cliniques transite obligatoirement par le Data Center du Siège. Aucune isolation inter-sites : un poste compromis dans une clinique peut communiquer directement en IP avec toutes les autres. ● Plans d'Aadressage IP (Plages internes) : ○ Siège & DC Principal : 10.100.0.0/16 ○ Réseaux des 12 Cliniques (Exemple Clinique 01 - Rennes) : 10.1.0.0/16 ■ 10.1.10.0/24 : VLA »
Cité par : M097 M108 M109 M110

[E203] Fiche_d_Audit_Technique_-_État_des_Lieux_SanteTech__As-Is_.pdf.md

« ■ 10.1.30.0/24 : VLAN IoT / Biomédical (Non cloisonné, routage direct vers les automates) ■ 10.1.40.0/24 : VLAN Wi-Fi Invités / Patients (Sortie Internet directe sans filtrage SSL) 3. Inventaire des Serveurs & Applications Métiers (On-Premise) ● Volumétrie globale : 185 serveurs (65 physiques, 120 virtuels sous VMware ESXi 6.5 / Hyper-V). ● Applications Clés (Hébergées en local / DC Siège) : ○ Dossier Patient Informatisé (DPI) : Progiciel Nexus (Version legacy déployée sur une ferme de serveurs Citrix XenApp / RDS pour l'accès des soignants). ○ Système d'Archivage & Imagerie (PACS/RIS) : Stockage des radios et DICOM sur des baies SAN locales vieillissantes (protocoles SMBv1 encore actifs par endroits pour compatibilité avec de vieux scanners). ○ Gestion Administrative & Facturation : Logiciel de gestion des patientèles et passerelles Sesam-Vitale. ○ Messagerie de Santé (Mél Messa »

Cité par : M001 M002 M003 M004 M005 M006 M007 M008 M009 M010 M011 M012 M014 M016 M017 M018 M020 M021 M022 M023 M024 M025 M027 M032 M037 M038 M039 M040 M042 M043 M044 M045 M046 M047 M048 M049 M061 M070 M089 M094

[E204] Fiche_d_Audit_Technique_-_État_des_Lieux_SanteTech__As-Is_.pdf.md

« messagerie interne hybride Exchange 2016 (Non totalement durci contre les attaques par usurpation). ## Page 3 4. Postes Clients & Flotte IoT Médical ● Parc Utilisateurs (4 500 collaborateurs) : ○ 1 200 Médecins / Praticiens ○ 2 300 Infirmiers / Personnels soignants ○ 1 000 Administratifs & Logistique ● Parc Informatique (Postes de travail) : 3 200 postes ○ 2 500 Postes Fixes & Chariots de Soins en clinique : Windows 10 Enterprise (Builds non mis à jour depuis 2022) + ~5% de postes irréductibles sous Windows 7 / Windows XP Embedded pilotant de vieux automates d'imagerie et des injecteurs de produits de contraste. ○ 700 PC Portables : Attribués aux cadres et administratifs (chiffrés par BitLocker mais sans agent EDR moderne, uniquement un vieil antivirus signature). ● Flotte IoT & Biomédical : ~4 000 dispositifs connectés (Pompes à perfusion intelligentes, moniteurs multiparamétriq »

Cité par : M056 M063 M065

[E205] Fiche_d_Audit_Technique_-_État_des_Lieux_SanteTech__As-Is_.pdf.md

« 5. Services Exposés sur Internet & Accès Distants ● Portail VPN Télétravail & Praticiens Libéraux : ○ URL : vpn.santetech-sante.fr (Passerelle FortiGate / FortiSSL). ○ Vulnérabilité As-Is : Authentification par simple Login + Mot de passe Active Directory (Pas de double facteur d'authentification / MFA sur 60% des comptes). ● Webmail de Santé & Accès Externe : ○ URL : webmail.santetech-sante.fr (OWA Exchange 2016 exposé en DMZ, vulnérable aux campagnes de type ProxyShell / Spraying si non patché). ● Portail Extranet Partenaires / Médecins Libéraux : ○ URL : extranet.santetech-sante.fr (Accès aux résultats d'examens pour les médecins traitants extérieurs, authentification par certificat faible). ● Sites Web des 12 Cliniques : ○ Hébergés chez un prestataire tiers (WordPress non durci), sans lien direct avec le SI interne mais servant de cibles pour du défacement ou du phishing de »

Cité par : M045 M066 M088 M090 M099 M100 M101 M102 M104 M120 A18

[E207] Présentation_du_Projet_d_Étude_-_M2_CYBE.pdf.md

« Périmètre : 12 cliniques, 4500 collaborateurs, 150 000 dossiers patients actifs. »

Cité par : —

[E208] Présentation_du_Projet_d_Étude_-_M2_CYBE.pdf.md

« Rôles recommandés Équipes de 4 à 5 CISO / Lead GRC Project Manager Incident Lead Architecte Cloud »

Cité par : M061

[E209] Présentation_du_Projet_d_Étude_-_M2_CYBE.pdf.md

« BLOC 1 Stratégie de Sécurisation des Architectures SI CTI & OSINT DAT Cible Innovation & Green IT »

Cité par : M064

[E223] Présentation_du_Projet_d_Étude_-_M2_CYBE.pdf.md

« ## Page 1 SUP DE VINCI M2 CYBERSÉCURITÉ 2026 2027 Projet SECU CLOUD HEALTH Cahier des charges, cadrage opérationnel et livrables par blocs de compétences. ## Page 2 CONTEXTE & ENJEUX Mise en situation : Groupe SanteTech Périmètre : 12 cliniques, 4500 collaborateurs, 150 000 dossiers patients actifs. Transformation : Migration vers un Cloud hybride, Mission de l'équipe microservices, API SaaS et IoT médical. Agir en mode cabinet de conseil pour concevoir, piloter, sécuriser et Menaces & Cadre : Ransomwares, fuites de données, tester la résilience globale du SI cible. réglementations NIS 2, RGPD, HDS / ISO 27001. ### Tableau 1 (page 2) | Colonne 1 | Colonne 2 | | --- | --- | | Mission de l'équipe | | ## Page 3 ORGANISATION DE GROUPE Rôles recommandés Équipes de 4 à 5 CISO / Lead GRC Project Manager Incident Lead Architecte Cloud »

Cité par : M119 A19

[E224] Présentation_du_Projet_d_Étude_-_M2_CYBE.pdf.md

« Stratégie SSI, conformité & Master Scrum, planning WBS & Analyste SOC, Red/Blue Team & DevSecOps, Zero Trust & CI/CD. gouvernance. budget. DFIR. ### Tableau 1 (page 3) | Colonne 1 | Colonne 2 | Colonne 3 | Colonne 4 | Colonne 5 | Colonne 6 | Colonne 7 | Colonne 8 | | --- | --- | --- | --- | --- | --- | --- | --- | | CISO / Lead GRC | | | P | roject Manager | | | | ### Tableau 2 (page 3) | | | | Incident Lead | | | --- | --- | --- | --- | --- | --- | | | | I | I | | | DevSecOps, Zero Trust & CI/CD. | | | | ## Page 4 BLOC 1 Stratégie de Sécurisation des Architectures SI CTI & OSINT DAT Cible Innovation & Green IT Matrice des menaces ciblées secteur Zero Trust, IAM/MFA, Vault & DevSecOps. Feuille de route Post-Quantique & RGESN. santé. ### Tableau 1 (page 4) »

Cité par : A37

[E228] Présentation_du_Projet_d_Étude_-_M2_CYBE.pdf.md

« | BLOC 1 □30 MIN□ | | | BLOC 2 □30 MIN□ | | | | BLOC 3 □45 MIN□ | | | | | | | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | | | | | | | | | | | | BLOC 4 □30 MIN□ | | | | COMEX | | | C | OPIL | | | A | UDIT | | | | | ### Tableau 2 (page 8) | Colonne 1 | Colonne 2 | | --- | --- | | Gestion de crise, ANSSI & CNIL. | | ## Page 9 ÉVALUATION Règles & Barème d'Évaluation Pondération Écrits & Oral Intégrité & Sanctions • Écrit Collectif : 75% de la note écrite • Plagiat & IA □ 10% : Réfaction de la note • Écrit Individuel □REX□ : 25% de la note écrite • Plagiat & IA □ 25% : Note 0/20 sans rattrapage • Note Orale : 30% à 60% de la note du bloc □Bonus/Malus • Retard : □0,5 pt / demi-journée (> 5j = élimination) □2 pts) ### Tableau 1 (page 9) | Pondération Écrits & Oral | | Intégr | | | | | --- | --- | --- | --- | --- | --- | »

Cité par : M120

[E230] Présentation_du_Projet_d_Étude_-_M2_CYBE.pdf.md

« Trajectoire IAM, Vault & CI/CD SBOM. RaaS. microservices. Carbone IT. ### Tableau 1 (page 11) | | | | | | | | 13h30 □ 15h30 □2h00□ | | | | | | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | --- | | 09h30 □ 10h30 □1h□ | | | 10 | h30 □ 12h30 □2h00□ | | | | | | | | | Atelier 1 □ CTI & OSINT | | | Ate | | lier 2 □ DAT Cible | | | Ate | | | | | ### Tableau 2 (page 11) | Colonne 1 | Colonne 2 | | --- | --- | | Atelier 4 □ Innovation | | ## Page 12 PROGRAMME MATIN □3H30□ Activités : CTI & Cartographie DAT Atelier CTI & OSINT □1h00□ Atelier DAT Cible □2h00□ • Cartographier 3 groupes de Ransomware ciblant les hôpitaux. • Modéliser l'interconnexion AWS/Azure + On-Premise. • Extraire les TTPs clés □Framework MITRE ATT&CK□. • Isoler le trafic IoT médical via VLAN/Micro-segmentation. »

Cité par : —

[E231] Présentation_du_Projet_d_Étude_-_M2_CYBE.pdf.md

« • Identifier la surface d'attaque externe des 12 cliniques. • Définir les flux API Gateway pour la télémédecine. ### Tableau 1 (page 12) | Atelier CTI & OSINT □1h00□ | | | Atelier | | DAT Cible □2h00□ | | | --- | --- | --- | --- | --- | --- | --- | | • Cartographier 3 groupes de Ransomware ciblant les hôpitaux. | | | • Mod | éliser l'interconnexion AWS/ Azure + On-Premise. | | | | • Extraire les TTPs clés □Framework MITRE ATT&CK□. | | | • Isole | r le trafic IoT médical via VLAN/Micro-segmentation. | | | • Identifier la surface d'attaque externe des 12 cliniques. | | | • Défi | nir les flux API Gateway pour la télémédecine. | | | ## Page 13 PROGRAMME APRÈS□MIDI □3H30□ Activités : Zero Trust, PQC & Green IT Innovation & Green IT □1h30□ Zero Trust & DevSecOps □2h00□ • Établir la feuille de route vers les algorithmes PQC • Schématiser le déploiement d'un coffre-fort HashiCorp Vault. □Kyber »

Cité par : M062 M107 M134 A18

[E232] Présentation_du_Projet_d_Étude_-_M2_CYBE.pdf.md

« • Intégrer la signature d'images Docker & génération SBOM. • Calculer l'empreinte carbone estimée de l'infra □PUE/WUE□. • Définir la politique d'accès IAM/MFA pour le personnel soignant. • Rédiger les recommandations d'éco-conception RGESN. ### Tableau 1 (page 13) | | | | Innovation & Green IT □1h30□ | | | | --- | --- | --- | --- | --- | --- | | | Zero Trust & DevSecOps □2h00□ | | | Innovati | Innovati | | | | | | • Établir la feuille de route vers les algorithmes PQC □Kyber/Dilithium). | | | | • Schématiser le déploiement d'un coffre-fort HashiCorp Vault. | | | • Étab | | | | • Intégrer la signature d'images Docker & génération SBOM. | | | | | | • Définir la politique d'accès IAM/MFA pour le personnel soignant. | | | | | ## Page 14 LIVRABLES ATTENDUS À 17H00 Check-list d'aboutissement de la Journée 1 Schéma Cible Matrice CTI Distribution Rôles Préparatif COMEX »

Cité par : M135

Historique des décisions de l'analyste

Type	Élément	Décision	Analyste	Date	Motif
contradiction	FAQ___Complément_de_Cadrage_-_Sant ≠ Fiche_d_Audit_Technique_-_État_des	Les deux conviennent (cas ou périmètres différents)	Melvin RAIMBAULT	2026-10-12 14:44	le premier est une hypothèse du devenir le deuxième est l'existant donc c'est important d'avoir les demandes hypothétique des entreprise sur les amélioration, les 2 sont donc a garder met mettre le deuxième en tant que valeur d'origine
contradiction	Fiche_d_Audit_Technique_-_État_des ≠ FAQ___Complément_de_Cadrage_-_Sant	Les deux conviennent (cas ou périmètres différents)	Melvin RAIMBAULT	2026-10-12 14:44	parrille l'un est le cas aujourd'hui liée a l'audit et l'autre une hypothèse sur le devenir. les 2 a garder mais a bien remplir l'existant par celui de l'audit

Type	Élément	Décision	Analyste	Date	Motif
question	Quelles sont les applications critiques et qui en est propriétaire ? — partiel	Je fournis la réponse (voir mon commentaire)	Melvin RAIMBAULT	2026-10-12 14:53	je valide ta réponse
question	Le réseau est-il segmenté et quels pare-feu protègent les sites ? — partiel	Je fournis la réponse (voir mon commentaire)	Melvin RAIMBAULT	2026-10-12 14:53	oui je valide ta réponse
etape	Étape 1 · Existant et actifs	À corriger (voir mon commentaire)	Melvin RAIMBAULT	2026-10-12 15:03	retravaille cette et trouve les preuves et redis moi
etape	Étape 2 · Choix de la méthode	À corriger (voir mon commentaire)	Melvin RAIMBAULT	2026-10-12 15:03	retravaille cette et trouve les preuves et redis moi
etape	Étape 3 · Menaces	À corriger (voir mon commentaire)	Melvin RAIMBAULT	2026-10-12 15:03	retravaille cette et trouve les preuves et redis moi
etape	Étape 4 · Évaluation	À corriger (voir mon commentaire)	Melvin RAIMBAULT	2026-10-12 15:03	retravaille cette et trouve les preuves et redis moi
question	Qui est le RSSI et est-il indépendant du DSI ? — non documenté	À demander à l'entreprise	Melvin RAIMBAULT	2026-10-12 15:05	
question	À quelle fréquence se réunit le comité de sécurité ? — non documenté	À demander à l'entreprise	Melvin RAIMBAULT	2026-10-12 15:05	
question	Comment sont réalisées les sauvegardes et où sont-elles stockées ? — non documenté	À demander à l'entreprise	Melvin RAIMBAULT	2026-10-12 15:05	
question	Quand a eu lieu la dernière restauration de sauvegarde réussie ? — non documenté	À demander à l'entreprise	Melvin RAIMBAULT	2026-10-12 15:05	
question	Existe-t-il un plan de reprise d'activité, quand a-t-il été testé, quel est le site de repli ? — non documenté	À demander à l'entreprise	Melvin RAIMBAULT	2026-10-12 15:05	
question	Les comptes d'administration sont-ils nominatifs ou partagés ? — non documenté	À demander à l'entreprise	Melvin RAIMBAULT	2026-10-12 15:05	
question	Comment et sous quel délai les comptes des personnes parties sont-ils désactivés ? — non documenté	À demander à l'entreprise	Melvin RAIMBAULT	2026-10-12 15:05	
question	Les journaux (logs) sont-ils centralisés et analysés, qui reçoit les alertes ? — non documenté	À demander à l'entreprise	Melvin RAIMBAULT	2026-10-12 15:05	
question	Comment sont gérés les correctifs de sécurité et les vulnérabilités ? — non documenté	À demander à l'entreprise	Melvin RAIMBAULT	2026-10-12 15:05	
question	Quels incidents de sécurité ont eu lieu récemment ? — non documenté	À demander à l'entreprise	Melvin RAIMBAULT	2026-10-12 15:05	